



ΔΙΕΘΝΕΣ
ΠΑΝΕΠΙΣΤΗΜΙΟ
ΕΛΛΑΔΟΣ

Δ Ι Ε Θ Ν Ε Σ Π Α Ν Ε Π Ι Σ Τ Η Μ Ι Ο Τ Η Σ Ε Λ Λ Α Δ Ο Σ
Π Ο Λ Υ Τ Ε Χ Ν Ι Κ Η Σ Χ Ο Λ Η
Τ Μ Η Μ Α Μ Η Χ Α Ν Ι Κ Ω Ν Π Λ Η Ρ Ο Φ Ο Ρ Ι Κ Η Σ ,
Υ Π Ο Λ Ο Γ Ι Σ Τ Ω Ν Κ Α Ι Τ Η Λ Ε Π Ι Κ Ο Ι Ν Ω Ν Ι Ω Ν

**Ανίχνευση και Αντιμετώπιση Επιθέσεων σε Δίκτυα
Οριζόμενα από Λογισμικό (SDN)**

Detection and Handling of Attacks in Software Defined Networks

Διπλωματική Εργασία της

Ζαφείρω Μπάρδα

(ΑΕΜ : 21015)

Επιβλέπων Καθηγητής:

Κωνσταντίνος Χειλάς, Καθηγητής

ΣΕΡΡΕΣ, Σεπτέμβριος 2026

Περίληψη

Η υιοθέτηση των Δικτύων Οριζόμενων από Λογισμικό (Software-Defined Networking, SDN) στα σύγχρονα κέντρα δεδομένων και στις υποδομές παρόχων έχει μεταβάλει θεμελιωδώς τη διαχείριση των δικτύων, εισάγοντας ταυτόχρονα μια νέα, κρίσιμη επιφάνεια επίθεσης. Ο διαχωρισμός του επιπέδου ελέγχου (control plane) από το επίπεδο δεδομένων (data plane) και η λογική κεντρικοποίηση της ευφυΐας του δικτύου μπορούν να καταστήσουν έναν ελεγκτή, ειδικά όταν λειτουργεί χωρίς πλεονασμό, μοναδικό σημείο αποτυχίας και πρωτεύοντα στόχο επιθέσεων άρνησης υπηρεσίας.

Η παρούσα διπλωματική σχεδιάζει, υλοποιεί και αξιολογεί ένα ολοκληρωμένο ερευνητικό πρότυπο ανίχνευσης και αυτόματης αντιμετώπισης επιθέσεων σε περιβάλλον SDN, βασισμένο σε τεχνικές Μηχανικής Μάθησης. Για τον σκοπό αυτό αναπτύσσονται δύο διακριτές και συμπληρωματικές μέθοδοι.

Η Μέθοδος Α αφορά τη ζωντανή ανίχνευση και αντιμετώπιση επιθέσεων σε εξομοιωμένο δίκτυο Mininet/Open vSwitch. Ο ελεγκτής υπολογίζει συγκεντρωτικά στατιστικά χαρακτηριστικά (aggregate features) της κίνησης ανά πηγή, εντοπίζει ασυνήθιστη συμπεριφορά χρησιμοποιώντας τον αλγόριθμο Isolation Forest και επιβάλλει αυτόματα στον μεταγωγέα κανόνα απόρριψης της ύποπτης κίνησης. Η μέθοδος δοκιμάζεται σε δύο πειραματικά σκέλη. Το πρώτο είναι ένα πείραμα σε επίπεδο πακέτου, με πλημμύρα μηνυμάτων SYN όπου συλλέγονται μετρήσεις από τον μεταγωγέα και εγκαθίσταται αυτόματα κανόνας απόρριψης. Το δεύτερο περιλαμβάνει πειράματα συνθετικής τηλεμετρίας μέσω διεπαφής προγραμματισμού εφαρμογών (API), δηλαδή με τεχνητά παραγόμενες μετρήσεις αντί για πραγματική κίνηση δικτύου. Συνολικά, η αξιολόγηση καλύπτει έξι σενάρια: το παραπάνω σενάριο πλημμύρας SYN, σάρωση θυρών, εξάντληση του πίνακα ροών, εξαγωγή δεδομένων, πλευρική κίνηση και πλαστογράφηση ARP.

Η Μέθοδος Β αφορά την εκτός σύνδεσης (offline) ανάλυση καταγεγραμμένων δικτυακών ροών και τη σύγκριση διαφορετικών αλγορίθμων Μηχανικής Μάθησης. Χρησιμοποιείται το δημόσια διαθέσιμο σύνολο δεδομένων InSDN, το οποίο έχει δημιουργηθεί για τη μελέτη επιθέσεων σε περιβάλλοντα SDN και περιλαμβάνει χαρακτηριστικά δικτυακών ροών που έχουν εξαχθεί με το CICFlowMeter. Στην κύρια συγκριτική αξιολόγηση εξετάζονται έξι κλασικά μοντέλα επιβλεπόμενης Μηχανικής Μάθησης, με διαχωρισμό που λαμβάνει υπόψη την παρουσία πανομοιότυπων εγγραφών, ώστε ο διαχωρισμός των δεδομένων εκπαίδευσης και ελέγχου να μην ευνοεί τεχνητά τα μοντέλα. Συμπληρωματικά, δύο μοντέλα Βαθιάς

Μάθησης αξιολογούνται στο συνθετικό σύνολο δεδομένων με διαφορετικό πρωτόκολλο και τα αποτελέσματά τους παρουσιάζονται χωριστά.

Πέρα από τη βασική αξιολόγηση των δύο μεθόδων, η μελέτη επεκτείνεται σε τέσσερις ακόμη κατευθύνσεις. Πρώτον, εξετάζεται η ερμηνευσιμότητα των αποφάσεων των μοντέλων, δηλαδή ποια χαρακτηριστικά της δικτυακής κίνησης επηρεάζουν περισσότερο την απόφασή τους. Δεύτερον, μελετάται η καθυστέρηση της ανίχνευσης. Τρίτον, εξετάζεται μέσω προσομοίωσης η συμπεριφορά του συστήματος κατά τον κορεσμό του επιπέδου ελέγχου. Τέταρτον, μελετάται η στιβαρότητα των μοντέλων απέναντι σε επιτιθέμενο που μεταβάλλει σκόπιμα τα χαρακτηριστικά της δικτυακής κίνησης με στόχο να αποφύγει την ανίχνευση, καθώς και η δυνατότητα ενίσχυσης της στιβαρότητάς τους μέσω εκπαίδευσης με αντίστοιχα τροποποιημένα δείγματα.

Abstract

The adoption of Software-Defined Networking (SDN) in modern data centres and service-provider infrastructures has fundamentally changed the way networks are managed, while at the same time introducing a new and critical attack surface. The separation of the control plane from the data plane, together with the logical centralisation of network intelligence, can make a controller, particularly when operating without redundancy, a single point of failure and a primary target for denial-of-service attacks.

This thesis designs, implements, and evaluates an integrated research prototype for the detection and automated mitigation of attacks in an SDN environment, based on Machine Learning techniques. For this purpose, two distinct and complementary methods are developed.

Method A concerns the live detection and mitigation of attacks in an emulated Mininet/Open vSwitch network. The controller computes aggregate statistical features of the traffic for each source, identifies abnormal behaviour using the Isolation Forest algorithm, and automatically installs a drop rule on the switch for suspicious traffic. The method is evaluated through two sets of experiments. The first is a packet-level experiment involving a SYN flood, in which measurements are collected from the switch and a drop rule is automatically installed. The second consists of synthetic-telemetry experiments performed through an Application Programming Interface (API), using artificially generated measurements instead of actual network traffic. Overall, the evaluation covers six attack scenarios: the aforementioned SYN-flood scenario, port scanning, flow-table exhaustion, data exfiltration, lateral movement, and ARP spoofing.

Method B concerns the offline analysis of recorded network flows and the comparison of different Machine Learning algorithms. The publicly available InSDN dataset is used; it was developed for the study of attacks in SDN environments and contains network-flow features extracted with CICFlowMeter. The main comparative evaluation considers six classical supervised Machine Learning models using a split that accounts for identical records, so that the separation between training and test data does not artificially favour the evaluated models. In addition, two Deep Learning models are evaluated separately on the synthetic dataset under a different experimental protocol.

Beyond the basic evaluation of the two methods, the study is extended in four additional directions. First, the interpretability of the models' decisions is examined, with emphasis on

identifying which network-traffic features have the greatest influence on their predictions. Second, detection latency is investigated. Third, the behaviour of the system under control-plane saturation is examined through simulation. Fourth, the study investigates the robustness of the models against an attacker who deliberately modifies network-traffic characteristics in an attempt to evade detection, as well as the possibility of improving their robustness by training them on similarly modified samples.

Υπεύθυνη Δήλωση: Βεβαιώνω ότι είμαι συγγραφέας αυτής της διπλωματικής και ότι κάθε βοήθεια την οποία είχα για την προετοιμασία της, είναι πλήρως αναγνωρισμένη και αναφέρεται στην διπλωματική εργασία. Επίσης έχω αναφέρει τις όποιες πηγές από τις οποίες έκανα χρήση δεδομένων, ιδεών ή λέξεων, είτε αυτές αναφέρονται ακριβώς είτε παραφρασμένες. Επίσης, βεβαιώνω ότι αυτή η διπλωματική προετοιμάστηκε από εμένα προσωπικά ειδικά για τις απαιτήσεις του προγράμματος σπουδών του Τμήματος Μηχανικών Πληροφορικής, Υπολογιστών και Τηλεπικοινωνιών του Διεθνούς Πανεπιστημίου της Ελλάδος.

Z. Μπάρδα

Πίνακας Περιεχομένων

Περίληψη	2
Abstract.....	4
Πίνακας Περιεχομένων	7
Πίνακας Πινάκων	11
Πίνακας Σχημάτων	13
Πίνακας Συντομογραφιών	16
1 Εισαγωγή	19
1.1 Πλαίσιο και κίνητρο	19
1.2 Ορισμός του προβλήματος	20
1.3 Στόχοι της διπλωματικής	21
1.4 Συνεισφορά της διπλωματικής	22
1.5 Δομή της διπλωματικής	22
1.6 Ιστορικό πλαίσιο.....	23
1.7 Το μέγεθος του προβλήματος.....	23
1.8 Μεθοδολογική προσέγγιση.....	24
2 Αρχιτεκτονική των Δικτύων SDN.....	25
2.1 Τα τρία επίπεδα της αρχιτεκτονικής.....	25
2.1.1 Επίπεδο Δεδομένων (Data Plane).....	25
2.1.2 Επίπεδο Ελέγχου (Control Plane).....	25
2.1.3 Επίπεδο Εφαρμογών (Application Plane)	26
2.2 Διεπαφές επικοινωνίας και πρωτόκολλα νότιας διεπαφής.....	26
2.3 Το πρωτόκολλο OpenFlow: μηνύματα, διοχέτευση και στατιστικά	27
2.4 Ελεγκτές SDN: εσωτερική δομή, διαθεσιμότητα και ασφάλεια του καναλιού ελέγχου	30
2.5 Mininet και Open vSwitch.....	32
2.6 Σύγκριση με τα παραδοσιακά δίκτυα: πλεονεκτήματα και προκλήσεις	33

2.7	Εικονικοποίηση δικτυακών λειτουργιών (Network Functions Virtualization, NFV)	35
2.8	Υπηρεσίες ασφαλείας στο επίπεδο εφαρμογών	35
3	Απειλές και Επιθέσεις σε Δίκτυα SDN	36
3.1	Επιφάνεια επίθεσης ανά επίπεδο	36
3.2	Επιθέσεις άρνησης υπηρεσίας (Denial of Service DoS): μορφές, μηχανισμός και ταξινόμηση	37
3.3	Κορεσμός του πίνακα ροών και του καναλιού ελέγχου	39
3.4	Πλαστογράφηση, δηλητηρίαση τηλεμετρίας και επιθέσεις ενδιάμεσου.....	39
3.5	Σάρωση, πλευρική κίνηση και εξαγωγή δεδομένων	40
3.6	Ο ελεγκτής χωρίς πλεονασμό ως πιθανό μοναδικό σημείο αποτυχίας και οι εσωτερικές απειλές.....	41
3.7	Ταξινόμηση των απειλών, υποδομή και αντίκτυπος των επιθέσεων	42
3.8	Μηχανισμοί άμυνας και ο ρόλος του συστήματος ανίχνευσης εισβολών (Intrusion Detection System, IDS)	45
4	Μέθοδοι Ανίχνευσης και Μηχανική Μάθηση.....	47
4.1	Παραδοσιακές μέθοδοι ανίχνευσης και οι περιορισμοί τους	47
4.2	Μηχανική Μάθηση και επισκόπηση των αλγορίθμων.....	48
4.3	Ο αλγόριθμος Isolation Forest και η μαθηματική του θεμελίωση	51
4.4	Δημόσια σύνολα δεδομένων και το σύνολο InSDN.....	55
4.5	Τα 24 χαρακτηριστικά ροής: περιγραφή και δικτυακή ερμηνεία.....	58
4.6	Μετρικές αξιολόγησης και καμπύλες ROC.....	62
4.7	Ερμηνευσιμότητα των αποφάσεων και τιμές SHAP	67
4.8	Σχετική βιβλιογραφία	68
4.9	Προεπεξεργασία, ρύθμιση υπερπαραμέτρων και γενίκευση.....	70
4.10	Ζητήματα ιδιωτικότητας και δεοντολογίας	73
5	Μεθοδολογία και Υλοποίηση.....	75
5.1	Συνολική αρχιτεκτονική του συστήματος	75

5.1.1	Αρχιτεκτονική ελέγχου: υβριδικό μοντέλο SDN	77
5.1.2	Αιτιολόγηση της σχεδιαστικής επιλογής.....	78
5.1.3	Συνολική ροή και πειραματικά προφίλ	79
5.2	Μέθοδος A: ζωντανή ανίχνευση και αντιμετώπιση	80
5.2.1	Τοπολογία, παραγωγή κίνησης και συλλογή τηλεμετρίας.....	81
5.2.2	Ανίχνευση, απόφαση και εφαρμογή μέτρων αντιμετώπισης	85
5.2.3	Λειτουργία του ελεγκτή, ασφάλεια και εποπτεία.....	90
5.3	Μέθοδος B: ανάλυση εκτός σύνδεσης	95
5.3.1	Προέλευση και δομή των δεδομένων	95
5.3.2	Προεπεξεργασία, τυποποίηση και διαχωρισμός των δεδομένων	97
5.3.3	Τα μοντέλα και η διαδικασία σύγκρισης.....	101
5.4	Περιβάλλον εκτέλεσης και αναπαραγωγικότητα	104
6	Πειράματα και Αποτελέσματα	108
6.1	Πειραματική διάταξη.....	108
6.2	Μέθοδος A: Πείραμα σε επίπεδο πακέτων με πλημμύρα SYN (SYN flood) ...	112
6.3	Μέθοδος A: Αξιολόγηση με συνθετική τηλεμετρία.....	117
6.4	Μέθοδος A: Καθυστέρηση ανίχνευσης και αποτελεσματικότητα αντιμετώπισης 120	
6.5	Συμπληρωματική αξιολόγηση της Μεθόδου A.....	125
6.5.1	Κορεσμός του επιπέδου ελέγχου	125
6.5.2	Δηλητηρίαση τηλεμετρίας.....	128
6.5.3	Στιβαρότητα του ζωντανού μοντέλου απέναντι σε στρατηγικές αποφυγής 130	
6.6	Μέθοδος B: Αξιολόγηση στο συνθετικό σύνολο δεδομένων.....	133
6.6.1	Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης.....	133
6.6.2	Σύγκριση με μοντέλα Βαθιάς Μάθησης.....	137
6.6.3	Καμπύλες ROC και διασταυρούμενη επικύρωση	138
6.7	Μέθοδος B: Αξιολόγηση στο σύνολο δεδομένων InSDN	142

6.7.1	Αξιολόγηση με τυχαίο διαχωρισμό	142
6.7.2	Αξιολόγηση με ομαδοποίηση των διπλοτύπων	143
6.8	Μέθοδος B: Συμπληρωματική αξιολόγηση, ερμηνευσιμότητα και στιβαρότητα 147	
6.8.1	Αξιολόγηση του Isolation Forest εκτός σύνδεσης.....	147
6.8.2	Ερμηνευσιμότητα των αποφάσεων με SHAP	149
6.8.3	Στιβαρότητα σε επιθέσεις αποφυγής και εκπαίδευση με αντίπαλα παραδείγματα.....	154
7	Συμπεράσματα και Μελλοντική Εργασία	157
7.1	Σύνοψη ευρημάτων	157
7.1.1	Απαντήσεις στα ερευνητικά ερωτήματα	159
7.2	Περιορισμοί της διπλωματικής.....	160
7.3	Μελλοντικές επεκτάσεις.....	162
7.4	Τελικό συμπέρασμα.....	163
8	Βιβλιογραφία	165
9	Παράρτημα A: Οδηγίες αναπαραγωγής των πειραμάτων	169
A.1	Απαιτήσεις συστήματος.....	169
A.2	Εκκίνηση της στοίβας.....	169
A.3	Εκτέλεση της αλυσίδας επεξεργασίας εκτός σύνδεσης (Μέθοδος B).....	169
A.4	Εκτέλεση των ζωντανών σεναρίων (Μέθοδος A)	170
A.5	Θέση των αποτελεσμάτων	170
A.6	Λίστα ελέγχου αναπαραγωγιμότητας	170

Πίνακας Πινάκων

Πίνακας 2-1: Βασικοί τύποι μηνυμάτων OpenFlow.	27
Πίνακας 2-2: Ενδεικτικοί ελεγκτές SDN και βασικά χαρακτηριστικά τους.	31
Πίνακας 2-3: Συγκριτική επισκόπηση παραδοσιακών δικτύων και SDN.	34
Πίνακας 3-1: Τυπικό μοντέλο απειλών των εξεταζόμενων επιθέσεων.	42
Πίνακας 3-2: Ταξινόμηση των επιθέσεων που αξιολογούνται πειραματικά.	44
Πίνακας 4-1: Ενδεικτικές τιμές ανωμαλίας του Isolation Forest για $n = 8$	54
Πίνακας 4-2: Τα 24 χαρακτηριστικά ροής που χρησιμοποιούνται στην παρούσα εργασία, ομαδοποιημένα κατά την πλευρά της δικτυακής συμπεριφοράς που περιγράφουν. Οι ορισμοί των πεδίων προέρχονται από την τεκμηρίωση του CICFlowMeter [26].	58
Πίνακας 5-1: Στοιχεία της ζωντανής υλοποίησης της Μεθόδου Α και χρήση τους στα δύο προφίλ εκτέλεσης.	76
Πίνακας 5-2: Διαμόρφωση του Isolation Forest που χρησιμοποιείται στο ζωντανό σύστημα.	86
Πίνακας 5-3: Συγκεντρωτικά χαρακτηριστικά εισόδου του ζωντανού μοντέλου Isolation Forest.	87
Πίνακας 5-4: Κυριότερα σημεία πρόσβασης REST της εφαρμογής ελέγχου.	91
Πίνακας 5-5: Μηχανισμοί προστασίας της εφαρμογής ελέγχου.	92
Πίνακας 5-6: Εφαρμογή των βασικών βημάτων προεπεξεργασίας στις δύο πηγές δεδομένων.	100
Πίνακας 5-7: Μοντέλα της Μεθόδου Β και βασικές υπερπαράμετροι της πειραματικής διαμόρφωσης.	102
Πίνακας 6-1: Τύποι πειραμάτων και το εύρος των συμπερασμάτων που επιτρέπουν.	110
Πίνακας 6-2: Κάλυψη αντιμετώπισης σε πραγματική εκτέλεση σε επίπεδο πακέτων (επίθεση 60 s), συναρτήσεως του χρόνου ζωής του κανόνα και της ανανέωσης.	115
Πίνακας 6-3: Κατανομές των βασικών μετρικών σε δέκα επαναλαμβανόμενους κύκλους επίθεσης μέσα στην ίδια εκτέλεση.	116
Πίνακας 6-4: Αποτελέσματα των σεναρίων συνθετικής τηλεμετρίας της Μεθόδου Α. ...	118
Πίνακας 6-5: Ρυθμός ανίχνευσης και καθυστέρηση ανά ένταση επίθεσης σε 30 προσομοιώσεις ανά επίπεδο.	121
Πίνακας 6-6: Μετρικές αποτελεσματικότητας αντιμετώπισης σε 50 προσομοιώσεις.	123
Πίνακας 6-7: Βασικές μετρήσεις κατά την προσομοίωση κορεσμού του επιπέδου ελέγχου (control plane).	126

Πίνακας 6-8: Αποτελέσματα της καταγεγραμμένης δοκιμής εισαγωγής πλαστής τηλεμετρίας.....	129
Πίνακας 6-9: Ανίχνευση και αποφυγή για τις προσομοιωμένες στρατηγικές αποφυγής του ζωντανού μοντέλου.	131
Πίνακας 6-10: Σύγκριση των έξι κλασικών μοντέλων στο συνθετικό σύνολο δεδομένων με 24 χαρακτηριστικά.	134
Πίνακας 6-11: Μακρο-F1 στο σύνολο ελέγχου για την καθαρή (clean) και την απαιτητική (hard) εκδοχή του συνθετικού συνόλου.	135
Πίνακας 6-12: Απόδοση των μοντέλων Βαθιάς Μάθησης στο συνθετικό σύνολο δεδομένων.	137
Πίνακας 6-13: Διασταυρούμενη επικύρωση πέντε πτυχών (5-fold cross-validation) με βάση τη μακρο-F1.....	140
Πίνακας 6-14: Απόδοση των κλασικών μοντέλων στο InSDN υπό τυχαίο διαχωρισμό. .	143
Πίνακας 6-15: Απόδοση των κλασικών μοντέλων στο InSDN υπό διαχωρισμό με ομαδοποίηση ακριβών διπλοτύπων.	144
Πίνακας 6-16: Σύγκριση της μακρο-F1 σε δύο ανεξάρτητους διαχωρισμούς με ομαδοποίηση διπλοτύπων.	146
Πίνακας 6-17: Διαμορφώσεις του Isolation Forest που χρησιμοποιούνται στην εργασία.	148
Πίνακας 6-18: Μετρικές του Isolation Forest εκτός σύνδεσης στο συνθετικό σύνολο και στο InSDN.....	149
Πίνακας 6-19: Τα πέντε σημαντικότερα χαρακτηριστικά κατά την ανάλυση SHAP.	150
Πίνακας 6-20: Ρυθμός αποφυγής του αρχικού και του ενισχυμένου Random Forest ανά τιμή διαταραχής ε.	154
Πίνακας 9-1: Λίστα ελέγχου αναπαραγωγιμότητας των πειραμάτων.....	170
Πίνακας 9-2: Κορυφαίοι συνδυασμοί υπερπαραμέτρων του Isolation Forest, ταξινομημένοι κατά ROC-AUC επικύρωσης. Η τιμή ROC-AUC ελέγχου αναφέρεται μόνο για τη διαμόρφωση αναφοράς.....	173

Πίνακας Σχημάτων

Σχήμα 4-1: Ενδεικτικό παράδειγμα λειτουργίας του Isolation Forest για σύνολο οκτώ παρατηρήσεων. Επτά σημεία σχηματίζουν την κύρια συστάδα, ενώ ένα απομακρυσμένο σημείο απομονώνεται ήδη από τον πρώτο τυχαίο διαχωρισμό. Το αντίστοιχο δέντρο δείχνει ότι η ανωμαλία καταλήγει σε φύλλο μικρού βάθους, ενώ τα σημεία της κύριας συστάδας απαιτούν περισσότερους διαχωρισμούς.	52
Σχήμα 4-2: Δομή του πίνακα σύγχυσης για δυαδική ταξινόμηση, με θετική κατηγορία την επίθεση και αρνητική κατηγορία τη νόμιμη δικτυακή κίνηση.	62
Σχήμα 4-3: Σχηματική ερμηνεία διαφορετικών περιπτώσεων απόδοσης μιας καμπύλης ROC.	66
Σχήμα 4-4: Ενδεικτική ανάλυση μιας πρόβλεψης του μοντέλου σε συνεισφορές χαρακτηριστικών κατά τη μέθοδο SHAP.	68
Σχήμα 5-1: Τοπολογία του προφίλ της Μεθόδου Α σε επίπεδο πακέτων με έξι εικονικούς κόμβους και έναν μεταγωγέα Open vSwitch.	82
Σχήμα 5-2: Αρχιτεκτονική του προφίλ της Μεθόδου Α σε επίπεδο πακέτων και ροή της τηλεμετρίας και της απόφασης αντιμετώπισης.	83
Σχήμα 5-3: Κλειστός βρόχος εποπτείας, απόφασης και εφαρμογής μέτρων αντιμετώπισης στη Μέθοδο Α.	89
Σχήμα 5-4: Διαδοχικά στάδια από τη συλλογή των στατιστικών έως την τοπική εγκατάσταση του κανόνα απόρριψης στον Open vSwitch.	90
Σχήμα 5-5: Προέλευση των δεδομένων και κοινός χώρος 24 χαρακτηριστικών που χρησιμοποιείται στη Μέθοδο Β.	97
Σχήμα 6-1: Οι τέσσερις τύποι πειραμάτων, οι συμμετέχοντες και η ροή της πληροφορίας.	109
Σχήμα 6-2: Πίνακας εποπτείας (monitoring dashboard) κατά τη φάση κανονικής λειτουργίας. Δεν έχει καταγραφεί ανίχνευση, δεν υπάρχει ενεργός κανόνας απόρριψης (drop rule) και δεν εμφανίζεται αποκλεισμένος κόμβος. Οι νόμιμοι κόμβοι h1 έως h4 εμφανίζονται ενεργοί με μηδενική ένδειξη ανωμαλίας στο συγκεκριμένο στιγμιότυπο.	113
Σχήμα 6-3: Πίνακας εποπτείας (monitoring dashboard) κατά τη φάση της πλημμύρας SYN (SYN flood). Ο κόμβος h6 (10.0.0.6) εμφανίζεται ως αποκλεισμένος, έχει εγκατασταθεί ένας κανόνας απόρριψης (drop rule) και η αντίστοιχη ένδειξη ανωμαλίας του φτάνει στο 100%, ενώ οι κόμβοι h1 και h4 παραμένουν ενεργοί.	114

Σχήμα 6-4: Καθυστέρηση ανίχνευσης (detection latency) και ρυθμός ανίχνευσης (detection rate) συναρτήσει της έντασης της επίθεσης.	122
Σχήμα 6-5: Χρονολόγιο (timeline) τυπικού σεναρίου αντιμετώπισης: ανίχνευση, αποκλεισμός και νέα ανίχνευση μετά τη λήξη του αποκλεισμού.	124
Σχήμα 6-6: Εξέλιξη του ρυθμού Packet-In, του βάθους της ουράς του ελεγκτή, του εκτιμώμενου χρόνου απόκρισης και της πληρότητας του πίνακα ροών κατά την προσομοίωση κορεσμού του επιπέδου ελέγχου.	127
Σχήμα 6-7: Ανίχνευση και αντιμετώπιση της επίθεσης κορεσμού του επιπέδου ελέγχου με βάση την εντροπία Shannon και τον ρυθμό Packet-In.	128
Σχήμα 6-8: Χρονολόγιο των 30 προσπαθειών εισαγωγής πλαστής τηλεμετρίας (telemetry injection) κατά την καταγεγραμμένη εκτέλεση.	130
Σχήμα 6-9: Ρυθμός ανίχνευσης (detection rate) του ζωντανού μοντέλου για τις εξεταζόμενες στρατηγικές αποφυγής (evasion strategies).	132
Σχήμα 6-10: Σύγκριση των κλασικών μοντέλων Μηχανικής Μάθησης ως προς τη συνολική ακρίβεια, τη μακρο-ορθότητα, τη μακρο-ανάκληση και τη μακρο-F1 στο συνθετικό σύνολο δεδομένων.	135
Σχήμα 6-11: Πίνακας σύγχυσης (confusion matrix) του Random Forest στο συνθετικό σύνολο δεδομένων.	136
Σχήμα 6-12: Καμπύλες ROC του Random Forest ανά κατηγορία, με προσέγγιση μία κατηγορία έναντι των υπολοίπων (one-vs-rest).	139
Σχήμα 6-13: Διασταυρούμενη επικύρωση πέντε πτυχών: μέση μακρο-F1 και τυπική απόκλιση ανά μοντέλο.	141
Σχήμα 6-14: Σύγκριση των κλασικών μοντέλων Μηχανικής Μάθησης στο σύνολο δεδομένων InSDN υπό διαχωρισμό με ομαδοποίηση ακριβών διπλοτύπων (group-aware split).	145
Σχήμα 6-15: Ρύθμιση υπερπαραμέτρων του Isolation Forest: ROC-AUC και F1 για τους εξεταζόμενους συνδυασμούς.	148
Σχήμα 6-16: Διάγραμμα σμήνους SHAP (SHAP beeswarm): κατεύθυνση και μέγεθος της επίδρασης των χαρακτηριστικών στις προβλέψεις.	151
Σχήμα 6-17: Συνολική σημαντικότητα των χαρακτηριστικών κατά SHAP, με βάση τη μέση απόλυτη τιμή SHAP.	152
Σχήμα 6-18: Θερμικός χάρτης SHAP: διαφοροποίηση της σημαντικότητας των χαρακτηριστικών μεταξύ των κατηγοριών κίνησης.	153

Σχήμα 6-19: Ρυθμός αποφυγής συναρτήσει της διαταραχής ϵ για το αρχικό Random Forest και το Random Forest που εκπαιδεύτηκε με αντίπαλα παραδείγματα.....	155
--	-----

Πίνακας Συντομογραφιών

Συντομογραφία	Επεξήγηση
ACK	Acknowledgement, σημαία TCP επιβεβαίωσης
API	Application Programming Interface, Διεπαφή Προγραμματισμού Εφαρμογών
ARP	Address Resolution Protocol, Πρωτόκολλο Ανάλυσης Διευθύνσεων
AUC	Area Under Curve, Εμβαδόν κάτω από την Καμπύλη
BFA	Brute Force Attack, Επίθεση Ωμής Βίας
CI	Confidence Interval, Διάστημα Εμπιστοσύνης
CICFlowMeter	Εργαλείο εξαγωγής στατιστικών χαρακτηριστικών ανά ροή
CNN	Convolutional Neural Network, Συνελκτικό Νευρωνικό Δίκτυο
CSV	Comma-Separated Values, μορφή αρχείου με τιμές χωρισμένες με κόμμα
DDoS	Distributed Denial of Service, Κατανεμημένη Άρνηση Υπηρεσίας
DoS	Denial of Service, Άρνηση Υπηρεσίας
F1	F1-score, αρμονικός μέσος ορθότητας (precision) και ανάκλησης (recall)
FIN	Finish, σημαία TCP ομαλού τερματισμού σύνδεσης
FN	False Negative, Ψευδώς Αρνητικό
FP	False Positive, Ψευδώς Θετικό
FPR	False Positive Rate, Ρυθμός Ψευδώς Θετικών
HIDS	Host-based Intrusion Detection System, IDS σε επίπεδο υπολογιστή
IAT	Inter-Arrival Time, Χρόνος μεταξύ αφίξεων
IDS	Intrusion Detection System, Σύστημα Ανίχνευσης Εισβολών
IF	Isolation Forest, αλγόριθμος ανίχνευσης ανωμαλιών με απομόνωση
InSDN	Δημόσιο σύνολο δεδομένων εισβολών ειδικά για περιβάλλοντα SDN
IoT	Internet of Things, Διαδίκτυο των Πραγμάτων
IP	Internet Protocol, Πρωτόκολλο Διαδικτύου
JSON	JavaScript Object Notation, μορφή ανταλλαγής δεδομένων
KNN	K-Nearest Neighbors, k Πλησιέστεροι Γείτονες
LDoS	Low-rate Denial of Service, Άρνηση Υπηρεσίας Χαμηλού Ρυθμού

MAC	Media Access Control, φυσική διεύθυνση δικτυακής διεπαφής
MITM	Man-in-the-Middle, Επίθεση Ενδιάμεσου
ML	Machine Learning, Μηχανική Μάθηση
MLP	Multi-Layer Perceptron, Πολυεπίπεδος Αντιληπτήρας
NETCONF	Network Configuration Protocol, πρωτόκολλο διαμόρφωσης συσκευών
NFV	Network Functions Virtualization, Εικονικοποίηση Δικτυακών Λειτουργιών
NIDS	Network-based Intrusion Detection System, IDS σε επίπεδο δικτύου
NOX	ο πρώτος ελεγκτής OpenFlow
ONOS	Open Network Operating System, ελεγκτής SDN για περιβάλλοντα παρόχων
OVS	Open vSwitch, λογισμικός μεταγωγέας ανοιχτού κώδικα
OVSDB	Open vSwitch Database Management Protocol, πρωτόκολλο διαχείρισης των ρυθμίσεων του μεταγωγέα
POX	ελεγκτής SDN υλοποιημένος σε Python, διάδοχος του NOX
RBF	Radial Basis Function, πυρήνας ακτινικής βάσης του SVM
REST	Representational State Transfer, αρχιτεκτονικό πρότυπο διεπαφών ιστού
RF	Random Forest, Τυχαίο Δάσος
ROC	Receiver Operating Characteristic, Χαρακτηριστική Λειτουργίας Δέκτη
ROC-AUC	Εμβαδόν κάτω από την καμπύλη ROC
RQ1 – RQ5	Research Questions, τα πέντε ερευνητικά ερωτήματα της εργασίας
RST	Reset, σημαία TCP απότομου τερματισμού σύνδεσης
RTT	Round-Trip Time, Χρόνος Μετάβασης και Επιστροφής
SDN	Software-Defined Networking, Δίκτυα Οριζόμενα από Λογισμικό
SHAP	SHapley Additive exPlanations, μέθοδος επεξήγησης αποφάσεων με τιμές Shapley
SLA	Service Level Agreement, Συμφωνία Επιπέδου Υπηρεσίας
SOM	Self-Organizing Map, Αυτο-Οργανούμενος Χάρτης
SVM	Support Vector Machine, Μηχανή Διανυσμάτων Υποστήριξης
SYN	Synchronize, σημαία TCP για την έναρξη σύνδεσης. Αξιοποιείται στην επίθεση SYN flood

TCAM	Ternary Content-Addressable Memory, τριαδική μνήμη διευθυνσιοδοτούμενη κατά περιεχόμενο
TCP	Transmission Control Protocol, Πρωτόκολλο Ελέγχου Μετάδοσης
TLS	Transport Layer Security, Ασφάλεια Επιπέδου Μεταφοράς
TN	True Negative, Αληθώς Αρνητικό
TP	True Positive, Αληθώς Θετικό
TPR	True Positive Rate, Ρυθμός Αληθώς Θετικών
TTL	Time to Live, χρόνος ζωής ενός κανόνα ροής
UDP	User Datagram Protocol, Πρωτόκολλο Αυτοδύναμων Πακέτων Χρήστη
WSL2	Windows Subsystem for Linux 2, υποσύστημα Linux για Windows
YANG	Yet Another Next Generation, γλώσσα μοντελοποίησης δεδομένων δικτύου

1 Εισαγωγή

1.1 Πλαίσιο και κίνητρο

Η ραγδαία αύξηση των απαιτήσεων των σύγχρονων δικτυακών εφαρμογών, από το υπολογιστικό νέφος (cloud computing) και το Διαδίκτυο των Πραγμάτων (Internet of Things, IoT) μέχρι τη ροή δεδομένων υψηλής ευκρίνειας και τις εφαρμογές πραγματικού χρόνου, έχει αναδείξει με έντονο τρόπο τους διαρθρωτικούς περιορισμούς της παραδοσιακής δικτυακής αρχιτεκτονικής [1]. Στα συμβατικά δίκτυα, η λογική ελέγχου (control logic) και η προώθηση των δεδομένων (data forwarding) είναι στενά συνυφασμένες μέσα σε κάθε δικτυακή συσκευή [2]. Κάθε δρομολογητής ή μεταγωγέας (switch) λαμβάνει τοπικές, αυτόνομες αποφάσεις, με αποτέλεσμα η διαχείριση του δικτύου να καθίσταται δύσκαμπτη, η κλιμάκωση δαπανηρή και η εισαγωγή νέων λειτουργιών ιδιαίτερα αργή, καθώς εξαρτάται από κλειστό, ιδιόκτητο υλικό και λογισμικό των κατασκευαστών [3].

Τα Δίκτυα Οριζόμενα από Λογισμικό (Software-Defined Networking, SDN) προτείνουν μια ριζική αναδιάρθρωση αυτού του μοντέλου: τον σαφή διαχωρισμό του επιπέδου ελέγχου από το επίπεδο δεδομένων [2]. Η λογική του δικτύου αφαιρείται από τις μεμονωμένες συσκευές και συγκεντρώνεται σε έναν λογικά κεντρικό ελεγκτή (controller), ο οποίος διαθέτει σφαιρική εικόνα της τοπολογίας και προγραμματίζει τη συμπεριφορά των μεταγωγέων μέσω ανοιχτών, τυποποιημένων πρωτοκόλλων, κατεξοχήν του OpenFlow [3]. Το αποτέλεσμα είναι ένα δίκτυο που καθίσταται προγραμματιζόμενο, ευέλικτο και δυναμικά αναδιατάξιμο μέσω λογισμικού, με οφέλη για την αυτοματοποίηση, τη διαχείριση πολιτικών και την ταχύτητα καινοτομίας [2], [3].

Η ίδια, ωστόσο, αρχιτεκτονική επιλογή που προσδίδει την ευελιξία δημιουργεί και μια νέα, κρίσιμη επιφάνεια επίθεσης. Η λογική κεντριοποίηση του ελέγχου μπορεί να καταστήσει έναν ελεγκτή, ειδικά όταν λειτουργεί χωρίς πλεονασμό, μοναδικό σημείο αποτυχίας (single point of failure) [1], καθώς, αν τεθεί εκτός λειτουργίας ή κορεστεί, διακυβεύεται η λειτουργία του δικτύου. Στην πράξη, οι κατανεμημένες υλοποιήσεις του ελεγκτή ή η λειτουργία του με εφεδρικούς κόμβους μετριάζουν τον κίνδυνο αυτόν [2], χωρίς όμως να εξαλείφουν τις απειλές που στοχεύουν το επίπεδο ελέγχου. Οι επιθέσεις άρνησης υπηρεσίας δεν αποτελούν νέο φαινόμενο, καθώς εμφανίζονται και στα παραδοσιακά δίκτυα. Εκείνο που εισάγει η αρχιτεκτονική SDN είναι μια πρόσθετη δυνατότητα επίθεσης στο ίδιο το επίπεδο ελέγχου. Δύο στοιχεία της αρχιτεκτονικής μπορούν να αξιοποιηθούν για τέτοιες επιθέσεις. Το πρώτο είναι το κανάλι ελέγχου (control channel), που συνδέει τον ελεγκτή με

τους μεταγωγείς. Το δεύτερο είναι ο μηχανισμός με τον οποίο ένα πακέτο, όταν δεν υπάρχει γι' αυτό κατάλληλος κανόνας προώθησης, αποστέλλεται στον ελεγκτή για να ληφθεί απόφαση. Αξιοποιώντας τα, ένας επιτιθέμενος μπορεί με σχετικά χαμηλό ρυθμό κίνησης να παραγάγει μεγάλο αριθμό αιτημάτων προς τον ελεγκτή και να εξαντλήσει τους πόρους του [4], [5]. Η προστασία του ελεγκτή SDN αναδεικνύεται, επομένως, σε κρίσιμο ζήτημα για την ασφάλεια και την αξιοπιστία ολόκληρης της δικτυακής υποδομής.

1.2 Ορισμός του προβλήματος

Το πρόβλημα που πραγματεύεται η παρούσα διπλωματική είναι η έγκαιρη και ακριβής ανίχνευση κακόβουλης δικτυακής κίνησης σε περιβάλλον SDN, καθώς και η αυτόματη αντιμετώπισή της πριν προκληθεί ουσιαστική ζημιά στην υποδομή. Οι παραδοσιακές μέθοδοι άμυνας, όπως τα συστήματα ανίχνευσης εισβολών βάσει υπογραφών (signature-based IDS), παρουσιάζουν δύο βασικούς περιορισμούς. Αφενός δυσκολεύονται να ανιχνεύσουν άγνωστες επιθέσεις, για τις οποίες δεν υπάρχει ακόμη κατάλληλη υπογραφή [6]. Αφετέρου, η επεξεργασία μεγάλου όγκου δικτυακής κίνησης και η σύγκρισή της με κανόνες ή πρότυπα μπορεί να αυξήσει το υπολογιστικό κόστος και, κατ' επέκταση, τον χρόνο που απαιτείται για την ανίχνευση [6]. Η προσέγγιση βάσει ανωμαλίας, η οποία εντοπίζει αποκλίσεις από τη φυσιολογική συμπεριφορά αντί για γνωστά πρότυπα επίθεσης, αντισταθμίζει μερικώς τους περιορισμούς αυτούς. Έχει όμως το δικό της κόστος σε ψευδώς θετικά, δηλαδή σε περιπτώσεις όπου νόμιμη κίνηση χαρακτηρίζεται λανθασμένα ως κακόβουλη [7]. Σε ένα περιβάλλον όπου ο ελεγκτής μπορεί να κορεστεί πολύ γρήγορα [5], η καθυστέρηση της ανίχνευσης είναι κρίσιμη.

Η Μηχανική Μάθηση προσφέρει μια εναλλακτική προσέγγιση. Αντί για στατικές υπογραφές, τα μοντέλα μπορούν να μάθουν στατιστικά πρότυπα της νόμιμης και της κακόβουλης κίνησης [6]. Έτσι μπορούν δυνητικά να επισημάνουν αποκλίσεις που δεν αντιστοιχούν σε γνωστή υπογραφή, χωρίς ωστόσο να εγγυώνται την ανίχνευση κάθε άγνωστης επίθεσης [6], [7]. Το ερώτημα που τίθεται είναι κατά πόσον μια τέτοια προσέγγιση μπορεί να ενσωματωθεί αποτελεσματικά στην αρχιτεκτονική SDN. Η ιδέα είναι να αξιοποιηθούν τα στατιστικά ροών που ο μεταγωγέας ήδη συλλέγει [8], ώστε να επιτυγχάνεται ανίχνευση σε πραγματικό χρόνο και αυτόματη αντιμετώπιση μέσω δυναμικής εγκατάστασης κανόνων ροής.

1.3 Στόχοι της διπλωματικής

Οι κύριοι στόχοι της παρούσας διπλωματικής εργασίας είναι τέσσερις. Πρώτον, η μελέτη της αρχιτεκτονικής SDN και του πρωτοκόλλου OpenFlow, με έμφαση στις επιπτώσεις τους στην ασφάλεια του δικτύου, και η συστηματική ανάλυση των βασικών κατηγοριών επιθέσεων ανά επίπεδο. Δεύτερον, ο σχεδιασμός και η υλοποίηση ζωντανού συστήματος ανίχνευσης και αυτόματης αντιμετώπισης επιθέσεων σε εξομοιωμένο περιβάλλον Mininet/Open vSwitch, μέσω δυναμικής εγκατάστασης κανόνων απόρριψης (Μέθοδος Α). Τρίτον, η εκτός σύνδεσης συγκριτική αξιολόγηση μοντέλων Μηχανικής Μάθησης σε καταγεγραμμένα δεδομένα δικτυακών ροών, ώστε να συγκριθεί η απόδοσή τους υπό κοινές συνθήκες αξιολόγησης (Μέθοδος Β). Τέταρτον, η πειραματική αξιολόγηση της απόδοσης ως προς τις μετρικές ταξινόμησης, την καθυστέρηση της ανίχνευσης, την αποτελεσματικότητα της αντιμετώπισης και την εμφάνιση ψευδώς θετικών. Πέρα από τους στόχους αυτούς, εξετάζονται συμπληρωματικά ζητήματα ερμηνευσιμότητας των αποφάσεων των μοντέλων, κορεσμού του επιπέδου ελέγχου και στιβαρότητας των μοντέλων απέναντι σε επιτιθέμενο που προσπαθεί να αποφύγει την ανίχνευση. Ως ερμηνευσιμότητα νοείται η δυνατότητα να προσδιοριστεί ποια χαρακτηριστικά της δικτυακής κίνησης επηρεάζουν περισσότερο τις αποφάσεις των μοντέλων. Μελετάται επίσης η δηλητηρίαση της τηλεμετρίας, κατά την οποία ο επιτιθέμενος κατασκευάζει πλαστά στατιστικά ροών με στόχο να οδηγήσει τον ελεγκτή στον αποκλεισμό ενός νόμιμου κόμβου.

Οι στόχοι αυτοί συγκεκριμενοποιούνται στα ακόλουθα πέντε ερευνητικά ερωτήματα, τα οποία καθοδηγούν τον σχεδιασμό των πειραμάτων, εξετάζονται πειραματικά στο Κεφάλαιο 6 και συζητούνται στο Κεφάλαιο 7:

RQ1: Σε επίπεδο πακέτου, σε δίκτυο Mininet/Open vSwitch, ανιχνεύεται και αντιμετωπίζεται μια επίθεση πλημμύρας SYN ήδη από την πρώτη περίοδο συλλογής μετρήσεων;

RQ2: Σε ποιο βαθμό μπορούν να περιοριστούν τα ψευδώς θετικά ώστε να μειώνεται η επίδραση στη νόμιμη κίνηση;

RQ3: Ποια είναι η επίδραση του μηχανισμού αντιμετώπισης στην απόδοση του δικτύου και ποιοι περιορισμοί της παρούσας υλοποίησης πρέπει να αντιμετωπιστούν για μια υλοποίηση στην οποία ο ελεγκτής λαμβάνει δυναμικά αποφάσεις για νέες ροές μέσω OpenFlow;

RQ4: Πόσο καλά ταξινομούν τα κλασικά μοντέλα Μηχανικής Μάθησης τις δικτυακές ροές SDN, όταν πανομοιότυπες εγγραφές δεν επιτρέπεται να βρίσκονται ταυτόχρονα στα δεδομένα εκπαίδευσης και ελέγχου;

RQ5: Πώς συμπεριφέρεται ένα μη επιβλεπόμενο μοντέλο Isolation Forest στο συνθετικό σύνολο δεδομένων σε σύγκριση με το σύνολο δεδομένων InSDN, και τι δείχνει η διαφορά της απόδοσης μεταξύ των δύο συνόλων;

1.4 Συνεισφορά της διπλωματικής

Η συνεισφορά της παρούσας διπλωματικής εντοπίζεται σε τρία επίπεδα. Πρώτον, υλοποιείται ζωντανό σύστημα ανίχνευσης και αντιμετώπισης σε εξομοιωμένο περιβάλλον Mininet/Open vSwitch, το οποίο συνδέει την απόφαση του μοντέλου με την αυτόματη εγκατάσταση κανόνων απόρριψης στον μεταγωγέα. Δεύτερον, πραγματοποιείται κύρια συγκριτική αξιολόγηση έξι κλασικών μοντέλων Μηχανικής Μάθησης σε καταγεγραμμένα δεδομένα δικτυακών ροών, υπό κοινές συνθήκες αξιολόγησης, ενώ δύο μοντέλα Βαθιάς Μάθησης εξετάζονται συμπληρωματικά στο συνθετικό σύνολο δεδομένων με διαφορετικό πρωτόκολλο. Κατά τον διαχωρισμό των δεδομένων λαμβάνεται υπόψη η παρουσία πανομοιότυπων εγγραφών, ώστε αυτές να μην εμφανίζονται ταυτόχρονα στα δεδομένα εκπαίδευσης και ελέγχου. Τρίτον, η αξιολόγηση επεκτείνεται πέρα από τις κλασικές μετρικές ταξινόμησης. Εξετάζονται η καθυστέρηση της ανίχνευσης, η αποτελεσματικότητα της αντιμετώπισης, η ερμηνευσιμότητα των αποφάσεων των μοντέλων και η στιβαρότητά τους απέναντι σε επιτιθέμενο που προσπαθεί να αποφύγει την ανίχνευση. Μελετάται επίσης η συμπεριφορά του συστήματος σε επιθέσεις ειδικές του SDN, όπως ο κορεσμός του επιπέδου ελέγχου και η δηλητηρίαση της τηλεμετρίας.

1.5 Δομή της διπλωματικής

Το υπόλοιπο της διπλωματικής οργανώνεται ως εξής. Το Κεφάλαιο 2 παρουσιάζει το θεωρητικό υπόβαθρο των δικτύων SDN και του πρωτοκόλλου OpenFlow. Το Κεφάλαιο 3 αναλύει τις απειλές και τις κατηγορίες επιθέσεων σε περιβάλλον SDN. Το Κεφάλαιο 4 επισκοπεί τις μεθόδους ανίχνευσης εισβολών και τα θεμέλια της Μηχανικής Μάθησης που αξιοποιούνται. Το Κεφάλαιο 5 περιγράφει αναλυτικά τη μεθοδολογία και την υλοποίηση, τόσο του ζωντανού συστήματος (Μέθοδος Α) όσο και της εκτός σύνδεσης ανάλυσης (Μέθοδος Β). Το Κεφάλαιο 6 παρουσιάζει τα πειραματικά αποτελέσματα και τις συμπληρωματικές αναλύσεις της εργασίας. Τέλος, το Κεφάλαιο 7 συζητά τα αποτελέσματα

και συνοψίζει τα συμπεράσματα, τους περιορισμούς και τις κατευθύνσεις για μελλοντική εργασία.

1.6 Ιστορικό πλαίσιο

Η ιδέα του διαχωρισμού ελέγχου και προώθησης δεν είναι εντελώς νέα. Προϋπήρξε σε ερευνητικές προσπάθειες όπως τα ενεργά δίκτυα (active networks) και άλλες προσεγγίσεις προγραμματιζόμενων δικτύων της δεκαετίας του 1990 [2]. Η πρακτική καθιέρωση των SDN συνδέεται, ωστόσο, στενά με την εργασία των McKeown κ.ά. [3], η οποία εισήγαγε το OpenFlow το 2008 και προσέφερε μια τυποποιημένη, ανοιχτή διεπαφή για τον προγραμματισμό εμπορικών μεταγωγέων. Η επακόλουθη υιοθέτηση της αρχιτεκτονικής και οι προσπάθειες τυποποίησης συνέβαλαν στην καθιέρωση των SDN ως βασικής προσέγγισης για σύγχρονες δικτυακές υποδομές [2].

Παράλληλα με τη λειτουργική ωρίμανση της αρχιτεκτονικής, αναδείχθηκε και η ανάγκη για εξειδικευμένη έρευνα ασφάλειας [4]. Η πρώιμη εργασία των Braga κ.ά. [8] έδειξε ότι τα ίδια τα στατιστικά ροών του OpenFlow μπορούν να τροφοδοτήσουν ελαφρείς ανιχνευτές κατανεμημένων επιθέσεων άρνησης υπηρεσίας (DDoS). Η εργασία αυτή αποτελεί άμεσο σημείο αναφοράς για την προσέγγιση που ακολουθείται και στην παρούσα διπλωματική. Έκτοτε, η σχετική βιβλιογραφία έχει εμπλουτιστεί με πλήθος μεθόδων Μηχανικής Μάθησης [6], οι οποίες αναλύονται στο Κεφάλαιο 4.

1.7 Το μέγεθος του προβλήματος

Η σημασία της προστασίας των δικτύων από επιθέσεις άρνησης υπηρεσίας δεν περιορίζεται σε θεωρητικό επίπεδο. Οι επιθέσεις αυτές παραμένουν από τις σοβαρότερες απειλές για τις σύγχρονες δικτυακές υποδομές και εξακολουθούν να απασχολούν την έρευνα [9], [10]. Χαρακτηριστικό παράδειγμα της κλίμακας που μπορούν να αποκτήσουν αποτελεί το δίκτυο Mirai. Στα τέλη του 2016 έφτασε σε κορύφωση περίπου 600.000 μολυσμένων συσκευών του Διαδικτύου των Πραγμάτων (Internet of Things, IoT) [11]. Για την παραβίαση ευάλωτων συσκευών χρησιμοποιούσε προκαθορισμένο κατάλογο 62 ζευγών διαπιστευτηρίων σύνδεσης [11]. Στο Mirai αποδίδεται επίθεση 623 gigabit ανά δευτερόλεπτο εναντίον του ιστολογίου Krebs on Security [11]. Μεταγενέστερη επίθεση έπληξε την υποδομή του παρόχου υπηρεσιών ονοματοδοσίας Dyn, επηρεάζοντας την πρόσβαση σε πολλές διαδικτυακές υπηρεσίες [11]. Το παράδειγμα αυτό δείχνει δύο πράγματα. Πρώτον, ότι ένα δίκτυο επίθεσης μεγάλης κλίμακας μπορεί να συγκροτηθεί από

μεγάλο αριθμό ανασφαλών συσκευών καθημερινής χρήσης. Δεύτερον, ότι μία επίθεση σε κοινή δικτυακή υποδομή μπορεί να έχει συνέπειες πολύ πέρα από τον άμεσο στόχο της.

Σε αυτό το πλαίσιο, η κεντροποίηση των SDN παρουσιάζει ταυτόχρονα ένα πλεονέκτημα και έναν κίνδυνο. Από τη μία πλευρά, προσφέρει κατάλληλο σημείο για την εγκατάσταση κεντρικού μηχανισμού άμυνας με συνολική εποπτεία του δικτύου [2], [4]. Από την άλλη πλευρά, συγκεντρώνει κρίσιμες λειτουργίες στο επίπεδο ελέγχου, καθιστώντας τον ελεγκτή σημαντικό στόχο επιθέσεων [4], [5]. Η παρούσα μελέτη τοποθετείται σε αυτό το σημείο τομής, αξιοποιώντας το πλεονέκτημα της κεντρικής εποπτείας για την προστασία του ίδιου του επιπέδου ελέγχου.

1.8 Μεθοδολογική προσέγγιση

Η μεθοδολογία που ακολουθήθηκε συνδυάζει τη θεωρητική μελέτη με την υλοποίηση και την πειραματική αξιολόγηση, σε μια επαναληπτική διαδικασία. Αρχικά μελετήθηκε το θεωρητικό υπόβαθρο των SDN και των απειλών τους, ώστε να προσδιοριστούν οι απαιτήσεις του συστήματος. Χρονικά, αναπτύχθηκε πρώτη η εκτός σύνδεσης ανάλυση (Μέθοδος Β), η οποία τροφοδότησε τον σχεδιασμό της επόμενης πειραματικής φάσης. Στη συνέχεια αναπτύχθηκε το ζωντανό σύστημα ανίχνευσης και αυτόματης αντιμετώπισης (Μέθοδος Α), το οποίο αξιολογήθηκε μέσω των πειραματικών σεναρίων. Τέλος, πραγματοποιήθηκαν συμπληρωματικές αναλύσεις σε ζητήματα ερμηνευσιμότητας και ασφάλειας. Η σταδιακή αυτή διαδικασία επιδιώκει οι σχεδιαστικές αποφάσεις να τεκμηριώνονται από τα διαθέσιμα δεδομένα και τα πειραματικά αποτελέσματα.

Καθ' όλη τη διάρκεια της εργασίας δόθηκε έμφαση στην αναπαραγωγιμότητα και στην τεκμηρίωση. Κάθε πείραμα σχεδιάστηκε ώστε να μπορεί να επαναληφθεί υπό τις ίδιες συνθήκες. Οι παράμετροι, οι διαδικασίες και τα αποτελέσματα καταγράφηκαν ώστε να διευκολύνεται η επανάληψη και ο έλεγχός τους, ενώ οι βασικές σχεδιαστικές επιλογές αιτιολογήθηκαν ρητά.

2 Αρχιτεκτονική των Δικτύων SDN

Ο διαχωρισμός του επιπέδου ελέγχου από το επίπεδο δεδομένων, που παρουσιάστηκε συνοπτικά στο Κεφάλαιο 1, αποτυπώνεται αρχιτεκτονικά σε τρία λογικά επίπεδα [2]. Το επίπεδο δεδομένων αναλαμβάνει την προώθηση των πακέτων, το επίπεδο ελέγχου τη λήψη των αποφάσεων και το επίπεδο εφαρμογών την υλοποίηση της δικτυακής πολιτικής [2]. Τα τρία επίπεδα επικοινωνούν μεταξύ τους μέσω καθορισμένων διεπαφών προγραμματισμού, οι οποίες εξετάζονται στη συνέχεια του κεφαλαίου.

2.1 Τα τρία επίπεδα της αρχιτεκτονικής

2.1.1 Επίπεδο Δεδομένων (Data Plane)

Το επίπεδο δεδομένων αποτελείται από τους δικτυακούς μεταγωγείς (switches), οι οποίοι στα SDN αναλαμβάνουν κυρίως τη λειτουργία προώθησης, ενώ οι αποφάσεις πολιτικής και διαχείρισης της προώθησης μεταφέρονται στον ελεγκτή [2]. Κάθε μεταγωγέας διατηρεί έναν ή περισσότερους πίνακες ροών (flow tables), οι οποίοι περιέχουν κανόνες που καθορίζουν πώς θα χειριστεί τα εισερχόμενα πακέτα [3]. Όταν ένα πακέτο ταιριάζει σε έναν κανόνα, εκτελείται η αντίστοιχη ενέργεια, όπως προώθηση σε θύρα, απόρριψη ή τροποποίηση πεδίων της επικεφαλίδας. Όταν όμως δεν ταιριάζει σε κανέναν υπάρχοντα κανόνα, προκύπτει η κατάσταση που στο OpenFlow ονομάζεται table-miss. Ανάλογα με τη διαμόρφωση του μεταγωγέα, το πακέτο μπορεί να απορριφθεί ή να αποσταλεί στον ελεγκτή, ολόκληρο ή εν μέρει, μέσω μηνύματος Packet-In [3]. Στη δεύτερη περίπτωση, ο ελεγκτής αποφασίζει πώς θα χειριστεί το πακέτο.

2.1.2 Επίπεδο Ελέγχου (Control Plane)

Το επίπεδο ελέγχου περιέχει τον ελεγκτή, ο οποίος αποτελεί τον λογικό «εγκέφαλο» του δικτύου. Ο ελεγκτής διατηρεί μια σφαιρική εικόνα του δικτύου (global network view) και λαμβάνει αποφάσεις σχετικά με την πολιτική και τη διαχείριση της προώθησης [2]. Στη συνέχεια προγραμματίζει τους πίνακες ροών των μεταγωγέων μέσω μηνυμάτων Flow-Mod, με τα οποία μπορούν να προστεθούν, να τροποποιηθούν ή να διαγραφούν καταχωρήσεις ροής [3]. Η λογική συγκέντρωση της ευφυΐας διευκολύνει την κεντρική και ομοιόμορφη εφαρμογή πολιτικών ασφάλειας και προώθησης στο δίκτυο [2]. Ταυτόχρονα, όμως, η ίδια συγκέντρωση μπορεί να δημιουργήσει κρίσιμο σημείο ευπάθειας, ιδιαίτερα όταν ο ελεγκτής λειτουργεί χωρίς πλεονασμό [4].

2.1.3 Επίπεδο Εφαρμογών (Application Plane)

Στο ανώτερο επίπεδο βρίσκονται οι δικτυακές εφαρμογές, όπως μηχανισμοί εξισορρόπησης φορτίου, τείχη προστασίας, συστήματα ανίχνευσης εισβολών και εφαρμογές μηχανίκευσης κίνησης (traffic engineering), οι οποίες υλοποιούν λειτουργίες και πολιτικές διαχείρισης του δικτύου [2]. Οι εφαρμογές αυτές δεν επικοινωνούν απευθείας με τις συσκευές του δικτύου. Αντ' αυτού, αλληλεπιδρούν με τον ελεγκτή μέσω της βόρειας διεπαφής (northbound API), η οποία σε πολλές υλοποιήσεις παρέχεται ως διεπαφή REST [2]. Το σύστημα ανίχνευσης που αναπτύσσεται στην παρούσα εργασία εντάσσεται εννοιολογικά σε αυτό το επίπεδο, καθώς αποτελεί εφαρμογή ασφάλειας που εποπτεύει το δίκτυο και λαμβάνει αποφάσεις για την επιβολή πολιτικών αντιμετώπισης. Η συγκεκριμένη υλοποίηση ακολουθεί υβριδική αρχιτεκτονική, η οποία περιγράφεται αναλυτικά στο Κεφάλαιο 5.

2.2 Διεπαφές επικοινωνίας και πρωτόκολλα νότιας διεπαφής

Η νότια διεπαφή (southbound API) συνδέει το επίπεδο ελέγχου με το επίπεδο δεδομένων και επιτρέπει την ανταλλαγή εντολών και πληροφοριών μεταξύ του ελεγκτή και των μεταγωγέων. Χαρακτηριστικό τυποποιημένο πρωτόκολλο αυτής της επικοινωνίας είναι το OpenFlow, μέσω του οποίου ο ελεγκτής μπορεί να προγραμματίζει τους πίνακες ροών και να λαμβάνει πληροφορίες για την κατάσταση του μεταγωγέα [3]. Στο ευρύτερο οικοσύστημα SDN χρησιμοποιούνται επίσης πρωτόκολλα όπως τα NETCONF και OVSDB, τα οποία εξυπηρετούν κυρίως λειτουργίες διαμόρφωσης και διαχείρισης συσκευών και μπορούν να λειτουργούν συμπληρωματικά προς το OpenFlow [2]. Η βόρεια διεπαφή, η οποία παρουσιάστηκε στην προηγούμενη ενότητα, συνδέει αντίστοιχα τον ελεγκτή με τις εφαρμογές του ανώτερου επιπέδου. Σε αντίθεση με το OpenFlow, δεν υπάρχει μία ενιαία τυποποιημένη βόρεια διεπαφή που να χρησιμοποιείται καθολικά, και η μορφή της εξαρτάται συχνά από τον εκάστοτε ελεγκτή [2].

Άλλα πρωτόκολλα διαμόρφωσης και διαχείρισης

Το NETCONF χρησιμοποιείται για τη διαμόρφωση και τη διαχείριση δικτυακών συσκευών, συχνά σε συνδυασμό με μοντέλα δεδομένων που ορίζονται μέσω της γλώσσας YANG. Το OVSDB είναι πρωτόκολλο διαχείρισης του Open vSwitch και λειτουργεί συμπληρωματικά προς το OpenFlow. Μέσω του OVSDB ρυθμίζονται στοιχεία όπως οι γέφυρες και οι θύρες του μεταγωγέα, ενώ το OpenFlow χρησιμοποιείται για τον προγραμματισμό της συμπεριφοράς προώθησης [2].

2.3 Το πρωτόκολλο OpenFlow: μηνύματα, διοχέτευση και στατιστικά

Το OpenFlow, που παρουσιάστηκε από τους McKeown κ.ά. [3], αποτελεί ένα από τα βασικά πρωτόκολλα νότιας διεπαφής για την επικοινωνία μεταξύ ελεγκτή και μεταγωγέα. Επιτρέπει στον ελεγκτή να προγραμματίζει τη συμπεριφορά προώθησης του μεταγωγέα μέσω των πινάκων ροών. Κάθε καταχώρηση ροής περιλαμβάνει πεδία ταιριάσματος (match fields), μετρητές και οδηγίες επεξεργασίας, ενώ μπορεί επίσης να περιλαμβάνει στοιχεία όπως προτεραιότητα και χρονικά όρια ισχύος [3], [12]. Τα πεδία ταιριάσματος συγκρίνονται με τη θύρα εισόδου και με τα πεδία των επικεφαλίδων του εισερχόμενου πακέτου, και καθορίζουν ποια πακέτα αντιστοιχούν στην καταχώρηση [12]. Οι μετρητές καταγράφουν στοιχεία όπως το πλήθος πακέτων και bytes. Οι οδηγίες καθορίζουν την περαιτέρω επεξεργασία του πακέτου, συμπεριλαμβανομένων των ενεργειών που θα εκτελεστούν. Όταν περισσότερες από μία καταχωρήσεις στον ίδιο πίνακα ταιριάζουν στο ίδιο πακέτο, επιλέγεται εκείνη με την υψηλότερη προτεραιότητα [12].

Ιδιαίτερη σημασία για την παρούσα μελέτη έχουν τα στατιστικά που διατηρεί ο μεταγωγέας. Για κάθε καταχώρηση ροής μπορούν να ανακτηθούν στοιχεία όπως το πλήθος πακέτων, το πλήθος bytes και η διάρκεια ισχύος της καταχώρησης μέσω μηνυμάτων Flow-Stats Request/Reply [12]. Αντίστοιχα, τα μηνύματα Port-Stats Request/Reply παρέχουν συγκεντρωτικά στατιστικά ανά θύρα και όχι ανά μεμονωμένη ροή [12]. Τα δεδομένα αυτά μπορούν να χρησιμοποιηθούν για την εξαγωγή στατιστικών χαρακτηριστικών που στη συνέχεια τροφοδοτούν ένα μοντέλο Μηχανικής Μάθησης [8]. Με τον τρόπο αυτό μπορεί να πραγματοποιηθεί ανίχνευση χωρίς εξέταση του περιεχομένου κάθε πακέτου, όπως συμβαίνει στη βαθιά επιθεώρηση πακέτων (deep packet inspection). Το κόστος συλλογής των στατιστικών εξαρτάται όμως από τον αριθμό των ροών και τη συχνότητα των αιτημάτων.

Τύποι μηνυμάτων OpenFlow

Το OpenFlow ορίζει διαφορετικούς τύπους μηνυμάτων για την επικοινωνία μεταξύ ελεγκτή και μεταγωγέα. Ο Πίνακας 2-1 συνοψίζει τα μηνύματα που είναι σημαντικότερα για την κατανόηση της παρούσας εργασίας και του μηχανισμού ανίχνευσης και αντιμετώπισης επιθέσεων [12].

Πίνακας 2-1: Βασικοί τύποι μηνυμάτων OpenFlow.

Μήνυμα	Κατεύθυνση	Σκοπός
--------	------------	--------

Packet-In	Μεταγωγέας → Ελεγκτής	Αποστολή ενός πακέτου ή μέρους του προς τον ελεγκτή όταν απαιτείται η παρέμβασή του, μεταξύ άλλων σε περίπτωση table-miss όταν ο μεταγωγέας έχει διαμορφωθεί κατάλληλα.
Packet-Out	Ελεγκτής → Μεταγωγέας	Εντολή του ελεγκτή προς τον μεταγωγέα για την εκτέλεση ενεργειών σε συγκεκριμένο πακέτο, συχνά για την προώθησή του μέσω μίας ή περισσότερων θυρών.
Flow-Mod	Ελεγκτής → Μεταγωγέας	Προσθήκη, τροποποίηση ή διαγραφή καταχωρήσεων ροής στους πίνακες του μεταγωγέα.
Flow-Stats Request/Reply	Ελεγκτής → Μεταγωγέας / Μεταγωγέας → Ελεγκτής	Αίτηση και επιστροφή στατιστικών που αφορούν καταχωρήσεις ροής, όπως το πλήθος πακέτων, το πλήθος bytes και η διάρκεια.
Port-Stats Request/Reply	Ελεγκτής → Μεταγωγέας / Μεταγωγέας → Ελεγκτής	Αίτηση και επιστροφή συγκεντρωτικών στατιστικών ανά θύρα του μεταγωγέα.

Όπως φαίνεται στον Πίνακα 2-1, τα μηνύματα OpenFlow εξυπηρετούν διαφορετικούς ρόλους στην επικοινωνία ελεγκτή και μεταγωγέα. Τα Packet-In και Packet-Out σχετίζονται με τον χειρισμό μεμονωμένων πακέτων, ενώ τα Flow-Mod χρησιμοποιούνται για τη διαχείριση των καταχωρήσεων ροής. Τα Flow-Stats και Port-Stats παρέχουν πληροφορίες για την κατάσταση της δικτυακής κίνησης και είναι ιδιαίτερα σημαντικά για μηχανισμούς παρακολούθησης και ανίχνευσης. Η διάκριση αυτή έχει σημασία για τη συνέχεια της εργασίας. Σε διαμορφώσεις όπου πακέτα που δεν αντιστοιχούν σε υπάρχουσες καταχωρήσεις προκαλούν μηνύματα Packet-In, η εμφάνιση μεγάλου αριθμού τέτοιων πακέτων μπορεί να αυξήσει σημαντικά τον φόρτο του ελεγκτή [5], [12].

Η διοχέτευση επεξεργασίας του OpenFlow

Στις νεότερες εκδόσεις του OpenFlow, η επεξεργασία ενός πακέτου δεν περιορίζεται σε έναν μόνο πίνακα ροών αλλά μπορεί να διέρχεται από μια διοχέτευση επεξεργασίας (pipeline) πολλαπλών πινάκων [12]. Το πακέτο εισέρχεται στον πρώτο πίνακα, όπου αναζητείται η καταχώρηση με την υψηλότερη προτεραιότητα που ταιριάζει. Οι οδηγίες της καταχώρησης μπορούν είτε να ολοκληρώσουν την επεξεργασία είτε να προωθήσουν το πακέτο σε επόμενο πίνακα μέσω της οδηγίας Goto-Table. Η διοχέτευση προχωρά μόνο προς πίνακες με μεγαλύτερο αριθμό και όχι προς προηγούμενους πίνακες [12].

Κατά τη διαδρομή αυτή μπορεί να δημιουργείται ένα σύνολο ενεργειών (action set). Σε αυτό προστίθενται ενέργειες μέσω της οδηγίας Write-Actions και το σύνολο εκτελείται όταν

ολοκληρωθεί η επεξεργασία της διοχέτευσης [12]. Άλλες ενέργειες μπορούν να εκτελεστούν άμεσα μέσω της οδηγίας Apply-Actions. Η αρχιτεκτονική πολλαπλών πινάκων επιτρέπει τον διαχωρισμό διαφορετικών λειτουργιών επεξεργασίας, για παράδειγμα της εφαρμογής πολιτικών ασφάλειας και της προώθησης της κίνησης.

Πέρα από τους πίνακες ροών, το OpenFlow ορίζει και πίνακες ομάδων (group tables), οι οποίοι υποστηρίζουν λειτουργίες όπως πολλαπλή προώθηση (multicast), εξισορρόπηση φορτίου και ταχεία εναλλαγή διαδρομής σε περίπτωση αστοχίας (fast failover) [12]. Παρότι η υλοποίηση της παρούσας εργασίας εστιάζει κυρίως στη σημασιολογία ταιριάσματος και ενέργειας (match-action) ενός μόνο πίνακα, η κατανόηση της πλήρους διοχέτευσης είναι σημαντική για την κατανόηση των δυνατοτήτων του προγραμματιζόμενου επιπέδου δεδομένων.

Το Open vSwitch διαχωρίζει την επεξεργασία μεταξύ του χώρου χρήστη και του πυρήνα του λειτουργικού συστήματος [13]. Όταν το πρώτο πακέτο μιας ροής δεν αντιστοιχεί σε ήδη αποθηκευμένη απόφαση προώθησης στον πυρήνα, προωθείται στο στοιχείο του Open vSwitch που λειτουργεί στον χώρο χρήστη για πρόσθετη επεξεργασία. Αφού εγκατασταθεί η αντίστοιχη απόφαση, τα επόμενα πακέτα μπορούν να εξυπηρετηθούν απευθείας από τον πυρήνα [13]. Με τον τρόπο αυτό αποφεύγεται η επανάληψη της ίδιας επεξεργασίας στον χώρο χρήστη για κάθε πακέτο της ίδιας ροής. Αντίστροφα, κίνηση που δεν επαναχρησιμοποιεί ήδη αποθηκευμένες αποφάσεις προώθησης μπορεί να οδηγεί σε συχνότερη επεξεργασία στον χώρο χρήστη.

Πεδία ταιριάσματος και δομή καταχώρησης ροής

Η εκφραστικότητα του OpenFlow απορρέει από το σύνολο των πεδίων ταιριάσματος που μπορεί να χρησιμοποιήσει μια καταχώρηση ροής [12]. Τα πεδία αυτά καλύπτουν πολλαπλά επίπεδα της στοίβας πρωτοκόλλων, όπως τη θύρα εισόδου του μεταγωγέα, τις διευθύνσεις MAC προέλευσης και προορισμού, τον τύπο Ethernet, τις διευθύνσεις IP, το πρωτόκολλο μεταφοράς και τις θύρες TCP ή UDP [12]. Ο συνδυασμός αυτών των πεδίων επιτρέπει τον καθορισμό καταχωρήσεων με διαφορετικό βαθμό εξειδίκευσης (granularity). Μια καταχώρηση μπορεί, για παράδειγμα, να αφορά ολόκληρο υποδίκτυο ή, αντίθετα, μία συγκεκριμένη ροή.

Κάθε καταχώρηση ροής περιλαμβάνει, μεταξύ άλλων, προτεραιότητα, χρονόμετρα λήξης και μετρητές [12]. Η προτεραιότητα καθορίζει ποια καταχώρηση επιλέγεται όταν περισσότερες από μία καταχωρήσεις στον ίδιο πίνακα ταιριάζουν στο πακέτο. Το

χρονόμετρο αδράνειας (idle timeout) καθορίζει για πόσο χρόνο μπορεί να παραμείνει μια καταχώρηση χωρίς να αντιστοιχιστεί σε αυτή νέο πακέτο. Αντίθετα, το απόλυτο χρονόμετρο λήξης (hard timeout) περιορίζει τη συνολική διάρκεια ζωής της καταχώρησης από τη στιγμή της εγκατάστασής της, ανεξάρτητα από το αν συνεχίζει να χρησιμοποιείται [12]. Τα χρονόμετρα αυτά επιτρέπουν την αυτόματη απομάκρυνση παλαιών ή ανενεργών καταχωρήσεων και περιορίζουν την άσκοπη συσσώρευσή τους στους πίνακες ροών.

Μηχανισμός συλλογής στατιστικών

Ο μεταγωγέας διατηρεί μετρητές για διάφορα αντικείμενα, ανάμεσά τους τις καταχωρήσεις ροής και τις θύρες του, οι οποίοι παρέχουν πληροφορίες για τη δικτυακή κίνηση [12]. Σε μια καταχώρηση ροής μπορούν να καταγράφονται, μεταξύ άλλων, το πλήθος των πακέτων και των bytes που έχουν αντιστοιχιστεί σε αυτή, καθώς και η διάρκειά της. Αντίστοιχα, οι μετρητές θυρών παρέχουν συγκεντρωτικά στοιχεία για την κίνηση που εισέρχεται και εξέρχεται από κάθε θύρα. Όπως παρουσιάστηκε στον Πίνακα 2-1, ο ελεγκτής μπορεί να ζητήσει αυτά τα στοιχεία μέσω των αντίστοιχων μηνυμάτων στατιστικών του OpenFlow. Η προδιαγραφή χαρακτηρίζει τους μετρητές πακέτων και bytes ανά καταχώρηση ροής προαιρετικούς, ενώ τους αντίστοιχους ανά θύρα υποχρεωτικούς [12]. Επομένως, η διαθεσιμότητα των μετρητών ανά καταχώρηση ροής εξαρτάται από τις δυνατότητες του εκάστοτε μεταγωγέα.

Οι τιμές των μετρητών είναι σωρευτικές [12]. Για να εκτιμηθεί η κίνηση που εμφανίστηκε μέσα σε ένα συγκεκριμένο χρονικό διάστημα, μπορούν να συγκριθούν δύο διαδοχικές μετρήσεις. Η διαφορά μεταξύ τους εκφράζει τη δραστηριότητα που καταγράφηκε στο αντίστοιχο χρονικό παράθυρο. Η περιοδική συλλογή τέτοιων μετρήσεων επιτρέπει την παρακολούθηση της εξέλιξης της δικτυακής κίνησης. Τα αιτήματα και οι απαντήσεις στατιστικών ανταλλάσσονται μέσω του καναλιού ελέγχου [12]. Συνεπώς, η συχνότητα συλλογής επηρεάζει και τον όγκο της επικοινωνίας μεταξύ ελεγκτή και μεταγωγέα.

2.4 Ελεγκτές SDN: εσωτερική δομή, διαθεσιμότητα και ασφάλεια του καναλιού ελέγχου

Στην πράξη έχουν αναπτυχθεί διαφορετικές πλατφόρμες ελεγκτών SDN, οι οποίες διαφέρουν ως προς τη γλώσσα υλοποίησης, την αρχιτεκτονική και το πεδίο χρήσης τους [2]. Ο Πίνακας 2-2 παρουσιάζει ενδεικτικά ορισμένους ελεγκτές και βασικά χαρακτηριστικά τους.

Πίνακας 2-2: Ενδεικτικοί ελεγκτές SDN και βασικά χαρακτηριστικά τους.

Ελεγκτής	Γλώσσα	Χαρακτηριστικά / Χρήση
POX / NOX	Python / C++	Κεντριοποιημένα πλαίσια ελεγκτή για την ανάπτυξη εφαρμογών SDN.
Ryu	Python	Κεντριοποιημένο πολυνηματικό πλαίσιο ελεγκτή με υποστήριξη OpenFlow και επεξεργασία συμβάντων.
ONOS	Java	Κατανεμημένη πλατφόρμα ελεγκτή με μηχανισμούς για κλιμάκωση και υψηλή διαθεσιμότητα.
OpenDaylight	Java	Κατανεμημένη και επεκτάσιμη πλατφόρμα ελεγκτή που υποστηρίζει διαφορετικές διεπαφές και πρωτόκολλα.

Όπως φαίνεται στον Πίνακα 2-2, τα πλαίσια POX, NOX και Ryu ακολουθούν κεντριοποιημένη αρχιτεκτονική, ενώ τα ONOS και OpenDaylight υποστηρίζουν κατανεμημένη λειτουργία [2].

Ο Ryu αποτελεί πλαίσιο ανάπτυξης ελεγκτών SDN σε Python και υποστηρίζει την επικοινωνία με μεταγωγείς μέσω OpenFlow [2]. Παρέχει μηχανισμούς επεξεργασίας συμβάντων και επιτρέπει την ανάπτυξη εφαρμογών που λαμβάνουν αποφάσεις ελέγχου και προγραμματίζουν τη συμπεριφορά των μεταγωγέων. Η αρχική εξέταση του Ryu στο πλαίσιο της παρούσας εργασίας και οι λόγοι που οδήγησαν στην τελική αρχιτεκτονική παρουσιάζονται στο Κεφάλαιο 5.

Εσωτερική δομή και υψηλή διαθεσιμότητα του ελεγκτή

Ένας ελεγκτής SDN μπορεί να αποτελείται από επιμέρους υπηρεσίες, όπως η διαχείριση της τοπολογίας, η δρομολόγηση, η διαχείριση συμβάντων και οι διεπαφές προς τις εφαρμογές [2]. Παρότι ο έλεγχος του δικτύου είναι λογικά κεντριοποιημένος, η φυσική υλοποίησή του δεν είναι απαραίτητο να περιορίζεται σε έναν μόνο κόμβο [2]. Σε κατανεμημένες αρχιτεκτονικές, η λειτουργία ελέγχου κατανέμεται σε περισσότερους κόμβους, οι οποίοι συνεργάζονται και ανταλλάσσουν πληροφορίες για την κατάσταση του δικτύου. Η προσέγγιση αυτή μπορεί να βελτιώσει την κλιμάκωση και τη διαθεσιμότητα του επιπέδου ελέγχου, αλλά δημιουργεί παράλληλα απαιτήσεις συντονισμού μεταξύ των κόμβων [2]. Οι κατανεμημένες πλατφόρμες διαφέρουν επίσης ως προς τις εγγυήσεις συνέπειας της κοινής κατάστασης που παρέχουν. Οι εγγυήσεις αυτές μπορεί να είναι

ασθενείς ή ισχυρές, ανάλογα με την αρχιτεκτονική και τις απαιτήσεις του εκάστοτε ελεγκτή [2].

Ασφάλεια του καναλιού ελέγχου

Το κανάλι ελέγχου μεταξύ ελεγκτή και μεταγωγέα μεταφέρει τις πληροφορίες και τις εντολές που απαιτούνται για τη λειτουργία του προγραμματιζόμενου δικτύου. Για τον λόγο αυτό, η παραβίασή του μπορεί να επηρεάσει τόσο το επίπεδο ελέγχου όσο και το επίπεδο δεδομένων [4]. Η προδιαγραφή OpenFlow 1.3.5 επιτρέπει την προστασία της επικοινωνίας μέσω TLS (Transport Layer Security), ενός κρυπτογραφικού πρωτοκόλλου που χρησιμοποιείται για την προστασία των δεδομένων κατά τη μεταφορά τους [12]. Όταν χρησιμοποιείται TLS, ο ελεγκτής και ο μεταγωγέας μπορούν να αυθεντικοποιούνται αμοιβαία μέσω πιστοποιητικών, ενώ προστατεύονται η εμπιστευτικότητα και η ακεραιότητα της επικοινωνίας [12].

Η χρήση TLS δεν είναι υποχρεωτική στην προδιαγραφή OpenFlow 1.3.5 [12]. Επιπλέον, έχει επισημανθεί στη βιβλιογραφία ότι η υποστήριξη και η χρήση του TLS δεν ήταν καθολικές σε εμπορικές και ανοιχτού κώδικα υλοποιήσεις ελεγκτών και μεταγωγέων [4]. Συνεπώς, το επίπεδο προστασίας του καναλιού ελέγχου εξαρτάται και από τη διαμόρφωση και τις δυνατότητες της εκάστοτε εγκατάστασης. Όταν η επικοινωνία πραγματοποιείται χωρίς TLS, δεν παρέχονται οι αντίστοιχες εγγυήσεις κρυπτογράφησης και αμοιβαίας αυθεντικοποίησης. Το γεγονός αυτό αυξάνει την έκθεση του καναλιού σε απειλές, όπως η υποκλοπή και η πλαστοπροσωπία ελεγκτή ή μεταγωγέα [4], [12].

2.5 Mininet και Open vSwitch

Το Mininet είναι ένα περιβάλλον εξομίωσης δικτύων που επιτρέπει τη δημιουργία εικονικών κόμβων, μεταγωγέων και συνδέσεων σε έναν μόνο φυσικό υπολογιστή [2], [14]. Οι εικονικοί κόμβοι εκτελούν πραγματικές δικτυακές εφαρμογές και αξιοποιούν μηχανισμούς απομόνωσης του πυρήνα Linux, γεγονός που επιτρέπει την εκτέλεση ολοκληρωμένων δικτυακών σεναρίων χωρίς να απαιτείται αντίστοιχος αριθμός φυσικών συσκευών [14]. Η τοπολογία μπορεί να δημιουργηθεί και να τερματιστεί γρήγορα, διευκολύνοντας την επανάληψη πειραμάτων υπό ελεγχόμενες συνθήκες [2], [14].

Οι εικονικοί μεταγωγείς του Mininet μπορούν να διατηρούν την ίδια σημασιολογία OpenFlow με αντίστοιχους φυσικούς μεταγωγείς, επιτρέποντας την ανάπτυξη και τον

λειτουργικό έλεγχο εφαρμογών SDN σε εξομοιωμένο περιβάλλον [2]. Η αντιστοιχία αυτή αφορά τη συμπεριφορά του πρωτοκόλλου και δεν συνεπάγεται ότι μετρήσεις απόδοσης ή καθυστέρησης ταυτίζονται με εκείνες ενός φυσικού δικτύου. Οι σχετικοί περιορισμοί εξετάζονται αναλυτικά στην ενότητα «Απειλές εγκυρότητας και στατιστική αξιοπιστία» του Κεφαλαίου 6 και συνοψίζονται στο Κεφάλαιο 7.

Το Open vSwitch (OVS) είναι ένας λογισμικός μεταγωγέας ανοιχτού κώδικα, σχεδιασμένος για εικονικά και προγραμματιζόμενα δικτυακά περιβάλλοντα [13]. Υποστηρίζει το OpenFlow, επιτρέποντας τον προγραμματισμό της συμπεριφοράς προώθησης μέσω καταχωρήσεων ροής. Παράλληλα, παρέχει λειτουργίες διαχείρισης, παρακολούθησης και συλλογής στατιστικών για τη δικτυακή κίνηση [13]. Ο τρόπος με τον οποίο το Open vSwitch κατανέμει την επεξεργασία μεταξύ πυρήνα και χώρου χρήστη παρουσιάστηκε στην παράγραφο 2.3.

Τα δύο εργαλεία επιτελούν διαφορετικούς αλλά συμπληρωματικούς ρόλους. Το Mininet παρέχει το εξομοιωμένο δικτυακό περιβάλλον και την τοπολογία, ενώ το Open vSwitch υλοποιεί τον προγραμματιζόμενο μεταγωγέα μέσα σε αυτό. Η συγκεκριμένη διαμόρφωση και ο τρόπος με τον οποίο χρησιμοποιούνται τα δύο εργαλεία στην παρούσα εργασία παρουσιάζονται αναλυτικά στο Κεφάλαιο 5.

2.6 Σύγκριση με τα παραδοσιακά δίκτυα: πλεονεκτήματα και προκλήσεις

Ο διαχωρισμός του επιπέδου ελέγχου από το επίπεδο δεδομένων προσφέρει στα SDN σημαντικές δυνατότητες διαχείρισης και προγραμματισμού [2]. Η κεντρική λογική διαχείρισης επιτρέπει τον ενιαίο καθορισμό πολιτικών και μπορεί να μειώσει τις ασυνέπειες διαμόρφωσης μεταξύ διαφορετικών συσκευών. Παράλληλα, η προγραμματισιμότητα μέσω των διεπαφών του ελεγκτή διευκολύνει την αυτοματοποίηση και την ανάπτυξη νέων δικτυακών λειτουργιών. Η συνολική εικόνα του δικτύου που διαθέτει ο ελεγκτής επιτρέπει επίσης τη λήψη αποφάσεων με βάση την κατάσταση περισσότερων τμημάτων του δικτύου, όπως στην περίπτωση της μηχανίκευσης κίνησης (traffic engineering) [2].

Τα πλεονεκτήματα αυτά συνοδεύονται από αντίστοιχες προκλήσεις. Η κλιμάκωση του επιπέδου ελέγχου απαιτεί ο ελεγκτής να μπορεί να διαχειρίζεται αυξανόμενο αριθμό συσκευών, ροών και συμβάντων [1], [2]. Η διαθεσιμότητα και η ανεκτικότητα σε αστοχίες

είναι επίσης κρίσιμες, καθώς ένας ελεγκτής που λειτουργεί χωρίς πλεονασμό μπορεί να αποτελέσει μοναδικό σημείο αποτυχίας [4]. Παράλληλα, η συγκέντρωση σημαντικών λειτουργιών ελέγχου αυξάνει τη σημασία της προστασίας του ελεγκτή και του καναλιού ελέγχου από επιθέσεις [1], [4]. Οι προκλήσεις αυτές δεν αναιρούν τα πλεονεκτήματα της αρχιτεκτονικής SDN, αλλά αποτελούν βασικές απαιτήσεις για την ασφαλή και αξιόπιστη λειτουργία της.

Οι βασικές διαφορές μεταξύ της παραδοσιακής αρχιτεκτονικής δικτύων και της αρχιτεκτονικής SDN συνοψίζονται στον Πίνακα 2-3 [2].

Πίνακας 2-3: Συγκριτική επισκόπηση παραδοσιακών δικτύων και SDN.

Πτυχή	Παραδοσιακό δίκτυο	SDN
Λήψη αποφάσεων ελέγχου	Κατανέμεται στις επιμέρους δικτυακές συσκευές	Λογικά κεντριοποιείται στον ελεγκτή
Διαμόρφωση	Πραγματοποιείται κυρίως ανά συσκευή	Μπορεί να εφαρμόζεται κεντρικά μέσω προγραμματιζόμενων πολιτικών
Εισαγωγή νέων λειτουργιών	Εξαρτάται σε μεγαλύτερο βαθμό από τις δυνατότητες των επιμέρους συσκευών	Μπορεί να πραγματοποιείται μέσω λογισμικών εφαρμογών και προγραμματιζόμενων διεπαφών
Εικόνα του δικτύου	Η πληροφορία κατανέμεται μεταξύ των συσκευών	Ο ελεγκτής διατηρεί λογικά συγκεντρωτική εικόνα του δικτύου
Επίπτωση αστοχίας	Η έκταση της επίπτωσης εξαρτάται από τον ρόλο της συσκευής και τον διαθέσιμο πλεονασμό	Η αστοχία ελεγκτή χωρίς πλεονασμό μπορεί να επηρεάσει τη λειτουργία ελέγχου του δικτύου [4]

Όπως φαίνεται στον Πίνακα 2-3, η αρχιτεκτονική SDN μεταφέρει σημαντικό μέρος της λογικής ελέγχου από τις επιμέρους συσκευές σε ένα προγραμματιζόμενο επίπεδο ελέγχου. Η μεταβολή αυτή διευκολύνει την κεντρική εφαρμογή πολιτικών και την αυτοματοποίηση, αλλά καθιστά ιδιαίτερα σημαντικές την κλιμάκωση, τη διαθεσιμότητα και την ασφάλεια του ελεγκτή. Η λογική κεντριοποίηση δεν συνεπάγεται υποχρεωτικά έναν μοναδικό φυσικό ελεγκτή. Οι κατανομημένες αρχιτεκτονικές ελεγκτών παρουσιάστηκαν στην παράγραφο 2.4.

2.7 Εικονικοποίηση δικτυακών λειτουργιών (Network Functions Virtualization, NFV)

Η εικονικοποίηση δικτυακών λειτουργιών (Network Functions Virtualization, NFV) είναι μια προσέγγιση κατά την οποία λειτουργίες που παραδοσιακά υλοποιούνται σε εξειδικευμένες δικτυακές συσκευές εκτελούνται ως λογισμικό σε υποδομή γενικού σκοπού [2]. Η NFV και τα SDN είναι διακριτές τεχνολογίες. Η NFV αφορά τον τρόπο υλοποίησης των δικτυακών λειτουργιών και δεν συνεπάγεται από μόνη της τον διαχωρισμό του επιπέδου ελέγχου από το επίπεδο δεδομένων [2]. Ο διαχωρισμός αυτός αποτελεί βασικό χαρακτηριστικό των SDN. Στην πράξη, οι δύο προσεγγίσεις μπορούν να χρησιμοποιούνται συνδυαστικά για την ευέλικτη και ταχύτερη ανάπτυξη νέων δικτυακών υπηρεσιών [2].

2.8 Υπηρεσίες ασφαλείας στο επίπεδο εφαρμογών

Τα SDN έχουν εφαρμοστεί σε περιβάλλοντα με αυξημένες ανάγκες διαχείρισης, όπως τα κέντρα δεδομένων πολλαπλών ενοίκων (multi-tenant data centers) [2]. Η κεντρική διαχείριση μπορεί να διευκολύνει την αυτοματοποίηση και την απομόνωση μεταξύ διαφορετικών ενοίκων. Σε τέτοια περιβάλλοντα, η διαθεσιμότητα και η προστασία του επιπέδου ελέγχου αποκτούν ιδιαίτερη σημασία.

Το επίπεδο εφαρμογών μπορεί να φιλοξενεί υπηρεσίες που αξιοποιούν την κεντρική εικόνα και τη δυνατότητα προγραμματισμού του δικτύου. Στον τομέα της ασφάλειας, η βιβλιογραφία περιγράφει εφαρμογές όπως δυναμικά τείχη προστασίας, συστήματα ανίχνευσης και πρόληψης εισβολών και μηχανισμούς προστασίας από επιθέσεις άρνησης υπηρεσίας [4]. Χαρακτηριστικό των εφαρμογών αυτών είναι η στενή σύνδεσή τους με το επίπεδο ελέγχου. Μια εφαρμογή ασφαλείας δεν περιορίζεται στην ανίχνευση ενός συμβάντος, αλλά μπορεί να ζητήσει την εφαρμογή αλλαγών στη συμπεριφορά του δικτύου ως απόκριση σε αυτό [4]. Η βιβλιογραφία επισημαίνει επίσης περιορισμούς τέτοιων προσεγγίσεων, όπως την πρόσθετη επιβάρυνση του ελεγκτή και την εξάρτηση από έναν μοναδικό ελεγκτή όταν δεν υπάρχει πλεονασμός [4].

3 Απειλές και Επιθέσεις σε Δίκτυα SDN

Η αρχιτεκτονική SDN προσφέρει δυνατότητες κεντρικής διαχείρισης και προγραμματισμού του δικτύου, αλλά ταυτόχρονα δημιουργεί πρόσθετα σημεία στα οποία μπορεί να εκδηλωθεί μια επίθεση [2], [4]. Τα σημεία αυτά περιλαμβάνουν τον ελεγκτή, τις εφαρμογές, τις διεπαφές επικοινωνίας και τους μεταγωγείς [4]. Στο κεφάλαιο αυτό παρουσιάζονται οι βασικές κατηγορίες απειλών και οι μηχανισμοί μέσω των οποίων μπορούν να επηρεάσουν τη διαθεσιμότητα, την ακεραιότητα και τη λειτουργία του δικτύου. Ιδιαίτερη έμφαση δίνεται στις απειλές του επιπέδου ελέγχου, λόγω του κεντρικού ρόλου του ελεγκτή στη λήψη και εφαρμογή αποφάσεων.

3.1 Επιφάνεια επίθεσης ανά επίπεδο

Με τον όρο επιφάνεια επίθεσης εννοούνται τα σημεία ενός συστήματος μέσω των οποίων ένας επιτιθέμενος μπορεί να επιχειρήσει να επηρεάσει τη λειτουργία ή την ασφάλειά του. Στην αρχιτεκτονική SDN, τα σημεία αυτά κατανέμονται στα διαφορετικά επίπεδα και στις διεπαφές που τα συνδέουν. Η επισκόπηση των Scott-Hayward κ.ά. [4] οργανώνει τις απειλές SDN με βάση το τμήμα της αρχιτεκτονικής που επηρεάζουν.

Στο επίπεδο εφαρμογών, κακόβουλες ή ευάλωτες εφαρμογές μπορούν να επηρεάσουν τις πολιτικές που εφαρμόζονται στο δίκτυο μέσω της επικοινωνίας τους με τον ελεγκτή. Στο επίπεδο ελέγχου, στόχοι μπορούν να αποτελέσουν τόσο ο ίδιος ο ελεγκτής όσο και το κανάλι ελέγχου, μέσω επιθέσεων όπως η άρνηση υπηρεσίας, η πλαστοπροσωπία και η μη εξουσιοδοτημένη πρόσβαση. Στο επίπεδο δεδομένων, οι απειλές μπορούν να στοχεύουν τους μεταγωγείς και τους διαθέσιμους πόρους τους, για παράδειγμα μέσω παραποιημένων πληροφοριών, δηλητηρίασης της τοπολογίας ή εξάντλησης πόρων [4].

Οι κατηγορίες αυτές δεν είναι πλήρως ανεξάρτητες μεταξύ τους. Μια επίθεση που ξεκινά σε ένα επίπεδο μπορεί να επηρεάσει τη λειτουργία άλλου επιπέδου, επειδή οι εφαρμογές, ο ελεγκτής και οι μεταγωγείς συνεργάζονται για τη λειτουργία του δικτύου [4]. Για τον λόγο αυτό, οι επόμενες ενότητες εξετάζουν όχι μόνο τον αρχικό στόχο κάθε επίθεσης αλλά και τον μηχανισμό μέσω του οποίου μπορεί να επηρεαστεί συνολικά το SDN.

3.2 Επιθέσεις άρνησης υπηρεσίας (Denial of Service DoS): μορφές, μηχανισμός και ταξινόμηση

Οι επιθέσεις άρνησης υπηρεσίας (Denial of Service, DoS) επιδιώκουν να καταστήσουν έναν πόρο ή μια υπηρεσία μη διαθέσιμη στους νόμιμους χρήστες. Στις καταναεμημένες επιθέσεις άρνησης υπηρεσίας (Distributed Denial of Service, DDoS), η κακόβουλη κίνηση προέρχεται από πολλαπλές πηγές, οι οποίες μπορεί να αποτελούν μέρος ενός δικτύου παραβιασμένων συσκευών [15]. Στα SDN, ο ελεγκτής αποτελεί ιδιαίτερα σημαντικό στόχο, επειδή συμμετέχει στη λήψη και εφαρμογή αποφάσεων για τη λειτουργία του δικτύου [4], [5].

Σε αντιδραστικές διαμορφώσεις OpenFlow, όταν ένα πακέτο δεν αντιστοιχεί σε υπάρχουσα καταχώρηση και το table-miss έχει διαμορφωθεί ώστε να προωθεί το πακέτο στον ελεγκτή, παράγεται μήνυμα Packet-In, όπως παρουσιάστηκε στην παράγραφο 2.1.1. Ένας επιτιθέμενος μπορεί να εκμεταλλευτεί τον μηχανισμό αυτό παράγοντας μεγάλο αριθμό διαφορετικών ροών που απαιτούν επεξεργασία από τον ελεγκτή [5]. Καθώς οι υπολογιστικοί πόροι του ελεγκτή είναι πεπερασμένοι, η αύξηση των αιτημάτων μπορεί να προκαλέσει αύξηση του φόρτου και του χρόνου απόκρισης και να επηρεάσει την εξυπηρέτηση της νόμιμης κίνησης [4], [5]. Επομένως, σε ένα SDN μια επίθεση άρνησης υπηρεσίας μπορεί να στοχεύσει όχι μόνο το εύρος ζώνης ή έναν τελικό εξυπηρετητή, αλλά και τους πόρους του επιπέδου ελέγχου.

Ένα χαρακτηριστικό παράδειγμα είναι η πλημμύρα SYN (SYN flood). Η επίθεση εκμεταλλεύεται τη διαδικασία δημιουργίας μιας σύνδεσης TCP. Ο επιτιθέμενος αποστέλλει μεγάλο αριθμό αιτημάτων έναρξης σύνδεσης χωρίς να ολοκληρώνει τη διαδικασία, με αποτέλεσμα να παραμένουν ημιτελείς συνδέσεις και να δεσμεύονται πόροι του στόχου [15]. Σε περιβάλλον SDN, εφόσον η παραγόμενη κίνηση δημιουργεί νέες ροές που απαιτούν απόφαση από τον ελεγκτή, μπορεί να προκύψει πρόσθετη επιβάρυνση και στο επίπεδο ελέγχου [4], [5].

Ταξινόμηση επιθέσεων άρνησης υπηρεσίας

Οι επιθέσεις άρνησης υπηρεσίας μπορούν να διαφέρουν ως προς τον μηχανισμό και τον πόρο που στοχεύουν. Οι Peng κ.ά. [15] διακρίνουν τις επιθέσεις κατανάλωσης εύρους ζώνης σε εκείνες που βασίζονται σε μηχανισμούς δικτυακών πρωτοκόλλων και σε εκείνες που βασίζονται σε αιτήματα εφαρμογών. Στην πρώτη κατηγορία ανήκουν επιθέσεις που εκμεταλλεύονται χαρακτηριστικά πρωτοκόλλων για να καταναλώσουν διαθέσιμους

πόρους, όπως η πλημμύρα SYN. Στη δεύτερη κατηγορία, η κατανάλωση πόρων προκαλείται μέσω αιτημάτων προς εφαρμογές ή υπηρεσίες. Οι ίδιοι συγγραφείς εξετάζουν χωριστά και επιθέσεις που στοχεύουν τη δικτυακή υποδομή [15].

Για την αρχιτεκτονική SDN ιδιαίτερη σημασία έχουν οι μορφές κίνησης που προκαλούν επανειλημμένη δημιουργία νέων αιτημάτων προς το επίπεδο ελέγχου. Ο μηχανισμός αυτός συνδέεται με τη διαχείριση νέων ροών μέσω Packet-In και μπορεί να αυξήσει τον φόρτο του ελεγκτή [4], [5].

Επιθέσεις άρνησης υπηρεσίας χαμηλού ρυθμού

Πέρα από τις παραπάνω κατηγορίες, η βιβλιογραφία περιγράφει και μορφές επίθεσης που δεν βασίζονται στη συνεχή παραγωγή μεγάλου όγκου κίνησης. Σε αυτές περιλαμβάνονται οι επιθέσεις άρνησης υπηρεσίας χαμηλού ρυθμού (Low-rate Denial of Service, LDoS) [16].

Οι επιθέσεις LDoS χαρακτηρίζονται από χαμηλό μέσο ρυθμό κίνησης, περιοδικότητα και δυνατότητα συγκάλυψης της δραστηριότητάς τους [16]. Αντί να εξαντλούν τους πόρους των ζεύξεων και των τελικών κόμβων, εκμεταλλεύονται τον μηχανισμό ελέγχου συμφόρησης του πρωτοκόλλου TCP [16].

Ο επιτιθέμενος εκμεταλλεύεται μηχανισμούς του TCP, όπως το χρονικό όριο επαναμετάδοσης (Retransmission Timeout, RTO) και τον μηχανισμό προσθετικής αύξησης και πολλαπλασιαστικής μείωσης (Additive Increase/Multiplicative Decrease, AIMD) [16]. Η επίθεση μπορεί να πραγματοποιείται μέσω περιοδικών παλμών κίνησης υψηλής έντασης, οι οποίοι προκαλούν προσωρινή συμφόρηση σε συγκεκριμένα χρονικά διαστήματα [16]. Το μοντέλο της επίθεσης χαρακτηρίζεται από τρεις παραμέτρους: τον ρυθμό, την περίοδο και τη διάρκεια του παλμού [16]. Ο στιγμιαίος ρυθμός του παλμού μπορεί να είναι αρκετά υψηλός ώστε να προκαλεί προσωρινή συμφόρηση, ενώ ο μέσος ρυθμός της κακόβουλης κίνησης κατά τη διάρκεια ολόκληρης της περιόδου παραμένει σχετικά χαμηλός [16]. Με τον τρόπο αυτό, η επίδραση στον μηχανισμό ελέγχου συμφόρησης μπορεί να επαναλαμβάνεται περιοδικά χωρίς να απαιτείται συνεχής κίνηση υψηλού ρυθμού [16].

Η κατηγορία αυτή έχει ιδιαίτερη σημασία και στα SDN. Ο μηχανισμός ελέγχου συμφόρησης του TCP εξακολουθεί να εφαρμόζεται και σε περιβάλλοντα με κεντριοποιημένο έλεγχο, επομένως η σχετική αδυναμία παραμένει [16]. Επιπλέον, όταν η επίθεση στοχεύει τον ελεγκτή ή υπηρεσίες του επιπέδου ελέγχου, μπορεί να επηρεαστεί η διαθεσιμότητα βασικών λειτουργιών του δικτύου [16].

3.3 Κορεσμός του πίνακα ροών και του καναλιού ελέγχου

Στενά συνδεδεμένος με την επιβάρυνση του επιπέδου ελέγχου είναι ο κορεσμός του πίνακα ροών (flow-table exhaustion). Οι μεταγωγείς διαθέτουν πεπερασμένο χώρο για την αποθήκευση καταχωρήσεων ροής [5]. Σε υλοποιήσεις υλικού, μέρος των καταχωρήσεων μπορεί να αποθηκεύεται σε μνήμη TCAM (Ternary Content-Addressable Memory), η οποία επιτρέπει την ταχεία αντιστοίχιση κανόνων με πολλαπλά πεδία, αλλά αποτελεί περιορισμένο και σχετικά ακριβό πόρο [2].

Ένας επιτιθέμενος μπορεί να παράγει μεγάλο αριθμό διαφορετικών ροών, μεταβάλλοντας πεδία όπως οι διευθύνσεις ή οι θύρες προέλευσης και προορισμού. Αν οι ροές αυτές οδηγούν στην εγκατάσταση νέων καταχωρήσεων, μπορούν να καταναλώσουν τη διαθέσιμη χωρητικότητα του πίνακα και να δυσχεράνουν την εγκατάσταση κανόνων για νόμιμη κίνηση [5].

Η ίδια δραστηριότητα μπορεί να επιβαρύνει ταυτόχρονα και το επίπεδο ελέγχου. Όταν ένα πακέτο δεν αντιστοιχεί σε υπάρχουσα καταχώρηση και το table-miss έχει διαμορφωθεί ώστε να προωθεί το πακέτο στον ελεγκτή, απαιτείται η επεξεργασία νέου αιτήματος από το επίπεδο ελέγχου. Μεγάλος αριθμός τέτοιων ροών μπορεί να καταναλώσει τόσο καταχωρήσεις του πίνακα ροών στο επίπεδο δεδομένων όσο και υπολογιστικούς πόρους του ελεγκτή [4], [5]. Η επίδραση της επίθεσης εξαρτάται, μεταξύ άλλων, από τη χωρητικότητα του πίνακα, τον τρόπο εγκατάστασης των καταχωρήσεων και τα χρονόμετρα λήξης που παρουσιάστηκαν στην παράγραφο 2.3.

3.4 Πλαστογράφηση, δηλητηρίαση τηλεμετρίας και επιθέσεις ενδιάμεσου

Εκτός από τις επιθέσεις που στοχεύουν τη διαθεσιμότητα, ένα SDN μπορεί να δεχθεί επιθέσεις που επηρεάζουν την ακεραιότητα των πληροφοριών και των κανόνων βάσει των οποίων λαμβάνονται αποφάσεις. Η μη εξουσιοδοτημένη εισαγωγή ή τροποποίηση καταχωρήσεων ροής μπορεί να αλλάξει τον τρόπο με τον οποίο προωθούνται, απορρίπτονται ή ανακατευθύνονται τα πακέτα [4]. Αντίστοιχα, ψευδείς ή αλλοιωμένες πληροφορίες που γίνονται αποδεκτές από το επίπεδο ελέγχου μπορούν να οδηγήσουν τον ελεγκτή σε εσφαλμένη εικόνα της κατάστασης του δικτύου.

Στην παρούσα εργασία, ως δηλητηρίαση τηλεμετρίας (telemetry poisoning) νοείται η κατασκευή ψευδών ή αλλοιωμένων στατιστικών κίνησης με στόχο την πρόκληση λανθασμένης απόφασης από έναν μηχανισμό ασφαλείας. Για παράδειγμα, ένας επιτιθέμενος

μπορεί να αποδώσει κακόβουλα χαρακτηριστικά σε έναν νόμιμο κόμβο, ώστε ο τελευταίος να θεωρηθεί υπεύθυνος για την επίθεση και να αποκλειστεί. Το σενάριο αυτό αφορά την ακεραιότητα και την προέλευση των δεδομένων τηλεμετρίας και όχι αποκλειστικά τον όγκο της δικτυακής κίνησης. Η συγκεκριμένη απειλή εξετάζεται πειραματικά στο Κεφάλαιο 6, χωρίς να παρουσιάζονται εδώ τα αποτελέσματά της.

Μια διαφορετική μορφή πλαστογράφησης είναι η πλαστογράφηση ARP (ARP spoofing). Το Πρωτόκολλο Ανάλυσης Διευθύνσεων (Address Resolution Protocol, ARP) χρησιμοποιείται για την αντιστοίχιση διευθύνσεων IP με διευθύνσεις MAC μέσα σε ένα τοπικό δίκτυο. Το ARP δεν διατηρεί κατάσταση προηγούμενων ανταλλαγών και δεν επαληθεύει τον αποστολέα από τον οποίο προέρχονται τα μηνύματα [17]. Την αδυναμία αυτή μπορεί να εκμεταλλευτεί ένας επιτιθέμενος, αποστέλλοντας πλαστά μηνύματα ARP που συσχετίζουν τη δική του διεύθυνση MAC με τη διεύθυνση IP μιας νόμιμης συσκευής [17]. Με τον τρόπο αυτό, η κίνηση μπορεί να ανακατευθυνθεί μέσω του επιτιθέμενου, επιτρέποντας την υποκλοπή ή την τροποποίησή της. Τέτοιες επιθέσεις μπορούν να οδηγήσουν σε επίθεση ενδιάμεσου (Man-in-the-Middle, MITM) ή σε άρνηση υπηρεσίας [17].

Σε περιβάλλον SDN, η εισαγωγή ψευδών ή αλλοιωμένων πληροφοριών είναι ιδιαίτερα σημαντική, επειδή οι αποφάσεις του ελεγκτή μπορούν να επηρεάσουν περισσότερα τμήματα του δικτύου [4]. Για τον λόγο αυτό, η προστασία της ακεραιότητας και της προέλευσης των πληροφοριών ελέγχου και τηλεμετρίας αποτελεί σημαντικό μέρος της ασφάλειας ενός SDN.

3.5 Σάρωση, πλευρική κίνηση και εξαγωγή δεδομένων

Η σάρωση θυρών (port scanning) μπορεί να αποτελεί ένα από τα αρχικά στάδια μιας επίθεσης. Στα αρχικά βήματα μιας απόπειρας εκμετάλλευσης μπορούν να περιλαμβάνονται η χαρτογράφηση του δικτύου, η ανακάλυψη διαθέσιμων υπηρεσιών, η αναγνώριση του λειτουργικού συστήματος και ο εντοπισμός τρωτοτήτων [4]. Μέσω αυτών των ενεργειών, ο επιτιθέμενος αποκτά πληροφορίες σχετικά με τους διαθέσιμους κόμβους και τις υπηρεσίες του δικτύου, οι οποίες μπορούν να χρησιμοποιηθούν για την επιλογή επόμενων στόχων.

Στην αρχιτεκτονική SDN η διαδικασία αναγνώρισης αποκτά πρόσθετο ενδιαφέρον. Σε μελέτη εφικτότητας έχει εξεταστεί κατά πόσο ένας επιτιθέμενος μπορεί, μέσω διαφορών στους χρόνους απόκρισης, να συμπεράνει αν ένα δίκτυο χρησιμοποιεί μεταγωγείς OpenFlow [5]. Η ίδια προσέγγιση έχει παρουσιαστεί στη βιβλιογραφία ως παράδειγμα κατά το οποίο προηγείται η αναγνώριση του δικτύου και ακολουθεί επίθεση που στοχεύει πόρους

του επιπέδου ελέγχου και του πίνακα ροών [4]. Επομένως, η αναγνώριση του δικτύου μπορεί να λειτουργήσει ως προπαρασκευαστικό στάδιο για επιθέσεις όπως εκείνες που παρουσιάστηκαν στις παραγράφους 3.2 και 3.3.

Η πλευρική κίνηση (lateral movement) αφορά τεχνικές με τις οποίες ένας επιτιθέμενος επιχειρεί να αποκτήσει πρόσβαση και έλεγχο σε άλλα συστήματα ενός δικτύου, αφού έχει ήδη αποκτήσει αρχική πρόσβαση στο περιβάλλον [18]. Για τον σκοπό αυτό μπορούν να χρησιμοποιηθούν εργαλεία απομακρυσμένης πρόσβασης ή νόμιμα διαπιστευτήρια [18]. Ο επιτιθέμενος μπορεί επίσης να μετακινείται διαδοχικά μέσα από πολλαπλά συστήματα και λογαριασμούς, επεκτείνοντας σταδιακά την πρόσβασή του στο εσωτερικό του δικτύου [18].

Η εξαγωγή δεδομένων (data exfiltration) αφορά τεχνικές που χρησιμοποιούνται για την απομάκρυνση δεδομένων από το δίκτυο-στόχο [19]. Η μεταφορά μπορεί να πραγματοποιηθεί μέσω του ίδιου καναλιού που χρησιμοποιείται για την επικοινωνία με το παραβιασμένο σύστημα ή μέσω διαφορετικού καναλιού [19]. Πριν από τη μεταφορά, τα δεδομένα μπορούν επίσης να συμπιεστούν ή να κρυπτογραφηθούν, ώστε να διευκολυνθεί η μεταφορά ή να δυσκολευτεί η αναγνώρισή της [19].

Οι τρεις αυτές δραστηριότητες εξυπηρετούν διαφορετικούς σκοπούς. Η σάρωση χρησιμοποιείται κυρίως για την απόκτηση πληροφοριών σχετικά με το δίκτυο και τις διαθέσιμες υπηρεσίες [4]. Η πλευρική κίνηση αφορά την επέκταση της πρόσβασης σε άλλα συστήματα του ίδιου περιβάλλοντος [18]. Η εξαγωγή δεδομένων αφορά την απομάκρυνση πληροφοριών από το παραβιασμένο δίκτυο [19].

3.6 Ο ελεγκτής χωρίς πλεονασμό ως πιθανό μοναδικό σημείο αποτυχίας και οι εσωτερικές απειλές

Το κοινό νήμα που διατρέχει τις παραπάνω απειλές είναι ο κεντρικός ρόλος του ελεγκτή.

Η κεντροποίηση του ελέγχου, ενώ απλοποιεί τη διαχείριση του δικτύου, εισάγει ταυτόχρονα ένα πιθανό μοναδικό σημείο αποτυχίας [9]. Επειδή η σχεδίαση βασίζεται σε μια κεντρική οντότητα, αν ο ελεγκτής πάψει να λειτουργεί, μπορούν να διακοπούν σημαντικές λειτουργίες του δικτύου και να υπονομευθούν οι ιδιότητες ασφάλειάς του [9].

Η ανάπτυξη πολλαπλών ελεγκτών μπορεί να μετριάσει το πρόβλημα, χωρίς όμως να το εξαλείφει. Έχει επισημανθεί ότι η κατανομή του ελέγχου δημιουργεί πρόσθετες απαιτήσεις σχετικά με την ακεραιότητα, την κλιμακωσιμότητα και τη συνέπεια των πολιτικών μεταξύ διαφορετικών τομέων ελέγχου [9]. Επιπλέον, προβλήματα σε έναν ελεγκτή μπορούν, υπό ορισμένες συνθήκες, να επηρεάσουν και άλλους ελεγκτές του κατανεμημένου συστήματος

[9]. Επομένως, ο πλεονασμός μειώνει την εξάρτηση από έναν μοναδικό ελεγκτή, αλλά εισάγει νέες απαιτήσεις συντονισμού και προστασίας.

Πέραν των εξωτερικών επιτιθέμενων, τα SDN είναι εκτεθειμένα και σε εσωτερικές απειλές. Καθώς η αρχιτεκτονική επιτρέπει την ένταξη εφαρμογών μέσω της βόρειας διεπαφής, μια κακόβουλη εφαρμογή μπορεί να έχει εξίσου επιζήμια επίδραση στο δίκτυο με έναν παραβιασμένο ελεγκτή [4]. Αντίστοιχα, μια κακοσχεδιασμένη ή ελαττωματική εφαρμογή μπορεί να εισαγάγει τρωτότητες ακόμη και χωρίς κακόβουλη πρόθεση [4].

Οι απειλές αυτές αναδεικνύουν την ανάγκη για έλεγχο πρόσβασης, αυθεντικοποίηση και εφαρμογή της αρχής του ελάχιστου προνομίου στη διεπαφή μεταξύ εφαρμογών και ελεγκτή. Έχουν προταθεί συστήματα δικαιωμάτων ανά εφαρμογή, ώστε να μην εκτίθεται το πλήρες σύνολο δυνατοτήτων του OpenFlow σε κάθε εφαρμογή [6]. Οι σχετικοί μηχανισμοί άμυνας εξετάζονται αναλυτικότερα στην παράγραφο 3.8.

3.7 Ταξινόμηση των απειλών, υποδομή και αντίκτυπος των επιθέσεων

Για τη συνολική αποτύπωση των απειλών που παρουσιάστηκαν στις προηγούμενες ενότητες, ο Πίνακας 3-1 συνοψίζει το μοντέλο απειλών της παρούσας εργασίας. Για κάθε κατηγορία προσδιορίζονται η ικανότητα του επιτιθέμενου, το προστατευόμενο αγαθό, το σημείο εισόδου, η βασική παραδοχή και ο πιθανός αντίκτυπος. Ο πίνακας συνοψίζει τους μηχανισμούς που αναλύθηκαν στις παραγράφους 3.2–3.6 και δεν αποτελεί ανεξάρτητη ταξινόμηση της βιβλιογραφίας.

Πίνακας 3-1: Τυπικό μοντέλο απειλών των εξεταζόμενων επιθέσεων.

Ικανότητα επιτιθέμενου	Αγαθό (asset)	Σημείο εισόδου	Παραδοχή	Αντίκτυπος
Εξωτερικός κόμβος που παράγει κίνηση υψηλού ρυθμού, όπως σε DDoS ή πλημμύρα SYN	Διαθεσιμότητα υπηρεσίας και πόρων ελέγχου	Επίπεδο δεδομένων (νόμιμος host)	Η παραγόμενη κίνηση μπορεί να καταναλώσει διαθέσιμους πόρους	Άρνηση υπηρεσίας και κορεσμός πόρων

Επιτιθέμενος που παράγει μεγάλο αριθμό διαφορετικών ροών	Πίνακας ροών και πόροι του επιπέδου ελέγχου	Επίπεδο δεδομένων	Οι νέες ροές οδηγούν σε νέες καταχωρήσεις και, όταν το table-miss έχει κατάλληλη διαμόρφωση, σε αιτήματα προς τον ελεγκτή	Κορεσμός πίνακα ροών, επιβάρυνση ελεγκτή και καθυστέρηση
Κακόβουλος ή παραβιασμένος κόμβος στο ίδιο τοπικό δίκτυο	Ακεραιότητα και εμπιστευτικότητα της επικοινωνίας	Επίπεδο δεδομένων	Το ARP δεν επαληθεύει τον αποστολέα των μηνυμάτων [17]	Υποκλοπή ή αλλοίωση κίνησης, επίθεση ενδιάμεσου ή άρνηση υπηρεσίας
Επιτιθέμενος που εισάγει ψευδή ή αλλοιωμένα δεδομένα τηλεμετρίας	Ακεραιότητα της διαδικασίας απόφασης	Μηχανισμός εισαγωγής τηλεμετρίας	Η προέλευση ή η ακεραιότητα της τηλεμετρίας δεν επαληθεύεται επαρκώς	Λανθασμένη απόφαση και πιθανός αποκλεισμός νόμιμου κόμβου
Κακόβουλη ή παραβιασμένη εφαρμογή	Πολιτική ελέγχου του δικτύου	Βόρεια διεπαφή	Η εφαρμογή διαθέτει πρόσβαση σε λειτουργίες του ελεγκτή [4]	Μη εξουσιοδοτημένη μεταβολή της συμπεριφοράς του δικτύου
Επιτιθέμενος που πραγματοποιεί σάθρωση	Πληροφορίες για κόμβους και υπηρεσίες	Επίπεδο δεδομένων	Ο επιτιθέμενος μπορεί να αποστέλλει αιτήματα αναγνώρισης	Χαρτογράφηση του δικτύου και επιλογή επόμενων στόχων
Επιτιθέμενος που έχει αποκτήσει αρχική πρόσβαση	Εσωτερικά συστήματα και λογαριασμοί	Παραβιασμένο εσωτερικό σύστημα	Υπάρχει δυνατότητα πρόσβασης σε πρόσθετα συστήματα ή λογαριασμούς [18]	Επέκταση της πρόσβασης στο εσωτερικό του δικτύου
Επιτιθέμενος με πρόσβαση σε δεδομένα του παραβιασμένου περιβάλλοντος	Εμπιστευτικότητα δεδομένων	Παραβιασμένο σύστημα και κανάλι εξόδου	Υπάρχει δυνατότητα μεταφοράς δεδομένων προς εξωτερικό προορισμό [19]	Μη εξουσιοδοτημένη εξαγωγή δεδομένων

Από τον Πίνακα 3-1 προκύπτει ότι οι απειλές δεν στοχεύουν αποκλειστικά τη διαθεσιμότητα. Ορισμένες επηρεάζουν την ακεραιότητα των πληροφοριών και των αποφάσεων του ελεγκτή, ενώ άλλες στοχεύουν την εμπιστευτικότητα των δεδομένων ή τη συλλογή πληροφοριών για το δίκτυο. Διαφορετικά είναι και τα σημεία εισόδου, καθώς μια επίθεση μπορεί να ξεκινήσει από το επίπεδο δεδομένων, από μια εφαρμογή ή από έναν ήδη παραβιασμένο εσωτερικό κόμβο. Η διάκριση αυτή είναι σημαντική, επειδή δεν μπορεί ένας μόνο μηχανισμός προστασίας να αντιμετωπίσει με τον ίδιο τρόπο όλες τις κατηγορίες απειλών.

Για τις κατηγορίες επιθέσεων που αξιολογούνται πειραματικά στην παρούσα εργασία, ο Πίνακας 3-2 συνοψίζει τον κύριο στόχο, τον μηχανισμό και την πιθανή επίπτωσή τους. Η απειλή μιας κακόβουλης εφαρμογής, η οποία περιλαμβάνεται στο ευρύτερο μοντέλο απειλών του Πίνακα 3-1, δεν αποτελεί ξεχωριστό πειραματικό σενάριο και για τον λόγο αυτό δεν περιλαμβάνεται στον Πίνακα 3-2.

Πίνακας 3-2: Ταξινόμηση των επιθέσεων που αξιολογούνται πειραματικά.

Επίθεση	Κύριος στόχος	Μηχανισμός	Κύρια επίπτωση
DDoS / πλημμύρα SYN	Υπηρεσία ή πόροι ελέγχου	Υψηλός ρυθμός αιτημάτων ή πακέτων	Κορεσμός πόρων και άρνηση υπηρεσίας
Εξάντληση πίνακα ροών	Μεταγωγέας	Μεγάλο πλήθος διακριτών ροών	Εξάντληση χωρητικότητας του πίνακα
Δηλητηρίαση τηλεμετρίας	Διαδικασία απόφασης	Ψευδή ή αλλοιωμένα στατιστικά	Λανθασμένη απόφαση ή αποκλεισμός νόμιμου κόμβου
Σάρωση θυρών	Κόμβοι και υπηρεσίες δικτύου	Επαναλαμβανόμενα αιτήματα αναγνώρισης	Αναγνώριση πιθανών στόχων
Πλευρική κίνηση	Εσωτερικά συστήματα	Διαδοχική πρόσβαση σε πρόσθετα συστήματα ή λογαριασμούς	Επέκταση της πρόσβασης
Εξαγωγή δεδομένων	Δεδομένα	Μη εξουσιοδοτημένη μεταφορά προς εξωτερικό προορισμό	Απώλεια εμπιστευτικότητας
Πλαστογράφηση ARP	Κόμβοι τοπικού δικτύου	Πλαστές αντιστοιχίσεις IP και MAC	Υποκλοπή, αλλοίωση κίνησης ή άρνηση υπηρεσίας

Όπως φαίνεται στον Πίνακα 3-2, οι επιθέσεις που βασίζονται σε υψηλό ρυθμό πακέτων ή σε μεγάλο πλήθος διακριτών ροών μπορούν να προκαλέσουν έντονες μεταβολές στα χαρακτηριστικά της δικτυακής κίνησης ή στην κατανάλωση πόρων. Αντίθετα, επιθέσεις που στοχεύουν την ακεραιότητα, την ταυτότητα ή την εμπιστευτικότητα μπορούν να εκδηλωθούν χωρίς αντίστοιχη αύξηση του συνολικού όγκου κίνησης. Για τον λόγο αυτό, η προστασία ενός SDN δεν μπορεί να βασίζεται αποκλειστικά σε συγκεντρωτικά στατιστικά κίνησης. Απαιτούνται επίσης μηχανισμοί ελέγχου πρόσβασης, αυθεντικοποίησης και προστασίας της ακεραιότητας [4], [17].

Πέρα από την τεχνική διάσταση, η διαθεσιμότητα του δικτύου μπορεί να αποτελεί και συμβατική απαίτηση. Οι συμφωνίες επιπέδου υπηρεσίας (Service Level Agreements, SLA) καθορίζουν απαιτήσεις σχετικά με την ποιότητα και τη διαθεσιμότητα της παρεχόμενης υπηρεσίας [1]. Για παράδειγμα, επίπεδο διαθεσιμότητας 99,999 % αντιστοιχεί σε περίπου 5,26 λεπτά μη διαθεσιμότητας σε ένα έτος [1]. Επομένως, ακόμη και μια διακοπή διάρκειας λίγων λεπτών μπορεί να καταναλώσει σημαντικό μέρος του επιτρεπόμενου ετήσιου χρόνου μη διαθεσιμότητας. Η ταχεία ανίχνευση και αντιμετώπιση τέτοιων συμβάντων αποτελεί συνεπώς σημαντική λειτουργική απαίτηση.

Η υποδομή που χρησιμοποιείται για επιθέσεις DDoS μπορεί επίσης να αυξήσει σημαντικά την κλίμακά τους. Όπως παρουσιάστηκε στην παράγραφο 1.7, δίκτυα παραβιασμένων συσκευών μπορούν να χρησιμοποιηθούν για την παραγωγή μεγάλης ποσότητας κακόβουλης κίνησης. Η βιβλιογραφία περιγράφει επίσης υπηρεσίες DDoS επί πληρωμή και τη χρήση τεχνικών ενίσχυσης σε επιθέσεις που παρέχονται μέσω τέτοιων υπηρεσιών [11]. Η ύπαρξη αυτής της υποδομής δείχνει ότι η πραγματοποίηση μιας επίθεσης μεγάλης κλίμακας δεν εξαρτάται αποκλειστικά από τους υπολογιστικούς πόρους που διαθέτει άμεσα ένας μεμονωμένος επιτιθέμενος.

3.8 Μηχανισμοί άμυνας και ο ρόλος του συστήματος ανίχνευσης εισβολών (Intrusion Detection System, IDS)

Οι μηχανισμοί άμυνας έναντι επιθέσεων άρνησης υπηρεσίας κατατάσσονται στη βιβλιογραφία σε τέσσερις βασικές κατηγορίες [15]. Η αποτροπή επιδιώκει να εμποδίσει την επίθεση πριν αυτή επηρεάσει τον στόχο της. Η ανίχνευση επιδιώκει να αναγνωρίσει την επίθεση κατά την εκδήλωσή της και να παρέχει τις πληροφορίες που απαιτούνται για τις επόμενες ενέργειες άμυνας. Η ταυτοποίηση της πηγής επιδιώκει τον εντοπισμό της προέλευσης της επίθεσης, ακόμη και όταν η διεύθυνση προέλευσης των πακέτων έχει πλαστογραφηθεί. Τέλος, η αντίδραση αποσκοπεί στον περιορισμό των συνεπειών της επίθεσης μετά την αναγνώρισή της [15].

Μία από τις βασικές δυσκολίες της αντίδρασης είναι ο διαχωρισμός της κακόβουλης από τη νόμιμη κίνηση. Η απόρριψη της κακόβουλης κίνησης πρέπει να πραγματοποιείται χωρίς να διαταράσσεται η εξυπηρέτηση των νόμιμων χρηστών [15]. Στα SDN, στους μηχανισμούς αποτροπής μπορούν να ενταχθούν μέτρα όπως η αυθεντικοποίηση, ο έλεγχος πρόσβασης και η προστασία του καναλιού ελέγχου, τα οποία παρουσιάστηκαν στις παραγράφους 2.4 και 3.6.

Ένα σύστημα ανίχνευσης εισβολών (Intrusion Detection System, IDS) παρακολουθεί και ελέγχει τη δραστηριότητα του δικτύου με στόχο την αναγνώριση κακόβουλης συμπεριφοράς [9]. Όταν εντοπίζεται ύποπτη ή κακόβουλη κίνηση, το σύστημα μπορεί να ειδοποιήσει τον διαχειριστή και, ανάλογα με την αρχιτεκτονική του, να υποστηρίξει ενέργειες όπως η ανακατεύθυνση ή το φιλτράρισμα της κίνησης και η εγκατάσταση κατάλληλων πολιτικών [9]. Τα συστήματα ανίχνευσης εισβολών διακρίνονται, μεταξύ άλλων, σε συστήματα επιπέδου υπολογιστή (Host-based IDS, HIDS) και συστήματα επιπέδου δικτύου (Network-based IDS, NIDS) [9]. Ως προς τη μέθοδο ανίχνευσης, δύο βασικές προσεγγίσεις είναι η ανίχνευση βάσει υπογραφών και η ανίχνευση βάσει ανωμαλίας [9]. Οι προσεγγίσεις αυτές εξετάζονται αναλυτικότερα στο Κεφάλαιο 4.

Στην αρχιτεκτονική SDN, η κεντρική εικόνα του δικτύου και η δυνατότητα προγραμματισμού του επιτρέπουν στενότερη σύνδεση μεταξύ της ανίχνευσης και της εφαρμογής μέτρων απόκρισης [4]. Η πληροφορία που συλλέγεται από το δίκτυο μπορεί να αξιοποιηθεί για την αναγνώριση μιας απειλής και, στη συνέχεια, για την εφαρμογή κατάλληλων αλλαγών στη συμπεριφορά του δικτύου. Στα παραδοσιακά δίκτυα, αντίστοιχες λειτουργίες ασφάλειας συχνά υλοποιούνται με ξεχωριστές συσκευές, όπως συστήματα ανίχνευσης εισβολών και τείχη προστασίας, οι οποίες πρέπει να τοποθετούνται σε κατάλληλα σημεία του δικτύου και μπορεί να είναι δαπανηρές και δύσκολες στη διαμόρφωση [2]. Το επόμενο κεφάλαιο εξετάζει τις βασικές μεθόδους με τις οποίες μπορεί να πραγματοποιηθεί η ανίχνευση.

4 Μέθοδοι Ανίχνευσης και Μηχανική Μάθηση

Το προηγούμενο κεφάλαιο παρουσίασε τις βασικές απειλές που μπορούν να επηρεάσουν ένα δίκτυο SDN και τους μηχανισμούς μέσω των οποίων εκδηλώνονται. Το παρόν κεφάλαιο εξετάζει τις βασικές μεθόδους που χρησιμοποιούνται για την αναγνώριση κακόβουλης ή ασυνήθιστης δικτυακής δραστηριότητας. Αρχικά παρουσιάζονται οι παραδοσιακές προσεγγίσεις ανίχνευσης και οι περιορισμοί τους. Στη συνέχεια εξετάζονται οι μέθοδοι Μηχανικής Μάθησης, οι βασικοί αλγόριθμοι που χρησιμοποιούνται στην παρούσα εργασία, τα χαρακτηριστικά της δικτυακής κίνησης και οι μετρικές αξιολόγησης των μοντέλων. Τέλος, παρουσιάζεται σχετική βιβλιογραφία και εξετάζονται ζητήματα προεπεξεργασίας των δεδομένων, ρύθμισης και γενίκευσης των μοντέλων, καθώς και θέματα ιδιωτικότητας και δεοντολογίας.

4.1 Παραδοσιακές μέθοδοι ανίχνευσης και οι περιορισμοί τους

Ως προς τη μέθοδο ανίχνευσης, τα συστήματα ανίχνευσης εισβολών μπορούν να διακριθούν σε προσεγγίσεις βάσει γνώσης (knowledge-based detection) ή γνωστής κατάχρησης (misuse detection), στις οποίες εντάσσεται η ανίχνευση βάσει υπογραφών (signature-based detection), και σε προσεγγίσεις βάσει ανωμαλίας (anomaly-based detection) [9]. Στην πρώτη κατηγορία, η παρατηρούμενη δραστηριότητα συγκρίνεται με προκαθορισμένες υπογραφές, κανόνες ή άλλες γνωστές ενδείξεις κακόβουλης συμπεριφοράς. Στην ίδια λογική μπορούν να χρησιμοποιηθούν προκαθορισμένα κατώφλια (thresholds), ώστε μια δραστηριότητα να θεωρείται ύποπτη όταν μια μετρούμενη τιμή υπερβεί ένα συγκεκριμένο όριο [9].

Στα διαδεδομένα συστήματα ανίχνευσης εισβολών ανοιχτού κώδικα ανήκουν το Snort και το Suricata [4], [9]. Στην ανίχνευση βάσει γνώσης, η απόφαση μπορεί να συνδεθεί με έναν συγκεκριμένο κανόνα ή με ένα γνωστό πρότυπο κακόβουλης συμπεριφοράς. Αυτό διευκολύνει την ερμηνεία της απόφασης, καθώς είναι δυνατό να προσδιοριστεί ποια συνθήκη οδήγησε στην παραγωγή μιας ειδοποίησης.

Η προσέγγιση αυτή προϋποθέτει ότι υπάρχει διαθέσιμη σαφής υπογραφή ή κανόνας που να περιγράφει την κακόβουλη δραστηριότητα [9]. Όταν δεν υπάρχει αντίστοιχη υπογραφή ή όταν η παρατηρούμενη συμπεριφορά αποκλίνει σημαντικά από τους γνωστούς κανόνες, η αναγνώρισή της μπορεί να είναι δυσκολότερη. Αντίστοιχα, στην περίπτωση προκαθορισμένων κατωφλίων, η απόφαση εξαρτάται άμεσα από την τιμή που έχει επιλεγεί. Ένα χαμηλό κατώφλι μπορεί να αυξήσει τον αριθμό των νόμιμων δραστηριοτήτων που

χαρακτηρίζονται ύποπτες, ενώ ένα υψηλότερο κατώφλι μειώνει την ευαισθησία του συγκεκριμένου κανόνα.

Η δεύτερη βασική προσέγγιση είναι η ανίχνευση βάσει ανωμαλίας (anomaly-based detection). Σε αυτή την περίπτωση συλλέγονται δεδομένα που περιγράφουν τη φυσιολογική ή την παρατηρούμενη συμπεριφορά του συστήματος και εξετάζεται αν μια νέα δραστηριότητα αποκλίνει σημαντικά από αυτή [9]. Για την αναγνώριση τέτοιων αποκλίσεων μπορούν να χρησιμοποιηθούν στατιστικές μέθοδοι και τεχνικές Μηχανικής Μάθησης (Machine Learning, ML) [9].

Η ανίχνευση βάσει ανωμαλίας μειώνει την αποκλειστική εξάρτηση από προκαθορισμένες υπογραφές, αλλά δημιουργεί διαφορετικές απαιτήσεις. Η αποτελεσματικότητά της εξαρτάται από την ποιότητα των δεδομένων, την επιλογή κατάλληλων χαρακτηριστικών (features) και την ικανότητα διάκρισης μιας πραγματικής ανωμαλίας από μια νόμιμη μεταβολή της δικτυακής συμπεριφοράς. Οι απαιτήσεις αυτές οδηγούν στη χρήση τεχνικών Μηχανικής Μάθησης, οι οποίες παρουσιάζονται στην επόμενη ενότητα.

4.2 Μηχανική Μάθηση και επισκόπηση των αλγορίθμων

Η Μηχανική Μάθηση περιλαμβάνει μεθόδους με τις οποίες ένα μοντέλο μαθαίνει σχέσεις και πρότυπα από δεδομένα, αντί να βασίζεται αποκλειστικά σε προκαθορισμένους κανόνες. Στα SDN, τα στατιστικά ροών που συλλέγονται από το δίκτυο μπορούν να αποτελέσουν είσοδο σε συστήματα ανίχνευσης που χρησιμοποιούν τεχνικές Μηχανικής Μάθησης [6]. Η δυνατότητα αυτή επιτρέπει την εξέταση διαφορετικών αλγορίθμων για την αναγνώριση κακόβουλης ή ασυνήθιστης δικτυακής δραστηριότητας [6].

Δύο βασικές και συμπληρωματικές προσεγγίσεις είναι η επιβλεπόμενη μάθηση (supervised learning) και η ανεπιβλεπτη μάθηση (unsupervised learning) [20]. Στην επιβλεπόμενη μάθηση, τα δεδομένα εκπαίδευσης συνοδεύονται από γνωστές ετικέτες (labels), οι οποίες δηλώνουν την κατηγορία κάθε εγγραφής. Το μοντέλο μαθαίνει τη σχέση μεταξύ των χαρακτηριστικών (features) και των αντίστοιχων ετικετών, ώστε στη συνέχεια να μπορεί να ταξινομεί νέες εγγραφές.

Στην ανεπιβλεπτη μάθηση, τα δεδομένα δεν συνοδεύονται από γνωστές ετικέτες. Ο αλγόριθμος επιχειρεί να εντοπίσει δομές, ομάδες ή ασυνήθιστα πρότυπα μέσα στα ίδια τα δεδομένα [20, p. 485]. Η προσέγγιση αυτή μπορεί να χρησιμοποιηθεί στην ανίχνευση

ανωμαλιών (anomaly detection), όπου ο στόχος είναι ο εντοπισμός παρατηρήσεων που διαφέρουν σημαντικά από τη συνήθη συμπεριφορά. Ο Isolation Forest, ο οποίος παρουσιάζεται αναλυτικά στην παράγραφο 4.3, αποτελεί παράδειγμα αλγορίθμου που μπορεί να χρησιμοποιηθεί για αυτόν τον σκοπό.

Στην παρούσα εργασία εξετάζονται συνολικά οκτώ επιβλεπόμενοι αλγόριθμοι. Οι βασικές αρχές λειτουργίας τους συνοψίζονται παρακάτω:

- **Random Forest (Τυχαίο Δάσος):** αποτελεί μέθοδο συνόλου (ensemble method) που συνδυάζει πολλά δέντρα απόφασης. Κάθε δέντρο εκπαιδεύεται σε τυχαίο δείγμα των δεδομένων, ενώ σε κάθε διαχωρισμό εξετάζεται τυχαίο υποσύνολο των διαθέσιμων χαρακτηριστικών [20, Ch. 15], [21]. Στην ταξινόμηση, η τελική πρόβλεψη προκύπτει από τον συνδυασμό των προβλέψεων των επιμέρους δέντρων, συνήθως μέσω ψηφοφορίας. Η χρήση τυχαίας επιλογής χαρακτηριστικών παρουσιάζει μεγαλύτερη στιβαρότητα στον θόρυβο σε σύγκριση με ενισχυτικές μεθόδους (boosting methods) [21].
- **Decision Tree (Δέντρο Απόφασης):** οργανώνει τη διαδικασία ταξινόμησης ως διαδοχικούς διαχωρισμούς των δεδομένων με βάση τις τιμές των χαρακτηριστικών [20, Ch. 9]. Κάθε εσωτερικός κόμβος αντιστοιχεί σε έναν κανόνα διαχωρισμού και κάθε τελικό φύλλο σε μια πρόβλεψη. Η δομή αυτή καθιστά το μοντέλο σχετικά εύκολο στην ερμηνεία. Ωστόσο, ένα πολύ σύνθετο δέντρο μπορεί να προσαρμοστεί υπερβολικά στα δεδομένα εκπαίδευσης. Το φαινόμενο αυτό ονομάζεται υπερπροσαρμογή (overfitting) [20, Ch. 9].
- **K-Nearest Neighbors (KNN, K Πλησιέστεροι Γείτονες):** ταξινομεί μια νέα παρατήρηση με βάση τις ετικέτες των k πλησιέστερων παρατηρήσεων του συνόλου εκπαίδευσης [20, Ch. 13]. Η έννοια της εγγύτητας καθορίζεται μέσω μιας μετρικής απόστασης (distance metric) στον χώρο των χαρακτηριστικών. Επομένως, η κλίμακα στην οποία εκφράζονται τα διαφορετικά χαρακτηριστικά μπορεί να επηρεάσει σημαντικά τη λειτουργία της μεθόδου.
- **Support Vector Machine (SVM, Μηχανή Διανυσμάτων Υποστήριξης):** αναζητά ένα διαχωριστικό υπερεπίπεδο (hyperplane) που διαχωρίζει τις κατηγορίες με όσο το δυνατόν μεγαλύτερο περιθώριο (margin) μεταξύ τους [20, Ch. 12]. Όταν ο διαχωρισμός δεν είναι γραμμικός, μπορούν να χρησιμοποιηθούν συναρτήσεις πυρήνα (kernel functions). Στην παρούσα εργασία εξετάζεται η συνάρτηση ακτινικής βάσης (Radial

Basis Function, RBF), η οποία επιτρέπει τη δημιουργία μη γραμμικών ορίων απόφασης [20, Ch. 12].

- **Logistic Regression (Λογιστική Παλινδρόμηση):** παρά το όνομά της, χρησιμοποιείται ευρέως σε προβλήματα ταξινόμησης. Υπολογίζει την πιθανότητα μια παρατήρηση να ανήκει σε μια συγκεκριμένη κατηγορία με βάση έναν γραμμικό συνδυασμό των χαρακτηριστικών της [20, Ch. 4]. Η σχετικά απλή δομή της την καθιστά χρήσιμη ως βάση αναφοράς (baseline) για τη σύγκριση με πιο σύνθετα μοντέλα.
- **Multi-Layer Perceptron (MLP, Πολυεπίπεδος Αντιληπτήρας):** είναι νευρωνικό δίκτυο πρόσθιας τροφοδότησης (feed-forward neural network), στο οποίο η πληροφορία μεταδίδεται από το επίπεδο εισόδου προς ένα ή περισσότερα κρυφά επίπεδα και στη συνέχεια προς το επίπεδο εξόδου [20, Ch. 11]. Οι νευρώνες εφαρμόζουν σταθμισμένους συνδυασμούς των εισόδων και μη γραμμικές συναρτήσεις ενεργοποίησης (activation functions), επιτρέποντας στο δίκτυο να αναπαριστά μη γραμμικές σχέσεις μεταξύ των χαρακτηριστικών.
- **Deep MLP (Βαθύς Πολυεπίπεδος Αντιληπτήρας):** στην παρούσα εργασία ο όρος χρησιμοποιείται για ένα MLP με περισσότερα κρυφά επίπεδα από την απλούστερη αρχιτεκτονική MLP. Η ύπαρξη περισσότερων επιπέδων επιτρέπει διαδοχικούς μη γραμμικούς μετασχηματισμούς των δεδομένων και αυξάνει την ικανότητα του δικτύου να αναπαριστά σύνθετες σχέσεις [20, Ch. 11].
- **1D-CNN (One-Dimensional Convolutional Neural Network, Μονοδιάστατο Συνελικτικό Νευρωνικό Δίκτυο):** εφαρμόζει μονοδιάστατες πράξεις συνέλιξης (convolution) στα δεδομένα εισόδου. Τα συνελικτικά επίπεδα χαρακτηρίζονται από περιορισμένη συνδεσιμότητα (limited connectivity) και κοινή χρήση βαρών (weight sharing), επιτρέποντας στο δίκτυο να αναγνωρίζει τοπικά πρότυπα κατά μήκος της μονοδιάστατης εισόδου [22].

Ιδιαίτερη θεωρητική σημασία έχει η λειτουργία των μεθόδων συνόλου (ensemble methods), στις οποίες ανήκει το Random Forest. Οι μέθοδοι αυτές συνδυάζουν τις προβλέψεις πολλών επιμέρους μοντέλων αντί να βασίζονται σε ένα μόνο μοντέλο [20, Ch. 16]. Στο Random Forest, κάθε δέντρο εξαρτάται από ένα τυχαίο διάνυσμα που δειγματοληπτείται ανεξάρτητα και με την ίδια κατανομή για όλα τα δέντρα [21]. Το σφάλμα γενίκευσης (generalization error), δηλαδή το σφάλμα του μοντέλου όταν εφαρμόζεται σε νέα δεδομένα, εξαρτάται από την ισχύ των επιμέρους δέντρων και από τη μεταξύ τους συσχέτιση [21].

Η τυχαιότητα που εισάγεται κατά την κατασκευή των δέντρων επιδιώκει να μειώσει τη συσχέτισή τους, ώστε ο συνδυασμός των προβλέψεων να μειώνει τη διακύμανση του τελικού μοντέλου [20, Ch. 15], [21]. Ο Breiman δείχνει επίσης, με βάση τον νόμο των μεγάλων αριθμών, ότι το σφάλμα γενίκευσης συγκλίνει σε μια οριακή τιμή καθώς αυξάνεται το πλήθος των δέντρων. Επομένως, η προσθήκη περισσότερων δέντρων στο δάσος δεν οδηγεί από μόνη της σε υπερπροσαρμογή [21].

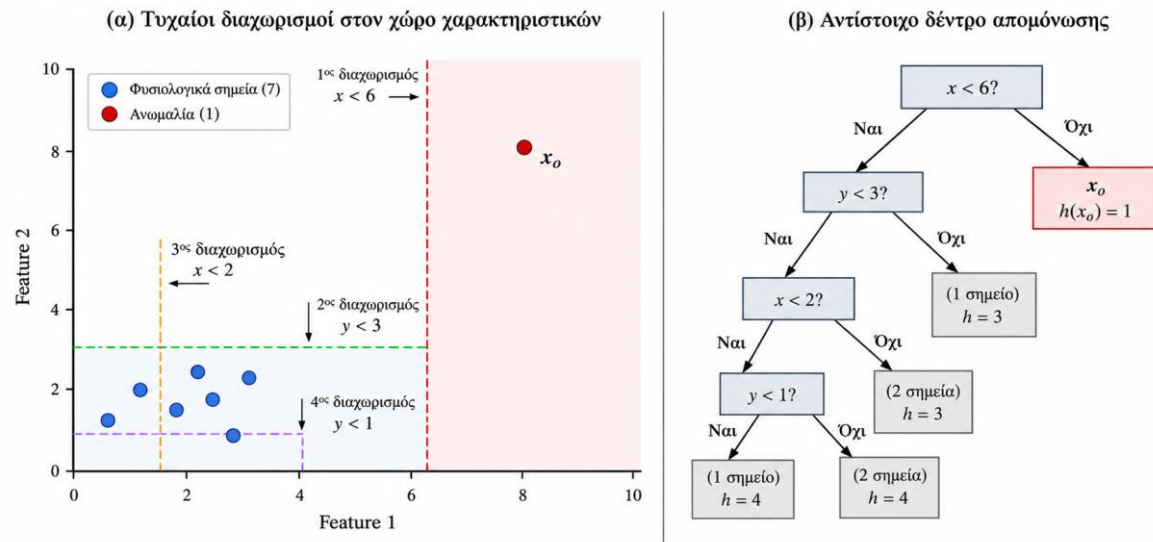
Η επιλογή διαφορετικών οικογενειών αλγορίθμων επιτρέπει τη σύγκριση μοντέλων που προσεγγίζουν το πρόβλημα της ταξινόμησης με διαφορετικό τρόπο. Τα γραμμικά μοντέλα, οι μέθοδοι που βασίζονται στην απόσταση, τα δέντρα απόφασης, οι μέθοδοι συνόλου και τα νευρωνικά δίκτυα χρησιμοποιούν διαφορετικούς μηχανισμούς μάθησης. Η πειραματική σύγκριση των αλγορίθμων και τα αποτελέσματά τους παρουσιάζονται στο Κεφάλαιο 6.

4.3 Ο αλγόριθμος Isolation Forest και η μαθηματική του

Θεμελίωση

Οι περισσότερες μέθοδοι ανίχνευσης ανωμαλιών κατασκευάζουν αρχικά ένα μοντέλο ή προφίλ της φυσιολογικής συμπεριφοράς και στη συνέχεια χαρακτηρίζουν ως ανωμαλίες τα δείγματα που αποκλίνουν από αυτό [23]. Ο Isolation Forest ακολουθεί διαφορετική λογική. Αντί να μοντελοποιεί άμεσα τα φυσιολογικά δείγματα, επιχειρεί να απομονώσει τις ανωμαλίες [23]. Η προσέγγιση βασίζεται σε δύο βασικές ιδιότητες των ανωμαλιών: συνήθως αποτελούν μικρό μέρος του συνόλου των δεδομένων και εμφανίζουν τιμές χαρακτηριστικών που διαφέρουν από εκείνες των φυσιολογικών παρατηρήσεων [23]. Επειδή είναι λίγες και διαφορετικές, μπορούν να απομονωθούν με μικρότερο αριθμό διαχωρισμών.

Ο αλγόριθμος κατασκευάζει ένα σύνολο από δέντρα απομόνωσης (isolation trees). Σε κάθε κόμβο επιλέγεται τυχαία ένα χαρακτηριστικό και στη συνέχεια ένα τυχαίο σημείο διαχωρισμού μεταξύ της ελάχιστης και της μέγιστης τιμής του συγκεκριμένου χαρακτηριστικού στο τρέχον υποσύνολο [23]. Η διαδικασία επαναλαμβάνεται αναδρομικά μέχρι να απομονωθούν τα δείγματα ή να επιτευχθεί το καθορισμένο μέγιστο βάθος του δέντρου. Το πλήθος των διαχωρισμών που απαιτούνται για την απομόνωση ενός δείγματος αντιστοιχεί στο μήκος διαδρομής (path length) από τη ρίζα του δέντρου μέχρι το φύλλο στο οποίο καταλήγει [23]. Επειδή οι ανωμαλίες βρίσκονται συνήθως σε αραιότερες περιοχές του χώρου των χαρακτηριστικών, τείνουν να απομονώνονται με μικρότερο μήκος διαδρομής από τα φυσιολογικά δείγματα.



Σχήμα 4-1: Ενδεικτικό παράδειγμα λειτουργίας του Isolation Forest για σύνολο οκτώ παρατηρήσεων. Επτά σημεία σχηματίζουν την κύρια συστάδα, ενώ ένα απομακρυσμένο σημείο απομονώνεται ήδη από τον πρώτο τυχαίο διαχωρισμό. Το αντίστοιχο δέντρο δείχνει ότι η ανωμαλία καταλήγει σε φύλλο μικρού βάθους, ενώ τα σημεία της κύριας συστάδας απαιτούν περισσότερους διαχωρισμούς.

Όπως φαίνεται στο Σχήμα 4-1, το απομακρυσμένο σημείο απομονώνεται με μικρό αριθμό τυχαίων διαχωρισμών και καταλήγει σε φύλλο μικρού βάθους. Αντίθετα, ένα σημείο που βρίσκεται μέσα στην κύρια συστάδα (cluster) παραμένει μαζί με άλλα δείγματα για περισσότερα επίπεδα του δέντρου και απαιτεί μεγαλύτερο αριθμό διαχωρισμών για να απομονωθεί. Ο αριθμός των διαχωρισμών αποτυπώνεται στο μήκος διαδρομής $h(x)$ του δείγματος σε ένα συγκεκριμένο δέντρο. Επειδή όμως ο Isolation Forest αποτελείται από πολλά δέντρα απομόνωσης, η τελική τιμή ανωμαλίας δεν υπολογίζεται από ένα μόνο μήκος διαδρομής. Χρησιμοποιείται ο μέσος όρος $E(h(x))$ των μηκών διαδρομής του ίδιου δείγματος στα διαφορετικά δέντρα του συνόλου.

Το μήκος διαδρομής εξαρτάται από το πλήθος των δειγμάτων και επομένως δεν μπορεί να συγκριθεί άμεσα μεταξύ συνόλων διαφορετικού μεγέθους. Για τον λόγο αυτό χρησιμοποιείται μια τιμή αναφοράς $c(n)$. Οι Liu κ.ά. [23] συνδέουν τη δομή των δέντρων απομόνωσης με εκείνη των δυαδικών δέντρων αναζήτησης (binary search trees). Η απομόνωση ενός δείγματος μπορεί να συσχετιστεί με το μήκος μιας ανεπιτυχούς αναζήτησης σε ένα τέτοιο δέντρο. Για σύνολο n δειγμάτων, η μέση αναμενόμενη τιμή του μήκους διαδρομής δίνεται από:

$$c(n) = 2H(n-1) - \frac{2(n-1)}{n}$$

όπου $H(i)$ είναι ο i -οστός αρμονικός αριθμός:

$$H(i) = \sum_{k=1}^i \frac{1}{k}$$

Για μεγαλύτερες τιμές του i , ο αρμονικός αριθμός μπορεί να προσεγγιστεί από:

$$H(i) \approx \ln i + \gamma$$

Όπου $\gamma \approx 0,5772$ είναι η σταθερά Euler–Mascheroni [23]. Η τιμή $c(n)$ χρησιμοποιείται επομένως ως σημείο αναφοράς για την κανονικοποίηση του μήκους διαδρομής.

Με βάση το μέσο μήκος διαδρομής, ο Isolation Forest υπολογίζει για κάθε δείγμα x την τιμή ανωμαλίας (anomaly score):

$$s(x, n) = 2^{-\frac{E(h(x))}{c(n)}}$$

όπου $E(h(x))$ είναι το μέσο μήκος διαδρομής του δείγματος x στα διαφορετικά δέντρα του συνόλου [23]. Μικρότερο μέσο μήκος διαδρομής οδηγεί σε μεγαλύτερη τιμή ανωμαλίας. Όταν $E(h(x))$ πλησιάζει το μηδέν, η τιμή $s(x, n)$ πλησιάζει τη μονάδα. Όταν $E(h(x))$ είναι περίπου ίσο με $c(n)$, η τιμή πλησιάζει το 0,5. Αντίθετα, μεγαλύτερα μήκη διαδρομής οδηγούν σε μικρότερες τιμές ανωμαλίας [23].

Οι συγγραφείς προτείνουν τρεις βασικούς κανόνες ερμηνείας της τιμής αυτής [23]. Τιμές πολύ κοντά στη μονάδα αποτελούν ισχυρή ένδειξη ανωμαλίας. Τιμές αρκετά μικρότερες από 0,5 αντιστοιχούν συνήθως σε φυσιολογικές παρατηρήσεις. Αν όλες οι παρατηρήσεις ενός συνόλου παρουσιάζουν τιμές περίπου ίσες με 0,5, τότε το σύνολο δεν εμφανίζει σαφώς διακριτές ανωμαλίες.

Ο μηχανισμός μπορεί να γίνει πιο κατανοητός με ένα απλό αριθμητικό παράδειγμα. Έστω σύνολο $n = 8$ παρατηρήσεων, στο οποίο οι περισσότερες βρίσκονται σχετικά κοντά μεταξύ τους, ενώ μία παρατήρηση βρίσκεται πιο απομακρυσμένη. Για το συγκεκριμένο μικρό σύνολο μπορεί να υπολογιστεί ο ακριβής αρμονικός αριθμός:

$$H(7) = 1 + \frac{1}{2} + \frac{1}{3} + \frac{1}{4} + \frac{1}{5} + \frac{1}{6} + \frac{1}{7} = 2,592857$$

άρα:

$$c(8) \approx 2 * H(7) - \frac{2 * (8 - 1)}{8} = 2 * (2,592857) - 1,75 = 3,435714 \approx 3,436$$

Για $n = 8$, η λογαριθμική προσέγγιση του αρμονικού αριθμού δίνει τιμή περίπου 4% μικρότερη από την ακριβή τιμή του $c(8)$. Για τον λόγο αυτό, στο συγκεκριμένο μικρό αριθμητικό παράδειγμα χρησιμοποιείται ο ακριβής αρμονικός αριθμός. Η προσέγγιση με τον φυσικό λογάριθμο είναι καταλλήλότερη για μεγαλύτερες τιμές του i .

Με βάση την τιμή $c(8)=3,436$, μπορούν να εξεταστούν τρεις ενδεικτικές περιπτώσεις μέσου μήκους διαδρομής.

Πίνακας 4-1: Ενδεικτικές τιμές ανωμαλίας του Isolation Forest για $n = 8$.

Μέσο μήκος διαδρομής $E(h(x))$	Τιμή $s(x, 8)$	Ερμηνεία
1	$\approx 0,82$	Σύντομη διαδρομή και ισχυρότερη ένδειξη ανωμαλίας
3,436	0,5	Ίσο με $c(8)$, τιμή αναφοράς
4,5	$\approx 0,4$	Μεγαλύτερη διαδρομή και ασθενέστερη ένδειξη ανωμαλίας

Η δεύτερη γραμμή του Πίνακα 4-1 δείχνει τη σημασία της τιμής 0,5. Όταν το μέσο μήκος διαδρομής είναι ίσο με την τιμή αναφοράς $c(n)$, τότε:

$$E(h(x)) = c(n)$$

και συνεπώς:

$$s(x, n) = 2^{-\frac{c(n)}{c(n)}} = 2^{-1} = 0,5$$

Η τιμή 0,5 δεν αποτελεί επομένως αυθαίρετο αριθμό. Προκύπτει άμεσα από τον μαθηματικό ορισμό της τιμής ανωμαλίας. Αντίστοιχα, μια μικρότερη διαδρομή, όπως $E(h(x)) = 1$, οδηγεί σε μεγαλύτερη τιμή ανωμαλίας, ενώ μια μεγαλύτερη διαδρομή, όπως $E(h(x)) = 4,5$, οδηγεί σε μικρότερη τιμή.

Στο μικρό αυτό παράδειγμα, ακόμη και μια απομακρυσμένη παρατήρηση δεν αναμένεται απαραίτητα να δώσει τιμή εξαιρετικά κοντά στη μονάδα. Ο σκοπός του παραδείγματος δεν είναι να αναπαραστήσει ένα πραγματικό σύνολο δεδομένων, αλλά να δείξει με απλό τρόπο τη σχέση μεταξύ του μήκους διαδρομής και της τιμής ανωμαλίας.

Στην αρχική διατύπωση του Isolation Forest, δύο βασικές παράμετροι είναι το πλήθος των δέντρων και το μέγεθος του υποδείγματος (subsample size) που χρησιμοποιείται για την κατασκευή κάθε δέντρου [23]. Οι Liu κ.ά. χρησιμοποιούν ως τυπικό μέγεθος υποδείγματος $\psi = 256$ και δείχνουν ότι σχετικά μικρά υποδείγματα μπορούν να είναι επαρκή για την απομόνωση ανωμαλιών [23]. Η υποδειματοληψία συμβάλλει επίσης στον περιορισμό του υπολογιστικού κόστους και των απαιτήσεων μνήμης [23]. Οι συγκεκριμένες παράμετροι και οι τιμές που χρησιμοποιήθηκαν στην υλοποίηση της παρούσας εργασίας παρουσιάζονται στο Κεφάλαιο 5.

4.4 Δημόσια σύνολα δεδομένων και το σύνολο InSDN

Η ανάπτυξη και η αξιολόγηση συστημάτων ανίχνευσης που βασίζονται στη Μηχανική Μάθηση απαιτούν σύνολα δεδομένων που περιλαμβάνουν αντιπροσωπευτικά παραδείγματα φυσιολογικής και κακόβουλης δικτυακής δραστηριότητας. Παλαιότερα δημόσια σύνολα δεδομένων δημιουργήθηκαν κυρίως για συμβατικά δίκτυα και όχι ειδικά για την αρχιτεκτονική SDN [9]. Η χρήση τους σε περιβάλλοντα SDN μπορεί να παρουσιάζει περιορισμούς, καθώς ορισμένα από τα χαρακτηριστικά τους δεν αντιστοιχούν άμεσα στις πληροφορίες που είναι διαθέσιμες σε ένα τέτοιο δίκτυο [9].

Στη βιβλιογραφία έχουν επίσης επισημανθεί προβλήματα ποιότητας σε παλαιότερα σύνολα δεδομένων, όπως παρωχημένη ή μη επαρκώς αντιπροσωπευτική κίνηση, περιορισμένη κάλυψη διαφορετικών επιθέσεων και παρουσία μεγάλου αριθμού διπλότυπων εγγραφών [9]. Οι διπλότυπες εγγραφές αποτελούν επαναλαμβανόμενες παρατηρήσεις μέσα στο σύνολο δεδομένων και μπορούν να επηρεάσουν τόσο την εκπαίδευση όσο και την αξιολόγηση ενός μοντέλου. Για τον λόγο αυτό, η εξέταση της σύνθεσης και της ποιότητας ενός συνόλου δεδομένων αποτελεί σημαντικό στάδιο πριν από την εκπαίδευση.

Το InSDN δημιουργήθηκε ειδικά για την ανάπτυξη και αξιολόγηση συστημάτων ανίχνευσης εισβολών σε περιβάλλον SDN [24]. Τα δεδομένα συλλέχθηκαν σε εικονικό περιβάλλον SDN και περιλαμβάνουν τόσο φυσιολογική δικτυακή δραστηριότητα όσο και διαφορετικές μορφές κακόβουλης κίνησης [24].

Για την εξαγωγή των χαρακτηριστικών των δικτυακών ροών χρησιμοποιήθηκε το CICFlowMeter [24]. Πρόκειται για εργαλείο δημιουργίας και ανάλυσης δικτυακών ροών, το οποίο οργανώνει την κίνηση σε αμφίδρομες ροές και υπολογίζει στατιστικά χαρακτηριστικά για καθεμία από αυτές [25]. Το πρώτο πακέτο μιας ροής καθορίζει την

κατεύθυνση από την πηγή προς τον προορισμό (forward direction), ενώ τα πακέτα που κινούνται από τον προορισμό προς την αρχική πηγή αποτελούν την αντίστροφη κατεύθυνση (backward direction) [25]. Με τον τρόπο αυτό μπορούν να υπολογίζονται χωριστά χαρακτηριστικά για τις δύο κατευθύνσεις, όπως το πλήθος και το μέγεθος των πακέτων, οι χρόνοι μεταξύ διαδοχικών αφίξεων και η διάρκεια της ροής.

Το πλήρες σύνολο InSDN περιλαμβάνει 83 χαρακτηριστικά ανά εγγραφή [24]. Τα χαρακτηριστικά αυτά περιγράφουν διαφορετικές πλευρές της συμπεριφοράς μιας δικτυακής ροής, όπως το πλήθος και το μέγεθος των πακέτων, τη διάρκεια της ροής, τους χρόνους μεταξύ διαδοχικών πακέτων, τις σημαίες του πρωτοκόλλου TCP και τη συμπεριφορά της κίνησης στις δύο κατευθύνσεις.

Οι δημιουργοί του InSDN προτείνουν επίσης ειδικό υποσύνολο 48 χαρακτηριστικών για περιβάλλοντα SDN και αξιολογούν χωριστά την απόδοση των μοντέλων χρησιμοποιώντας τόσο το πλήρες σύνολο των 83 όσο και το υποσύνολο των 48 χαρακτηριστικών [24]. Η διαδικασία αυτή δείχνει ότι δεν είναι απαραίτητο να χρησιμοποιούνται όλα τα διαθέσιμα χαρακτηριστικά σε κάθε σύστημα ανίχνευσης. Ένα μικρότερο υποσύνολο μπορεί να διατηρεί τις πληροφορίες που θεωρούνται περισσότερο σχετικές με το εξεταζόμενο περιβάλλον, περιορίζοντας ταυτόχρονα τη διάσταση των δεδομένων που εισάγονται στο μοντέλο.

Το InSDN περιλαμβάνει φυσιολογική κίνηση (Normal) και διαφορετικές κατηγορίες επιθέσεων [24]. Οι επιθέσεις άρνησης υπηρεσίας (Denial of Service, DoS) και οι κατανεμημένες επιθέσεις άρνησης υπηρεσίας (Distributed Denial of Service, DDoS) αφορούν τη διαθεσιμότητα των δικτυακών πόρων. Η κατηγορία σάρωσης (Probe) περιλαμβάνει δραστηριότητες αναγνώρισης και σάρωσης, όπως αυτές που παρουσιάστηκαν στην παράγραφο 3.5. Η επίθεση ωμής βίας (Brute Force Attack) αφορά επαναλαμβανόμενες προσπάθειες απόκτησης πρόσβασης μέσω συστηματικής δοκιμής διαπιστευτηρίων. Στα αρχεία του συνόλου η συγκεκριμένη κατηγορία εμφανίζεται με την ετικέτα brute-force-attack. Το σύνολο περιλαμβάνει επίσης επιθέσεις εφαρμογών ιστού (Web Attack), δραστηριότητα δικτύου παραβιασμένων συσκευών (botnet) και επιθέσεις εκμετάλλευσης που στον Πίνακα 5 της πηγής καταγράφονται με την ετικέτα Exploitation (R2L) [24].

Οι κατηγορίες του InSDN παρουσιάζουν σημαντική ανισορροπία ως προς το πλήθος των εγγραφών τους. Οι ίδιοι οι δημιουργοί αναγνωρίζουν την ανισορροπία μεταξύ των κλάσεων (class imbalance) ως περιορισμό του συνόλου, καθώς μπορεί να οδηγήσει ένα σύστημα ανίχνευσης σε μεγαλύτερη προσαρμογή προς τις πολυπληθέστερες κατηγορίες [24]. Για τον

λόγο αυτό, η αξιολόγηση ενός ταξινομητή δεν πρέπει να βασίζεται αποκλειστικά στη συνολική ορθότητα, αλλά να εξετάζει και την επίδοση ανά κατηγορία. Οι σχετικές μετρικές παρουσιάζονται στην παράγραφο 4.6.

Παρότι το InSDN σχεδιάστηκε ειδικά για SDN, δεν καλύπτει κάθε πιθανή απειλή ή αιτία δυσλειτουργίας ενός τέτοιου δικτύου. Οι δημιουργοί επισημαίνουν ότι τα σενάρια του συνόλου επικεντρώνονται σε κακόβουλες επιθέσεις, ενώ απειλές που προκύπτουν από λανθασμένες διαμορφώσεις των μεταγωγέων δεν περιλαμβάνονται [24]. Επιπλέον, έχει επισημανθεί στη βιβλιογραφία ότι η αποκλειστική χρήση του InSDN δεν παρέχει πλήρη κάλυψη όλων των επιθέσεων υψηλού κινδύνου [9]. Συνεπώς, τα αποτελέσματα που προκύπτουν από το συγκεκριμένο σύνολο πρέπει να ερμηνεύονται μέσα στα όρια των σεναρίων και των κατηγοριών που περιλαμβάνει.

Στην παρούσα εργασία χρησιμοποιούνται πέντε από τις κατηγορίες του InSDN. Οι κατηγορίες Web_attack, Botnet και Exploitation δεν περιλαμβάνονται στη συγκριτική αξιολόγηση, καθώς διαθέτουν μόλις 192, 164 και 17 εγγραφές αντίστοιχα [24]. Τα μεγέθη αυτά είναι ιδιαίτερα μικρά σε σύγκριση με τις δεκάδες χιλιάδες εγγραφές των πολυπληθέστερων κατηγοριών και θα περιόριζαν την αξιοπιστία της εκπαίδευσης και της αξιολόγησης χωρίς ειδική αντιμετώπιση της ανισορροπίας. Οι πέντε κατηγορίες που διατηρούνται εξακολουθούν να μην είναι πλήρως ισορροπημένες, γεγονός που λαμβάνεται υπόψη κατά την αξιολόγηση των μοντέλων.

Στην παρούσα εργασία δεν χρησιμοποιούνται επίσης και τα 83 διαθέσιμα χαρακτηριστικά. Επιλέγεται ένα μειωμένο σύνολο 24 χαρακτηριστικών. Η επιλογή αυτή αποτελεί σχεδιαστική επιλογή της παρούσας εργασίας και όχι αποτέλεσμα αυτόματου αλγορίθμου επιλογής χαρακτηριστικών. Από τα 24 χαρακτηριστικά, τα 18 περιλαμβάνονται ήδη στο υποσύνολο των 48 χαρακτηριστικών που προτείνουν οι δημιουργοί του InSDN για περιβάλλοντα SDN [24]. Τα υπόλοιπα έξι προέρχονται από το πλήρες σύνολο των 83 και περιλαμβάνουν τέσσερις μετρητές σημαιών TCP, ένα χαρακτηριστικό που περιγράφει το αρχικό παράθυρο TCP και ένα χαρακτηριστικό που εκφράζει τον λόγο της κίνησης μεταξύ των δύο κατευθύνσεων της ροής. Τα χαρακτηριστικά αυτά διατηρήθηκαν ώστε το σύνολο εισόδου να περιλαμβάνει πληροφορίες τόσο για τον όγκο και τον χρονισμό της κίνησης όσο και για τη συμπεριφορά των συνδέσεων TCP και τη σχέση μεταξύ των δύο κατευθύνσεων μιας ροής. Δεν υποστηρίζεται ότι τα 24 χαρακτηριστικά αποτελούν το μοναδικό ή το βέλτιστο δυνατό υποσύνολο.

Η αναλυτική παρουσίαση των 24 χαρακτηριστικών, η ελληνική απόδοσή τους και η δικτυακή σημασία κάθε χαρακτηριστικού δίνονται στην παράγραφο 4.5 και στον Πίνακα 4-2. Η ακριβής διαδικασία προεπεξεργασίας και ο τρόπος με τον οποίο χρησιμοποιούνται τα χαρακτηριστικά κατά την εκπαίδευση των μοντέλων παρουσιάζονται στο Κεφάλαιο 5.

4.5 Τα 24 χαρακτηριστικά ροής: περιγραφή και δικτυακή ερμηνεία

Στην παράγραφο 4.4 παρουσιάστηκε το CICFlowMeter και ο τρόπος με τον οποίο η δικτυακή κίνηση οργανώνεται σε αμφίδρομες ροές και μετατρέπεται σε αριθμητικά χαρακτηριστικά. Στην παρούσα εργασία χρησιμοποιούνται 24 χαρακτηριστικά, τα οποία περιγράφουν διαφορετικές πλευρές της συμπεριφοράς μιας ροής. Για ευκολότερη κατανόηση, τα χαρακτηριστικά οργανώνονται σε τέσσερις ομάδες: χαρακτηριστικά χρονισμού, χαρακτηριστικά όγκου και ρυθμού κίνησης, χαρακτηριστικά που περιγράφουν τις δύο κατευθύνσεις της ροής και χαρακτηριστικά που σχετίζονται με τη λειτουργία του πρωτοκόλλου TCP.

Για την ερμηνεία των χαρακτηριστικών είναι απαραίτητο να διευκρινιστούν δύο βασικές έννοιες. Στο CICFlowMeter, το πρώτο πακέτο μιας ροής καθορίζει την κατεύθυνση από την πηγή προς τον προορισμό (forward direction). Τα πακέτα που κινούνται από τον προορισμό προς την αρχική πηγή αποτελούν την αντίστροφη κατεύθυνση (backward direction) [25], [26]. Οι δύο όροι επομένως περιγράφουν μόνο την κατεύθυνση κίνησης των πακέτων μέσα στην ίδια αμφίδρομη ροή και όχι το αν η κίνηση είναι νόμιμη ή κακόβουλη.

Μία ακόμη βασική έννοια είναι ο χρόνος μεταξύ διαδοχικών αφίξεων (Inter-Arrival Time, IAT). Πρόκειται για το χρονικό διάστημα μεταξύ δύο διαδοχικών πακέτων. Το CICFlowMeter υπολογίζει στατιστικά αυτού του χρόνου τόσο για ολόκληρη τη ροή όσο και χωριστά για τις δύο κατευθύνσεις της [26]. Για παράδειγμα, η μέση τιμή περιγράφει το μέσο χρονικό διάστημα μεταξύ πακέτων, ενώ η τυπική απόκλιση δείχνει πόσο μεταβάλλονται μεταξύ τους αυτά τα χρονικά διαστήματα.

Πίνακας 4-2: Τα 24 χαρακτηριστικά ροής που χρησιμοποιούνται στην παρούσα εργασία, ομαδοποιημένα κατά την πλευρά της δικτυακής συμπεριφοράς που περιγράφουν. Οι ορισμοί των πεδίων προέρχονται από την τεκμηρίωση του CICFlowMeter [26].

Πεδίο CICFlowMeter	Ελληνική απόδοση	Τι μετρά και πώς ερμηνεύεται
Flow_Duration	Διάρκεια ροής	Χρόνος από την έναρξη έως τη λήξη της ροής. Στην έξοδο του CICFlowMeter καταγράφεται σε μικροδευτερόλεπτα.

Flow_IAT_Mean	Μέσος χρόνος μεταξύ αφίξεων της ροής	Μέσο χρονικό διάστημα μεταξύ διαδοχικών πακέτων, ανεξάρτητα από την κατεύθυνσή τους.
Flow_IAT_Std	Τυπική απόκλιση του χρόνου μεταξύ αφίξεων	Δείχνει πόσο μεταβάλλεται ο χρόνος μεταξύ διαδοχικών πακέτων της ροής. Μικρότερη τιμή σημαίνει πιο σταθερά χρονικά διαστήματα, ενώ μεγαλύτερη τιμή μεγαλύτερη μεταβολή.
Fwd_IAT_Mean	Μέσος χρόνος μεταξύ αφίξεων στην αρχική κατεύθυνση	Μέσο χρονικό διάστημα μεταξύ διαδοχικών πακέτων που κινούνται από την αρχική πηγή προς τον προορισμό.
Bwd_IAT_Mean	Μέσος χρόνος μεταξύ αφίξεων στην αντίστροφη κατεύθυνση	Μέσο χρονικό διάστημα μεταξύ διαδοχικών πακέτων που κινούνται από τον προορισμό προς την αρχική πηγή.
Active_Mean	Μέσος χρόνος ενεργής περιόδου	Μέση διάρκεια κατά την οποία η ροή παραμένει ενεργή πριν εισέλθει σε περίοδο αδράνειας.
Idle_Mean	Μέσος χρόνος αδράνειας	Μέση χρονική διάρκεια κατά την οποία η ροή παραμένει ανενεργή πριν εμφανιστεί ξανά δραστηριότητα.
Tot_Fwd_Pkts	Συνολικό πλήθος πακέτων στην αρχική κατεύθυνση	Πλήθος πακέτων που μεταδόθηκαν από την αρχική πηγή προς τον προορισμό.
Tot_Bwd_Pkts	Συνολικό πλήθος πακέτων στην αντίστροφη κατεύθυνση	Πλήθος πακέτων που μεταδόθηκαν από τον προορισμό προς την αρχική πηγή.
TotLen_Fwd_Pkts	Συνολικό μήκος πακέτων στην αρχική κατεύθυνση	Συνολική ποσότητα δεδομένων, σε byte, που μεταφέρθηκε από την αρχική πηγή προς τον προορισμό.
TotLen_Bwd_Pkts	Συνολικό μήκος πακέτων στην αντίστροφη κατεύθυνση	Συνολική ποσότητα δεδομένων, σε byte, που μεταφέρθηκε από τον προορισμό προς την αρχική πηγή.
Flow_Pkts_s	Ρυθμός πακέτων της ροής	Πλήθος πακέτων που μεταδίδονται ανά δευτερόλεπτο στη ροή.
Flow_Byts_s	Ρυθμός δεδομένων της ροής	Πλήθος byte που μεταδίδονται ανά δευτερόλεπτο στη ροή.
Pkt_Len_Mean	Μέσο μήκος πακέτου	Μέση τιμή του μήκους των πακέτων της ροής.

Pkt_Len_Std	Τυπική απόκλιση του μήκους πακέτου	Δείχνει πόσο μεταβάλλεται το μήκος των πακέτων μέσα στην ίδια ροή.
Pkt_Size_Avg	Μέσο μέγεθος πακέτου	Χαρακτηριστικό του CICFlowMeter που περιγράφει το μέσο μέγεθος των πακέτων της ροής. Είναι στενά συγγενικό με το Pkt_Len_Mean [26].
Fwd_Pkt_Len_Mean	Μέσο μήκος πακέτου στην αρχική κατεύθυνση	Μέσο μέγεθος των πακέτων που κινούνται από την αρχική πηγή προς τον προορισμό.
Bwd_Pkt_Len_Mean	Μέσο μήκος πακέτου στην αντίστροφη κατεύθυνση	Μέσο μέγεθος των πακέτων που κινούνται από τον προορισμό προς την αρχική πηγή.
Down_Up_Ratio	Λόγος κίνησης λήψης προς αποστολή	Περιγράφει τη σχέση μεταξύ της κίνησης στις δύο κατευθύνσεις της ροής. Η τεκμηρίωση του CICFlowMeter το ορίζει ως λόγο λήψης προς αποστολή χωρίς να παρέχει αναλυτικό τύπο [26].
SYN_Flag_Cnt	Πλήθος πακέτων με σημαία SYN	Μετρά τα πακέτα TCP στα οποία είναι ενεργή η σημαία SYN, η οποία χρησιμοποιείται κατά την έναρξη μιας σύνδεσης TCP.
ACK_Flag_Cnt	Πλήθος πακέτων με σημαία ACK	Μετρά τα πακέτα TCP με ενεργή τη σημαία ACK, η οποία χρησιμοποιείται για επιβεβαίωση λήψης στο TCP.
RST_Flag_Cnt	Πλήθος πακέτων με σημαία RST	Μετρά τα πακέτα TCP με ενεργή τη σημαία RST, η οποία χρησιμοποιείται για άμεση επαναφορά ή διακοπή μιας σύνδεσης.
FIN_Flag_Cnt	Πλήθος πακέτων με σημαία FIN	Μετρά τα πακέτα TCP με ενεργή τη σημαία FIN, η οποία χρησιμοποιείται κατά τον ομαλό τερματισμό μιας σύνδεσης.
Init_Fwd_Win_Byts	Αρχικό παράθυρο TCP στην αρχική κατεύθυνση	Καταγράφει το μέγεθος του αρχικού παραθύρου TCP στην κατεύθυνση από την αρχική πηγή προς τον προορισμό.

Όπως φαίνεται στον Πίνακα 4-2, τα 24 χαρακτηριστικά δεν περιγράφουν όλα την ίδια πλευρά της κίνησης. Τα χαρακτηριστικά χρονισμού δείχνουν πότε μεταδίδονται τα πακέτα και πόσο σταθερά ή μεταβαλλόμενα είναι τα χρονικά διαστήματα μεταξύ τους. Για παράδειγμα, το Flow_IAT_Mean περιγράφει τον μέσο χρόνο μεταξύ διαδοχικών πακέτων, ενώ το Flow_IAT_Std δείχνει πόσο μεταβάλλονται αυτά τα διαστήματα.

Τα χαρακτηριστικά όγκου και ρυθμού δείχνουν πόσα πακέτα ή byte μεταδίδονται και με ποιον ρυθμό. Με τον τρόπο αυτό διακρίνεται, για παράδειγμα, μια ροή που αποτελείται από μεγάλο αριθμό μικρών πακέτων από μια ροή που μεταφέρει μικρότερο αριθμό

μεγαλύτερων πακέτων. Τα χαρακτηριστικά αυτά δεν αποδεικνύουν από μόνα τους ότι μια ροή είναι κακόβουλη. Αποτελούν αριθμητικές περιγραφές της συμπεριφοράς της, τις οποίες μπορεί να αξιοποιήσει ένα μοντέλο Μηχανικής Μάθησης.

Τα χαρακτηριστικά κατεύθυνσης επιτρέπουν τη χωριστή εξέταση της κίνησης από την πηγή προς τον προορισμό και της κίνησης προς την αντίθετη κατεύθυνση. Αυτό επιτρέπει να περιγραφεί αν οι δύο πλευρές μιας επικοινωνίας παρουσιάζουν παρόμοια ή διαφορετική συμπεριφορά. Ο λόγος `Down_Up_Ratio` προσθέτει μία συνοπτική ένδειξη της σχέσης μεταξύ των δύο κατευθύνσεων.

Τέλος, οι μετρητές των σημαιών TCP παρέχουν πληροφορίες σχετικά με την κατάσταση και την εξέλιξη μιας σύνδεσης. Το `CICFlowMeter` διαθέτει περισσότερους μετρητές σημαιών από όσους χρησιμοποιούνται στην παρούσα εργασία [26]. Από αυτούς επιλέγονται οι `SYN`, `ACK`, `RST` και `FIN`. Η επιλογή τους επιτρέπει την καταγραφή πληροφοριών σχετικών με την έναρξη, την επιβεβαίωση, την επαναφορά και τον τερματισμό των συνδέσεων TCP. Το `Init_Fwd_Win_Byts` προσθέτει πληροφορία σχετικά με το αρχικό παράθυρο TCP στην αρχική κατεύθυνση.

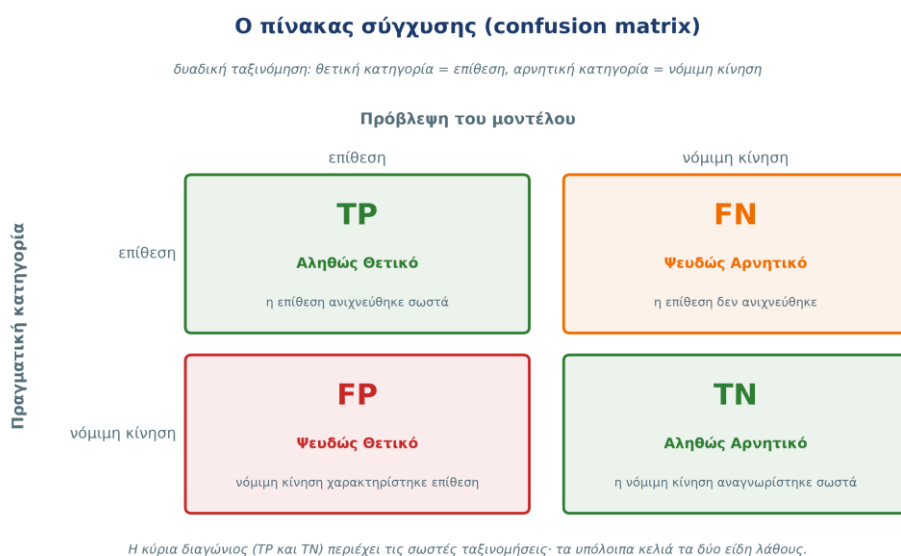
Ορισμένα από τα χαρακτηριστικά είναι στενά συγγενικά μεταξύ τους. Για παράδειγμα, τα `Pkt_Len_Mean` και `Pkt_Size_Avg` περιγράφουν και τα δύο το μέσο μέγεθος των πακέτων, ενώ τα `Flow_Pkts_s` και `Flow_Byts_s` εκφράζουν διαφορετικές όψεις του ρυθμού της ίδιας ροής. Η παρουσία συγγενικών χαρακτηριστικών δεν σημαίνει ότι θεωρούνται ανεξάρτητα ούτε ότι έχουν την ίδια χρησιμότητα για την ταξινόμηση. Η πραγματική συνεισφορά τους στις αποφάσεις των μοντέλων εξετάζεται πειραματικά στο Κεφάλαιο 6.

Η επιλογή των 24 χαρακτηριστικών δεν αποτελεί αποτέλεσμα αυτόματης διαδικασίας μείωσης της διάστασης. Όπως παρουσιάστηκε στην παράγραφο 4.4, τα 18 από αυτά ανήκουν στο υποσύνολο των 48 χαρακτηριστικών που προτείνουν οι δημιουργοί του `InSDN` για περιβάλλοντα SDN [24]. Τα υπόλοιπα έξι προέρχονται από το πλήρες σύνολο των 83 χαρακτηριστικών. Με αυτόν τον τρόπο, το τελικό σύνολο περιλαμβάνει πληροφορίες σχετικές με τον χρονισμό, τον όγκο και τον ρυθμό της κίνησης, τη συμπεριφορά στις δύο κατευθύνσεις και τη λειτουργία του TCP. Η ακριβής διαδικασία με την οποία τα 24 χαρακτηριστικά χρησιμοποιούνται για την εκπαίδευση και την αξιολόγηση των μοντέλων παρουσιάζεται στο Κεφάλαιο 5.

4.6 Μετρικές αξιολόγησης και καμπύλες ROC

Η απόδοση ενός μοντέλου ταξινόμησης δεν μπορεί να αξιολογηθεί μόνο από το συνολικό ποσοστό σωστών προβλέψεων. Ιδιαίτερα όταν οι κατηγορίες του συνόλου δεδομένων δεν περιέχουν τον ίδιο αριθμό εγγραφών, όπως συμβαίνει στο InSDN, απαιτούνται περισσότερες μετρικές ώστε να εξεταστεί τόσο η σωστή αναγνώριση των επιθέσεων όσο και η λανθασμένη ταξινόμηση νόμιμης κίνησης [27].

Η βάση για τον υπολογισμό αυτών των μετρικών είναι ο πίνακας σύγχυσης (confusion matrix). Στη δυαδική περίπτωση, όπου μια παρατήρηση χαρακτηρίζεται ως θετική ή αρνητική, ο πίνακας περιλαμβάνει τέσσερις δυνατές περιπτώσεις [27], [28]. Στο πλαίσιο ενός συστήματος ανίχνευσης εισβολών, ως θετική περίπτωση μπορεί να θεωρηθεί η επίθεση και ως αρνητική η νόμιμη κίνηση. Μία αληθώς θετική πρόβλεψη (True Positive, TP) αντιστοιχεί σε επίθεση που ανιχνεύθηκε σωστά. Μία ψευδώς θετική πρόβλεψη (False Positive, FP) αντιστοιχεί σε νόμιμη κίνηση που χαρακτηρίστηκε λανθασμένα ως επίθεση. Μία αληθώς αρνητική πρόβλεψη (True Negative, TN) είναι νόμιμη κίνηση που αναγνωρίστηκε σωστά, ενώ μία ψευδώς αρνητική πρόβλεψη (False Negative, FN) είναι επίθεση που δεν ανιχνεύθηκε και χαρακτηρίστηκε ως νόμιμη κίνηση [28]. Οι τέσσερις αυτές περιπτώσεις συνοψίζονται στο Σχήμα 4-2.



Σχήμα 4-2: Δομή του πίνακα σύγχυσης για δυαδική ταξινόμηση, με θετική κατηγορία την επίθεση και αρνητική κατηγορία τη νόμιμη δικτυακή κίνηση.

Στην περίπτωση πολλών κατηγοριών, όπως στη Μέθοδο Β της παρούσας εργασίας, ο πίνακας σύγχυσης περιλαμβάνει μία γραμμή και μία στήλη για κάθε κατηγορία. Οι τιμές της κύριας διαγώνιου αντιστοιχούν στις σωστές ταξινομήσεις, ενώ οι τιμές εκτός της διαγώνιου

δείχνουν μεταξύ ποιων κατηγοριών πραγματοποιήθηκαν λανθασμένες ταξινομήσεις [28]. Επομένως, ο πίνακας σύγχυσης δεν δείχνει μόνο πόσα λάθη έκανε ένα μοντέλο, αλλά και το είδος των λαθών του.

Από τις τιμές του πίνακα σύγχυσης υπολογίζονται οι βασικές μετρικές αξιολόγησης. Η συνολική ακρίβεια (*accuracy*) εκφράζει το ποσοστό όλων των παρατηρήσεων που ταξινομήθηκαν σωστά:

$$Accuracy = \frac{TP + TN}{TP + TN + FP + FN}$$

Μία υψηλή τιμή συνολικής ακρίβειας δεν είναι πάντοτε αρκετή για την αξιολόγηση ενός μοντέλου. Αν μία κατηγορία περιέχει πολύ περισσότερες εγγραφές από τις υπόλοιπες, ένα μοντέλο μπορεί να εμφανίζει υψηλή συνολική ακρίβεια επειδή ταξινομεί σωστά κυρίως την πολυπληθέστερη κατηγορία, χωρίς να αναγνωρίζει εξίσου αποτελεσματικά τις μικρότερες. Η συνολική ακρίβεια παραμένει αναίσθητη στην επίδοση σε μια συγκεκριμένη κατηγορία και, για τον λόγο αυτό, δεν αποτελεί από μόνη της αξιόπιστο κριτήριο σύγκρισης σε σύνολα με ανισόρροπη κατανομή κατηγοριών [27]. Το ζήτημα αυτό είναι ιδιαίτερα σημαντικό στην παρούσα εργασία λόγω της ανισορροπίας των κατηγοριών του InSDN που παρουσιάστηκε στην παράγραφο 4.4.

Η ορθότητα (*precision*) εκφράζει πόσες από τις παρατηρήσεις που το μοντέλο χαρακτήρισε ως θετικές ήταν πράγματι θετικές:

$$Precision = \frac{TP}{TP + FP}$$

Στην ανίχνευση εισβολών, υψηλή ορθότητα σημαίνει ότι όταν το σύστημα χαρακτηρίζει μία ροή ως επίθεση, η πρόβλεψη αυτή είναι συχνά σωστή. Αντίθετα, χαμηλή ορθότητα υποδηλώνει αυξημένο αριθμό ψευδώς θετικών προβλέψεων, δηλαδή περιπτώσεων στις οποίες νόμιμη κίνηση χαρακτηρίζεται λανθασμένα ως κακόβουλη.

Η ανάκληση (*recall*) εκφράζει το ποσοστό των πραγματικών επιθέσεων που αναγνωρίστηκαν σωστά:

$$Recall = \frac{TP}{TP + FN}$$

Στην ανίχνευση εισβολών, υψηλή ανάκληση σημαίνει ότι εντοπίζεται μεγάλο ποσοστό των επιθέσεων. Αντίθετα, χαμηλή ανάκληση σημαίνει ότι αρκετές επιθέσεις ταξινομούνται ως νόμιμη κίνηση και επομένως δεν ανιχνεύονται από το σύστημα.

Η μετρική F1 (F1-score) συνδυάζει την ορθότητα και την ανάκληση μέσω του αρμονικού τους μέσου [27]:

$$F1 = 2 * \frac{precision * recall}{precision + recall}$$

Η τιμή F1 μειώνεται όταν μία από τις δύο επιμέρους μετρικές είναι χαμηλή. Για τον λόγο αυτό παρέχει πιο ισορροπημένη εικόνα της απόδοσης του μοντέλου από την εξέταση μόνο της ορθότητας ή μόνο της ανάκλησης.

Ένα απλό αριθμητικό παράδειγμα βοηθά στην ερμηνεία των παραπάνω μετρικών. Έστω ότι ένα σύστημα εξετάζει 1.000 δικτυακές ροές, από τις οποίες οι 100 αντιστοιχούν σε επιθέσεις και οι 900 σε νόμιμη κίνηση. Αν το σύστημα αναγνωρίσει σωστά 95 από τις 100 επιθέσεις, τότε TP=95 και FN=5. Αν ταυτόχρονα χαρακτηρίσει λανθασμένα 10 από τις 900 νόμιμες ροές ως επιθέσεις, τότε FP=10 και TN=890.

Για το συγκεκριμένο παράδειγμα, η συνολική ακρίβεια είναι:

$$Accuracy = \frac{95 + 890}{95 + 890 + 10 + 5} = \frac{985}{1000} = 0,985 \text{ ή } 98,5\%$$

Η ορθότητα είναι:

$$Precision = \frac{95}{95 + 10} = \frac{95}{105} \approx 0,905 \text{ ή περίπου } 90,5\%$$

Η ανάκληση είναι:

$$Recall = \frac{95}{95 + 5} = \frac{95}{100} = 0,95 \text{ ή } 95\%$$

Τέλος, η τιμή F1 είναι:

$$F1 = 2 * \frac{0,905 * 0,95}{0,905 + 0,95} \approx 0,927 \text{ ή περίπου } 92,7\%$$

Παρότι η συνολική ακρίβεια του συστήματος στο παράδειγμα είναι 98,5%, το σύστημα εξακολουθεί να μην ανιχνεύει πέντε επιθέσεις και να χαρακτηρίζει δέκα νόμιμες ροές ως κακόβουλες. Το παράδειγμα δείχνει γιατί η συνολική ακρίβεια δεν επαρκεί από μόνη της για την αξιολόγηση ενός συστήματος ανίχνευσης. Η ορθότητα αποτυπώνει την επίδραση των ψευδώς θετικών προβλέψεων, ενώ η ανάκληση αποτυπώνει τις επιθέσεις που δεν ανιχνεύονται.

Στα προβλήματα πολλών κατηγοριών οι παραπάνω μετρικές μπορούν να υπολογίζονται χωριστά για κάθε κατηγορία. Για τον υπολογισμό τους, η εξεταζόμενη κατηγορία θεωρείται κάθε φορά ως θετική και όλες οι υπόλοιπες ως αρνητικές. Η προσέγγιση αυτή είναι γνωστή ως μία κατηγορία έναντι των υπολοίπων (one-vs-rest).

Για τη συνοπτική αποτίμηση της απόδοσης σε όλες τις κατηγορίες μπορεί να χρησιμοποιηθεί η μακρο-F1 (macro-F1), η οποία υπολογίζεται ως ο απλός μέσος όρος των επιμέρους τιμών F1:

$$Macro - F1 = \frac{1}{K} \sum_{k=1}^K F1_k$$

όπου K είναι το πλήθος των κατηγοριών. Με αυτόν τον τρόπο κάθε κατηγορία συμμετέχει εξίσου στο τελικό αποτέλεσμα, ανεξάρτητα από το πλήθος των εγγραφών της, σε αντίθεση με τη μικρο-στάθμιση (micro-averaging), η οποία επηρεάζεται περισσότερο από τις πολυπληθέστερες κατηγορίες [27]. Για τον λόγο αυτό η μακρο-F1 είναι ιδιαίτερα χρήσιμη στην παρούσα εργασία, όπου οι κατηγορίες του InSDN είναι άνισες ως προς το μέγεθός τους.

Εκτός από τις παραπάνω μετρικές, για την αξιολόγηση της διακριτικής ικανότητας ενός μοντέλου χρησιμοποιείται η καμπύλη λειτουργικού χαρακτηριστικού δέκτη (Receiver Operating Characteristic, ROC) [28]. Η καμπύλη ROC παρουσιάζει τη σχέση μεταξύ του ρυθμού αληθώς θετικών (True Positive Rate, TPR) και του ρυθμού ψευδώς θετικών (False Positive Rate, FPR), καθώς μεταβάλλεται το κατώφλι απόφασης (decision threshold) του μοντέλου.

Ο ρυθμός πραγματικά θετικών προβλέψεων (True Positive Rate, TPR) είναι ίσος με την ανάκληση:

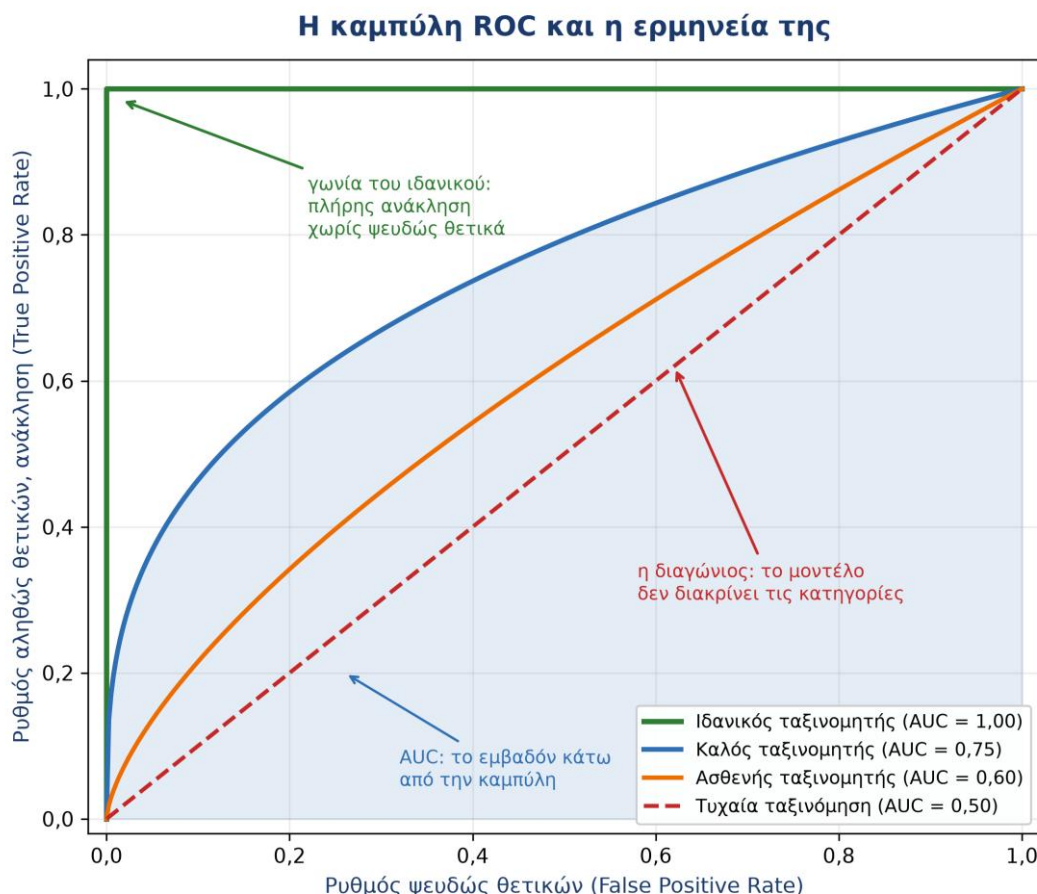
$$TPR = \frac{TP}{TP + FN}$$

Ο ρυθμός ψευδώς θετικών προβλέψεων (False Positive Rate, FPR) εκφράζει το ποσοστό των πραγματικά αρνητικών περιπτώσεων που χαρακτηρίστηκαν λανθασμένα ως θετικές:

$$FPR = \frac{FP}{FP + TN}$$

Στην καμπύλη ROC ο οριζόντιος άξονας αντιστοιχεί στο FPR και ο κατακόρυφος άξονας στο TPR. Ένα επιθυμητό μοντέλο επιτυγχάνει υψηλό TPR και ταυτόχρονα χαμηλό FPR. Για

τον λόγο αυτό, μία καλή καμπύλη ROC πλησιάζει την επάνω αριστερή γωνία του διαγράμματος. Αντίθετα, η διαγώνια γραμμή από την κάτω αριστερή προς την επάνω δεξιά γωνία αντιστοιχεί σε ταξινόμηση χωρίς ουσιαστική διακριτική ικανότητα [28]. Το Σχήμα 4-3 δείχνει τις χαρακτηριστικές περιπτώσεις.



Σχήμα 4-3: Σχηματική ερμηνεία διαφορετικών περιπτώσεων απόδοσης μιας καμπύλης ROC.

Η συνολική πληροφορία της καμπύλης ROC συνοψίζεται μέσω του εμβαδού κάτω από την καμπύλη (Area Under the Curve, AUC). Το AUC εκφράζει τη συνολική ικανότητα του μοντέλου να διακρίνει τη θετική από την αρνητική κατηγορία καθώς μεταβάλλεται το κατώφλι απόφασης. Επομένως, δεν εκφράζει το ποσοστό σωστών προβλέψεων σε ένα συγκεκριμένο κατώφλι, αλλά συνοψίζει τη διακριτική ικανότητα του μοντέλου σε διαφορετικές τιμές του κατωφλίου [28].

Η ιδανική περίπτωση αντιστοιχεί στο σημείο με μηδενικό FPR και μοναδιαίο TPR, δηλαδή στην επάνω αριστερή γωνία του διαγράμματος. Στο σημείο αυτό όλες οι επιθέσεις ανιχνεύονται χωρίς καμία ψευδώς θετική πρόβλεψη και το AUC ισούται με 1 [28]. Αντίθετα, η διαγώνια γραμμή από την κάτω αριστερή προς την επάνω δεξιά γωνία αντιστοιχεί σε

ταξινόμηση χωρίς διακριτική ικανότητα, με AUC ίσο με 0,5 [28]. Τιμή AUC μικρότερη από 0,5 δηλώνει επίδοση χειρότερη από την τυχαία κατάταξη και μπορεί να υποδηλώνει ότι η σειρά διάκρισης των κατηγοριών έχει ουσιαστικά αντιστραφεί [28].

Στην πολυκατηγορική ταξινόμηση της παρούσας εργασίας, οι καμπύλες ROC υπολογίζονται με την προσέγγιση μία κατηγορία έναντι των υπολοίπων (one-vs-rest). Για κάθε κατηγορία εξετάζεται η δυνατότητα του μοντέλου να τη διακρίνει από όλες τις υπόλοιπες. Οι πίνακες σύγχυσης, οι καμπύλες ROC και οι τιμές των μετρικών που προκύπτουν από τα πειράματα παρουσιάζονται στο Κεφάλαιο 6.

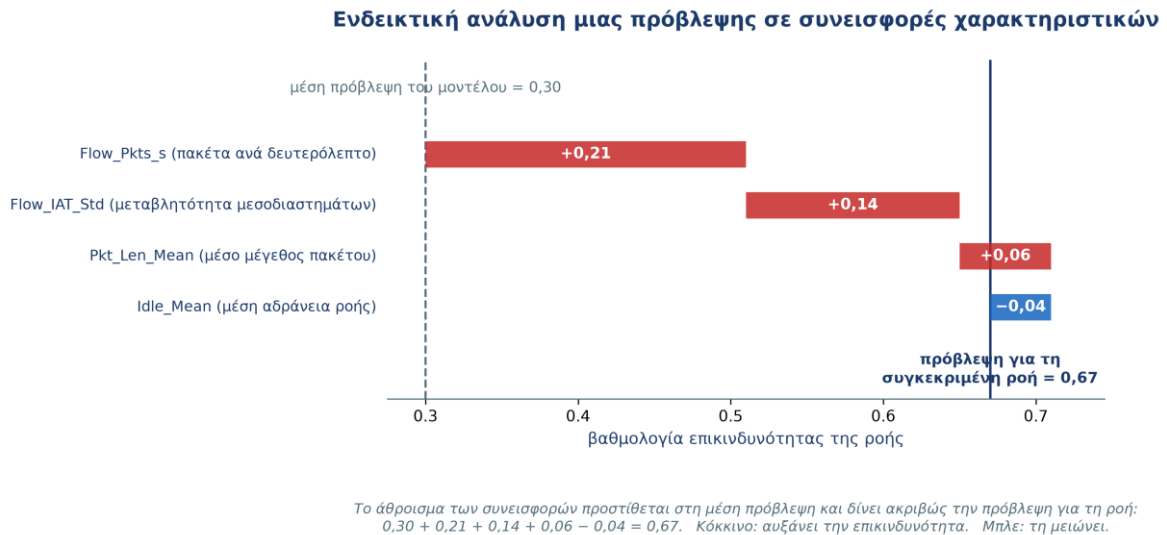
4.7 Ερμηνευσιμότητα των αποφάσεων και τιμές SHAP

Τα μοντέλα που παρουσιάστηκαν στην παράγραφο 4.2 παράγουν μια απόφαση χωρίς να εξηγούν άμεσα τον λόγο που οδήγησε σε αυτήν. Σε ένα σύστημα ανίχνευσης εισβολών αυτό αποτελεί πρακτικό πρόβλημα, καθώς ο διαχειριστής που βλέπει μια ροή να χαρακτηρίζεται κακόβουλη χρειάζεται να γνωρίζει ποια χαρακτηριστικά επηρέασαν περισσότερο την απόφαση, πριν εφαρμόσει μέτρα αποκλεισμού.

Μια διαδεδομένη μέθοδος για τον σκοπό αυτό είναι οι τιμές SHAP (SHapley Additive exPlanations)[29]. Η μέθοδος βασίζεται στις τιμές Shapley της θεωρίας συνεργατικών παιγνίων. Κάθε χαρακτηριστικό αντιμετωπίζεται ως «παίκτης» που συνεισφέρει στο τελικό αποτέλεσμα, και η συνολική πρόβλεψη κατανέμεται στις επιμέρους συνεισφορές των χαρακτηριστικών.

Βασικό γνώρισμα της μεθόδου είναι ο προσθετικός της χαρακτήρας. Για μια συγκεκριμένη παρατήρηση, το άθροισμα των συνεισφορών όλων των χαρακτηριστικών προστίθεται στη μέση πρόβλεψη του μοντέλου και δίνει ακριβώς την πρόβλεψη για τη συγκεκριμένη παρατήρηση [29].

Ένα ενδεικτικό παράδειγμα αποσαφηνίζει τη λογική. Έστω μοντέλο του οποίου η μέση πρόβλεψη σε όλες τις ροές είναι 0,30. Για μια συγκεκριμένη ροή, ο υψηλός ρυθμός πακέτων συνεισφέρει κατά 0,21, η μεγάλη μεταβλητότητα των μεσοδιαστημάτων άφιξης κατά 0,14 και το μέσο μέγεθος πακέτου κατά 0,06, ενώ η μέση αδράνεια της ροής μειώνει την πρόβλεψη κατά 0,04. Το άθροισμα των συνεισφορών δίνει 0,67, δηλαδή ακριβώς την πρόβλεψη του μοντέλου για τη συγκεκριμένη ροή. Το Σχήμα 4-4 αποτυπώνει γραφικά την ανάλυση αυτή.



Σχήμα 4-4: Ενδεικτική ανάλυση μιας πρόβλεψης του μοντέλου σε συνεισφορές χαρακτηριστικών κατά τη μέθοδο SHAP.

Πέρα από τη μεμονωμένη παρατήρηση, οι συνεισφορές αυτές μπορούν να συγκεντρωθούν σε πολλές παρατηρήσεις. Η μέση απόλυτη τιμή της συνεισφοράς κάθε χαρακτηριστικού δίνει μια συνολική κατάταξη σημαντικότητας. Η κατάταξη αυτή δείχνει ποια χαρακτηριστικά χρησιμοποιεί πράγματι το μοντέλο, και όχι ποια υποθέτει ο ερευνητής ότι χρησιμοποιεί.

Πρέπει να σημειωθεί ότι οι τιμές SHAP εξηγούν τη συμπεριφορά του μοντέλου και όχι αιτιώδεις σχέσεις στο ίδιο το δίκτυο. Υψηλή συνεισφορά ενός χαρακτηριστικού σημαίνει ότι το μοντέλο στηρίζεται σε αυτό για την πρόβλεψή του, όχι ότι το χαρακτηριστικό αυτό προκαλεί από μόνο του την επίθεση.

4.8 Σχετική βιβλιογραφία

Η χρήση της Μηχανικής Μάθησης για την ανίχνευση επιθέσεων σε δίκτυα SDN έχει μελετηθεί εκτενώς στη σχετική βιβλιογραφία. Οι Braga κ.ά. [8] πρότειναν έναν ελαφρύ μηχανισμό ανίχνευσης επιθέσεων DDoS βασισμένο σε αυτο-οργανούμενους χάρτες (Self-Organizing Maps, SOM), αξιοποιώντας στατιστικά χαρακτηριστικά ροών που συλλέγονταν μέσω ελεγκτή NOX. Η εργασία τους έδειξε ότι τα στατιστικά στοιχεία των ροών που είναι διαθέσιμα μέσω του OpenFlow μπορούν να αξιοποιηθούν για την ανίχνευση επιθέσεων χωρίς να απαιτείται εξέταση του περιεχομένου κάθε πακέτου. Η παρούσα εργασία ακολουθεί την ίδια γενική αρχή της αξιοποίησης στατιστικών χαρακτηριστικών της δικτυακής κίνησης, αλλά εξετάζει περισσότερες κατηγορίες μοντέλων και περιλαμβάνει και ζωντανό μηχανισμό εφαρμογής κανόνα αντιμετώπισης.

Οι επισκοπήσεις του πεδίου αναδεικνύουν τόσο τις δυνατότητες όσο και τους περιορισμούς των προσεγγίσεων αυτών. Οι Sultana κ.ά. [6] εξετάζουν τεχνικές Μηχανικής Μάθησης για συστήματα ανίχνευσης εισβολών σε SDN και επισημαίνουν ζητήματα που σχετίζονται με την κλιμάκωση, την επιλογή χαρακτηριστικών και την αξιοπιστία της ανίχνευσης. Οι Janabi κ.ά. [9] παρουσιάζουν νεότερη επισκόπηση των συστημάτων ανίχνευσης εισβολών σε SDN, εξετάζοντας μεταξύ άλλων τα χρησιμοποιούμενα σύνολα δεδομένων, τις μεθόδους ανίχνευσης και τους περιορισμούς τους. Οι Doğan κ.ά. [10] εξετάζουν εφαρμογές Μηχανικής και Βαθιάς Μάθησης τόσο για την ανίχνευση όσο και για την αντιμετώπιση επιθέσεων σε περιβάλλοντα SDN. Παράλληλα, οι Scott-Hayward κ.ά. [4] εξετάζουν συνολικά την ασφάλεια της αρχιτεκτονικής SDN και αναδεικνύουν τους κινδύνους που προκύπτουν από τον διαχωρισμό των επιπέδων και τη συγκέντρωση λειτουργιών ελέγχου.

Ορισμένες εργασίες συνδέονται πιο άμεσα με επιμέρους στοιχεία της μεθοδολογίας της παρούσας μελέτης. Οι Shin και Gu [5] μελέτησαν τη σκοπιμότητα επιθέσεων που εκμεταλλεύονται τον διαχωρισμό των δύο επιπέδων. Έδειξαν ότι μεγάλος αριθμός αιτημάτων σε σύντομο χρονικό διάστημα μπορεί να προκαλέσει αυξημένο φόρτο στο επίπεδο ελέγχου, καθώς το επίπεδο δεδομένων προωθεί μεγάλο αριθμό μηνυμάτων προς τον ελεγκτή. Οι Elsayed κ.ά. [24] δημοσίευσαν το InSDN, σύνολο δεδομένων σχεδιασμένο ειδικά για την αξιολόγηση συστημάτων ανίχνευσης σε περιβάλλον SDN, το οποίο χρησιμοποιείται και στην παρούσα εργασία. Η διερεύνηση του ίδιου προβλήματος συνεχίζεται και σε νεότερες μελέτες. Οι Hamarshe κ.ά. [30] εξετάζουν μοντέλα Μηχανικής Μάθησης για την ανίχνευση επιθέσεων DDoS σε SDN, ενώ οι Jafari Gohari κ.ά. [31] προτείνουν σύστημα ανίχνευσης βασισμένο σε συνελκτική μηχανή Tsetlin (Convolutional Tsetlin Machine). Οι δύο τελευταίες εργασίες είναι προδημοσιεύσεις και χρησιμοποιούνται εδώ συμπληρωματικά, ως ενδείξεις της συνεχιζόμενης ερευνητικής δραστηριότητας στο συγκεκριμένο πεδίο.

Σε σχέση με την παραπάνω βιβλιογραφία, η παρούσα εργασία συνδυάζει τρεις πλευρές του προβλήματος. Πρώτον, πραγματοποιεί συγκριτική αξιολόγηση πολλών μοντέλων σε δεδομένα ροών εκτός σύνδεσης και, χωριστά, εξετάζει ζωντανή λειτουργία από τη συλλογή της τηλεμετρίας έως την εφαρμογή κανόνα αντιμετώπισης. Δεύτερον, εξετάζει τη στιβαρότητα (robustness) των μοντέλων έναντι αντίπαλων τροποποιήσεων των δεδομένων εισόδου. Τρίτον, συνδυάζει επιβλεπόμενη και ανεπίβλεπτη μάθηση. Το επιβλεπόμενο σκέλος εκπαιδεύεται με γνωστές ετικέτες φυσιολογικής και κακόβουλης κίνησης και επομένως βρίσκεται πλησιέστερα στη λογική της ανίχνευσης γνωστής κατάχρησης, χωρίς

όμως να αποτελεί σύστημα υπογραφών. Αντίθετα, το ανεπίβλεπτο σκέλος με τον Isolation Forest βασίζεται στην ανίχνευση αποκλίσεων από τη φυσιολογική συμπεριφορά. Ως προς τη θέση παρακολούθησης, το σύστημα αναλύει χαρακτηριστικά της δικτυακής κίνησης και επομένως λειτουργεί σε επίπεδο δικτύου.

4.9 Προεπεξεργασία, ρύθμιση υπερπαραμέτρων και γενίκευση

Πριν από την εκπαίδευση ενός μοντέλου Μηχανικής Μάθησης, τα δεδομένα πρέπει να προετοιμαστούν σε μορφή κατάλληλη για τον αλγόριθμο που θα χρησιμοποιηθεί. Η διαδικασία αυτή ονομάζεται προεπεξεργασία (preprocessing) και μπορεί να περιλαμβάνει τον καθαρισμό ελλিপών ή μη έγκυρων εγγραφών, την κωδικοποίηση των κατηγοριών και τη μετατροπή της κλίμακας των αριθμητικών χαρακτηριστικών. Οι επιλογές προεπεξεργασίας πρέπει να γίνονται με τρόπο που να διατηρεί το νόημα των δεδομένων και να μην εισάγει τεχνητές σχέσεις μεταξύ των χαρακτηριστικών.

Στην επιβλεπόμενη μάθηση, οι λεκτικές κατηγορίες της μεταβλητής-στόχου μπορούν να αναπαρασταθούν αριθμητικά, ώστε να μπορούν να χρησιμοποιηθούν από τους αλγορίθμους Μηχανικής Μάθησης. Η διαδικασία αυτή αφορά την κωδικοποίηση των κατηγοριών που πρέπει να προβλεφθούν και δεν σημαίνει ότι αναγνωριστικά χωρίς αριθμητική σημασία, όπως διευθύνσεις ή ονόματα κόμβων, πρέπει να μετατρέπονται αυθαίρετα σε αριθμούς και να χρησιμοποιούνται ως αριθμητικά χαρακτηριστικά.

Ιδιαίτερη σημασία έχει η αριθμητική κλίμακα των χαρακτηριστικών. Ένα χαρακτηριστικό μπορεί, για παράδειγμα, να λαμβάνει τιμές της τάξης των εκατομμυρίων, ενώ ένα άλλο να περιορίζεται σε πολύ μικρότερες τιμές. Η διαφορά αυτή μπορεί να επηρεάσει αλγορίθμους που βασίζονται σε αποστάσεις ή αριθμητικές διαφορές μεταξύ των παρατηρήσεων, όπως ο KNN και το SVM [20, Ch. 12–13].

Μία συνηθισμένη τεχνική αντιμετώπισης αυτού του προβλήματος είναι η τυποποίηση (standardization). Ο τυποποιητής StandardScaler μετασχηματίζει κάθε αριθμητικό χαρακτηριστικό σύμφωνα με τη σχέση [32]:

$$z = \frac{x - \mu}{\sigma}$$

όπου x είναι η αρχική τιμή, μ ο μέσος όρος του χαρακτηριστικού και σ η τυπική του απόκλιση. Οι δύο αυτές ποσότητες υπολογίζονται από τα δεδομένα εκπαίδευσης. Μετά την τυποποίηση, το χαρακτηριστικό έχει μέσο όρο περίπου ίσο με μηδέν και διακύμανση ίση με τη μονάδα στα δεδομένα στα οποία προσαρμόστηκε ο μετασχηματισμός [20, Ch. 13], [32].

Η διαδικασία δεν δημιουργεί νέο χαρακτηριστικό, αλλά μεταβάλλει την αριθμητική κλίμακα με την οποία το υπάρχον χαρακτηριστικό εισάγεται στο μοντέλο.

Οι παράμετροι της τυποποίησης πρέπει να υπολογίζονται μόνο από τα δεδομένα εκπαίδευσης. Στη συνέχεια, οι ίδιες τιμές του μέσου όρου και της τυπικής απόκλισης χρησιμοποιούνται για τον μετασχηματισμό των δεδομένων επικύρωσης και ελέγχου. Αν πληροφορία από τα σύνολα επικύρωσης ή ελέγχου χρησιμοποιηθεί κατά την προετοιμασία ή την εκπαίδευση του μοντέλου, δημιουργείται διαρροή δεδομένων (data leakage). Η διαρροή επιτρέπει στο μοντέλο ή στη διαδικασία επιλογής του να αξιοποιήσει πληροφορία που κανονικά δεν θα ήταν διαθέσιμη κατά την εκπαίδευση και μπορεί να οδηγήσει σε υπερβολικά αισιόδοξη εκτίμηση της απόδοσής του [33].

Διαρροή δεδομένων μπορεί να προκύψει και όταν ίδιες ή πολύ στενά συσχετισμένες εγγραφές εμφανίζονται τόσο στο σύνολο εκπαίδευσης όσο και στο σύνολο αξιολόγησης [33]. Στην περίπτωση αυτή, το μοντέλο μπορεί να αξιολογείται σε πληροφορία που είναι ήδη σε μεγάλο βαθμό γνωστή από την εκπαίδευση. Όταν υπάρχουν γνωστές ομάδες συσχετισμένων εγγραφών, ο διαχωρισμός μπορεί να σχεδιαστεί έτσι ώστε οι εγγραφές της ίδιας ομάδας να μην κατανέμονται μεταξύ εκπαίδευσης και αξιολόγησης. Η συγκεκριμένη διαδικασία που εφαρμόζεται στην παρούσα εργασία περιγράφεται στο Κεφάλαιο 5.

Ένα δεύτερο βασικό ζήτημα αφορά την πολυπλοκότητα του μοντέλου. Το ισοζύγιο μεροληψίας και διακύμανσης (bias–variance trade-off) περιγράφει τη σχέση μεταξύ ενός μοντέλου που είναι υπερβολικά απλό και ενός μοντέλου που προσαρμόζεται υπερβολικά στα δεδομένα εκπαίδευσης [20, Para. 2.9]. Στην πρώτη περίπτωση μπορεί να εμφανιστεί υποπροσαρμογή (underfitting), κατά την οποία το μοντέλο δεν αποτυπώνει επαρκώς τις σχέσεις που υπάρχουν στα δεδομένα. Στη δεύτερη περίπτωση μπορεί να εμφανιστεί υπερπροσαρμογή (overfitting), κατά την οποία το μοντέλο μαθαίνει σε υπερβολικό βαθμό τις ιδιαιτερότητες του συνόλου εκπαίδευσης και δεν διατηρεί αντίστοιχη απόδοση σε νέα δεδομένα.

Η συμπεριφορά και η πολυπλοκότητα ενός μοντέλου επηρεάζονται επίσης από τις υπερπαραμέτρους (hyperparameters). Σε αντίθεση με τις παραμέτρους που μαθαίνονται από το ίδιο το μοντέλο κατά την εκπαίδευση, οι υπερπαραμέτροι καθορίζουν εκ των προτέρων πλευρές της δομής ή της λειτουργίας του αλγορίθμου. Παραδείγματα αποτελούν το πλήθος των δέντρων σε ένα Random Forest και το πλήθος των δειγμάτων που χρησιμοποιούνται για την κατασκευή των δέντρων ενός Isolation Forest [21], [23].

Στην υλοποίηση του Isolation Forest από τη βιβλιοθήκη scikit-learn υπάρχει επιπλέον η παράμετρος πρόσμειξης (contamination). Η παράμετρος αυτή εκφράζει την αναμενόμενη αναλογία ακραίων παρατηρήσεων στα δεδομένα και χρησιμοποιείται από την υλοποίηση για τον καθορισμό του κατωφλίου με βάση το οποίο η συνεχής βαθμολογία ανωμαλίας μετατρέπεται σε τελική απόφαση [34]. Όταν δίνεται αριθμητική τιμή, αυτή πρέπει να βρίσκεται στο διάστημα:

$$0 < \text{contamination} \leq 0,5$$

[34]. Η παράμετρος πρόσμειξης δεν αποτελεί μέρος της αρχικής μαθηματικής διατύπωσης του Isolation Forest που παρουσιάστηκε από τους Liu κ.ά. [23], αλλά αφορά τη συγκεκριμένη υλοποίηση του αλγορίθμου. Η ακριβής τιμή που χρησιμοποιείται στην παρούσα εργασία αποτελεί μεθοδολογική επιλογή και παρουσιάζεται στο Κεφάλαιο 5.

Η επιλογή των υπερπαραμέτρων πρέπει να διαχωρίζεται από την τελική αξιολόγηση του μοντέλου. Για τον σκοπό αυτό, τα διαθέσιμα δεδομένα μπορούν να χωριστούν σε σύνολο εκπαίδευσης (training set), σύνολο επικύρωσης (validation set) και σύνολο ελέγχου (test set) [20, Ch. 7]. Το σύνολο εκπαίδευσης χρησιμοποιείται για την εκμάθηση του μοντέλου. Το σύνολο επικύρωσης χρησιμοποιείται για την επιλογή υπερπαραμέτρων ή για τη σύγκριση διαφορετικών διαμορφώσεων. Το σύνολο ελέγχου διατηρείται ανεξάρτητο από τις παραπάνω αποφάσεις και χρησιμοποιείται μετά την ολοκλήρωση της διαδικασίας επιλογής, ώστε να παρέχει τελική εκτίμηση της απόδοσης σε δεδομένα που δεν χρησιμοποιήθηκαν για τη διαμόρφωση του μοντέλου [20, Ch. 7].

Μία συμπληρωματική διαδικασία είναι η διασταυρούμενη επικύρωση (cross-validation). Σε αυτή, τα διαθέσιμα δεδομένα χωρίζονται σε επιμέρους τμήματα ή πτυχές (folds) και το μοντέλο εκπαιδεύεται και αξιολογείται επανειλημμένα χρησιμοποιώντας διαφορετικούς συνδυασμούς αυτών των τμημάτων [20, Ch. 7]. Με τον τρόπο αυτό, η εκτίμηση της απόδοσης εξαρτάται λιγότερο από έναν μόνο τυχαίο διαχωρισμό των δεδομένων. Η ακριβής μορφή της διασταυρούμενης επικύρωσης που χρησιμοποιείται στην παρούσα εργασία παρουσιάζεται στο Κεφάλαιο 5.

Ο τελικός στόχος των παραπάνω διαδικασιών είναι η γενίκευση (generalization), δηλαδή η ικανότητα ενός μοντέλου να διατηρεί ικανοποιητική απόδοση σε νέα δεδομένα που δεν χρησιμοποιήθηκαν για την εκπαίδευση ή τη ρύθμισή του [20, Ch. 7]. Επομένως, υψηλή απόδοση στο σύνολο εκπαίδευσης δεν αποτελεί από μόνη της απόδειξη καλής γενίκευσης,

καθώς μπορεί να οφείλεται σε υπερπροσαρμογή ή σε διαρροή πληροφοριών μεταξύ των διαφορετικών σταδίων της διαδικασίας.

Η γενίκευση μπορεί επιπλέον να επηρεαστεί όταν οι στατιστικές σχέσεις των δεδομένων μεταβάλλονται με τον χρόνο. Το φαινόμενο αυτό ονομάζεται μετατόπιση εννοιών (concept drift) και περιγράφει μεταβολές στη σχέση μεταξύ των δεδομένων εισόδου και της μεταβλητής που επιχειρεί να προβλέψει το μοντέλο [32]. Ένα μοντέλο που αποδίδει ικανοποιητικά σε δεδομένα μιας συγκεκριμένης χρονικής περιόδου δεν είναι δεδομένο ότι θα διατηρήσει την ίδια απόδοση αν μεταβληθεί η συμπεριφορά της δικτυακής κίνησης ή των επιθέσεων. Για τον λόγο αυτό, η μακροχρόνια χρήση ενός συστήματος Μηχανικής Μάθησης μπορεί να απαιτεί παρακολούθηση της απόδοσής του και, όταν είναι απαραίτητο, προσαρμογή ή επανεκπαίδευση του μοντέλου [32].

Στην παρούσα εργασία, οι συγκεκριμένες επιλογές προεπεξεργασίας, οι αναλογίες διαχωρισμού των δεδομένων, η μορφή της διασταυρούμενης επικύρωσης και οι τιμές των υπερπαραμέτρων που εξετάστηκαν παρουσιάζονται στο Κεφάλαιο 5. Οι μετρήσεις που προέκυψαν από αυτές τις επιλογές, καθώς και η επίδραση των διπλότυπων εγγραφών στην αξιολόγηση των μοντέλων, παρουσιάζονται στο Κεφάλαιο 6.

4.10 Ζητήματα ιδιωτικότητας και δεοντολογίας

Η παρακολούθηση δικτυακής κίνησης για σκοπούς ανίχνευσης εισβολών μπορεί να δημιουργήσει ζητήματα ιδιωτικότητας, ακόμη και όταν δεν εξετάζεται το περιεχόμενο των πακέτων. Ο Γενικός Κανονισμός για την Προστασία Δεδομένων (General Data Protection Regulation, GDPR) θεωρεί προσωπικά δεδομένα τις πληροφορίες που μπορούν να συνδεθούν άμεσα ή έμμεσα με ταυτοποιήσιμο φυσικό πρόσωπο και προβλέπει, μεταξύ άλλων, την αρχή της ελαχιστοποίησης των δεδομένων [35]. Επομένως, η χρήση μεταδεδομένων δεν σημαίνει από μόνη της ότι απουσιάζουν ζητήματα προστασίας προσωπικών δεδομένων.

Η ανάλυση χαρακτηριστικών ροής περιορίζει την ανάγκη εξέτασης του περιεχομένου των επικοινωνιών. Χαρακτηριστικά όπως το πλήθος και το μέγεθος των πακέτων, η διάρκεια μιας ροής και οι χρόνοι μεταξύ διαδοχικών αφίξεων μπορούν να χρησιμοποιηθούν για την ανίχνευση χωρίς να απαιτείται βαθιά επιθεώρηση του περιεχομένου κάθε πακέτου. Ωστόσο, πληροφορίες όπως οι διευθύνσεις IP, οι χρονικές σημάνσεις και τα πρότυπα επικοινωνίας μπορούν, σε πραγματικά δίκτυα, να συνδεθούν υπό ορισμένες προϋποθέσεις με

συγκεκριμένους χρήστες ή συσκευές και επομένως δεν πρέπει να θεωρούνται αυτομάτως ανώνυμες [35].

Στη ζωντανή υλοποίηση της παρούσας εργασίας, οι διευθύνσεις IP χρησιμοποιούνται για την ταυτοποίηση των κόμβων και για την εφαρμογή κανόνων αποκλεισμού, ενώ καταγράφονται επίσης στα αρχεία των πειραμάτων. Οι διευθύνσεις αυτές δεν περιλαμβάνονται στα χαρακτηριστικά εισόδου του μοντέλου, το οποίο χρησιμοποιεί συγκεντρωτικά στατιστικά της δικτυακής κίνησης, όπως το πλήθος πακέτων, τον όγκο δεδομένων και τη διάρκεια των ροών. Στο πειραματικό περιβάλλον της παρούσας εργασίας οι διευθύνσεις αφορούν εξομοιωμένους κόμβους. Σε πραγματική ανάπτυξη, όμως, αντίστοιχα δικτυακά αναγνωριστικά θα πρέπει να αντιμετωπίζονται με μεγαλύτερη προσοχή όταν μπορούν να συνδεθούν με ταυτοποιήσιμα φυσικά πρόσωπα.

Για τον λόγο αυτό, ένα πραγματικό σύστημα ανίχνευσης πρέπει να περιορίζει τη συλλογή και τη διατήρηση πληροφοριών στα στοιχεία που είναι αναγκαία για τον σκοπό της ασφάλειας. Η αποθήκευση αναγνωριστικών ή άλλων στοιχείων που δεν είναι απαραίτητα για την ανίχνευση πρέπει να αποφεύγεται ή να περιορίζεται κατάλληλα. Η προσέγγιση αυτή συνδέεται με τις αρχές της ελαχιστοποίησης των δεδομένων και του περιορισμού του σκοπού επεξεργασίας [35].

Δεοντολογικό ζήτημα προκύπτει επίσης όταν η ανίχνευση συνδέεται με αυτοματοποιημένη αντιμετώπιση. Ένα σύστημα ανίχνευσης μπορεί να παράγει ψευδώς θετικές και ψευδώς αρνητικές αποφάσεις και, επομένως, μια αυτόματη ενέργεια που βασίζεται σε λανθασμένη πρόβλεψη μπορεί να επηρεάσει νόμιμη δικτυακή κίνηση [36]. Για τον λόγο αυτό, οι μηχανισμοί αυτόματης απόκρισης πρέπει να σχεδιάζονται με προσοχή, ιδιαίτερα όταν μπορούν να οδηγήσουν σε αποκλεισμό κόμβων ή απόρριψη κίνησης. Η αξιολόγηση των ψευδώς θετικών προβλέψεων και της συμπεριφοράς του μηχανισμού αντιμετώπισης στην παρούσα εργασία παρουσιάζεται στο Κεφάλαιο 6.

5 Μεθοδολογία και Υλοποίηση

Το προηγούμενο κεφάλαιο παρουσίασε τις μεθόδους ανίχνευσης και τους αλγορίθμους Μηχανικής Μάθησης που χρησιμοποιούνται στην παρούσα διπλωματική εργασία. Το παρόν κεφάλαιο περιγράφει τον σχεδιασμό και την υλοποίηση του συστήματος. Η υλοποίηση χωρίζεται σε δύο συμπληρωματικές μεθόδους. Η Μέθοδος Α αφορά τη ζωντανή ανίχνευση και αντιμετώπιση μέσα σε εξομοιωμένο δίκτυο SDN, ενώ η Μέθοδος Β αφορά την ανάλυση ροών εκτός σύνδεσης (offline) με Μηχανική Μάθηση, σε δεδομένα με τη δομή του InSDN. Ολόκληρος ο κώδικας αναπτύχθηκε σε γλώσσα Python και οργανώνεται σε αναπαραγώγιμο περιβάλλον εκτέλεσης βασισμένο σε Docker. Στη συνέχεια παρουσιάζονται η συνολική αρχιτεκτονική και η αρχιτεκτονική ελέγχου, οι δύο μέθοδοι, οι μηχανισμοί ασφάλειας του ελεγκτή, ο βρόχος τηλεμετρίας, το περιβάλλον εκτέλεσης και η διαδικασία αυτοματοποιημένου ελέγχου.

5.1 Συνολική αρχιτεκτονική του συστήματος

Η συνολική υλοποίηση αποτελείται από δύο διακριτές μεθόδους. Η Μέθοδος Α αφορά τη ζωντανή ανίχνευση και αντιμετώπιση και αξιολογείται με δύο διαφορετικά επίπεδα πειραματικής πιστότητας. Η Μέθοδος Β λειτουργεί εκτός σύνδεσης και αφορά την εκπαίδευση και τη συγκριτική αξιολόγηση μοντέλων Μηχανικής Μάθησης σε καταγεγραμμένες και συνθετικές δικτυακές ροές. Τα μοντέλα της Μεθόδου Β δεν χρησιμοποιούνται για τη λήψη αποφάσεων στο ζωντανό σύστημα της Μεθόδου Α, το οποίο βασίζεται σε διαφορετική διαμόρφωση Isolation Forest.

Στη Μέθοδο Α χρησιμοποιούνται δύο διαφορετικά προφίλ εκτέλεσης. Το πρώτο λειτουργεί σε επίπεδο εφαρμογής και χρησιμοποιείται για τα πειράματα συνθετικής τηλεμετρίας. Σε αυτό, το στοιχείο `sdn_switch` υλοποιεί προώθηση σε επίπεδο εφαρμογής μέσω UDP datagrams μεταξύ διεργασιών Python. Δεν αποτελεί πραγματικό μεταγωγέα OpenFlow και δεν αντικαθιστά το Open vSwitch. Ο σκοπός του είναι να υποστηρίξει την ελεγχόμενη δοκιμή της τηλεμετρίας, της λογικής απόφασης και του μηχανισμού απόκρισης χωρίς να απαιτείται παραγωγή πραγματικής δικτυακής κίνησης.

Το δεύτερο προφίλ λειτουργεί σε επίπεδο πακέτων και χρησιμοποιεί το `sdn_mininet`. Σε αυτό εκτελείται εξομοιωμένη τοπολογία Mininet με Open vSwitch και χώρους ονομάτων του πυρήνα Linux. Τα πακέτα παράγονται από δικτυακά εργαλεία και διασχίζουν το Open vSwitch, επιτρέποντας τη συλλογή τηλεμετρίας από πραγματική εκτέλεση της δικτυακής

στοίβας μέσα στο εξομοιωμένο περιβάλλον. Το συγκεκριμένο προφίλ χρησιμοποιείται για το πείραμα πλημμύρας SYN και εκτελείται χωριστά από το προφίλ συνθετικής τηλεμετρίας. Τα δύο προφίλ χρησιμοποιούν κοινά την εφαρμογή ελέγχου sdn_controller και τον πίνακα εποπτείας sdn_dashboard. Ο ελεγκτής εκτελεί το ζωντανό μοντέλο Isolation Forest, διαχειρίζεται την τηλεμετρία και τις αποφάσεις αντιμετώπισης, ενώ ο πίνακας εποπτείας παρουσιάζει την κατάσταση του συστήματος και τις σχετικές μετρήσεις. Η διαφορά μεταξύ των δύο προφίλ βρίσκεται κυρίως στον τρόπο με τον οποίο παράγεται και εισάγεται η δικτυακή πληροφορία στο σύστημα.

Πίνακας 5-1: Στοιχεία της ζωντανής υλοποίησης της Μεθόδου Α και χρήση τους στα δύο προφίλ εκτέλεσης.

Στοιχείο	Προφίλ χρήσης	Ρόλος
sdn_controller (Flask, θύρα 9000)	Κοινό και στα δύο προφίλ	Εκτελεί το ζωντανό μοντέλο Isolation Forest, δέχεται τηλεμετρία και διαχειρίζεται τις αποφάσεις αντιμετώπισης μέσω της διεπαφής REST.
sdn_πίνακας εποπτείας (Dash/Cytoscape, θύρα 8050)	Κοινό και στα δύο προφίλ	Παρουσιάζει την τοπολογία, την κατάσταση των κόμβων και τις βασικές μετρήσεις της ζωντανής εκτέλεσης.
sdn_switch	Συνθετική τηλεμετρία σε επίπεδο εφαρμογής	Υλοποιεί προώθηση UDP datagrams μεταξύ διεργασιών Python. Χρησιμοποιείται για την ελεγχόμενη δοκιμή της τηλεμετρίας και της λογικής απόφασης χωρίς Open vSwitch.
sdn_mininet (Mininet + OVS, privileged)	Πείραμα σε επίπεδο πακέτων	Εκτελεί την εξομοιωμένη δικτυακή τοπολογία με Open vSwitch και πραγματική δικτυακή κίνηση μέσα στους χώρους ονομάτων του Linux.

Τα στοιχεία sdn_switch και sdn_mininet δεν αποτελούν δύο διαδοχικά επίπεδα του ίδιου πειράματος. Αντιστοιχούν σε δύο διαφορετικά προφίλ αξιολόγησης της Μεθόδου Α: το πρώτο σε επίπεδο εφαρμογής και το δεύτερο σε επίπεδο πακέτων.

5.1.1 Αρχιτεκτονική ελέγχου: υβριδικό μοντέλο SDN

Η Μέθοδος Α υλοποιείται με υβριδική αρχιτεκτονική ελέγχου. Στο πείραμα σε επίπεδο πακέτων, η προώθηση της δικτυακής κίνησης πραγματοποιείται από τον Open vSwitch. Ο Open vSwitch είναι λογισμικός μεταγωγέας που υποστηρίζει το πρωτόκολλο OpenFlow και επιτρέπει τη διαχείριση καταχωρήσεων ροής [12].

Στην παρούσα υλοποίηση ο μεταγωγέας έχει διαμορφωθεί σε κατάσταση αυτόνομης λειτουργίας (failMode=standalone). Στην κατάσταση αυτή χρησιμοποιείται κανόνας κανονικής προώθησης (NORMAL), ώστε ο μεταγωγέας να μαθαίνει τις διευθύνσεις MAC και να προωθεί την κίνηση χωρίς να απαιτείται μόνιμη σύνδεση με εξωτερικό ελεγκτή. Η επιλογή αυτή επιτρέπει να συνεχίζεται η βασική προώθηση της κίνησης, ενώ η απόφαση ασφαλείας λαμβάνεται χωριστά από την κεντρική εφαρμογή.

Η εφαρμογή ελέγχου λειτουργεί ως λογικά κεντριοποιημένος μηχανισμός ασφάλειας. Συλλέγει πληροφορίες για τη δικτυακή κίνηση, υπολογίζει τα χαρακτηριστικά που απαιτούνται από το ζωντανό μοντέλο Isolation Forest και αποφασίζει αν πρέπει να εφαρμοστεί μέτρο αντιμετώπισης. Στο προφίλ Mininet/Open vSwitch, η ανάκτηση των στατιστικών από τον μεταγωγέα και η εγκατάσταση κανόνων απόρριψης πραγματοποιούνται τοπικά με το εργαλείο onvs-ofctl.

Η αρχιτεκτονική αυτή διαφέρει από μια πλήρη αντιδραστική υλοποίηση OpenFlow. Σε μια τέτοια υλοποίηση, ο ελεγκτής επικοινωνεί με τον μεταγωγέα μέσω καναλιού OpenFlow. Όταν ένα πακέτο δεν αντιστοιχεί σε κατάλληλη καταχώρηση και ο μεταγωγέας έχει διαμορφωθεί ώστε να ζητά απόφαση από τον ελεγκτή, μπορεί να αποσταλεί μήνυμα Packet-In. Ο ελεγκτής μπορεί στη συνέχεια να εγκαταστήσει, να τροποποιήσει ή να διαγράψει καταχωρήσεις ροής μέσω μηνυμάτων Flow-Mod [12]. Οι μηχανισμοί αυτοί παρουσιάστηκαν στην παράγραφο 2.3.

Στην κύρια υλοποίηση της Μεθόδου Α δεν διατηρείται αντίστοιχη μόνιμη συνεδρία OpenFlow μεταξύ της εφαρμογής ελέγχου και του Open vSwitch. Για τον λόγο αυτό, η εφαρμογή δεν λειτουργεί ως πλήρης αντιδραστικός ελεγκτής OpenFlow. Η απόφαση ασφαλείας λαμβάνεται κεντρικά και, όταν απαιτείται, εφαρμόζεται στον Open vSwitch μέσω της τοπικής διαχείρισης των καταχωρήσεων ροής. Παράλληλα με την κύρια υλοποίηση, αναπτύχθηκε και εναλλακτική διαδρομή μέσω πλήρους ελεγκτή OpenFlow, η οποία παρουσιάζεται αργότερα στο πλαίσιο της Μεθόδου Α.

Στο δεύτερο προφίλ της Μεθόδου A, το οποίο χρησιμοποιείται για τα πειράματα συνθετικής τηλεμετρίας, η ανταλλαγή δεδομένων μεταξύ των στοιχείων της εφαρμογής πραγματοποιείται μέσω διεπαφής REST. Η διεπαφή αυτή αποτελεί μέρος της εφαρμογής και δεν είναι μηχανισμός του πρωτοκόλλου OpenFlow. Χρησιμοποιείται για τη μεταφορά των συνθετικών μετρήσεων προς την εφαρμογή ελέγχου και για τη δοκιμή της λογικής ανίχνευσης και αντιμετώπισης χωρίς παραγωγή πραγματικής δικτυακής κίνησης.

Ο όρος «υβριδική» χρησιμοποιείται επομένως στην παρούσα εργασία επειδή η βασική προώθηση της κίνησης πραγματοποιείται αυτόνομα από τον μεταγωγέα, ενώ η ανάλυση της τηλεμετρίας και η απόφαση ασφαλείας πραγματοποιούνται χωριστά από την κεντρική εφαρμογή. Η εφαρμογή μπορεί στη συνέχεια να μεταβάλει τη συμπεριφορά του επιπέδου δεδομένων εγκαθιστώντας κανόνες απόρριψης, χωρίς όμως η κύρια διαδρομή να βασίζεται σε πλήρη αντιδραστική επικοινωνία OpenFlow μεταξύ ελεγκτή και μεταγωγέα.

5.1.2 Αιτιολόγηση της σχεδιαστικής επιλογής

Η επιλογή της υβριδικής αρχιτεκτονικής βασίστηκε τόσο σε αρχιτεκτονικούς όσο και σε πρακτικούς λόγους. Σε μια πλήρως αντιδραστική διαμόρφωση SDN, νέες ροές μπορούν να απαιτούν επεξεργασία από τον ελεγκτή πριν εγκατασταθούν οι αντίστοιχοι κανόνες στον μεταγωγέα. Μεγάλος αριθμός τέτοιων αιτημάτων μπορεί να αυξήσει τον φόρτο του επιπέδου ελέγχου και να επηρεάσει τη λειτουργία του συστήματος [4], [5]. Στην παρούσα υλοποίηση η βασική προώθηση της κίνησης πραγματοποιείται αυτόνομα από τον Open vSwitch, όπως περιγράφηκε στην παράγραφο 5.1.1, ενώ η εφαρμογή ασφαλείας λειτουργεί χωριστά και παρεμβαίνει μόνο όταν απαιτείται η εφαρμογή κανόνα αντιμετώπισης.

Κατά τον αρχικό σχεδιασμό εξετάστηκε η χρήση του Ryu, ο οποίος παρουσιάστηκε στην παράγραφο 2.4, ως πλήρους ελεγκτή OpenFlow. Κατά την ανάπτυξη, όμως, παρουσιάστηκαν προβλήματα συμβατότητας μεταξύ του Ryu, της έκδοσης της Python και των βιβλιοθηκών του περιβάλλοντος εκτέλεσης. Η αντιμετώπισή τους απαιτούσε τροποποιήσεις στο περιβάλλον εκτέλεσης ή εξάρτηση από παλαιότερες εκδόσεις λογισμικού. Οι τροποποιήσεις αυτές υλοποιήθηκαν τελικά για τη συμπληρωματική διαδρομή, δεν επιλέχθηκαν όμως ως βάση της κύριας υλοποίησης, ώστε το πειραματικό περιβάλλον να παραμείνει σταθερό και αναπαραγώγιμο. Η παρατήρηση αυτή αφορά το συγκεκριμένο περιβάλλον της παρούσας εργασίας και δεν σημαίνει ότι ο Ryu παρουσιάζει γενικά αδυναμία λειτουργίας ως ελεγκτής OpenFlow [2].

Η κύρια υλοποίηση, επομένως, δεν αποτελεί πλήρη αντιδραστικό έλεγχο OpenFlow. Όπως διευκρινίστηκε στην παράγραφο 5.1.1, η κύρια διαδρομή δεν διατηρεί μόνιμη συνεδρία OpenFlow μεταξύ της εφαρμογής και του μεταγωγέα. Η κεντρική εφαρμογή αναλύει την τηλεμετρία και αποφασίζει για την αντιμετώπιση, ενώ η μεταβολή των καταχωρήσεων του Open vSwitch πραγματοποιείται τοπικά. Η διάκριση αυτή αποτελεί περιορισμό της πειραματικής αρχιτεκτονικής και οριοθετεί το είδος των συμπερασμάτων που μπορούν να εξαχθούν από την κύρια υλοποίηση.

Ως συμπληρωματική διαδρομή της Μεθόδου Α αναπτύχθηκε επίσης υλοποίηση με πλήρη ελεγκτή OpenFlow, ώστε να εξεταστεί η δυνατότητα μετάβασης σε αρχιτεκτονική όπου η συλλογή της τηλεμετρίας και η εγκατάσταση των κανόνων πραγματοποιούνται απευθείας μέσω του καναλιού OpenFlow [12]. Η διαδρομή αυτή παρουσιάζεται στην παράγραφο 5.2.3 και δεν αποτελεί την κύρια πειραματική διαμόρφωση της παρούσας εργασίας.

5.1.3 Συνολική ροή και πειραματικά προφίλ

Η Μέθοδος Α ακολουθεί την ίδια βασική λογική ανίχνευσης και αντιμετώπισης και στα δύο πειραματικά προφίλ. Αρχικά παράγονται ή συλλέγονται μετρήσεις που περιγράφουν τη δικτυακή δραστηριότητα. Οι μετρήσεις μεταφέρονται στην εφαρμογή ελέγχου sdn_controller, όπου σχηματίζονται τα συγκεντρωτικά χαρακτηριστικά που χρησιμοποιεί το ζωντανό μοντέλο Isolation Forest. Με βάση τα χαρακτηριστικά αυτά, το μοντέλο αξιολογεί αν η παρατηρούμενη συμπεριφορά αποκλίνει από τη φυσιολογική και η εφαρμογή αποφασίζει αν απαιτείται μέτρο αντιμετώπισης. Η κατάσταση των κόμβων και οι βασικές μετρήσεις της εκτέλεσης παρουσιάζονται στον πίνακα εποπτείας (sdn_dashboard). Η διαδικασία συλλογής της τηλεμετρίας και η λειτουργία της ανίχνευσης και αντιμετώπισης παρουσιάζονται αναλυτικά στις παραγράφους 5.2.1 και 5.2.2.

Το πρώτο πειραματικό προφίλ χρησιμοποιεί το στοιχείο sdn_switch και λειτουργεί σε επίπεδο εφαρμογής. Στην παρούσα υλοποίηση, διεργασίες Python ανταλλάσσουν αυτοδύναμα πακέτα UDP (UDP datagrams), ενώ οι μετρήσεις που χρησιμοποιούνται για τη δοκιμή του συστήματος παράγονται συνθετικά. Στο προφίλ αυτό δεν χρησιμοποιείται Open vSwitch ούτε δημιουργείται εξομοιωμένη δικτυακή τοπολογία. Σκοπός του είναι η ελεγχόμενη δοκιμή της τηλεμετρίας, της λογικής ανίχνευσης και της απόφασης αντιμετώπισης.

Το δεύτερο πειραματικό προφίλ χρησιμοποιεί το sdn_mininet και λειτουργεί σε επίπεδο πακέτων. Το Mininet δημιουργεί την εξομοιωμένη δικτυακή τοπολογία, ενώ ο Open

vSwitch λειτουργεί ως λογισμικός μεταγωγέας μέσα σε αυτή [13], [14]. Οι εικονικοί κόμβοι εκτελούνται σε απομονωμένους χώρους ονομάτων του Linux (Linux namespaces), γεγονός που επιτρέπει την παραγωγή πραγματικής δικτυακής κίνησης μέσα στο εξομοιωμένο περιβάλλον [14]. Στην παρούσα υλοποίηση, η τηλεμετρία δεν συλλέγεται με σύλληψη και εξέταση των πακέτων. Αντίθετα, πραγματοποιείται περιοδική ανάγνωση των στατιστικών του πίνακα ροών του Open vSwitch μέσω της εντολής `ovs-ofctl dump-flows`. Από τα στατιστικά αυτά προκύπτουν οι μετρήσεις που χρησιμοποιούνται από την εφαρμογή ελέγχου.

Όπως συνοψίζεται στον Πίνακα 5-1, τα στοιχεία `sdn_controller` και `sdn_dashboard` χρησιμοποιούνται και στα δύο πειραματικά προφίλ. Το πρώτο αναλαμβάνει την επεξεργασία της τηλεμετρίας, την εκτέλεση του Isolation Forest και τη διαχείριση της απόφασης αντιμετώπισης, ενώ το δεύτερο χρησιμοποιείται για την εποπτεία της κατάστασης των κόμβων και των βασικών μετρήσεων της ζωντανής λειτουργίας. Αυτό συμφωνεί με τον ρόλο που ήδη αποδίδεται στα δύο κοινά στοιχεία στον Πίνακα 5-1.

Η βασική διαφορά μεταξύ των δύο προφίλ βρίσκεται στην προέλευση της τηλεμετρίας και στο επίπεδο στο οποίο πραγματοποιείται το πείραμα. Στο `sdn_switch` οι μετρήσεις παράγονται συνθετικά σε επίπεδο εφαρμογής. Στο `sdn_mininet` οι μετρήσεις προκύπτουν από τα στατιστικά πραγματικών δικτυακών ροών που δημιουργούνται μέσα στην εξομοιωμένη τοπολογία. Και στις δύο περιπτώσεις, η μεταφορά της τηλεμετρίας προς την εφαρμογή ελέγχου πραγματοποιείται μέσω της ίδιας διεπαφής REST, ενώ διαφέρει η προέλευση των μετρήσεων. Με αυτόν τον τρόπο, η ίδια βασική λογική ανίχνευσης και απόφασης εξετάζεται υπό δύο διαφορετικές συνθήκες.

Τα στοιχεία `sdn_switch` και `sdn_mininet` δεν αποτελούν δύο διαδοχικά επίπεδα του ίδιου πειράματος. Αντιστοιχούν σε δύο διαφορετικά προφίλ αξιολόγησης της Μεθόδου Α: το πρώτο σε επίπεδο εφαρμογής και το δεύτερο σε επίπεδο πακέτων.

5.2 Μέθοδος Α: ζωντανή ανίχνευση και αντιμετώπιση

Η Μέθοδος Α αφορά τη λειτουργία του συστήματος κατά τη διάρκεια της εκτέλεσης, από τη συλλογή της τηλεμετρίας έως τη λήψη και την εφαρμογή της απόφασης αντιμετώπισης. Η ίδια βασική λογική χρησιμοποιείται στα δύο πειραματικά προφίλ που παρουσιάστηκαν στην παράγραφο 5.1.3, με διαφορετικό τρόπο παραγωγής των μετρήσεων σε κάθε περίπτωση.

Μία διευκρίνιση είναι απαραίτητη από την αρχή. Στη ζωντανή λειτουργία, η εφαρμογή ελέγχου συγκεντρώνει τις μετρήσεις ανά διεύθυνση IP προέλευσης και σχηματίζει οκτώ συγκεντρωτικά χαρακτηριστικά, τα οποία αποτελούν την είσοδο του ζωντανού μοντέλου Isolation Forest. Η θεωρητική λειτουργία του Isolation Forest παρουσιάστηκε στην παράγραφο 4.3. Το σύνολο αυτό είναι διαφορετικό από τα 24 χαρακτηριστικά δικτυακής ροής που παρουσιάστηκαν στην παράγραφο 4.5 και χρησιμοποιούνται στη Μέθοδο B για την ανάλυση εκτός σύνδεσης. Το ζωντανό μοντέλο αποτελεί επομένως ξεχωριστή διαμόρφωση του συστήματος και δεν χρησιμοποιεί τα ίδια δεδομένα εισόδου με τα μοντέλα της Μεθόδου B.

Η παρουσίαση της Μεθόδου A οργανώνεται σε τρία διαδοχικά μέρη. Αρχικά περιγράφονται η τοπολογία, ο τρόπος παραγωγής της κίνησης και η συλλογή της τηλεμετρίας. Στη συνέχεια παρουσιάζονται η μετατροπή των μετρήσεων σε χαρακτηριστικά, η ανίχνευση με το Isolation Forest, η λήψη της απόφασης και η εφαρμογή του μέτρου αντιμετώπισης. Τέλος, εξετάζονται η λειτουργία της εφαρμογής ελέγχου, η ασφάλεια της υλοποίησης και τα στοιχεία που επιτρέπουν την επανάληψη των πειραμάτων υπό τις ίδιες συνθήκες.

5.2.1 Τοπολογία, παραγωγή κίνησης και συλλογή τηλεμετρίας

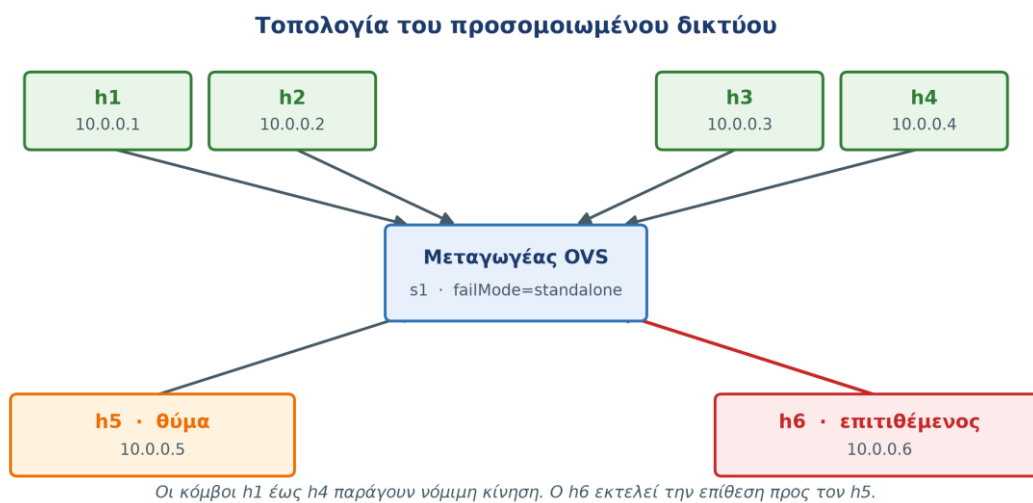
Η περιγραφή που ακολουθεί αφορά κυρίως το προφίλ σε επίπεδο πακέτων, στο οποίο δημιουργείται εξομοιωμένη δικτυακή τοπολογία. Στο προφίλ σε επίπεδο εφαρμογής δεν κατασκευάζεται αντίστοιχη τοπολογία και οι μετρήσεις παράγονται συνθετικά, όπως παρουσιάστηκε στην παράγραφο 5.1.3.

Στο προφίλ σε επίπεδο πακέτων η τοπολογία δημιουργείται με το Mininet και αποτελείται από έναν μεταγωγέα Open vSwitch και έξι εικονικούς κόμβους. Οι κόμβοι h1 έως h4 χρησιμοποιούνται για την παραγωγή νόμιμης κίνησης, ο h5 λειτουργεί ως κόμβος-θύμα και ο h6 ως πηγή της κακόβουλης κίνησης. Το Mininet επιτρέπει τη δημιουργία εικονικών κόμβων, μεταγωγέων και συνδέσεων στον ίδιο φυσικό υπολογιστή, με χρήση απομονωμένων χώρων ονομάτων του Linux [14], ενώ ο Open vSwitch χρησιμοποιείται ως λογισμικός μεταγωγέας της τοπολογίας [13].

Στην παρούσα υλοποίηση ο Open vSwitch λειτουργεί σε κατάσταση αυτόνομης προώθησης, όπως εξηγήθηκε στην παράγραφο 5.1.1, και χρησιμοποιεί διαδρομή δεδομένων σε χώρο χρήστη (userspace datapath). Η επιλογή αυτή ήταν απαραίτητη στο περιβάλλον WSL2 της πειραματικής διάταξης, όπου δεν ήταν διαθέσιμο το αντίστοιχο άρθρωμα πυρήνα του Open vSwitch. Η διαμόρφωση αυτή επιτρέπει την εκτέλεση του πειράματος στο συγκεκριμένο

περιβάλλον, αλλά δεν αναπαράγει πλήρως τις συνθήκες ενός φυσικού μεταγωγέα ή μιας υλοποίησης που χρησιμοποιεί διαδρομή δεδομένων στον πυρήνα. Επομένως, οι παρατηρήσεις που σχετίζονται με τη χρονική συμπεριφορά και την απόδοση της υλοποίησης ερμηνεύονται μέσα στα όρια του συγκεκριμένου εξομοιωμένου περιβάλλοντος [13].

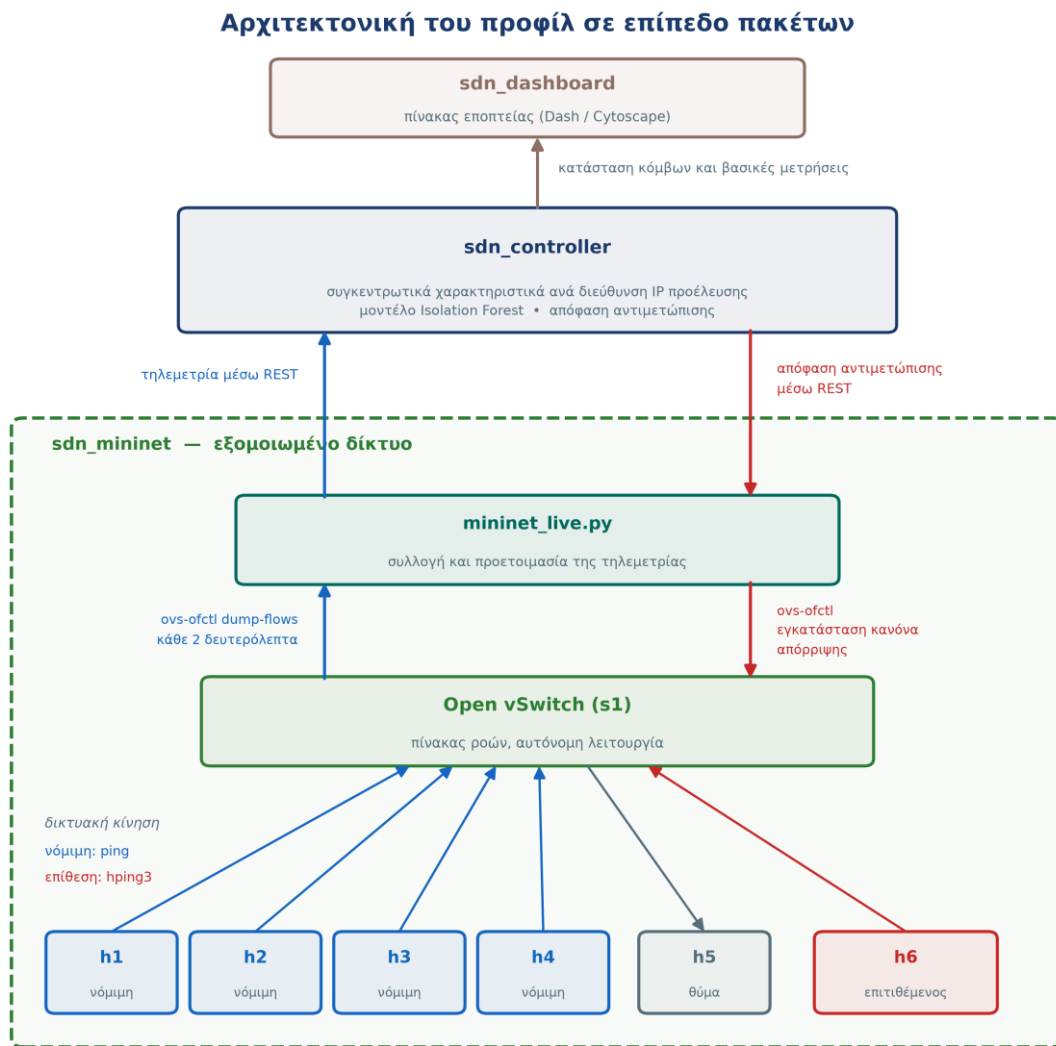
Στο Σχήμα 5-1 παρουσιάζεται η τοπολογία του πειράματος και ο ρόλος των έξι κόμβων. Οι h1 έως h4 δημιουργούν τη νόμιμη δραστηριότητα, ο h5 αποτελεί τον προορισμό της κίνησης και ο h6 χρησιμοποιείται για την παραγωγή της κακόβουλης δραστηριότητας. Η διάκριση αυτή επιτρέπει να είναι γνωστή εκ των προτέρων η προέλευση της νόμιμης και της κακόβουλης κίνησης κατά την εκτέλεση του πειράματος.



Σχήμα 5-1: Τοπολογία του προφίλ της Μεθόδου Α σε επίπεδο πακέτων με έξι εικονικούς κόμβους και έναν μεταγωγέα Open vSwitch.

Η συνολική αρχιτεκτονική του προφίλ σε επίπεδο πακέτων παρουσιάζεται στο Σχήμα 5-2. Η δικτυακή κίνηση διέρχεται από τον Open vSwitch, ενώ το mininet_live.py αναλαμβάνει τη συλλογή και την προετοιμασία της τηλεμετρίας διαβάζοντας περιοδικά τα στατιστικά του πίνακα ροών. Οι μετρήσεις αποστέλλονται μέσω της διεπαφής REST στην εφαρμογή ελέγχου sdn_controller, όπου σχηματίζονται τα συγκεντρωτικά χαρακτηριστικά ανά διεύθυνση IP προέλευσης και εκτελείται το μοντέλο Isolation Forest. Όταν απαιτείται αντιμετώπιση, η απόφαση επιστρέφει μέσω REST στο mininet_live.py, το οποίο εφαρμόζει τοπικά τον αντίστοιχο κανόνα απόρριψης στον Open vSwitch. Παράλληλα, ο sdn_dashboard ενημερώνεται με την κατάσταση των κόμβων και τις βασικές μετρήσεις της

εκτέλεσης.



Σχήμα 5-2: Αρχιτεκτονική του προφίλ της Μεθόδου Α σε επίπεδο πακέτων και ροή της τηλεμετρίας και της απόφασης αντιμετώπισης.

Για την παραγωγή της νόμιμης κίνησης, οι κόμβοι h1 έως h4 αποστέλλουν προς τον κόμβο-θύμα h5 είκοσι πακέτα ανά κόμβο με την εντολή ping. Ο αριθμός αυτός επιλέχθηκε ώστε η νόμιμη δραστηριότητα να υπερβαίνει σαφώς το όριο κάτω από το οποίο οι πολύ μικρές ροές δεν προωθούνται προς αξιολόγηση και να μην αποτελεί τετριμμένη περίπτωση ελέγχου. Η κακόβουλη κίνηση της πλημμύρας SYN παράγεται από τον h6 με το εργαλείο hping3. Με τον τρόπο αυτό, τόσο η νόμιμη όσο και η κακόβουλη κίνηση διέρχονται από τον ίδιο μεταγωγέα και οι αντίστοιχες μετρήσεις προκύπτουν από την ίδια δικτυακή υποδομή.

Η συλλογή της τηλεμετρίας στο προφίλ σε επίπεδο πακέτων πραγματοποιείται από νήμα παρασκηνίου, το οποίο διαβάζει τον πίνακα ροών του Open vSwitch κάθε δύο δευτερόλεπτα

μέσω της εντολής `ons-ofctl dump-flows`. Από κάθε καταχώρηση ανακτώνται η διεύθυνση προέλευσης, η διεύθυνση προορισμού, το πλήθος των πακέτων, το πλήθος των bytes και η διάρκεια της ροής.

Η περίοδος δειγματοληψίας των δύο δευτερολέπτων επιλέχθηκε ως συμβιβασμός μεταξύ της έγκαιρης αποτύπωσης των μεταβολών της κίνησης και της ανάγκης να συγκεντρώνεται επαρκής δραστηριότητα μέσα σε κάθε χρονικό παράθυρο. Μικρότερο διάστημα θα παρείχε συχνότερες μετρήσεις, αλλά θα μπορούσε να δημιουργεί παράθυρα με πολύ μικρό αριθμό πακέτων και μεγαλύτερη μεταβλητότητα στα υπολογιζόμενα χαρακτηριστικά. Αντίθετα, μεγαλύτερο διάστημα θα συγκέντρωνε περισσότερα δεδομένα ανά μέτρηση, αλλά θα αύξανε τον χρόνο μέχρι να αποτυπωθεί μια σημαντική μεταβολή της δικτυακής συμπεριφοράς. Η τιμή των δύο δευτερολέπτων αφορά το προφίλ σε επίπεδο πακέτων. Στο προφίλ σε επίπεδο εφαρμογής η παραγωγή και αποστολή της συνθετικής τηλεμετρίας πραγματοποιείται ανά τρία δευτερόλεπτα.

Οι μετρητές των καταχωρήσεων ροής είναι σωρευτικοί [12]. Για τον λόγο αυτό, στην παρούσα υλοποίηση δεν χρησιμοποιούνται αυτούσιες οι τιμές τους. Διατηρείται η προηγούμενη μέτρηση και υπολογίζεται η διαφορά ως προς την επόμενη. Έτσι, οι τιμές που χρησιμοποιούνται από το σύστημα περιγράφουν τη δραστηριότητα που εμφανίστηκε μέσα στο συγκεκριμένο χρονικό παράθυρο και όχι το σύνολο της δραστηριότητας από τη δημιουργία της καταχώρησης.

Στη διάρκεια που αποστέλλεται ως χαρακτηριστικό εφαρμόζεται άνω φράγμα εξήντα δευτερολέπτων. Το φράγμα είναι απαραίτητο επειδή ο πίνακας ροών αναφέρει τη σωρευτική διάρκεια ζωής κάθε ροής, η οποία αυξάνεται συνεχώς όσο η καταχώρηση παραμένει ενεργή. Αν χρησιμοποιούνταν η τιμή αυτή χωρίς περιορισμό, το χαρακτηριστικό θα εξαρτιόταν όλο και περισσότερο από τη χρονική στιγμή της μέτρησης και όχι από τη συμπεριφορά της ίδιας της ροής. Με την εφαρμογή του άνω φράγματος, οι μακρόβιες ροές δεν αποκτούν συνεχώς αυξανόμενη τιμή διάρκειας. Η τιμή των εξήντα δευτερολέπτων επιλέχθηκε ώστε να συμπίπτει με το άνω άκρο του εύρους διαρκειών που χρησιμοποιείται κατά την εκπαίδευση του ζωντανού μοντέλου, το οποίο εκτείνεται από 0,5 έως 60 δευτερόλεπτα. Με τον τρόπο αυτό διατηρείται αντιστοιχία μεταξύ των τιμών που χρησιμοποιούνται κατά την εκπαίδευση και εκείνων που μπορούν να εμφανιστούν κατά τη ζωντανή λειτουργία.

Η αρχική ομαδοποίηση των μετρήσεων πραγματοποιείται ανά ζεύγος διευθύνσεων προέλευσης και προορισμού. Στη συνέχεια οι επιμέρους μετρήσεις συγκεντρώνονται ανά διεύθυνση IP προέλευσης, καθώς η πηγή αποτελεί τη μονάδα πάνω στην οποία λαμβάνεται

η απόφαση του ζωντανού συστήματος. Πριν αποσταλεί μια εγγραφή στο μοντέλο εφαρμόζονται δύο φίλτρα. Αρχικά, η κίνηση απάντησης που προέρχεται από τον κόμβο-θύμα h5 αγνοείται, ώστε οι απαντήσεις του θύματος να μην ερμηνεύονται λανθασμένα ως ανεξάρτητη ύποπτη δραστηριότητα. Επιπλέον, παραλείπονται οι πηγές που εμφανίζουν λιγότερα από τέσσερα πακέτα μέσα στο παράθυρο δειγματοληψίας, ώστε να μη λαμβάνονται αποφάσεις με βάση πολύ μικρό αριθμό παρατηρήσεων.

Η κύρια διαδρομή συλλογής χρησιμοποιεί τα στατιστικά των επιμέρους καταχωρήσεων του πίνακα ροών. Υπάρχει όμως και εφεδρική διαδρομή για τις περιπτώσεις στις οποίες δεν έχουν ακόμη δημιουργηθεί οι απαιτούμενες καταχωρήσεις ανά ροή. Στην περίπτωση αυτή χρησιμοποιούνται οι διαφορές των μετρητών ανά θύρα του μεταγωγέα. Κάθε πηγή περιγράφεται τότε από μία συγκεντρωτική ροή και ως διάρκεια χρησιμοποιείται η διάρκεια του παραθύρου δειγματοληψίας. Η ύπαρξη των δύο διαδρομών συλλογής εξηγεί γιατί το πλήθος των ροών που αντιστοιχούν σε μία πηγή μπορεί να διαφέρει ανάλογα με τα διαθέσιμα στοιχεία του μεταγωγέα.

Κάθε εκτέλεση ακολουθεί προκαθορισμένη διαδοχή σταδίων. Αρχικά η εφαρμογή ελέγχου επαναφέρεται σε καθαρή κατάσταση και δημιουργείται η τοπολογία. Στη συνέχεια ξεκινά η φάση της νόμιμης κίνησης, ώστε να συλλεχθούν μετρήσεις της φυσιολογικής λειτουργίας του δικτύου. Ακολουθεί η φάση της κακόβουλης κίνησης, κατά την οποία συνεχίζεται η συλλογή της τηλεμετρίας και ενεργοποιείται η διαδικασία ανίχνευσης και αντιμετώπισης. Μετά την ολοκλήρωση της επίθεσης ακολουθεί η φάση ανάκαμψης, κατά την οποία παρακολουθείται η κατάσταση του συστήματος καθώς η κίνηση επιστρέφει στη φυσιολογική λειτουργία. Η ίδια σειρά σταδίων χρησιμοποιείται στις επαναλαμβανόμενες εκτελέσεις, ώστε τα πειράματα να ξεκινούν από συγκρίσιμη αρχική κατάσταση.

5.2.2 Ανίχνευση, απόφαση και εφαρμογή μέτρων αντιμετώπισης

Μετά τη συλλογή και την προετοιμασία της τηλεμετρίας που περιγράφηκαν στην παράγραφο 5.2.1, οι διαθέσιμες μετρήσεις συγκεντρώνονται ανά διεύθυνση IP προέλευσης και μετατρέπονται στο διάνυσμα εισόδου του ζωντανού μοντέλου. Η διεύθυνση IP χρησιμοποιείται ως μονάδα ομαδοποίησης και εφαρμογής της απόφασης, αλλά δεν αποτελεί η ίδια αριθμητικό χαρακτηριστικό του μοντέλου. Η αξιολόγηση βασίζεται αποκλειστικά στη συμπεριφορά της κίνησης που έχει καταγραφεί για κάθε πηγή μέσα στο αντίστοιχο χρονικό παράθυρο.

Το ζωντανό σύστημα χρησιμοποιεί διαφορετική διαμόρφωση Isolation Forest από εκείνη που χρησιμοποιείται στη Μέθοδο Β για την ανάλυση εκτός σύνδεσης. Η συγκεκριμένη διαμόρφωση δέχεται οκτώ συγκεντρωτικά χαρακτηριστικά ανά πηγή και χρησιμοποιεί τις παραμέτρους που παρουσιάζονται στον Πίνακα 5-2. Η διάκριση αυτή είναι απαραίτητη, καθώς πρόκειται για διαφορετικό εκπαιδευμένο μοντέλο και διαφορετικό χώρο χαρακτηριστικών. Η ίδια διάκριση μεταξύ ζωντανού μοντέλου οκτώ χαρακτηριστικών και των διαμορφώσεων 24 χαρακτηριστικών καταγράφεται και στην υφιστάμενη αξιολόγηση της εργασίας.

Πίνακας 5-2: Διαμόρφωση του Isolation Forest που χρησιμοποιείται στο ζωντανό σύστημα.

Παράμετρος	Τιμή	Ρόλος
Χαρακτηριστικά εισόδου	8	Συγκεντρωτικά χαρακτηριστικά ανά διεύθυνση IP προέλευσης
n_estimators	300	Πλήθος δέντρων απομόνωσης του μοντέλου
max_samples	512	Μέγιστο πλήθος δειγμάτων που χρησιμοποιείται για την κατασκευή κάθε δέντρου
contamination	0,03	Παράμετρος που χρησιμοποιείται από την υλοποίηση για τον καθορισμό του ορίου μεταξύ φυσιολογικών και ακραίων παρατηρήσεων
max_features	0,75	Ποσοστό των διαθέσιμων χαρακτηριστικών που επιλέγεται κατά την κατασκευή των επιμέρους δέντρων

Η παράμετρος contamination δεν εκφράζει το πραγματικό ποσοστό επιθέσεων που αναμένεται να εμφανιστεί στο δίκτυο. Στην υλοποίηση του Isolation Forest χρησιμοποιείται για τον προσδιορισμό του ορίου που διαχωρίζει τις συνήθεις από τις ακραίες παρατηρήσεις [34]. Η τιμή 0,03 αποτελεί συντηρητική επιλογή της ζωντανής διαμόρφωσης. Αντίστοιχα, η χρήση 300 δέντρων επιλέχθηκε ώστε η βαθμολογία του μοντέλου να είναι σταθερότερη, ενώ η τιμή max_features = 0,75 σημαίνει ότι κάθε δέντρο χρησιμοποιεί έξι από τα οκτώ διαθέσιμα χαρακτηριστικά. Η θεωρητική λειτουργία του Isolation Forest έχει παρουσιαστεί στην παράγραφο 4.3 [23], [34].

Τα οκτώ χαρακτηριστικά που σχηματίζουν το διάνυσμα εισόδου παρουσιάζονται στον Πίνακα 5-3. Η σειρά τους παραμένει σταθερή τόσο κατά την εκπαίδευση όσο και κατά τη ζωντανή λειτουργία του μοντέλου.

Πίνακας 5-3: Συγκεντρωτικά χαρακτηριστικά εισόδου του ζωντανού μοντέλου Isolation Forest.

Χαρακτηριστικό	Περιγραφή
flow_count	Πλήθος ενεργών ροών που αντιστοιχούν στην πηγή μέσα στο παράθυρο δειγματοληψίας
total_packets	Συνολικό πλήθος πακέτων της πηγής μέσα στο ίδιο παράθυρο
total_bytes	Συνολικός όγκος δεδομένων της πηγής σε bytes
avg_packets_per_flow	Μέσο πλήθος πακέτων ανά ροή
avg_bytes_per_flow	Μέσο πλήθος bytes ανά ροή
avg_duration	Μέση διάρκεια των ροών
avg_pkt_size	Μέσο μέγεθος πακέτου, ως λόγος συνολικών bytes προς συνολικά πακέτα
short_flow_ratio	Αναλογία των ροών που περιλαμβάνουν τρία πακέτα ή λιγότερα

Τα χαρακτηριστικά αυτά μπορούν να προκύψουν από τα στατιστικά που είναι διαθέσιμα κατά τη ζωντανή λειτουργία του συστήματος. Η επιλογή οκτώ αντί των 24 χαρακτηριστικών της Μεθόδου Β δεν αποτελεί απλώς επιλογή περιορισμού της πολυπλοκότητας. Προκύπτει από τη διαφορετική πηγή των δεδομένων. Ο ζωντανός ελεγκτής λαμβάνει συγκεντρωτικά στατιστικά από τον πίνακα ροών του Open vSwitch και επομένως δεν διαθέτει όλες τις πληροφορίες που μπορεί να παράγει το CICFlowMeter από αναλυτικότερη επεξεργασία της δικτυακής κίνησης. Για παράδειγμα, δεν είναι δυνατό να εξαχθούν με τον ίδιο τρόπο οι χρόνοι μεταξύ διαδοχικών αφίξεων ανά κατεύθυνση ή όλα τα επιμέρους γνωρίσματα των TCP πακέτων. Για τον λόγο αυτό χρησιμοποιείται μικρότερο σύνολο χαρακτηριστικών, προσαρμοσμένο στις μετρήσεις που είναι πραγματικά διαθέσιμες κατά τη ζωντανή λειτουργία.

Ιδιαίτερη σημασία έχει το χαρακτηριστικό `short_flow_ratio`, το οποίο εκφράζει την αναλογία των ροών που περιλαμβάνουν έως και τρία πακέτα. Η τιμή αυτή επιτρέπει στο σύστημα να εντοπίζει συμπεριφορές στις οποίες μία πηγή δημιουργεί μεγάλο αριθμό πολύ σύντομων ροών. Η χρήση αυτού του ορίου συνδέεται και με τη διαμόρφωση της νόμιμης κίνησης που παρουσιάστηκε στην παράγραφο 5.2.1, όπου οι νόμιμοι κόμβοι παράγουν σαφώς περισσότερα από τρία πακέτα ανά ροή.

Πριν δοθεί το διάνυσμα των οκτώ χαρακτηριστικών στο Isolation Forest, εφαρμόζεται ο ίδιος μετασχηματιστής τυποποίησης που χρησιμοποιήθηκε κατά την εκπαίδευση. Οι παράμετροι του μετασχηματισμού δεν υπολογίζονται εκ νέου κατά τη ζωντανή λειτουργία. Με τον τρόπο αυτό οι τιμές που λαμβάνει το μοντέλο βρίσκονται στην ίδια αριθμητική κλίμακα με εκείνη στην οποία είχε εκπαιδευτεί και διατηρείται σταθερή η σειρά των χαρακτηριστικών.

Για κάθε νέα παρατήρηση, το τυποποιημένο διάνυσμα εισάγεται στο Isolation Forest και παράγεται η αντίστοιχη βαθμολογία ανωμαλίας. Με βάση το όριο απόφασης της συγκεκριμένης διαμόρφωσης, η παρατήρηση χαρακτηρίζεται ως φυσιολογική ή ως ακραία. Αν η πηγή χαρακτηριστεί ως φυσιολογική, δεν εφαρμόζεται ενέργεια αντιμετώπισης και αξιολογείται ξανά όταν καταστεί διαθέσιμο το επόμενο παράθυρο τηλεμετρίας. Αν χαρακτηριστεί ως ανώμαλη, η διεύθυνση IP προέλευσης προωθείται στο στάδιο αντιμετώπισης.

Η υλοποίηση προβλέπει επίσης δύο διαδοχικά εφεδρικά επίπεδα ώστε η διαδικασία απόφασης να μη διακόπτεται πλήρως σε περίπτωση που το κύριο μοντέλο δεν είναι διαθέσιμο. Αν το Isolation Forest δεν μπορεί να χρησιμοποιηθεί ή προκύψει σφάλμα κατά την αξιολόγηση, επιχειρείται η χρήση διαθέσιμου επιβλεπόμενου μοντέλου. Αν δεν είναι διαθέσιμη ούτε αυτή η διαδρομή, εφαρμόζεται ένας απλός κανόνας ασφαλείας: μια πηγή θεωρείται ύποπτη όταν δημιουργεί περισσότερες από είκοσι ροές μέσα στο ίδιο παράθυρο και περισσότερο από το 60% αυτών είναι σύντομες ροές. Ο μηχανισμός αυτός αποτελεί εφεδρική λειτουργία και όχι την κύρια μέθοδο ανίχνευσης της Μεθόδου Α.

Η διαδοχή συλλογής, ανίχνευσης και αντιμετώπισης δημιουργεί έναν κλειστό βρόχο λειτουργίας, όπως παρουσιάζεται στο Σχήμα 5-3. Η κατάσταση του δικτύου παράγει νέα τηλεμετρία, η οποία μετατρέπεται σε χαρακτηριστικά και αξιολογείται από τη μηχανή ανίχνευσης. Όταν απαιτείται αντιμετώπιση, η εφαρμοζόμενη ενέργεια μεταβάλλει την κατάσταση του επιπέδου δεδομένων και η μεταβολή αυτή αποτυπώνεται στις επόμενες μετρήσεις.

Ο κλειστός βρόχος εποπτείας, απόφασης και δράσης



Σχήμα 5-3: Κλειστός βρόχος εποπτείας, απόφασης και εφαρμογής μέτρων αντιμετώπισης στη Μέθοδο Α.

Όταν η απόφαση απαιτεί αποκλεισμό της πηγής, η αντίστοιχη διεύθυνση IP καταχωρίζεται στην κατάσταση του ελεγκτή μαζί με την ενέργεια αντιμετώπισης και τον χρόνο ισχύος της. Στο προφίλ σε επίπεδο πακέτων, η απόφαση αποστέλλεται μέσω REST στο mininet_live.py, όπως παρουσιάστηκε στο Σχήμα 5-2. Στη συνέχεια εγκαθίσταται τοπικά στον Open vSwitch, μέσω του `ovs-ofctl`, κανόνας απόρριψης υψηλότερης προτεραιότητας που αντιστοιχεί στη διεύθυνση IP προέλευσης. Η υψηλότερη προτεραιότητα εξασφαλίζει ότι ο συγκεκριμένος κανόνας υπερισχύει των κανόνων κανονικής προώθησης που θα μπορούσαν επίσης να ταιριάξουν στην ίδια κίνηση [12], [13].

Ο αποκλεισμός δεν είναι μόνιμος. Ο κανόνας απόρριψης συνοδεύεται από πεπερασμένο χρόνο ζωής, μέσω `hard_timeout`, ο οποίος συγχρονίζεται με τον χρόνο διατήρησης της απόφασης από την εφαρμογή ελέγχου. Όσο η κακόβουλη δραστηριότητα συνεχίζεται, ο χρόνος ισχύος ανανεώνεται ώστε η αντιμετώπιση να παραμένει ενεργή. Όταν η δραστηριότητα παύσει, ο τελευταίος κανόνας αφήνεται να λήξει και η πηγή επανέρχεται στην κανονική διαδικασία παρακολούθησης. Η χρήση πεπερασμένου χρόνου ζωής αποτρέπει τη διατήρηση ενός αποκλεισμού επ' αόριστον μετά την παύση της ύποπτης δραστηριότητας. Η υφιστάμενη υλοποίηση καταγράφει επίσης το `hard_timeout` ως συγχρονισμένο με τον χρόνο ζωής της απόφασης και την αυτόματη ανανέωση όσο η επίθεση συνεχίζεται.

Η πλήρης ακολουθία παρουσιάζεται στο Σχήμα 5-4. Τα στατιστικά των ροών μετατρέπονται στα οκτώ συγκεντρωτικά χαρακτηριστικά της πηγής και στη συνέχεια αξιολογούνται από το Isolation Forest. Αν η συμπεριφορά δεν χαρακτηριστεί ως ανώμαλη, δεν εφαρμόζεται κάποια ενέργεια και η διαδικασία επαναλαμβάνεται στο επόμενο παράθυρο. Αν προκύψει

ανωμαλία, δημιουργείται η απόφαση αντιμετώπισης και εγκαθίσταται τοπικά στον Open vSwitch ο αντίστοιχος κανόνας απόρριψης.



Σχήμα 5-4: Διαδοχικά στάδια από τη συλλογή των στατιστικών έως την τοπική εγκατάσταση του κανόνα απόρριψης στον Open vSwitch.

Στο προφίλ σε επίπεδο εφαρμογής διατηρείται η ίδια βασική λογική σχηματισμού χαρακτηριστικών και λήψης απόφασης. Η συνθετική τηλεμετρία αποστέλλεται στον ίδιο sdn_controller και αξιολογείται από το ζωντανό μοντέλο. Η διαφορά βρίσκεται στο επίπεδο εφαρμογής της ενέργειας: στο συγκεκριμένο προφίλ δεν υπάρχει Open vSwitch ούτε πραγματικός πίνακας ροών και ο αποκλεισμός εφαρμόζεται από το sdn_switch στο επίπεδο εφαρμογής. Αντίθετα, στο προφίλ σε επίπεδο πακέτων η αντιμετώπιση υλοποιείται μέσω πραγματικού κανόνα απόρριψης στον Open vSwitch.

Παράλληλα με την εφαρμογή της ενέργειας, ενημερώνεται η εσωτερική κατάσταση του sdn_controller και οι σχετικές πληροφορίες διατίθενται στον sdn_dashboard. Ο πίνακας εποπτείας παρουσιάζει την κατάσταση των κόμβων, τις ανιχνεύσεις και τους ενεργούς αποκλεισμούς, χωρίς να συμμετέχει ο ίδιος στη διαδικασία λήψης της απόφασης. Οι μηχανισμοί προστασίας της επικοινωνίας, διαχείρισης της κατάστασης και αναπαραγωγιμότητας της υλοποίησης παρουσιάζονται στην παράγραφο 5.2.3.

5.2.3 Λειτουργία του ελεγκτή, ασφάλεια και εποπτεία

Κεντρικό στοιχείο της Μεθόδου Α αποτελεί η εφαρμογή ελέγχου sdn_controller, η οποία συγκεντρώνει την τηλεμετρία (telemetry), διατηρεί την τρέχουσα κατάσταση του συστήματος, εκτελεί τη διαδικασία ανίχνευσης που περιγράφηκε στην παράγραφο 5.2.2 και διαχειρίζεται τις αποφάσεις αντιμετώπισης. Η επικοινωνία με τα υπόλοιπα στοιχεία της υλοποίησης πραγματοποιείται μέσω διεπαφής REST (REST interface), η οποία έχει αναπτυχθεί με το πλαίσιο Flask. Η ίδια διεπαφή χρησιμοποιείται και στα δύο προφίλ της

Μεθόδου A, παρότι η προέλευση της τηλεμετρίας διαφέρει μεταξύ του προφίλ σε επίπεδο εφαρμογής και του προφίλ σε επίπεδο πακέτων.

Η διεπαφή REST αποτελεί το κοινό σημείο ανταλλαγής πληροφοριών μεταξύ του ελεγκτή, των στοιχείων που παράγουν την τηλεμετρία και του πίνακα εποπτείας (dashboard). Τα κυριότερα σημεία πρόσβασης (endpoints) παρουσιάζονται στον Πίνακα 5-4. Στην παρούσα υλοποίηση, το POST /telemetry χρησιμοποιείται για την εισαγωγή των μετρήσεων στον ελεγκτή, ενώ τα GET /flow_table, GET /topology, GET /stats και GET /anomaly_scores παρέχουν διαφορετικές όψεις της τρέχουσας κατάστασης του συστήματος. Το POST /register χρησιμοποιείται για την εγγραφή ενός μεταγωγέα στις έμπιστες πηγές τηλεμετρίας, ενώ το POST /reset επιτρέπει την επαναφορά της κατάστασης πριν από την έναρξη νέου σεναρίου.

Πίνακας 5-4: Κυριότερα σημεία πρόσβασης REST της εφαρμογής ελέγχου.

Σημείο πρόσβασης	Λειτουργία
POST /register	Εγγραφή μεταγωγέα στις έμπιστες πηγές τηλεμετρίας
POST /telemetry	Λήψη της τηλεμετρίας από εξουσιοδοτημένη πηγή
GET /flow_table	Επιστροφή της τρέχουσας εικόνας των ροών
GET /topology	Επιστροφή της τοπολογίας προς τον πίνακα εποπτείας
GET /stats	Επιστροφή συγκεντρωτικών μετρικών λειτουργίας
GET /anomaly_scores	Επιστροφή των τιμών ανωμαλίας ανά πηγή
POST /reset	Επαναφορά της κατάστασης πριν από νέο σενάριο

Η αποθήκευση των δεδομένων για μεταγενέστερη ανάλυση δεν πραγματοποιείται μέσω ξεχωριστού σημείου πρόσβασης REST. Στο προφίλ σε επίπεδο πακέτων, το αρχείο data/live_mininet_flows.csv δημιουργείται απευθείας στο σύστημα αρχείων κατά την εκτέλεση της εφαρμογής.

Στην παρούσα υλοποίηση, η τηλεμετρία που φτάνει στον ελεγκτή επηρεάζει άμεσα τη διαδικασία ανίχνευσης και την πιθανή εφαρμογή μέτρων αντιμετώπισης. Για τον λόγο αυτό, η διεπαφή δεν αντιμετωπίζεται ως απλό κανάλι μεταφοράς δεδομένων. Οι μηχανισμοί περιορισμού και ελέγχου της πρόσβασης που έχουν ενσωματωθεί στην εφαρμογή ελέγχου συνοψίζονται στον Πίνακα 5-5.

Πίνακας 5-5: Μηχανισμοί προστασίας της εφαρμογής ελέγχου.

Μηχανισμός	Διαμόρφωση
Περιορισμός ρυθμού αιτημάτων (rate limiting)	120 αιτήματα ανά 60 δευτερόλεπτα ανά πηγή
Προστασία διαχειριστικών κλήσεων	X-Admin-Token
Αυθεντικοποίηση πηγής τηλεμετρίας (authentication)	X-Switch-Token

Ο περιορισμός του ρυθμού αιτημάτων χρησιμοποιείται ώστε μία μεμονωμένη πηγή να μην μπορεί να προκαλεί ανεξέλεγκτα μεγάλο φόρτο προς το επίπεδο ελέγχου, το οποίο αποτελεί ιδιαίτερα ευαίσθητο στοιχείο της αρχιτεκτονικής SDN λόγω του κεντρικού ρόλου του ελεγκτή [4], [5]. Στην παρούσα υλοποίηση ο περιορισμός εφαρμόζεται αποκλειστικά στο σημείο πρόσβασης της τηλεμετρίας και υπολογίζεται χωριστά για κάθε διεύθυνση IP του καλούντος. Το όριο έχει οριστεί σε 120 αιτήματα ανά 60 δευτερόλεπτα ανά πηγή. Έτσι, η υπέρβαση του ορίου από μία πηγή δεν εξαντλεί το αντίστοιχο όριο των υπόλοιπων πηγών. Η συγκεκριμένη αριθμητική τιμή αποτελεί επιλογή της πειραματικής υλοποίησης και δεν παρουσιάζεται ως γενικό όριο για συστήματα SDN.

Οι διαχειριστικές κλήσεις προστατεύονται μέσω του X-Admin-Token, ώστε λειτουργίες που μεταβάλλουν την κατάσταση του συστήματος να μην εκτελούνται χωρίς το αντίστοιχο διακριτικό (token). Διαφορετικό ρόλο έχει το X-Switch-Token, το οποίο συνοδεύει την τηλεμετρία και χρησιμοποιείται για την αναγνώριση εξουσιοδοτημένης πηγής μετρήσεων. Στην παρούσα υλοποίηση, η διαδικασία εγγραφής μέσω του POST /register καθορίζει ποιες πηγές αναγνωρίζονται ως έμπιστες.

Η αυθεντικοποίηση και η διατήρηση της ακεραιότητας (integrity) των πληροφοριών που φτάνουν στο επίπεδο ελέγχου είναι σημαντικές, καθώς ψευδείς ή αλλοιωμένες πληροφορίες μπορούν να οδηγήσουν τον ελεγκτή σε εσφαλμένη εικόνα της κατάστασης του δικτύου και, κατ' επέκταση, σε λανθασμένες αποφάσεις [4]. Για τον λόγο αυτό, στην παρούσα υλοποίηση, όταν ο έλεγχος μέσω του X-Switch-Token είναι ενεργός, τηλεμετρία που δεν προέρχεται από εξουσιοδοτημένη πηγή απορρίπτεται πριν εισέλθει στη διαδικασία ανίχνευσης. Η αποτελεσματικότητα του μηχανισμού αυτού εξετάζεται πειραματικά στο Κεφάλαιο 6 στο πλαίσιο του σεναρίου εισαγωγής πλαστής τηλεμετρίας.

Η τηλεμετρία μεταφέρεται με δομημένα μηνύματα JSON. Κάθε μήνυμα περιλαμβάνει τις πληροφορίες που απαιτούνται για την αναγνώριση της πηγής και του προορισμού, καθώς και τις μετρήσεις που χρησιμοποιούνται για τον σχηματισμό των χαρακτηριστικών, όπως το

πλήθος πακέτων, το πλήθος των bytes και η διάρκεια των ροών. Η κοινή αυτή μορφή επιτρέπει στον sdn_controller να επεξεργάζεται με ενιαίο τρόπο την τηλεμετρία που προέρχεται από τα δύο διαφορετικά προφίλ της Μεθόδου Α, παρά τη διαφορετική διαδικασία παραγωγής των αρχικών μετρήσεων.

Ο sdn_controller διατηρεί επίσης την εσωτερική κατάσταση που απαιτείται για τη ζωντανή λειτουργία. Σε αυτήν περιλαμβάνονται η τρέχουσα εικόνα των ροών, οι ενεργές ενέργειες αντιμετώπισης, οι χρόνοι λήξης τους, οι ανιχνεύσεις και οι συγκεντρωτικές μετρικές. Επειδή διαφορετικές λειτουργίες του ελεγκτή μπορούν να προσπελαύνουν τα ίδια δεδομένα κατά τη διάρκεια της εκτέλεσης, στην παρούσα υλοποίηση χρησιμοποιούνται μηχανισμοί συγχρονισμού (synchronization mechanisms), ώστε να διατηρείται συνεπής η κοινή κατάσταση και να αποφεύγονται συνθήκες ανταγωνισμού (race conditions).

Ο sdn_controller αποτελεί παράλληλα την πηγή των πληροφοριών που εμφανίζονται στον sdn_dashboard. Ο πίνακας εποπτείας αντλεί μέσω της διεπαφής REST την τοπολογία, τις συγκεντρωτικές μετρικές, την κατάσταση των ροών και τις τιμές ανωμαλίας. Στην παρούσα αρχιτεκτονική, ο πίνακας εποπτείας δεν συμμετέχει στην εκτέλεση του μοντέλου ούτε στη λήψη της απόφασης αντιμετώπισης. Οι λειτουργίες αυτές παραμένουν στον ελεγκτή, ενώ ο sdn_dashboard χρησιμοποιείται αποκλειστικά για την παρουσίαση της κατάστασης του συστήματος. Ο διαχωρισμός της λογικής ελέγχου από τις εφαρμογές που αξιοποιούν την κεντρική εικόνα του δικτύου αποτελεί βασικό χαρακτηριστικό της αρχιτεκτονικής SDN [2].

Οι ενδείξεις που εμφανίζονται στον πίνακα εποπτείας αποτελούν επομένως απεικόνιση κατάστασης που έχει ήδη υπολογιστεί από τον ελεγκτή. Οι τιμές ανωμαλίας, οι ενεργοί αποκλεισμοί και οι υπόλοιπες πληροφορίες της οθόνης δεν αποτελούν ανεξάρτητη διαδικασία απόφασης. Για τον λόγο αυτό, τα στιγμιότυπα του sdn_dashboard χρησιμοποιούνται στο Κεφάλαιο 6 για την παρουσίαση της συμπεριφοράς του συστήματος κατά τα πειραματικά σενάρια και όχι ως μέρος της περιγραφής της μεθοδολογίας.

Εκτός από την κύρια υβριδική διαδρομή της Μεθόδου Α, αναπτύχθηκε και συμπληρωματικό πειραματικό προφίλ με χρήση του Ryu ως πλήρους ελεγκτή OpenFlow. Ο Ryu αποτελεί πλαίσιο ανάπτυξης ελεγκτών σε Python με υποστήριξη της επικοινωνίας με μεταγωγείς μέσω OpenFlow, όπως παρουσιάστηκε στην παράγραφο 2.4 [2]. Το OpenFlow επιτρέπει στον ελεγκτή να ζητά στατιστικά από τον μεταγωγέα και να μεταβάλλει τις καταχωρήσεις του πίνακα ροών (flow table) μέσω του καναλιού ελέγχου [12].

Στη συμπληρωματική διαδρομή που αναπτύχθηκε στην παρούσα εργασία, η συλλογή των στατιστικών πραγματοποιείται μέσω αιτημάτων στατιστικών ροής (flow statistics requests) `OFPFFlowStatsRequest`. Τα αιτήματα αυτά αντιστοιχούν στον μηχανισμό αιτήματος και απόκρισης στατιστικών που προβλέπεται από το OpenFlow [12]. Αντίθετα, στην κύρια υβριδική υλοποίηση τα στατιστικά ανακτώνται τοπικά από τον Open vSwitch μέσω του `ovs-ofctl dump-flows`. Ο Open vSwitch αποτελεί λογισμικό μεταγωγέα (software switch) που υποστηρίζει πίνακες ροών και λειτουργία μέσω OpenFlow [13].

Αντίστοιχα, σε πλήρη διαμόρφωση OpenFlow οι μεταβολές των καταχωρήσεων του πίνακα ροών μπορούν να πραγματοποιούνται μέσω μηνυμάτων τροποποίησης ροής (Flow-Mod messages) που αποστέλλονται από τον ελεγκτή προς τον μεταγωγέα [12]. Στην κύρια διαδρομή της παρούσας εργασίας, όπως περιγράφηκε στην παράγραφο 5.2.2, η απόφαση μεταφέρεται μέσω REST στο `mininet_live.py` και ο κανόνας απόρριψης (drop rule) εγκαθίσταται τοπικά στον Open vSwitch μέσω του `ovs-ofctl`. Η διαφορά αυτή αποτελεί βασικό στοιχείο της υβριδικής αρχιτεκτονικής που αναλύθηκε στην παράγραφο 5.1.1.

Το προφίλ Ryu/OpenFlow έχει υλοποιηθεί ως συμπληρωματική πειραματική διαδρομή, χωρίς πλήρη επικύρωση από άκρο σε άκρο (end-to-end validation), και δεν αποτελεί τη βασική διαμόρφωση πάνω στην οποία στηρίζονται τα αποτελέσματα της Μεθόδου Α. Η διάκριση αυτή είναι απαραίτητη ώστε να μην δημιουργείται η εντύπωση ότι η κύρια πειραματική αρχιτεκτονική χρησιμοποιεί μόνιμη συνεδρία OpenFlow μεταξύ του `sdn_controller` και του Open vSwitch. Στην κύρια υλοποίηση η απόφαση λαμβάνεται κεντρικά, αλλά οι μεταβολές στον πίνακα ροών εφαρμόζονται τοπικά.

Η συμπληρωματική διαδρομή δείχνει τον τρόπο με τον οποίο η ίδια βασική λογική ανίχνευσης και αντιμετώπισης μπορεί να συνδεθεί με πληρέστερη ενσωμάτωση OpenFlow. Η ύπαρξη προγραμματιζόμενης διεπαφής μεταξύ του επιπέδου ελέγχου (control plane) και του επιπέδου δεδομένων (data plane) αποτελεί θεμελιώδες χαρακτηριστικό της αρχιτεκτονικής SDN [2], [12]. Στην παρούσα εργασία, όμως, η δυνατότητα αυτή παρουσιάζεται ως συμπληρωματική διαδρομή και όχι ως η διαμόρφωση που χρησιμοποιήθηκε για την κύρια πειραματική αξιολόγηση.

Με την παρούσα παράγραφο ολοκληρώνεται η περιγραφή της Μεθόδου Α. Η παράγραφος 5.2.1 παρουσίασε την τοπολογία, την παραγωγή της κίνησης και τη συλλογή της τηλεμετρίας, ενώ η παράγραφος 5.2.2 περιέγραψε τον σχηματισμό των χαρακτηριστικών, τη διαδικασία ανίχνευσης και την εφαρμογή των μέτρων αντιμετώπισης. Η παρούσα

παράγραφος συμπληρώνει τη μέθοδο με τη λειτουργία του ελεγκτή, τη διεπαφή επικοινωνίας, τους μηχανισμούς προστασίας και την εποπτεία του συστήματος.

5.3 Μέθοδος B: ανάλυση εκτός σύνδεσης

Η Μέθοδος B αφορά την ανάλυση καταγεγραμμένων δικτυακών ροών εκτός σύνδεσης (offline analysis) και τη σύγκριση διαφορετικών μοντέλων Μηχανικής Μάθησης (Machine Learning). Σε αντίθεση με τη Μέθοδο A, δεν συμμετέχει στη ζωντανή λειτουργία του δικτύου και δεν χρησιμοποιείται για την εγκατάσταση κανόνων αντιμετώπισης. Σκοπός της είναι η εκπαίδευση, η σύγκριση και η αξιολόγηση μοντέλων πάνω σε προκαταγεγραμμένα δεδομένα με κοινό χώρο χαρακτηριστικών.

Η αλυσίδα επεξεργασίας χρησιμοποιεί 24 χαρακτηριστικά δικτυακής ροής (flow features), τα οποία αποτελούν υποσύνολο της δομής που χρησιμοποιείται από το InSDN και το CICFlowMeter [24], [26]. Τα χαρακτηριστικά αυτά είναι διαφορετικά από τα οκτώ συγκεντρωτικά χαρακτηριστικά της ζωντανής Μεθόδου A. Η διάκριση αυτή είναι ουσιαστική, καθώς τα δύο σκέλη της εργασίας χρησιμοποιούν διαφορετικές πηγές δεδομένων και διαφορετικά εκπαιδευμένα μοντέλα.

Η παρουσίαση της Μεθόδου B οργανώνεται σε τρία στάδια. Αρχικά παρουσιάζονται η προέλευση και η δομή των δεδομένων. Στη συνέχεια περιγράφονται η προεπεξεργασία και ο διαχωρισμός τους σε υποσύνολα εκπαίδευσης, επικύρωσης και ελέγχου. Τέλος παρουσιάζονται τα μοντέλα που συγκρίνονται και η διαδικασία αξιολόγησής τους.

5.3.1 Προέλευση και δομή των δεδομένων

Η Μέθοδος B χρησιμοποιεί δύο πηγές δεδομένων με κοινή δομή χαρακτηριστικών. Η πρώτη είναι το δημόσια διαθέσιμο σύνολο δεδομένων InSDN, το οποίο σχεδιάστηκε ειδικά για τη μελέτη επιθέσεων σε περιβάλλοντα SDN και περιλαμβάνει τόσο νόμιμη όσο και κακόβουλη δικτυακή κίνηση [24]. Τα χαρακτηριστικά των ροών του έχουν εξαχθεί με χρήση του CICFlowMeter, εργαλείου που μετατρέπει την κίνηση δικτύου σε στατιστική περιγραφή ανά ροή [24], [26].

Στην παρούσα εργασία δεν χρησιμοποιείται ολόκληρο το σύνολο των διαθέσιμων χαρακτηριστικών του InSDN. Επιλέγεται σταθερό υποσύνολο 24 χαρακτηριστικών, το οποίο αποτελεί τον κοινό χώρο εισόδου των μοντέλων της Μεθόδου B. Στα χαρακτηριστικά αυτά περιλαμβάνονται μεγέθη που σχετίζονται με τη διάρκεια της ροής, το πλήθος και το μέγεθος των πακέτων, τους ρυθμούς μετάδοσης, τους χρόνους μεταξύ διαδοχικών αφίξεων

(inter-arrival times) και γνωρίσματα των σημαιών TCP [24], [26]. Η θεωρητική σημασία των χαρακτηριστικών αυτών έχει παρουσιαστεί στην παράγραφο 4.5.

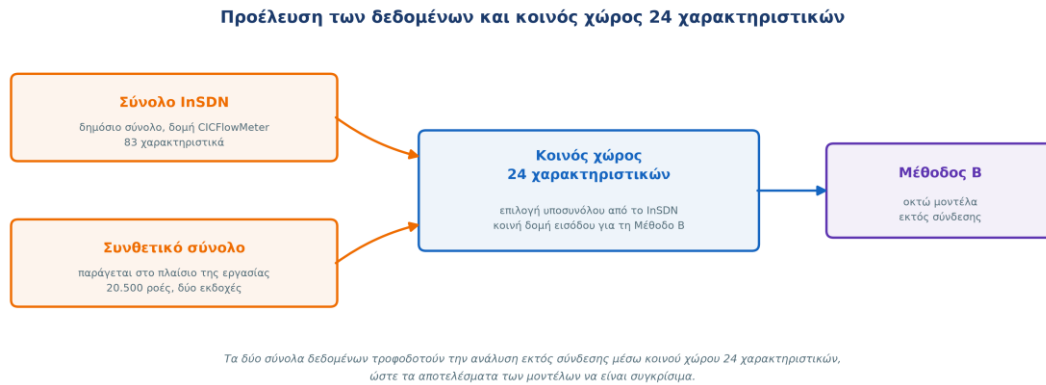
Η δεύτερη πηγή είναι ένα συνθετικό σύνολο δεδομένων που δημιουργήθηκε στο πλαίσιο της παρούσας εργασίας για την ανάπτυξη και τον αρχικό έλεγχο της αλυσίδας επεξεργασίας. Το συνθετικό σύνολο ακολουθεί την ίδια δομή 24 χαρακτηριστικών, ώστε τα ίδια στάδια προεπεξεργασίας και τα ίδια μοντέλα να μπορούν να εφαρμοστούν χωρίς αλλαγή και στο πραγματικό σύνολο InSDN. Η προεπιλεγμένη εκδοχή του αποτελείται από 20.500 ροές και οργανώνεται σε πέντε κατηγορίες: κανονική κίνηση (Normal), κατανεμημένη άρνηση υπηρεσίας (Distributed Denial of Service, DDoS), άρνηση υπηρεσίας (Denial of Service, DoS), διερεύνηση ή σάρωση (Probe) και επίθεση ωμής βίας (Brute-Force Attack, BFA).

Οι κατηγορίες του συνθετικού συνόλου δεν προκύπτουν από πραγματικές καταγραφές δικτύου. Στην παρούσα υλοποίηση δημιουργούνται με προκαθορισμένες στατιστικές κατανομές, ώστε κάθε κατηγορία να έχει διακριτό αποτύπωμα. Για παράδειγμα, οι ροές DDoS σχεδιάζονται με πολύ υψηλούς ρυθμούς πακέτων και σχετικά μικρά πακέτα, οι ροές Probe με μεγάλο αριθμό μικρών συνδέσεων και αυξημένη παρουσία επαναφορών TCP μέσω της σημαίας RST, ενώ οι ροές BFA χαρακτηρίζονται από επαναλαμβανόμενες συνδέσεις με παρόμοια χαρακτηριστικά. Η συγκεκριμένη διαμόρφωση χρησιμοποιήθηκε για να υπάρχει ελεγχόμενο σύνολο ανάπτυξης στο οποίο ήταν γνωστή εκ των προτέρων η αναμενόμενη συμπεριφορά των κατηγοριών.

Το συνθετικό σύνολο παράγεται σε δύο εκδοχές. Η προεπιλεγμένη εκδοχή χρησιμοποιεί καθαρές και σε μεγάλο βαθμό μη επικαλυπτόμενες στατιστικές υπογραφές μεταξύ των κατηγοριών. Η δεύτερη, απαιτητικότερη εκδοχή, η οποία ενεργοποιείται με την παράμετρο --hard, εισάγει πρόσθετο θόρυβο και ελεγχόμενη επικάλυψη μεταξύ γειτονικών κατηγοριών. Τα κύρια αποτελέσματα της εργασίας για το συνθετικό σύνολο προέρχονται από την προεπιλεγμένη εκδοχή.

Η διάκριση αυτή είναι απαραίτητη για την ερμηνεία των αποτελεσμάτων. Επειδή οι κατηγορίες της προεπιλεγμένης συνθετικής εκδοχής έχουν σχεδιαστεί ώστε να παρουσιάζουν σαφώς διαχωρίσιμες στατιστικές υπογραφές, πολύ υψηλές τιμές επίδοσης των μοντέλων σε αυτό το σύνολο είναι αναμενόμενες. Συνεπώς, οι σχεδόν τέλει επιδόσεις στο συγκεκριμένο συνθετικό σύνολο δεν αποτελούν από μόνες τους ένδειξη ότι ένα μοντέλο θα γενικεύσει με την ίδια επιτυχία σε πραγματική δικτυακή κίνηση. Για τον λόγο αυτό η αξιολόγηση επαναλαμβάνεται και στο πραγματικό σύνολο InSDN [24].

Η σχέση των δύο πηγών δεδομένων με τη Μέθοδο Β παρουσιάζεται στο Σχήμα 5-5. Το InSDN και το συνθετικό σύνολο αποτελούν δύο διαφορετικές πηγές, αλλά μετατρέπονται στον ίδιο χώρο των 24 χαρακτηριστικών πριν εισέλθουν στην αλυσίδα ανάλυσης εκτός σύνδεσης. Η Μέθοδος Α δεν συμμετέχει σε αυτή τη ροή και, όπως έχει ήδη διευκρινιστεί, χρησιμοποιεί διαφορετικό σύνολο οκτώ ζωντανών χαρακτηριστικών.



Σχήμα 5-5: Προέλευση των δεδομένων και κοινός χώρος 24 χαρακτηριστικών που χρησιμοποιείται στη Μέθοδο Β.

Με τον τρόπο αυτό, το συνθετικό σύνολο χρησιμοποιείται ως ελεγχόμενο περιβάλλον ανάπτυξης και ελέγχου της αλυσίδας επεξεργασίας, ενώ το InSDN παρέχει την αξιολόγηση πάνω σε πραγματικότερο σύνολο ροών που έχει δημιουργηθεί ειδικά για περιβάλλον SDN [24]. Η χρήση του ίδιου χώρου χαρακτηριστικών επιτρέπει την εφαρμογή της ίδιας διαδικασίας προεπεξεργασίας και των ίδιων μοντέλων και στις δύο πηγές, χωρίς να συγχέονται τα δεδομένα ή οι πειραματικοί τους ρόλοι.

5.3.2 Προεπεξεργασία, τυποποίηση και διαχωρισμός των δεδομένων

Πριν από την εισαγωγή των δεδομένων στα μοντέλα εφαρμόζεται σταθερή διαδικασία προεπεξεργασίας (preprocessing), ώστε οι διαφορετικοί αλγόριθμοι να λαμβάνουν δεδομένα με κοινή δομή. Η διαδικασία περιλαμβάνει τον έλεγχο των αριθμητικών τιμών, τη διαχείριση των διπλότυπων εγγραφών (duplicate records), την κωδικοποίηση των ετικετών των κατηγοριών, τον διαχωρισμό των δεδομένων και, όπου απαιτείται, την τυποποίηση (standardization). Η θεωρητική σημασία της τυποποίησης και της αποφυγής διαρροής δεδομένων (data leakage) έχει ήδη παρουσιαστεί στο Κεφάλαιο 4 [20], [33].

Το πρώτο στάδιο αφορά τον έλεγχο των αριθμητικών τιμών. Σε χαρακτηριστικά ρυθμού της δομής CICFlowMeter, όπως οι τιμές σε bytes ανά δευτερόλεπτο, μπορεί να εμφανιστούν μη πεπερασμένες τιμές όταν ο αντίστοιχος υπολογισμός δεν είναι αριθμητικά ορισμένος. Στην

παρούσα υλοποίηση οι μη πεπερασμένες τιμές μετατρέπονται σε ελλείπουσες και στη συνέχεια απορρίπτονται οι εγγραφές που εξακολουθούν να περιέχουν τέτοιες τιμές. Στην έκδοση του InSDN που χρησιμοποιήθηκε στην εργασία δεν απορρίφθηκε καμία εγγραφή κατά το συγκεκριμένο στάδιο. Η δομή των χαρακτηριστικών του CICFlowMeter έχει παρουσιαστεί στην παράγραφο 4.5 [26].

Η διαχείριση των διπλότυπων εγγραφών διαφέρει μεταξύ των δύο πηγών δεδομένων. Στο συνθετικό σύνολο τα ακριβή διπλότυπα αφαιρούνται κατά την προεπεξεργασία. Στην πράξη, όμως, καμία από τις 20.500 εγγραφές του συνθετικού συνόλου δεν αφαιρείται σε αυτό το στάδιο, καθώς όλες αντιστοιχούν ήδη σε διακριτά διανύσματα χαρακτηριστικών. Στο InSDN, αντίθετα, τα διπλότυπα διατηρούνται, επειδή η πλήρης αφαίρεσή τους θα άλλαζε ουσιωδώς τη σύνθεση του αρχικού συνόλου και ιδιαίτερα την εκπροσώπηση της κατηγορίας DDoS. Στην παρούσα ανάλυση η συγκεκριμένη κατηγορία περιλαμβάνει 121.942 εγγραφές, αλλά μόλις 1.517 διακριτά διανύσματα των 24 χαρακτηριστικών. Η αφαίρεση όλων των επαναλήψεων θα μείωνε επομένως δραστικά την παρουσία της συγκεκριμένης κατηγορίας και θα μετέβαλλε το ίδιο το πρόβλημα που αξιολογείται.

Συνολικά, το 47,5% των εγγραφών του InSDN αποτελεί πλεονάζοντα ακριβή αντίγραφα ως προς το διάνυσμα των 24 χαρακτηριστικών. Στην κατηγορία DDoS το αντίστοιχο ποσοστό φτάνει το 98,8%. Τα ποσοστά αυτά εκφράζουν τα πλεονάζοντα αντίγραφα και όχι το σύνολο των εγγραφών που ανήκουν σε κάποια ομάδα διπλοτύπων. Για τον λόγο αυτό, τα διπλότυπα του InSDN δεν αφαιρούνται, αλλά αντιμετωπίζονται κατά τον διαχωρισμό των δεδομένων.

Στη συνέχεια πραγματοποιείται η κωδικοποίηση των ετικετών των κατηγοριών (class labels). Στην παρούσα υλοποίηση τα ονόματα των πέντε κατηγοριών μετατρέπονται σε ακέραιες ετικέτες και η ίδια αντιστοίχιση διατηρείται σε όλα τα υποσύνολα των δεδομένων.

Μετά την προεπεξεργασία, τα δεδομένα χωρίζονται σε σύνολο εκπαίδευσης (training set), σύνολο επικύρωσης (validation set) και σύνολο ελέγχου (test set). Η αρχική διαμόρφωση στοχεύει ονομαστικά σε περίπου 55% των δεδομένων για εκπαίδευση, 15% για επικύρωση και 30% για τελικό έλεγχο. Το σύνολο εκπαίδευσης χρησιμοποιείται για την προσαρμογή των μοντέλων, το σύνολο επικύρωσης για την επιλογή της διαμόρφωσης και των υπερπαραμέτρων, ενώ το σύνολο ελέγχου διατηρείται για την τελική αξιολόγηση [20], [33].

Ο διαχωρισμός δεν πραγματοποιείται με απλή τυχαία κατανομή των μεμονωμένων εγγραφών. Κάθε διακριτό διάνυσμα των 24 χαρακτηριστικών αντιστοιχίζεται σε μία ομάδα και όλα τα ακριβή αντίγραφα του παραμένουν στην ίδια ομάδα. Στη συνέχεια εφαρμόζεται

στρωματοποιημένος διαχωρισμός κατά ομάδες (stratified group-aware split), ώστε καμία ομάδα πανομοιότυπων διανυσμάτων να μη μοιράζεται μεταξύ εκπαίδευσης, επικύρωσης και ελέγχου. Η παρουσία της ίδιας παρατήρησης τόσο στην εκπαίδευση όσο και στην αξιολόγηση αποτελεί μορφή διαρροής δεδομένων και μπορεί να οδηγήσει σε υπερεκτίμηση της ικανότητας γενίκευσης του μοντέλου [33]. Επομένως, στην παρούσα υλοποίηση εφαρμόζεται η αντίστοιχη προφύλαξη στο InSDN.

Ο ίδιος μηχανισμός διαχωρισμού κατά ομάδες εφαρμόζεται και στο συνθετικό σύνολο. Εκεί, όμως, δεν έχει πρακτική επίδραση στη σύνθεση των ομάδων, καθώς και οι 20.500 εγγραφές αντιστοιχούν σε διαφορετικά διανύσματα χαρακτηριστικών και συνεπώς κάθε ομάδα περιλαμβάνει μία μόνο εγγραφή.

Η διαμέριση κατά ομάδες υλοποιείται μέσω πτυχών (folds). Για τον τελικό έλεγχο, το ονομαστικό ποσοστό 30% αντιστοιχίζεται σε μία από τρεις πτυχές, με αποτέλεσμα περίπου το ένα τρίτο του συνόλου να διατηρείται για έλεγχο. Από το υπόλοιπο τμήμα αποσπάται στη συνέχεια μία από πέντε πτυχές για επικύρωση. Για τον λόγο αυτό οι πραγματικές αναλογίες της πλήρους εκτέλεσης στο InSDN διαφέρουν από τις αρχικές ονομαστικές τιμές 55%, 15% και 30%.

Συγκεκριμένα, από τις 343.516 εγγραφές του InSDN, 183.208 χρησιμοποιούνται για εκπαίδευση, 45.802 για επικύρωση και 114.506 για έλεγχο. Οι πραγματικές αναλογίες είναι επομένως 53,3%, 13,3% και 33,3%, αντίστοιχα. Η απόκλιση αυτή οφείλεται κυρίως στη μετατροπή των ζητούμενων αναλογιών σε ακέραιο αριθμό πτυχών κατά τη διαδικασία του διαχωρισμού, ενώ παράλληλα οι ομάδες των πανομοιότυπων διανυσμάτων παραμένουν ακέραιες. Η ίδια διαδικασία οδηγεί στις ίδιες ποσοστιαίες αναλογίες 53,3%, 13,3% και 33,3% και για το συνθετικό σύνολο. Με αυτόν τον τρόπο, ακριβή αντίγραφα του ίδιου διανύσματος δεν κατανέμονται σε διαφορετικά υποσύνολα.

Η γεννήτρια τυχαίων αριθμών αρχικοποιείται με σταθερή τιμή, ώστε ο ίδιος διαχωρισμός να μπορεί να αναπαραχθεί. Παράλληλα εφαρμόζεται στρωματοποίηση, ώστε να διατηρείται όσο είναι δυνατό η κατανομή των κατηγοριών στα επιμέρους υποσύνολα, υπό τον περιορισμό ότι οι ομάδες δεν μπορούν να διασπαστούν.

Η επίδραση του απλού τυχαίου διαχωρισμού και του διαχωρισμού κατά ομάδες στις επιδόσεις των μοντέλων εξετάζεται στο Κεφάλαιο 6.

Μετά τον διαχωρισμό εφαρμόζεται, όπου απαιτείται από το αντίστοιχο μοντέλο, η τυποποίηση των αριθμητικών χαρακτηριστικών. Όπως παρουσιάστηκε στην παράγραφο

4.9, ο μετασχηματιστής προσαρμόζεται αποκλειστικά στο σύνολο εκπαίδευσης και οι ίδιες παράμετροι εφαρμόζονται χωρίς νέα προσαρμογή στα σύνολα επικύρωσης και ελέγχου. Με τον τρόπο αυτό δεν μεταφέρεται πληροφορία από τα δεδομένα αξιολόγησης προς τη διαδικασία εκπαίδευσης [20], [33].

Οι βασικές διαφορές της διαδικασίας προεπεξεργασίας μεταξύ του συνθετικού συνόλου και του InSDN συνοψίζονται στον Πίνακα 5-6.

Πίνακας 5-6: Εφαρμογή των βασικών βημάτων προεπεξεργασίας στις δύο πηγές δεδομένων.

Βήμα	Συνθετικό σύνολο	InSDN
Έλεγχος μη πεπερασμένων και ελλειπουσών τιμών	Ναι	Ναι
Ακριβή διπλότυπα	Δεν εντοπίζονται μετά την παραγωγή· το βήμα αφαίρεσης δεν μεταβάλλει το σύνολο	Διατηρούνται
Κωδικοποίηση ετικετών	Ακέραιες ετικέτες	Ακέραιες ετικέτες
Διαχωρισμός δεδομένων	Στρωματοποιημένος διαχωρισμός κατά ομάδες	Στρωματοποιημένος διαχωρισμός κατά ομάδες
Προστασία ακριβών αντιγράφων μεταξύ υποσυνόλων	Ο μηχανισμός εφαρμόζεται, αλλά κάθε ομάδα περιλαμβάνει μία εγγραφή	Κάθε ομάδα παραμένει σε ένα μόνο υποσύνολο
Τυποποίηση	Παράμετροι από το σύνολο εκπαίδευσης	Παράμετροι από το σύνολο εκπαίδευσης

Όπως φαίνεται στον Πίνακα 5-6, η βασική ακολουθία προεπεξεργασίας είναι κοινή για τις δύο πηγές, αλλά η διαχείριση των ακριβών διπλοτύπων διαφέρει. Η ουσιαστική διαφορά βρίσκεται στην παρουσία των διπλότυπων εγγραφών: στο συνθετικό σύνολο όλες οι εγγραφές είναι ήδη διακριτές και επομένως η ομαδοποίηση δεν μεταβάλλει τον διαχωρισμό, ενώ στο InSDN οι επαναλαμβανόμενες εγγραφές διατηρούνται και η απομόνωσή τους μεταξύ των υποσυνόλων εξασφαλίζεται μέσω των ομάδων.

Μετά την ολοκλήρωση των παραπάνω βημάτων, τα δεδομένα βρίσκονται σε κοινή μορφή 24 χαρακτηριστικών και μπορούν να χρησιμοποιηθούν από τα μοντέλα της Μεθόδου Β. Η εκπαίδευση των μοντέλων, οι βασικές υπερπαραμέτροί τους και η διαδικασία σύγκρισής τους παρουσιάζονται στην παράγραφο 5.3.3.

5.3.3 Τα μοντέλα και η διαδικασία σύγκρισης

Η Μέθοδος Β περιλαμβάνει δύο διακριτές διαδρομές αξιολόγησης. Η κύρια διαδρομή συγκρίνει έξι μοντέλα επιβλεπόμενης Μηχανικής Μάθησης (supervised Machine Learning) στον κοινό χώρο των 24 χαρακτηριστικών, τόσο στο συνθετικό σύνολο όσο και στο InSDN. Συμπληρωματικά εξετάζονται δύο μοντέλα Βαθιάς Μάθησης (Deep Learning), τα οποία έχουν αξιολογηθεί μόνο στο συνθετικό σύνολο και με διαφορετικό πρωτόκολλο διαχωρισμού. Για τον λόγο αυτό τα αποτελέσματα των δύο διαδρομών παρουσιάζονται χωριστά στο Κεφάλαιο 6 και δεν θεωρούνται άμεσα συγκρίσιμα μεταξύ τους.

Τα έξι μοντέλα της κύριας διαδρομής είναι το Τυχαίο Δάσος (Random Forest), το Δέντρο Απόφασης (Decision Tree), οι k Πλησιέστεροι Γείτονες (k-Nearest Neighbors, KNN), η Μηχανή Διανυσμάτων Υποστήριξης (Support Vector Machine, SVM), η Λογιστική Παλινδρόμηση (Logistic Regression) και ο Πολυεπίπεδος Αντιληπτήρας (Multi-Layer Perceptron, MLP). Οι αλγόριθμοι αυτοί αντιπροσωπεύουν διαφορετικές οικογένειες ταξινομητών, όπως δενδρικές μεθόδους, μεθόδους βασισμένες σε αποστάσεις, γραμμικά και μη γραμμικά όρια απόφασης και νευρωνικά δίκτυα. Η θεωρητική λειτουργία τους έχει παρουσιαστεί στην παράγραφο 4.2 [20], [21].

Στην παρούσα υλοποίηση, το Τυχαίο Δάσος χρησιμοποιεί 120 δέντρα χωρίς περιορισμό του μέγιστου βάθους τους. Το Δέντρο Απόφασης περιορίζεται σε μέγιστο βάθος 20. Ο ταξινομητής KNN χρησιμοποιεί πέντε πλησιέστερους γείτονες, ενώ η SVM χρησιμοποιεί πυρήνα ακτινικής βάσης (Radial Basis Function, RBF), παράμετρο κανονικοποίησης C ίση με 10 και αυτόματη κλιμάκωση της παραμέτρου γ του πυρήνα. Η Λογιστική Παλινδρόμηση έχει ανώτατο όριο 1.000 επαναλήψεων, ενώ το MLP της βιβλιοθήκης scikit-learn χρησιμοποιεί δύο κρυφά επίπεδα με 64 και 32 νευρώνες και εκπαιδεύεται έως 300 επαναλήψεις. Οι συγκεκριμένες τιμές αποτελούν ρυθμίσεις της πειραματικής υλοποίησης και δεν παρουσιάζονται ως γενικές βέλτιστες τιμές για τους αντίστοιχους αλγορίθμους.

Τα δύο μοντέλα Βαθιάς Μάθησης υλοποιούνται σε χωριστή πειραματική διαδρομή. Το πρώτο είναι βαθύ Πολυεπίπεδο Νευρωνικό Δίκτυο (Deep MLP) με τρία κρυφά πλήρως συνδεδεμένα επίπεδα 128, 64 και 32 νευρώνων. Μεταξύ των επιπέδων χρησιμοποιούνται κανονικοποίηση κατά δεσμίδα (batch normalization) και απόρριψη νευρώνων (dropout) με ποσοστό 0,3, με στόχο τον περιορισμό της υπερπροσαρμογής. Το δεύτερο είναι μονοδιάστατο Συνελικτικό Νευρωνικό Δίκτυο (One-Dimensional Convolutional Neural Network, 1D-CNN), με τρία συνελικτικά επίπεδα που χρησιμοποιούν 32, 32 και 16 φίλτρα, αντίστοιχα, πυρήνα μεγέθους 3 και πυκνό επίπεδο 64 νευρώνων πριν από την έξοδο. Η

γενική λειτουργία των μονοδιάστατων συνελκτικών δικτύων έχει παρουσιαστεί στην παράγραφο 4.2 [22].

Στο 1D-CNN το διάνυσμα των 24 χαρακτηριστικών αντιμετωπίζεται ως μονοδιάστατη ακολουθία εισόδου. Λόγω του μικρού αριθμού εισόδων, η αρχιτεκτονική δεν εφαρμόζει επιθετική υποδειγματοληψία μεταξύ των συνελκτικών επιπέδων, ώστε να μη μειωθεί υπερβολικά η διαθέσιμη αναπαράσταση. Μετά το τελευταίο συνελκτικό επίπεδο η αναπαράσταση ισοπεδώνεται και οδηγείται στο πυκνό επίπεδο. Και στα δύο βαθιά μοντέλα η έξοδος αποτελείται από πέντε μονάδες με συνάρτηση softmax, μία για κάθε κατηγορία ταξινόμησης.

Η εκπαίδευση των δύο μοντέλων Βαθιάς Μάθησης πραγματοποιείται σε δεσμίδες (batches) των 128 δειγμάτων και με ανώτατο όριο 40 εποχών. Εφαρμόζεται πρόωρη διακοπή (early stopping) με παρακολούθηση της απώλειας επικύρωσης και υπομονή οκτώ διαδοχικών εποχών. Αν η απώλεια δεν βελτιωθεί στο διάστημα αυτό, η εκπαίδευση τερματίζεται και επαναφέρονται τα βάρη της καλύτερης εποχής. Επομένως, η εκπαίδευση μπορεί να ολοκληρωθεί πριν από τις 40 εποχές, ανάλογα με την εξέλιξη της απώλειας επικύρωσης.

Οι βασικές ρυθμίσεις των οκτώ μοντέλων συνοψίζονται στον Πίνακα 5-7.

Πίνακας 5-7: Μοντέλα της Μεθόδου Β και βασικές υπερπαράμετροι της πειραματικής διαμόρφωσης.

Μοντέλο	Οικογένεια	Βασικές υπερπαράμετροι
Random Forest	Δενδρικό σύνολο	120 δέντρα, χωρίς όριο βάθους
Decision Tree	Δενδρικό	μέγιστο βάθος 20
KNN	Βασισμένο σε αποστάσεις	k = 5
SVM	Μέθοδος ορίου απόφασης	RBF, C = 10, γ = scale
Logistic Regression	Γραμμικό μοντέλο	έως 1.000 επαναλήψεις
MLP	Νευρωνικό μοντέλο	κρυφά επίπεδα 64 και 32, έως 300 επαναλήψεις
Deep MLP	Βαθιά Μάθηση	128–64–32, dropout 0,3, batch normalization
1D-CNN	Βαθιά Μάθηση	φίλτρα 32–32–16, πυρήνας 3, πυκνό επίπεδο 64, dropout 0,3

Όπως φαίνεται στον Πίνακα 5-7, η πειραματική σύγκριση περιλαμβάνει μοντέλα με διαφορετικό βαθμό πολυπλοκότητας και διαφορετική λογική ταξινόμησης. Οι αριθμητικές ρυθμίσεις του πίνακα αφορούν τη συγκεκριμένη υλοποίηση. Η παρουσία τόσο του MLP της

scikit-learn όσο και του Deep MLP δεν αποτελεί διπλή χρήση του ίδιου μοντέλου: το πρώτο είναι σχετικά απλή διαμόρφωση δύο κρυφών επιπέδων, ενώ το δεύτερο είναι χωριστή βαθύτερη αρχιτεκτονική με τρία κρυφά επίπεδα, κανονικοποίηση κατά δεσμίδα και dropout.

Για την κύρια σύγκριση των έξι μοντέλων χρησιμοποιείται ο διαχωρισμός των δεδομένων που παρουσιάστηκε στην παράγραφο 5.3.2. Και στις δύο πηγές δεδομένων εφαρμόζεται στρωματοποιημένος διαχωρισμός κατά ομάδες (stratified group-aware split). Στο συνθετικό σύνολο κάθε ομάδα περιλαμβάνει μία μόνο εγγραφή, ενώ στο InSDN ο μηχανισμός εξασφαλίζει ότι ακριβή αντίγραφα του ίδιου διανύσματος χαρακτηριστικών δεν κατανέμονται μεταξύ εκπαίδευσης, επικύρωσης και ελέγχου. Η επιλογή της διαμόρφωσης πραγματοποιείται με βάση το σύνολο επικύρωσης, ενώ το σύνολο ελέγχου χρησιμοποιείται για την τελική αξιολόγηση.

Η αξιολόγηση των έξι μοντέλων βασίζεται στις μετρικές που παρουσιάστηκαν στην παράγραφο 4.6. Εκτός από τη συνολική ακρίβεια (accuracy), υπολογίζονται η μακρο-ορθότητα (macro-precision), η μακρο-ανάκληση (macro-recall) και η μακρο-F1 (macro-F1). Ο μακρομέσος όρος υπολογίζει τη μετρική ανεξάρτητα για κάθε κατηγορία και στη συνέχεια λαμβάνει τον μη ζυγισμένο μέσο όρο, ώστε οι μικρότερες κατηγορίες να μην επισκιάζονται από τις πολυπληθέστερες [27]. Η επιλογή αυτή είναι ιδιαίτερα χρήσιμη στο InSDN, όπου η κατανομή των κατηγοριών είναι έντονα ανισομερής και η κατηγορία BFA περιλαμβάνει μόλις 1.405 εγγραφές.

Συμπληρωματικά χρησιμοποιούνται πίνακες σύγχυσης (confusion matrices) και καμπύλες χαρακτηριστικής λειτουργίας δέκτη (Receiver Operating Characteristic, ROC), μαζί με το εμβαδόν κάτω από την καμπύλη (Area Under the Curve, AUC), όπως παρουσιάστηκε στην παράγραφο 4.6 [27], [28]. Οι μετρικές αυτές δεν ερμηνεύονται απομονωμένα. Ιδιαίτερα στο συνθετικό σύνολο, τιμές πολύ κοντά στη μονάδα πρέπει να εξετάζονται σε συνδυασμό με τη σχεδιασμένη διαχωρισσιμότητα των κατηγοριών που περιγράφηκε στην παράγραφο 5.3.1.

Εκτός από τις μετρικές ταξινόμησης, καταγράφονται ο χρόνος εκπαίδευσης και ο χρόνος πρόβλεψης. Η καταγραφή αυτή επιτρέπει να αξιολογείται όχι μόνο η ποιότητα της ταξινόμησης, αλλά και το υπολογιστικό κόστος της κάθε διαμόρφωσης. Η παράμετρος αυτή είναι ιδιαίτερα σημαντική όταν εξετάζεται αν ένα μοντέλο θα μπορούσε μελλοντικά να χρησιμοποιηθεί κοντά στον πραγματικό χρόνο, χωρίς όμως να σημαίνει ότι τα μοντέλα της Μεθόδου Β χρησιμοποιούνται αυτούσια στη ζωντανή Μέθοδο Α.

Τα δύο μοντέλα Βαθιάς Μάθησης δεν ακολουθούν το ίδιο πρωτόκολλο αξιολόγησης με τα έξι προηγούμενα μοντέλα. Στην υλοποίηση που παρήγαγε τα αποτελέσματα της εργασίας, το Deep MLP και το 1D-CNN αξιολογήθηκαν μόνο στο συνθετικό σύνολο, με απλό στρωματοποιημένο διαχωρισμό των δεδομένων. Η επικύρωση πραγματοποιείται εσωτερικά κατά την εκπαίδευση των δικτύων και δεν χρησιμοποιείται ο ανεξάρτητος διαχωρισμός κατά ομάδες της παραγράφου 5.3.2. Επιπλέον, η συγκεκριμένη πειραματική διαδρομή δεν έχει εκτελεστεί στο InSDN.

Για τον λόγο αυτό, τα αποτελέσματα των δύο βαθιών μοντέλων παρουσιάζονται χωριστά στο Κεφάλαιο 6 ως συμπληρωματική διερεύνηση και δεν χρησιμοποιούνται για άμεση κατάταξη απέναντι στα έξι μοντέλα της κύριας διαδρομής.

Υπάρχει ακόμη ένας μεθοδολογικός περιορισμός στη συγκεκριμένη διαδρομή Βαθιάς Μάθησης: η επιλογή της καλύτερης διαμόρφωσης δεν χρησιμοποιεί πλήρως ανεξάρτητο σύνολο επικύρωσης με τον ίδιο τρόπο όπως η κύρια διαδρομή των έξι μοντέλων.

Η ερμηνευσιμότητα των αποφάσεων εξετάζεται συμπληρωματικά με τη μέθοδο SHAP (SHapley Additive exPlanations), η θεωρητική λειτουργία της οποίας έχει παρουσιαστεί στην παράγραφο 4.7 [29]. Στο Κεφάλαιο 6 παρουσιάζονται οι αντίστοιχες τιμές σημαντικότητας και η κατεύθυνση της επίδρασης των χαρακτηριστικών.

5.4 Περιβάλλον εκτέλεσης και αναπαραγωγιμότητα

Η αναπαραγωγιμότητα αντιμετωπίστηκε ως σχεδιαστική απαίτηση της υλοποίησης και υποστηρίζεται σε τρία επίπεδα: στην απομόνωση του περιβάλλοντος εκτέλεσης, στη δέσμευση των εκδόσεων των βασικών βιβλιοθηκών και στην ύπαρξη σεναρίων που αυτοματοποιούν τις επιμέρους πειραματικές διαδικασίες. Τα στοιχεία αυτά περιορίζουν τις αποκλίσεις μεταξύ διαφορετικών εκτελέσεων, χωρίς να εξαλείφουν πλήρως την εξάρτηση από το υποκείμενο λειτουργικό και τους διαθέσιμους υπολογιστικούς πόρους.

Το περιβάλλον ανάπτυξης και εκτέλεσης της εργασίας βασίστηκε σε Windows με Windows Subsystem for Linux 2 (WSL2). Στην παρούσα εγκατάσταση δεν ήταν διαθέσιμο το άρθρωμα πυρήνα (kernel module) του Open vSwitch. Για τον λόγο αυτό, στο πείραμα σε επίπεδο πακέτων ο μεταγωγέας δημιουργείται με διαδρομή δεδομένων σε χώρο χρήστη (userspace datapath) και σε κατάσταση failMode=standalone. Ο Open vSwitch υποστηρίζει διαδρομές δεδομένων τόσο στον χώρο πυρήνα όσο και στον χώρο χρήστη [13]. Η επιλογή αυτή κατέστησε δυνατή την εκτέλεση του πειράματος στο συγκεκριμένο περιβάλλον WSL2

και είναι συνεπής με το υβριδικό μοντέλο ελέγχου που περιγράφηκε στην παράγραφο 5.1.1, στο οποίο ο μεταγωγέας διατηρεί τοπική δυνατότητα προώθησης της κίνησης.

Η ζωντανή στοίβα της Μεθόδου Α ενορχηστρώνεται μέσω Docker Compose. Στην παρούσα υλοποίηση το αντίστοιχο αρχείο διαμόρφωσης ορίζει πέντε υπηρεσίες, το εικονικό δίκτυο επικοινωνίας τους και τις απαιτούμενες αντιστοιχίσεις θυρών. Οι κύριες υπηρεσίες αντιστοιχούν στην εφαρμογή ελέγχου, στον πίνακα εποπτείας και στα δύο πειραματικά προφίλ που παρουσιάστηκαν στην παράγραφο 5.1.3. Η πέμπτη υπηρεσία αφορά το συμπληρωματικό προφίλ με πλήρη ελεγκτή OpenFlow που παρουσιάστηκε στην παράγραφο 5.2.3 και ενεργοποιείται μόνο όταν ζητηθεί ρητά, ώστε να μην αποτελεί μέρος της προεπιλεγμένης πειραματικής διαμόρφωσης.

Η σειρά εκκίνησης των υπηρεσιών ελέγχεται επίσης από την ίδια διαμόρφωση. Η εφαρμογή ελέγχου διαθέτει σημείο ελέγχου κατάστασης (health check), το οποίο ερωτάται περιοδικά, και οι υπηρεσίες που εξαρτώνται από αυτήν εκκινούν αφού επιβεβαιωθεί η ορθή λειτουργία της. Με τον τρόπο αυτό περιορίζονται αποτυχίες που θα μπορούσαν να προκύψουν αποκλειστικά από διαφορετικό χρονισμό κατά την εκκίνηση των επιμέρους στοιχείων.

Το πειραματικό προφίλ σε επίπεδο πακέτων απαιτεί αυξημένα δικαιώματα εκτέλεσης, επειδή το Mininet δημιουργεί εικονικούς κόμβους, χώρους ονομάτων δικτύου και εικονικές διεπαφές [14]. Για τον λόγο αυτό η αντίστοιχη υπηρεσία εκτελείται σε προνομιακή λειτουργία και με τις απαραίτητες δικτυακές δυνατότητες. Η επιλογή αυτή αφορά αποκλειστικά τις ανάγκες δημιουργίας της εικονικής τοπολογίας και δεν απαιτείται από όλα τα στοιχεία της εφαρμογής.

Η απομόνωση των επιμέρους υπηρεσιών περιορίζει τις μεταξύ τους συγκρούσεις εξαρτήσεων και επιτρέπει κάθε στοιχείο να εκτελείται με το δικό του σύνολο βιβλιοθηκών. Παράλληλα, η μεταξύ τους επικοινωνία πραγματοποιείται μέσω του εικονικού δικτύου του Docker Compose, χρησιμοποιώντας τα ονόματα των υπηρεσιών αντί για διευθύνσεις που εξαρτώνται από τον συγκεκριμένο υπολογιστή φιλοξενίας. Με τον τρόπο αυτό μειώνονται οι χειροκίνητες αλλαγές που απαιτούνται όταν η στοίβα εκτελείται εκ νέου σε συμβατό περιβάλλον.

Οι βασικές παράμετροι των ζωντανών πειραμάτων δεν απαιτούν τροποποίηση του πηγαίου κώδικα. Η διάρκεια της κανονικής φάσης, της φάσης επίθεσης και της φάσης ανάκαμψης, το πλήθος των πειραματικών κύκλων, ο χρόνος ζωής του κανόνα αποκλεισμού και ο ρυθμός παραγωγής της επίθεσης μπορούν να δίνονται μέσω μεταβλητών περιβάλλοντος

(environment variables), για τις οποίες υπάρχουν προκαθορισμένες τιμές. Στις πληροφορίες της εκτέλεσης μπορεί επίσης να περιλαμβάνεται αναγνωριστικό της έκδοσης του κώδικα, ώστε τα παραγόμενα αποτελέσματα να μπορούν να συνδεθούν με τη διαμόρφωση που τα δημιούργησε.

Η αναπαραγωγή των πειραμάτων δεν βασίζεται σε μία ενιαία εντολή, επειδή οι διαφορετικές πειραματικές διαδρομές έχουν διαφορετικές απαιτήσεις. Το σενάριο `run_all.sh` εκτελεί τον βασικό κορμό της εκτός σύνδεσης αξιολόγησης και παράγει τα κύρια αρχεία αποτελεσμάτων, ενώ το `reproduce_thesis.sh` εκτελεί την εκτεταμένη ροή αναπαραγωγής για επιλεγμένο σύνολο δεδομένων. Τα πειράματα συνθετικής τηλεμετρίας της Μεθόδου Α εκτελούνται μέσω του `run_live_experiments.sh`, ενώ το πείραμα σε επίπεδο πακέτων με Mininet και Open vSwitch μέσω του `run_packet_level_experiment.sh`.

Ο διαχωρισμός αυτός έχει σημασία και για την ερμηνεία των μοντέλων. Το Isolation Forest που εξετάζεται στο σκέλος ανάλυσης εκτός σύνδεσης χρησιμοποιεί τον χώρο των 24 χαρακτηριστικών ροής της Μεθόδου Β. Αντίθετα, το Isolation Forest που χρησιμοποιείται στη ζωντανή Μέθοδο Α λειτουργεί στα οκτώ συγκεντρωτικά χαρακτηριστικά που παρουσιάστηκαν στην παράγραφο 5.2.2. Επομένως, πρόκειται για δύο διαφορετικές διαμορφώσεις μοντέλου, οι οποίες εξυπηρετούν διαφορετικό πειραματικό σκοπό.

Οι βασικές βιβλιοθήκες που χρησιμοποιούνται στην ανάλυση εκτός σύνδεσης καταγράφονται με συγκεκριμένες εκδόσεις, μαζί με την αντίστοιχη έκδοση της γλώσσας Python. Η δέσμευση των εκδόσεων περιορίζει την πιθανότητα διαφορετικές εκδόσεις βιβλιοθηκών να μεταβάλουν τη συμπεριφορά της ίδιας πειραματικής διαδικασίας. Η κάλυψη αυτή δεν είναι πλήρης για όλα τα βοηθητικά στοιχεία της εφαρμογής: οι βιβλιοθήκες του πίνακα εποπτείας και ορισμένες προαιρετικές εξαρτήσεις, μεταξύ των οποίων εκείνες που χρησιμοποιούνται στη διαδρομή Βαθιάς Μάθησης, δεν δεσμεύονται με τον ίδιο βαθμό αυστηρότητας. Το στοιχείο αυτό αποτελεί περιορισμό της αναπαραγωγιμότητας και λαμβάνεται υπόψη κατά την ερμηνεία των αντίστοιχων αποτελεσμάτων.

Συμπληρωματικά τηρείται κατάλογος συνόψεων SHA-256 (MANIFEST.sha256) για επιλεγμένα βασικά αρχεία της υλοποίησης και των αποτελεσμάτων. Ο έλεγχος των συνόψεων επιτρέπει να επαληθευτεί ότι τα αρχεία που χρησιμοποιούνται σε μια μεταγενέστερη εκτέλεση είναι τα ίδια με εκείνα της εκτέλεσης αναφοράς. Η υπάρχουσα διαδικασία επαλήθευσης περιλαμβάνει, μεταξύ άλλων, το συνθετικό σύνολο δεδομένων και

επιλεγμένα βασικά παραγόμενα αρχεία, χωρίς να καλύπτει κατ' ανάγκη κάθε αρχείο του καταλόγου αποτελεσμάτων.

Η ορθή λειτουργία της υλοποίησης υποστηρίζεται επίσης από 147 αυτοματοποιημένους ελέγχους, οργανωμένους σε δέκα αρχεία. Οι έλεγχοι καλύπτουν τη λογική της μηχανής ανίχνευσης, την αλυσίδα επεξεργασίας της ανάλυσης εκτός σύνδεσης, τη διεπαφή REST της εφαρμογής ελέγχου, τη συλλογή τηλεμετρίας, την ανανέωση των κανόνων αποκλεισμού, τα ζωντανά πειραματικά σενάρια, την ακεραιότητα βασικών αποτελεσμάτων και επιλεγμένους μηχανισμούς ασφαλείας. Ο αριθμός όσων εκτελούνται ή παραλείπονται μπορεί να διαφοροποιείται ανάλογα με τη διαθεσιμότητα του Docker και της ζωντανής υποδομής.

Οι αυτοματοποιημένοι έλεγχοι δεν αποδεικνύουν από μόνοι τους την ορθότητα των πειραματικών αποτελεσμάτων, αλλά μειώνουν τον κίνδυνο μεταβολές του κώδικα ή σφάλματα σε επιμέρους λειτουργίες να περνούν απαρατήρητα. Σε συνδυασμό με την απομόνωση των υπηρεσιών, τη δέσμευση των βασικών εξαρτήσεων, τα χωριστά σενάρια αναπαραγωγής και τον έλεγχο ακεραιότητας των αρχείων, παρέχουν ένα ελεγχόμενο πλαίσιο για την επανάληψη των πειραμάτων της εργασίας. Οι αναλυτικές εντολές εκτέλεσης και επαλήθευσης παρατίθενται στο Παράρτημα Α.

6 Πειράματα και Αποτελέσματα

Στο παρόν κεφάλαιο παρουσιάζεται η πειραματική αξιολόγηση των δύο μεθόδων που αναπτύχθηκαν στο Κεφάλαιο 5. Αρχικά εξετάζεται η Μέθοδος Α, η οποία αφορά τη ζωντανή ανίχνευση και αντιμετώπιση επιθέσεων στο περιβάλλον Mininet/Open vSwitch και συμπληρώνεται από ελεγχόμενα πειράματα συνθετικής τηλεμετρίας και προσομοίωσης. Στη συνέχεια παρουσιάζεται η Μέθοδος Β, η οποία αφορά την εκτός σύνδεσης αξιολόγηση των μοντέλων Μηχανικής Μάθησης στο συνθετικό σύνολο δεδομένων και στο InSDN. Για κάθε πειραματικό σκέλος παρουσιάζονται οι αντίστοιχες μετρήσεις και εξηγείται τι μπορεί να συναχθεί από αυτές. Ιδιαίτερη έμφαση δίνεται στην καθυστέρηση ανίχνευσης, στην αποτελεσματικότητα της αντιμετώπισης, στην απόδοση των μοντέλων και στην ερμηνεία των αποφάσεών τους. Εξετάζονται επίσης η συμπεριφορά του συστήματος σε ειδικές συνθήκες επίθεσης και η στιβαρότητα των μοντέλων απέναντι σε προσπάθειες αποφυγής της ανίχνευσης. Τέλος, αποσαφηνίζονται οι περιορισμοί των πειραμάτων, ώστε τα αποτελέσματα να ερμηνεύονται μέσα στα όρια των συνθηκών υπό τις οποίες προέκυψαν.

6.1 Πειραματική διάταξη

Η μεθοδολογία και η υλοποίηση των δύο μεθόδων παρουσιάστηκαν αναλυτικά στο Κεφάλαιο 5. Στην παρούσα ενότητα δεν επαναλαμβάνεται η διαδικασία κατασκευής του συστήματος, αλλά αποσαφηνίζεται ο τρόπος με τον οποίο οργανώθηκε η πειραματική αξιολόγηση. Η διάκριση αυτή είναι απαραίτητη, επειδή τα αποτελέσματα του κεφαλαίου δεν προέρχονται όλα από τον ίδιο τύπο πειράματος και, συνεπώς, δεν επιτρέπουν όλα το ίδιο εύρος συμπερασμάτων.

Η αξιολόγηση οργανώνεται σε τέσσερις τύπους πειραμάτων. Οι τρεις πρώτοι αφορούν τη Μέθοδο Α και εξετάζουν διαφορετικές πλευρές της ζωντανής λειτουργίας του συστήματος. Ο τέταρτος αφορά τη Μέθοδο Β και πραγματοποιείται εκτός σύνδεσης σε ήδη διαθέσιμα σύνολα δεδομένων. Η διάκριση των τεσσάρων περιπτώσεων παρουσιάζεται συνοπτικά στο Σχήμα 6-1.

Οι τέσσερις τύποι πειραμάτων και η ροή της πληροφορίας



Σχήμα 6-1: Οι τέσσερις τύποι πειραμάτων, οι συμμετέχοντες και η ροή της πληροφορίας.

Στο Σχήμα 6-1 παρουσιάζεται πρώτα η Μέθοδος Α και στη συνέχεια η Μέθοδος Β. Στη Μέθοδο Α διακρίνονται τρεις διαφορετικές μορφές αξιολόγησης: η εκτέλεση σε επίπεδο πραγματικών πακέτων, η εισαγωγή συνθετικής τηλεμετρίας μέσω της διεπαφής του ελεγκτή και οι συμπληρωματικές προσομοιώσεις. Η Μέθοδος Β παρουσιάζεται χωριστά ως διαδικασία εκτός σύνδεσης, στην οποία χρησιμοποιούνται καταγεγραμμένα δεδομένα ροών για την εκπαίδευση και την αξιολόγηση των μοντέλων Μηχανικής Μάθησης. Με τον τρόπο αυτό γίνεται σαφής η διάκριση μεταξύ αποτελεσμάτων που προκύπτουν από πραγματική διακίνηση πακέτων στο πειραματικό δίκτυο και αποτελεσμάτων που προκύπτουν από ελεγχόμενη εισαγωγή δεδομένων, προσομοίωση ή εκτός σύνδεσης ανάλυση.

Στον πρώτο τύπο πειράματος της Μεθόδου Α χρησιμοποιούνται πραγματικά πακέτα μέσα στην πειραματική τοπολογία Mininet/Open vSwitch. Η κακόβουλη κίνηση παράγεται από κόμβο του δικτύου και διασχίζει τον μεταγωγέα Open vSwitch. Από τον μεταγωγέα συλλέγονται οι διαθέσιμες μετρήσεις της κίνησης και τροφοδοτούν τον μηχανισμό ανίχνευσης. Όταν η παρατηρούμενη συμπεριφορά χαρακτηριστεί ως ανώμαλη, το σύστημα εφαρμόζει κανόνα απόρριψης στον μεταγωγέα. Ο συγκεκριμένος τύπος πειράματος χρησιμοποιείται για να ελεγχθεί αν η ακολουθία συλλογής μετρήσεων, ανίχνευσης και εφαρμογής του κανόνα αντιμετώπισης λειτουργεί από άκρο σε άκρο στην πραγματική εκτέλεση της πειραματικής τοπολογίας.

Ο δεύτερος τύπος πειράματος της Μεθόδου Α πραγματοποιείται σε επίπεδο διεπαφής. Στην περίπτωση αυτή δεν παράγεται για κάθε σενάριο αντίστοιχη πραγματική κίνηση μέσα στο Mininet. Αντίθετα, δημιουργούνται ελεγχόμενα διανύσματα τηλεμετρίας, τα οποία αναπαριστούν διαφορετικά προφίλ δικτυακής συμπεριφοράς και εισάγονται στη διεπαφή του ελεγκτή. Η διαδικασία αυτή επιτρέπει την επαναλαμβανόμενη εξέταση της συμπεριφοράς της μηχανής απόφασης υπό συγκεκριμένες συνθήκες. Τα αποτελέσματα αυτά αξιολογούν επομένως τη λογική ανίχνευσης και απόκρισης, αλλά δεν παρουσιάζονται ως αποτελέσματα πραγματικής παραγωγής της αντίστοιχης επίθεσης στο επίπεδο πακέτων.

Ο τρίτος τύπος πειράματος της Μεθόδου Α περιλαμβάνει συμπληρωματικές προσομοιώσεις. Οι προσομοιώσεις χρησιμοποιούνται όταν το ζητούμενο είναι η μελέτη μιας συγκεκριμένης δυναμικής του συστήματος υπό ελεγχόμενες παραμέτρους, όπως η συμπεριφορά κατά τον κορεσμό του επιπέδου ελέγχου ή η επίδραση της έντασης μιας επίθεσης στην καθυστέρηση ανίχνευσης. Τα αποτελέσματα των προσομοιώσεων περιγράφουν επομένως τη συμπεριφορά του αντίστοιχου μοντέλου υπό τις εξεταζόμενες συνθήκες και δεν πρέπει να ερμηνεύονται ως μετρήσεις από φυσικό δίκτυο ή από πραγματικό ελεγκτή OpenFlow.

Αφού ολοκληρωθεί η αξιολόγηση της Μεθόδου Α, εξετάζεται χωριστά η Μέθοδος Β. Η Μέθοδος Β πραγματοποιείται εξ ολοκλήρου εκτός σύνδεσης και χρησιμοποιεί το συνθετικό σύνολο δεδομένων της εργασίας και το δημόσιο σύνολο δεδομένων InSDN [24]. Στο σκέλος αυτό συγκρίνεται η ικανότητα των μοντέλων Μηχανικής Μάθησης να διακρίνουν διαφορετικές κατηγορίες δικτυακής κίνησης υπό κοινές συνθήκες αξιολόγησης. Δεν συμμετέχει η ζωντανή τοπολογία Mininet και δεν εφαρμόζονται κανόνες αντιμετώπισης στον μεταγωγέα. Επομένως, τα αποτελέσματα της Μεθόδου Β αφορούν την απόδοση των μοντέλων ταξινόμησης και όχι τη λειτουργία του ολοκληρωμένου μηχανισμού ανίχνευσης και αντιμετώπισης σε πραγματικό χρόνο.

Οι τέσσερις τύποι πειραμάτων και τα όρια των συμπερασμάτων που μπορούν να εξαχθούν από καθέναν συνοψίζονται στον Πίνακα 6-1

Πίνακας 6-1: Τύποι πειραμάτων και το εύρος των συμπερασμάτων που επιτρέπουν.

Μέθοδος	Τύπος πειράματος	Υλοποίηση	Τι τεκμηριώνει	Όρια ερμηνείας
Μέθοδος Α	Πείραμα σε επίπεδο πακέτων	simulation/mininet live.py: παραγωγή πλημμύρας SYN με hping3, συλλογή τηλεμετρίας μέσω onvs-ofctl dump-flows	Ότι ο βρόχος συλλογής μετρήσεων,	Δεν τεκμηριώνει ότι όλα τα υπόλοιπα

		και εφαρμογή κανόνα απόρριψης στον Open vSwitch	ανίχνευσης και εφαρμογής του κανόνα αντιμετώπισης λειτουργεί από άκρο σε άκρο με πραγματικά πακέτα στο συγκεκριμένο σενάριο πλημμύρας SYN	σενάρια επίθεσης έχουν εκτελεστεί σε επίπεδο πραγματικών πακέτων
Μέθοδος A	Πειράματα συνθετικής τηλεμετρίας σε επίπεδο διεπαφής	run_live_experiments.sh: κατασκευασμένα διανύσματα στατιστικών που αποστέλλονται στη διεπαφή /telemetry	Τη συμπεριφορά της μηχανής απόφασης και του μηχανισμού απόκρισης υπό ελεγχόμενα προφίλ δικτυακής συμπεριφοράς	Δεν αποτελούν πραγματική παραγωγή της αντίστοιχης επίθεσης μέσα στο δίκτυο Mininet
Μέθοδος A	Προσομοίωση διακριτών γεγονότων	simulation/control_plane_saturation.py, ml_pipeline/latency_analysis.py, mitigation_analysis.py	Τη δυναμική του κορεσμού του επιπέδου ελέγχου και τη συμπεριφορά της μηχανής απόφασης υπό διαφορετικές εντάσεις και παραμέτρους	Τα αποτελέσματα εξαρτώνται από τις παραδοχές και τις παραμέτρους της προσομοίωσης και δεν αποτελούν άμεσες μετρήσεις πραγματικού ελεγκτή
Μέθοδος B	Αξιολόγηση εκτός σύνδεσης	ml_pipeline/, συνθετικό σύνολο δεδομένων και InSDN	Τη συγκριτική ικανότητα των μοντέλων Μηχανικής Μάθησης να ταξινομούν καταγεγραμμένα δεδομένα δικτυακών ροών	Δεν τεκμηριώνει από μόνη της λειτουργία του μοντέλου σε πραγματικό χρόνο ούτε εφαρμογή μηχανισμού αντιμετώπισης στο δίκτυο

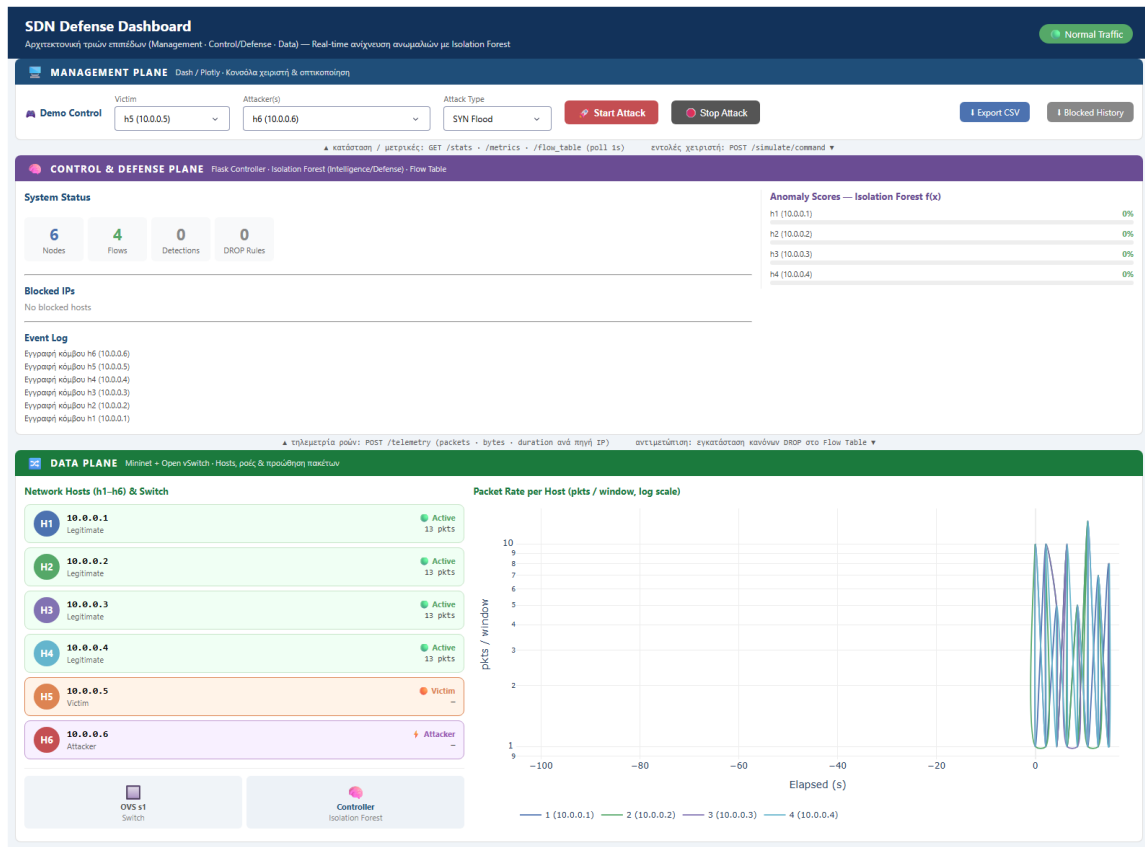
Όπως φαίνεται στον Πίνακα 6-1, οι τέσσερις τύποι αξιολόγησης είναι συμπληρωματικοί, αλλά δεν είναι ισοδύναμοι ως προς το είδος των συμπερασμάτων που επιτρέπουν. Το πείραμα σε επίπεδο πακέτων βρίσκεται πλησιέστερα στην πραγματική λειτουργία της πειραματικής τοπολογίας, καθώς περιλαμβάνει πραγματική κίνηση και εφαρμογή κανόνα στον Open vSwitch. Τα πειράματα συνθετικής τηλεμετρίας επιτρέπουν μεγαλύτερο έλεγχο των τιμών εισόδου και διευκολύνουν την επαναλαμβανόμενη εξέταση διαφορετικών προφίλ συμπεριφοράς, χωρίς όμως να αποτελούν πραγματική εκτέλεση των αντίστοιχων επιθέσεων στο δίκτυο. Οι προσομοιώσεις χρησιμοποιούνται για την εξέταση ειδικών συνθηκών υπό καθορισμένες παραμέτρους, ενώ η αξιολόγηση εκτός σύνδεσης της Μεθόδου B επιτρέπει τη σύγκριση διαφορετικών μοντέλων πάνω στα ίδια δεδομένα. Η διάκριση αυτή διατηρείται σε όλη τη συνέχεια του κεφαλαίου, ώστε κάθε αποτέλεσμα να συνδέεται με τον τύπο πειράματος από τον οποίο προέκυψε.

6.2 Μέθοδος A: Πείραμα σε επίπεδο πακέτων με πλημμύρα SYN (SYN flood)

Η παρουσίαση των αποτελεσμάτων της Μεθόδου A αρχίζει από το πείραμα σε επίπεδο πακέτων (packet-level experiment), καθώς αυτό αποτελεί τη δοκιμή στην οποία χρησιμοποιήθηκε πραγματική δικτυακή κίνηση μέσα στην τοπολογία Mininet/Open vSwitch. Η πειραματική διάταξη και ο μηχανισμός συλλογής της τηλεμετρίας έχουν παρουσιαστεί στην παράγραφο 5.3. Στην παρούσα ενότητα εξετάζεται αποκλειστικά το αποτέλεσμα της εκτέλεσης: αν η κακόβουλη κίνηση ανιχνεύεται, αν ο κανόνας απόρριψης (drop rule) εφαρμόζεται πράγματι στον μεταγωγέα (switch) και αν η αντιμετώπιση παραμένει ενεργή όσο συνεχίζεται η επίθεση.

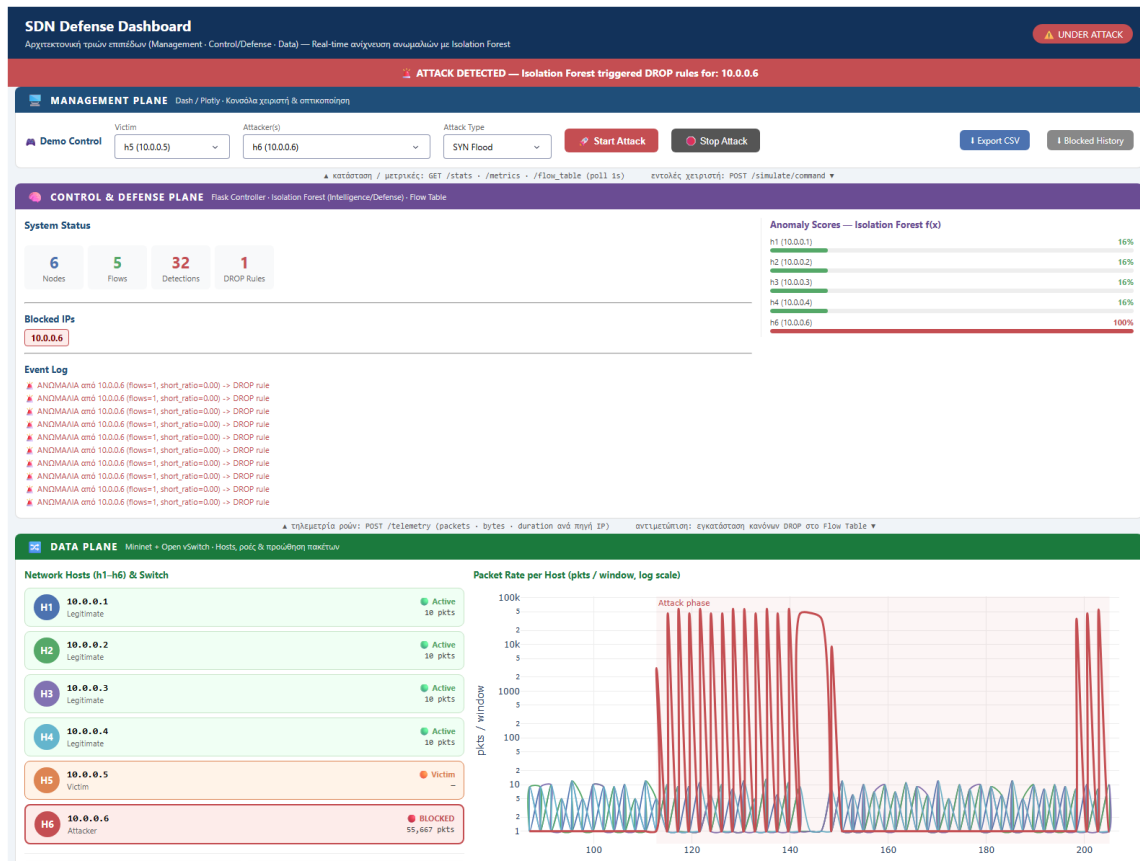
Στο συγκεκριμένο σενάριο, ο κόμβος h6 (10.0.0.6) λειτουργεί ως επιτιθέμενος και παράγει πλημμύρα πακέτων SYN προς τον κόμβο h5 (10.0.0.5) με το εργαλείο hping3. Η τηλεμετρία δεν εισάγεται τεχνητά στη διεπαφή (interface) του ελεγκτή, αλλά προκύπτει από τα πραγματικά στατιστικά των καταχωρήσεων ροής (flow entries) του Open vSwitch. Με τον τρόπο αυτό, το συγκεκριμένο πείραμα διαφοροποιείται από τις δοκιμές συνθετικής τηλεμετρίας που παρουσιάζονται αργότερα στο κεφάλαιο.

Πριν από την έναρξη της επίθεσης, ο πίνακας εποπτείας (monitoring dashboard) παρουσιάζει την κατάσταση κανονικής λειτουργίας του συστήματος, όπως φαίνεται στο Σχήμα 6-2. Στο συγκεκριμένο στιγμιότυπο δεν έχει καταγραφεί ανίχνευση, δεν έχει εγκατασταθεί κανόνας απόρριψης και δεν εμφανίζεται αποκλεισμένος κόμβος. Οι νόμιμοι κόμβοι h1 έως h4 εμφανίζονται ενεργοί και οι αντίστοιχες ενδείξεις ανωμαλίας τους παραμένουν στο 0%. Η κατάσταση αυτή χρησιμοποιείται ως σημείο αναφοράς για τη σύγκριση με τη συμπεριφορά του συστήματος μετά την έναρξη της πλημμύρας SYN.



Σχήμα 6-2: Πίνακας εποπτείας (monitoring dashboard) κατά τη φάση κανονικής λειτουργίας. Δεν έχει καταγραφεί ανίχνευση, δεν υπάρχει ενεργός κανόνας απόρριψης (drop rule) και δεν εμφανίζεται αποκλεισμένος κόμβος. Οι νόμιμοι κόμβοι h1 έως h4 εμφανίζονται ενεργοί με μηδενική ένδειξη ανωμαλίας στο συγκεκριμένο στιγμιότυπο.

Μετά την έναρξη της επίθεσης, η κατάσταση του συστήματος μεταβάλλεται, όπως παρουσιάζεται στο Σχήμα 6-3. Ο κόμβος h6 αναγνωρίζεται ως η πηγή της ανώμαλης δραστηριότητας και εμφανίζεται πλέον σε κατάσταση αποκλεισμού (blocked). Παράλληλα, στον πίνακα εποπτείας εμφανίζεται ένας ενεργός κανόνας απόρριψης, ενώ οι νόμιμοι κόμβοι h1 έως h4 παραμένουν ενεργοί. Η εικόνα αποτυπώνει επομένως τη μετάβαση από την παρακολούθηση της κίνησης στην ενεργοποίηση του μηχανισμού αντιμετώπισης.



Σχήμα 6-3: Πίνακας εποπτείας (monitoring dashboard) κατά τη φάση της πλημμύρας SYN (SYN flood). Ο κόμβος h6 (10.0.0.6) εμφανίζεται ως αποκλεισμένος, έχει εγκατασταθεί ένας κανόνας απόρριψης (drop rule) και η αντίστοιχη ένδειξη ανωμαλίας του φτάνει στο 100%, ενώ οι κόμβοι h1 και h4 παραμένουν ενεργοί.

Κατά την εκτέλεση αναφοράς, η πρώτη τηλεμετρία που περιείχε την κακόβουλη δραστηριότητα καταγράφηκε 1,14 s μετά την έναρξη της επίθεσης. Η απόφαση του μοντέλου παρήχθη στα 1,16 s και ο κανόνας απόρριψης εγκαταστάθηκε στον μεταγωγέα στα 1,17 s. Το πρώτο πραγματικά απορριφθέν πακέτο καταγράφηκε περίπου στα 1,5 s. Η τελευταία μέτρηση έχει ακρίβεια περίπου $\pm 0,5$ s, επειδή ο μετρητής του κανόνα απόρριψης ελεγχόταν ανά μισό δευτερόλεπτο. Αντίθετα, οι χρόνοι της απόφασης και της εγκατάστασης του κανόνα προέρχονται από άμεσες χρονοσημάνσεις (timestamps) της εκτέλεσης.

Η ύπαρξη του κανόνα απόρριψης από μόνη της δεν αρκεί για να αποδειχθεί ότι πραγματοποιήθηκε πραγματική αντιμετώπιση. Για τον λόγο αυτό εξετάστηκε και ο μετρητής πακέτων (packet counter) του συγκεκριμένου κανόνα στον Open vSwitch. Στην εκτέλεση αναφοράς καταγράφηκαν συνολικά 1.456.155 απορριφθέντα πακέτα. Επομένως, ο κανόνας δεν εγκαταστάθηκε απλώς στον πίνακα ροών (flow table), αλλά χρησιμοποιήθηκε πράγματι για την απόρριψη της κακόβουλης κίνησης στο επίπεδο δεδομένων (data plane).

Ο κανόνας απόρριψης έχει πεπερασμένο χρόνο ζωής (rule lifetime). Στην παρούσα υλοποίηση η σχετική παράμετρος συμβολίζεται ως TTL. Επομένως, σε μια επίθεση μεγαλύτερης διάρκειας απαιτείται η ανανέωσή του, εφόσον η πηγή εξακολουθεί να χαρακτηρίζεται ως κακόβουλη. Στην εκτέλεση διάρκειας περίπου 60 s, με χρόνο ζωής του κανόνα ίσο με 10 s, χρησιμοποιήθηκαν συνολικά εννέα διαδοχικές περίοδοι ισχύος, δηλαδή πραγματοποιήθηκαν οκτώ ανανεώσεις. Η συνολική κάλυψη της επίθεσης έφτασε το 97,7%, ενώ από τη στιγμή της πρώτης ανίχνευσης και μετά η κάλυψη ήταν 100%. Το τμήμα της επίθεσης που δεν καλύφθηκε αντιστοιχεί στο αρχικό χρονικό διάστημα πριν από την πρώτη ανίχνευση.

Για να εξεταστεί η επίδραση του χρόνου ζωής και της ανανέωσης του κανόνα, το πείραμα επαναλήφθηκε με διαφορετικές ρυθμίσεις. Τα αποτελέσματα παρουσιάζονται στον Πίνακα 6-2.

Πίνακας 6-2: Κάλυψη αντιμετώπισης σε πραγματική εκτέλεση σε επίπεδο πακέτων (επίθεση 60 s), συναρτήσει του χρόνου ζωής του κανόνα και της ανανέωσης.

Ρύθμιση	Χρόνος ζωής, TTL (s)	Ανανέωση	Κάλυψη συνολικής επίθεσης	Κάλυψη μετά την ανίχνευση	Περίοδοι ισχύος (ανανεώσεις)	Απορριφθέντα πακέτα
Κανονική	10	Προληπτική	97,7%	100%	9 (8)	1.456.155
Χωρίς προληπτική ανανέωση	10	Αντιδραστική	91,4%	93,6%	6 (5)	1.333.599
Μικρός χρόνος ζωής	5	Προληπτική	96,9%	100%	21 (20)	1.415.331
Μεγάλος χρόνος ζωής	20	Προληπτική	97,7%	100%	5 (4)	1.458.553

Όπως φαίνεται στον Πίνακα 6-2, όταν χρησιμοποιείται προληπτική ανανέωση (proactive renewal), η κάλυψη μετά την πρώτη ανίχνευση παραμένει 100% και για τις τρεις εξεταζόμενες τιμές του χρόνου ζωής. Η βασική διαφορά εντοπίζεται στο πλήθος των ανανεώσεων. Με χρόνο ζωής 5 s απαιτήθηκαν είκοσι ανανεώσεις, ενώ με χρόνο ζωής 20 s απαιτήθηκαν μόνο τέσσερις. Αντίθετα, όταν η προληπτική ανανέωση απενεργοποιήθηκε και χρησιμοποιήθηκε αντιδραστική ανανέωση (reactive renewal), η κάλυψη μετά την ανίχνευση μειώθηκε στο 93,6%. Αυτό συμβαίνει επειδή μετά τη λήξη ενός κανόνα μεσολαβεί χρονικό διάστημα κατά το οποίο η κακόβουλη κίνηση πρέπει να γίνει ξανά ορατή, να ανιχνευθεί και να οδηγήσει σε νέα εγκατάσταση κανόνα. Το αποτέλεσμα δείχνει ότι η ανανέωση είναι

σημαντική για τη συνεχή αντιμετώπιση μιας επίθεσης που διαρκεί περισσότερο από τον χρόνο ζωής ενός μεμονωμένου κανόνα.

Η αξιολόγηση δεν περιορίστηκε σε μία μόνο εκτέλεση. Το ίδιο σενάριο επαναλήφθηκε σε δέκα διαδοχικούς κύκλους επίθεσης μέσα στην ίδια εκτέλεση της πειραματικής στοίβας. Μεταξύ των κύκλων πραγματοποιήθηκε επαναφορά της κατάστασης, χωρίς όμως να επανεκκινείται ολόκληρη η τοπολογία, ο ελεγκτής και το μοντέλο. Επομένως, πρόκειται για δέκα επαναλαμβανόμενους κύκλους υπό τις ίδιες συνθήκες και όχι για δέκα πλήρως ανεξάρτητες εκτελέσεις του πειράματος. Και στους δέκα κύκλους ο επιτιθέμενος ανιχνεύθηκε και αποκλείστηκε, ενώ δεν καταγράφηκε ψευδώς θετικός αποκλεισμός (false-positive blocking) στη νόμιμη κίνηση. Τα συγκεντρωτικά αποτελέσματα παρουσιάζονται στον Πίνακα 6-3.

Πίνακας 6-3: Κατανομές των βασικών μετρικών σε δέκα επαναλαμβανόμενους κύκλους επίθεσης μέσα στην ίδια εκτέλεση.

Μετρική	Διάμεσος	Μέσος	95ο εκατοστημόριο	Διάστημα εμπιστοσύνης 95% του μέσου
Καθυστέρηση ανίχνευσης (s)	1,41	1,52	2,66	[1,06, 1,98]
Πρώτο απορριφθέν πακέτο (s) *	1,52	1,66	2,97	[1,18, 2,13]
Κάλυψη αντιμετώπισης (%)	95,6	95,0	97,1	[93,6, 96,4]
Κάλυψη μετά την ανίχνευση (%)	100	100	100	[100, 100]
Απορριφθέντα πακέτα	744.845	746.757	770.106	[736.192, 757.321]

* Ο χρόνος του πρώτου απορριφθέντος πακέτου έχει ακρίβεια δειγματοληψίας περίπου $\pm 0,5$ s, επειδή ο μετρητής του κανόνα ελεγχόταν ανά μισό δευτερόλεπτο.

Ο Πίνακας 6-3 δείχνει ότι η συμπεριφορά του συστήματος παρέμεινε σχετικά σταθερή μεταξύ των δέκα κύκλων. Η μέση καθυστέρηση ανίχνευσης ήταν 1,52 s και η διάμεση τιμή (median) 1,41 s, ενώ στο 95ο εκατοστημόριο (95th percentile) η καθυστέρηση παρέμεινε κάτω από 3 s. Η κάλυψη μετά την ανίχνευση ήταν 100% σε όλους τους κύκλους. Η συνολική κάλυψη είναι μικρότερη, με μέση τιμή 95,0%, επειδή περιλαμβάνει και το αρχικό διάστημα της επίθεσης πριν από την πρώτη απόφαση του μοντέλου.

Παράλληλα εξετάστηκε η επίδραση της αντιμετώπισης στη νόμιμη κίνηση μέσω πακέτων ping. Στους δέκα κύκλους δεν καταγράφηκε απώλεια πακέτων (packet loss) ούτε πριν ούτε κατά τη διάρκεια της επίθεσης. Ο μέσος χρόνος μετάβασης και επιστροφής (Round-Trip

Time, RTT) ήταν περίπου 4,52 ms στη φυσιολογική λειτουργία και 4,29 ms κατά τη διάρκεια της επίθεσης. Μετά την αποκατάσταση καταγράφηκε μία επιπλέον μέτρηση με μέσο RTT περίπου 4,47 ms και μηδενική απώλεια πακέτων. Η τελευταία τιμή προέρχεται από μία μόνο μέτρηση και, για τον λόγο αυτό, δεν αντιμετωπίζεται ως μέσος όρος δέκα κύκλων.

Τα αποτελέσματα αυτά πρέπει να ερμηνεύονται μέσα στα όρια των μεγεθών που πράγματι μετρήθηκαν. Η αξιολόγηση της επίδρασης στη νόμιμη κίνηση αφορά την απώλεια πακέτων και τον χρόνο μετάβασης και επιστροφής (RTT). Δεν μετρήθηκαν η ρυθμαπόδοση του δικτύου (throughput), η διακύμανση της καθυστέρησης (jitter) ούτε η χρήση της κεντρικής μονάδας επεξεργασίας (CPU utilization) και της μνήμης του ελεγκτή. Επομένως, δεν μπορεί να υποστηριχθεί γενικά ότι ο μηχανισμός αντιμετώπισης δεν επιβαρύνει το δίκτυο. Μπορεί όμως να υποστηριχθεί ότι, στις συγκεκριμένες μετρήσεις, ο αποκλεισμός του επιτιθέμενου δεν προκάλεσε απώλεια πακέτων ή αύξηση του RTT στη νόμιμη κίνηση που εξετάστηκε.

Συνολικά, το πείραμα σε επίπεδο πακέτων δείχνει ότι, για το συγκεκριμένο σενάριο πλημμύρας SYN και τη συγκεκριμένη πειραματική τοπολογία, ο πλήρης βρόχος της Μεθόδου Α λειτουργεί από τη συλλογή πραγματικής τηλεμετρίας έως την εφαρμογή και την ανανέωση του κανόνα απόρριψης στον Open vSwitch. Το συμπέρασμα αυτό περιορίζεται στο συγκεκριμένο σενάριο και δεν επεκτείνεται στα υπόλοιπα είδη επιθέσεων, τα οποία αξιολογούνται με διαφορετικό πειραματικό τρόπο στην επόμενη ενότητα.

6.3 Μέθοδος Α: Αξιολόγηση με συνθετική τηλεμετρία

Μετά το πείραμα σε επίπεδο πραγματικών πακέτων, η αξιολόγηση της Μεθόδου Α συνεχίζεται με πέντε σενάρια συνθετικής τηλεμετρίας (synthetic telemetry). Στα πειράματα αυτά δεν παράγεται η αντίστοιχη επίθεση ως πραγματική δικτυακή κίνηση μέσα στο Mininet. Αντίθετα, δημιουργούνται ελεγχόμενα διανύσματα στατιστικών χαρακτηριστικών, τα οποία αποστέλλονται στη διεπαφή προγραμματισμού εφαρμογών (Application Programming Interface, API) του ελεγκτή και, ειδικότερα, στο σημείο πρόσβασης /telemetry. Με τον τρόπο αυτό εξετάζεται η συμπεριφορά του μηχανισμού λήψης απόφασης (decision engine) όταν δέχεται διαφορετικά προφίλ δικτυακής δραστηριότητας. Επομένως, τα αποτελέσματα της παρούσας ενότητας αφορούν τη λειτουργία του μηχανισμού ανίχνευσης και απόκρισης υπό ελεγχόμενες εισόδους και δεν αποτελούν εκτέλεση των αντίστοιχων επιθέσεων σε επίπεδο πραγματικών πακέτων.

Σε κάθε σενάριο προηγείται μία φάση νόμιμης συμπεριφοράς και ακολουθεί η εισαγωγή του αντίστοιχου κακόβουλου προφίλ. Εξετάζονται η σάρωση θυρών (port scan), η εξαγωγή δεδομένων (data exfiltration), η εξάντληση του πίνακα ροών (flow-table exhaustion), η πλευρική κίνηση (lateral movement) και η πλαστογράφηση ARP (ARP spoofing). Τα βασικά αποτελέσματα συνοψίζονται στον Πίνακα 6-4.

Πίνακας 6-4: Αποτελέσματα των σεναρίων συνθετικής τηλεμετρίας της Μεθόδου Α.

Σενάριο	Καθυστέρηση ανίχνευσης	Αποκλεισμός	Ψευδώς θετικά
Σάρωση θυρών	0,24 s	Ναι	0
Εξαγωγή δεδομένων	0,71 s	Ναι	4
Εξάντληση πίνακα ροών	0,14 s	Ναι	0
Πλευρική κίνηση	0,31 s	Ναι	1
Πλαστογράφηση ARP	–	Ναι, ως γενική ανωμαλία	0
Μόνο νόμιμη κίνηση	–	Όχι	0/4

Όπως φαίνεται στον Πίνακα 6-4, τα αποτελέσματα δεν είναι ομοιόμορφα μεταξύ των επιμέρους σεναρίων. Η καθαρότερη συμπεριφορά παρατηρήθηκε στη σάρωση θυρών και στην εξάντληση του πίνακα ροών, όπου η κακόβουλη δραστηριότητα ανιχνεύθηκε και ο επιτιθέμενος αποκλείστηκε χωρίς να καταγραφούν ψευδώς θετικές αποφάσεις. Αντίθετα, στην εξαγωγή δεδομένων και στην πλευρική κίνηση εμφανίστηκαν λανθασμένοι χαρακτηρισμοί νόμιμης δραστηριότητας. Στην πλαστογράφηση ARP ο τελικός αποκλεισμός δεν προέκυψε από ειδική αναγνώριση της συγκεκριμένης επίθεσης, αλλά από τη γενικότερη στατιστική απόκλιση που παρουσίασε η δραστηριότητα του επιτιθέμενου.

Στο σενάριο σάρωσης θυρών, ο επιτιθέμενος παράγει μεγάλο αριθμό σύντομων ροών προς διαφορετικές θύρες. Η δραστηριότητα ανιχνεύθηκε σε 0,24 s, καταγράφηκαν δύο ορθές ανιχνεύσεις (true positives) και δεν εμφανίστηκε ψευδώς θετική απόφαση. Ο επιτιθέμενος αποκλείστηκε επιτυχώς. Το αποτέλεσμα δείχνει ότι, στο συγκεκριμένο ελεγχόμενο προφίλ τηλεμετρίας, το στατιστικό αποτύπωμα των πολλών σύντομων ροών ήταν αρκετά διαφορετικό από εκείνο της νόμιμης συμπεριφοράς ώστε να ενεργοποιηθεί ο μηχανισμός ανίχνευσης.

Στο σενάριο εξάντλησης του πίνακα ροών καταγράφηκε η μικρότερη καθυστέρηση μεταξύ των πέντε σεναρίων συνθετικής τηλεμετρίας. Η μέση τιμή ήταν 0,14 s, ενώ οι επιμέρους χρόνοι ανίχνευσης των τεσσάρων κακόβουλων κόμβων κυμάνθηκαν από 0,04 έως 0,22 s. Και οι τέσσερις κόμβοι αποκλείστηκαν χωρίς ψευδώς θετικές αποφάσεις. Στο συγκεκριμένο συνθετικό προφίλ, η ταχεία δημιουργία μεγάλου αριθμού διαφορετικών ροών προκαλεί

έντονη μεταβολή στα συγκεντρωτικά στατιστικά χαρακτηριστικά (aggregate statistical features) που εξετάζει το σύστημα. Η μεταβολή αυτή επιτρέπει τον σαφή διαχωρισμό του συγκεκριμένου προφίλ από τη νόμιμη συμπεριφορά.

Διαφορετικό αποτέλεσμα προέκυψε στην εξαγωγή δεδομένων. Στο συγκεκριμένο σενάριο αναπαρίσταται μεταφορά περίπου 9,5 MB με ρυθμό 8 Mbps. Ο επιτιθέμενος εντοπίστηκε σε 0,71 s, αλλά μαζί του αποκλείστηκαν και οι τέσσερις νόμιμοι κόμβοι. Καταγράφηκαν επομένως τέσσερις ψευδώς θετικές αποφάσεις έναντι δύο ορθών ανιχνεύσεων. Το αποτέλεσμα αυτό δεν μπορεί να θεωρηθεί ικανοποιητικό, επειδή το σύστημα χαρακτήρισε ως ανώμαλη και νόμιμη κίνηση υψηλού όγκου. Ο μη επιβλεπόμενος (unsupervised) αλγόριθμος Isolation Forest στηρίζεται στα διαθέσιμα στατιστικά χαρακτηριστικά και, στο συγκεκριμένο σενάριο, το αποτύπωμα της νόμιμης μεταφοράς μεγάλου όγκου είναι πολύ κοντά σε εκείνο της κακόβουλης εξαγωγής δεδομένων. Για τον λόγο αυτό, τα χρησιμοποιούμενα χαρακτηριστικά δεν επαρκούν για αξιόπιστο διαχωρισμό των δύο περιπτώσεων.

Αντίστοιχος περιορισμός παρατηρήθηκε στην πλευρική κίνηση. Στο συγκεκριμένο σενάριο ένας παραβιασμένος εσωτερικός κόμβος εξετάζει άλλους κόμβους του ίδιου δικτύου. Η δραστηριότητα ανιχνεύθηκε σε 0,31 s και ο επιτιθέμενος αποκλείστηκε, καταγράφηκε όμως μία ορθή ανίχνευση και μία ψευδώς θετική απόφαση. Η αναλογία αυτή δεν επιτρέπει ισχυρισμό αξιόπιστης διάκρισης της πλευρικής κίνησης από τη νόμιμη εσωτερική δραστηριότητα. Στο συγκεκριμένο πείραμα, το στατιστικό προφίλ της εσωτερικής σάρωσης παρουσιάζει επικάλυψη με νόμιμες μορφές επικοινωνίας και επομένως τα διαθέσιμα συγκεντρωτικά χαρακτηριστικά δεν επαρκούν πάντοτε για σαφή διαχωρισμό.

Η πλαστογράφηση ARP αποτελεί διαφορετική περίπτωση. Το σύστημα δεν παρήγαγε ορθή ανίχνευση της ίδιας της πλαστογράφησης: καταγράφηκαν μηδέν αληθώς θετικές περιπτώσεις (true positives) και δύο ψευδώς αρνητικές περιπτώσεις (false negatives). Ο επιτιθέμενος αποκλείστηκε τελικά επειδή η συνοδευτική δραστηριότητά του προκάλεσε γενική στατιστική ανωμαλία και όχι επειδή αναγνωρίστηκε η αλλοίωση των αντιστοιχίσεων μεταξύ διευθύνσεων IP και MAC. Επομένως, το συγκεκριμένο αποτέλεσμα δεν παρουσιάζεται ως επιτυχής ανίχνευση πλαστογράφησης ARP. Αντίθετα, αναδεικνύει έναν περιορισμό της παρούσας υλοποίησης: ο μηχανισμός χρησιμοποιεί συγκεντρωτικά στατιστικά της κίνησης και δεν εξετάζει άμεσα το περιεχόμενο των μηνυμάτων ARP ή την εγκυρότητα των αντιστοιχίσεων IP-MAC.

Πραγματοποιήθηκε επίσης έλεγχος με αποκλειστικά νόμιμη τηλεμετρία. Στις τέσσερις περιπτώσεις που εξετάστηκαν δεν καταγράφηκε ψευδώς θετική απόφαση και δεν εφαρμόστηκε αποκλεισμός. Το αποτέλεσμα αποτελεί θετική ένδειξη για το συγκεκριμένο ελεγχόμενο προφίλ νόμιμης δραστηριότητας. Ωστόσο, το μικρό πλήθος των εξεταζόμενων περιπτώσεων δεν επαρκεί για την εξαγωγή γενικού συμπεράσματος σχετικά με τον ρυθμό ψευδώς θετικών αποφάσεων (false-positive rate) σε διαφορετικές μορφές πραγματικής δικτυακής κίνησης.

Συνολικά, τα σενάρια συνθετικής τηλεμετρίας δείχνουν ότι η Μέθοδος Α ανταποκρίνεται σαφέστερα όταν το εξεταζόμενο κακόβουλο προφίλ παρουσιάζει έντονη στατιστική διαφοροποίηση από τη νόμιμη δραστηριότητα, όπως στη σάρωση θυρών και στην εξάντληση του πίνακα ροών. Αντίθετα, όταν η κακόβουλη συμπεριφορά παρουσιάζει σημαντική στατιστική επικάλυψη με νόμιμη κίνηση, όπως στην εξαγωγή δεδομένων και στην πλευρική κίνηση, αυξάνεται ο κίνδυνος ψευδώς θετικών αποφάσεων. Η περίπτωση της πλαστογράφησης ARP δείχνει επιπλέον ότι επιθέσεις των οποίων η αναγνώριση εξαρτάται από πληροφορία σε επίπεδο συγκεκριμένου πρωτοκόλλου δεν μπορούν να προσδιοριστούν αξιόπιστα μόνο από τα συγκεντρωτικά στατιστικά χαρακτηριστικά που χρησιμοποιεί το παρόν σύστημα. Τα συμπεράσματα αυτά αφορούν τα συγκεκριμένα ελεγχόμενα προφίλ συνθετικής τηλεμετρίας και δεν αποτελούν απόδειξη αντίστοιχης συμπεριφοράς σε πραγματική εκτέλεση των πέντε επιθέσεων σε επίπεδο πακέτων.

6.4 Μέθοδος Α: Καθυστέρηση ανίχνευσης και αποτελεσματικότητα αντιμετώπισης

Μετά την αξιολόγηση των επιμέρους σεναρίων, εξετάστηκε συμπληρωματικά η συμπεριφορά της Μεθόδου Α ως προς την καθυστέρηση ανίχνευσης (detection latency) και την αποτελεσματικότητα του μηχανισμού αντιμετώπισης. Οι δοκιμές της παρούσας ενότητας πραγματοποιήθηκαν μέσω προσομοίωσης και δεν αποτελούν επαναλήψεις του πειράματος σε επίπεδο πραγματικών πακέτων της παραγράφου 6.2. Για τον λόγο αυτό, οι χρόνοι που παρουσιάζονται εδώ δεν πρέπει να συγκρίνονται άμεσα με τον χρόνο των 1,16 s της εκτέλεσης πλημμύρας SYN. Στην παρούσα ανάλυση η καθυστέρηση προσδιορίζεται με βάση διαδοχικά παράθυρα συλλογής τηλεμετρίας (telemetry collection windows), διάρκειας 5 s, από το πρώτο παράθυρο στο οποίο εμφανίζεται η επίθεση έως το πρώτο παράθυρο στο οποίο παράγεται απόφαση ανίχνευσης.

Για τη μελέτη της επίδρασης της έντασης της επίθεσης εξετάστηκαν εννέα επίπεδα, από 10 έως 200 κακόβουλες ροές ανά παράθυρο. Για κάθε επίπεδο πραγματοποιήθηκαν 30 επαναλήψεις της προσομοίωσης με διαφορετική αρχικοποίηση των τυχαίων τιμών, δηλαδή συνολικά 270 προσομοιωμένες δοκιμές. Ο Πίνακας 6-5 παρουσιάζει τον ρυθμό ανίχνευσης (detection rate), τη μέση καθυστέρηση ανίχνευσης και τις αστοχίες ανίχνευσης για κάθε εξεταζόμενη ένταση.

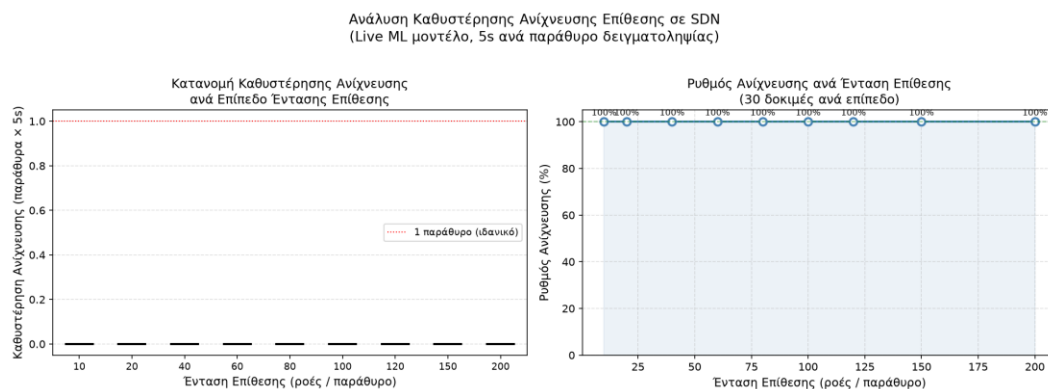
Πίνακας 6-5: Ρυθμός ανίχνευσης και καθυστέρηση ανά ένταση επίθεσης σε 30 προσομοιώσεις ανά επίπεδο.

Ένταση επίθεσης (ροές ανά παράθυρο)	Ρυθμός ανίχνευσης	Μέση καθυστέρηση	Αστοχίες ανίχνευσης
10	100%	0,0 s	0/30
20	100%	0,0 s	0/30
40	100%	0,0 s	0/30
60	100%	0,0 s	0/30
80	100%	0,0 s	0/30
100	100%	0,0 s	0/30
120	100%	0,0 s	0/30
150	100%	0,0 s	0/30
200	100%	0,0 s	0/30

Όπως φαίνεται στον Πίνακα 6-5, η επίθεση ανιχνεύθηκε σε όλες τις προσομοιώσεις και σε όλα τα εξεταζόμενα επίπεδα έντασης. Ο ρυθμός ανίχνευσης εκφράζει εδώ το ποσοστό των προσομοιώσεων στις οποίες η επίθεση ανιχνεύθηκε τουλάχιστον μία φορά. Επομένως, η τιμή 100% σημαίνει ότι πραγματοποιήθηκε επιτυχής ανίχνευση και στις 30 δοκιμές κάθε εξεταζόμενου επιπέδου έντασης. Δεν εκφράζει το ποσοστό των επιμέρους χρονικών παραθύρων στα οποία παράχθηκε νέα απόφαση ανίχνευσης.

Η πρώτη απόφαση λήφθηκε στο ίδιο παράθυρο συλλογής τηλεμετρίας στο οποίο εμφανίστηκε για πρώτη φορά η επίθεση. Για τον λόγο αυτό, η καταγεγραμμένη καθυστέρηση είναι 0,0 s σύμφωνα με τον ορισμό που χρησιμοποιείται στη συγκεκριμένη προσομοίωση. Η τιμή αυτή δεν σημαίνει ότι ένα πραγματικό πακέτο ανιχνεύεται χωρίς χρονική καθυστέρηση. Σημαίνει ότι δεν απαιτήθηκε ένα επιπλέον παράθυρο τηλεμετρίας μετά την εμφάνιση της επίθεσης για να παραχθεί η πρώτη απόφαση ανίχνευσης.

Η συμπεριφορά αυτή σχετίζεται με τον τρόπο κατασκευής των προφίλ της συγκεκριμένης προσομοίωσης. Η φυσιολογική δραστηριότητα παράχθηκε με περίπου τέσσερις ροές ανά παράθυρο κατά μέσο όρο, ενώ ακόμη και η χαμηλότερη εξεταζόμενη ένταση επίθεσης αντιστοιχούσε σε δέκα ροές ανά παράθυρο και παρουσίαζε διαφορετικά χαρακτηριστικά διάρκειας και όγκου. Επομένως, ακόμη και το ηπιότερο εξεταζόμενο προφίλ παρουσίαζε σαφή στατιστική απόκλιση από τη φυσιολογική συμπεριφορά. Το αποτέλεσμα δείχνει ότι το μοντέλο διαχώρισε αποτελεσματικά τα συγκεκριμένα προφίλ που δημιουργήθηκαν για την προσομοίωση, αλλά δεν αποτελεί απόδειξη ότι κάθε επίθεση χαμηλής έντασης θα ανιχνεύεται από το πρώτο παράθυρο σε πραγματική δικτυακή κίνηση. Η συμπεριφορά αυτή αποτυπώνεται και στο Σχήμα 6-4.



Σχήμα 6-4: Καθυστερήση ανίχνευσης (detection latency) και ρυθμός ανίχνευσης (detection rate) συναρτήσει της έντασης της επίθεσης.

Στο Σχήμα 6-4 ο ρυθμός ανίχνευσης παραμένει στο 100% για όλα τα εξεταζόμενα επίπεδα έντασης, ενώ η καθυστέρηση παραμένει μηδενική ως προς τον αριθμό των πρόσθετων παραθύρων που απαιτούνται μέχρι την πρώτη απόφαση. Η απουσία διαφοροποίησης μεταξύ των εντάσεων δεν πρέπει να ερμηνευθεί ως ένδειξη ότι η ένταση της επίθεσης δεν επηρεάζει γενικά την ανίχνευση. Δείχνει ότι, μέσα στο συγκεκριμένο εύρος τιμών και με τον συγκεκριμένο τρόπο δημιουργίας των δεδομένων της προσομοίωσης, ακόμη και η χαμηλότερη εξεταζόμενη ένταση ήταν ήδη αρκετά διακριτή από το φυσιολογικό προφίλ. Στην προηγούμενη έκδοση της διπλωματικής το συγκεκριμένο διάγραμμα χρησιμοποιούνταν επίσης για την παρουσίαση της ανάλυσης καθυστέρησης και έντασης.

δεύτερη συμπληρωματική ανάλυση αφορά την αποτελεσματικότητα της αντιμετώπισης μετά την ανίχνευση. Πραγματοποιήθηκαν 50 προσομοιώσεις ενός σεναρίου το οποίο

περιλαμβάνει αρχικά νόμιμη κίνηση, στη συνέχεια μία περίοδο επίθεσης, ένα ενδιάμεσο διάστημα χωρίς επίθεση και, τέλος, επανεμφάνιση της κακόβουλης δραστηριότητας. Με τον τρόπο αυτό εξετάστηκε όχι μόνο η πρώτη αντίδραση του συστήματος, αλλά και η συμπεριφορά του μετά τη λήξη ενός προσωρινού αποκλεισμού.

Για κάθε δοκιμή υπολογίστηκαν ο χρόνος μέχρι την πρώτη ανίχνευση, η κάλυψη της επίθεσης από ενεργό αποκλεισμό (mitigation coverage), η μείωση της κακόβουλης κίνησης (traffic reduction), ο ρυθμός ψευδώς θετικών αποφάσεων (false-positive rate) και το ποσοστό των παραθύρων της επαναλαμβανόμενης επίθεσης στα οποία παράχθηκε νέα απόφαση ανίχνευσης. Τα συγκεντρωτικά αποτελέσματα παρουσιάζονται στον Πίνακα 6-6.

Πίνακας 6-6: Μετρικές αποτελεσματικότητας αντιμετώπισης σε 50 προσομοιώσεις.

Μετρική	Μέση τιμή	Τυπική απόκλιση
Χρόνος μέχρι την πρώτη ανίχνευση	0,0 s	$\pm 0,0$ s
Κάλυψη της επίθεσης από ενεργό αποκλεισμό	74,2%	$\pm 0,0\%$
Μείωση της κακόβουλης κίνησης	74,3%	$\pm 1,1\%$
Ρυθμός ψευδώς θετικών	0,0%	$\pm 0,0\%$
Παράθυρα της επαναλαμβανόμενης επίθεσης με νέα απόφαση ανίχνευσης	25,0%	$\pm 0,0\%$

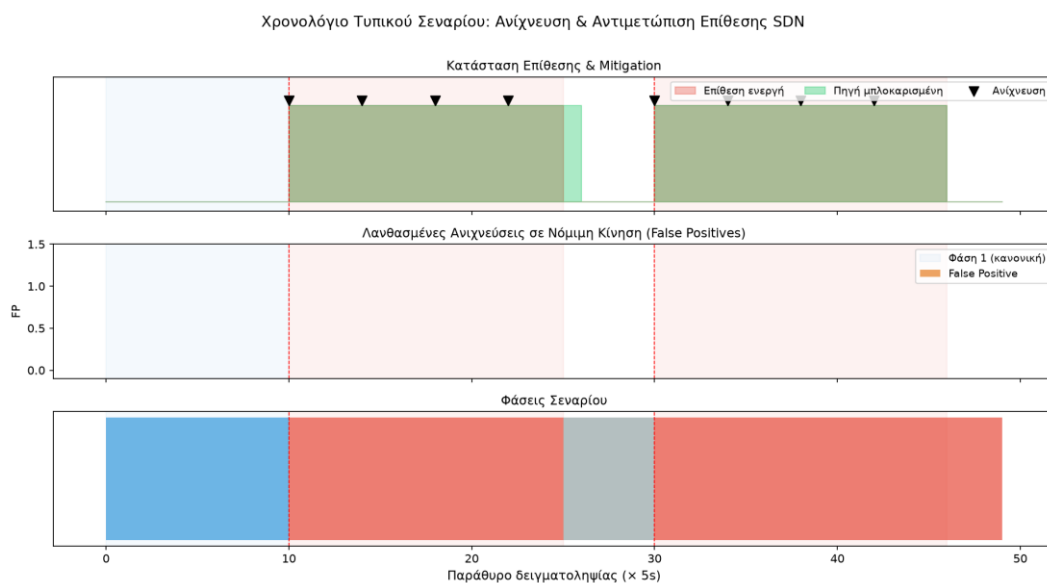
Η μηδενική τιμή του χρόνου μέχρι την πρώτη ανίχνευση έχει την ίδια ερμηνεία με την προηγούμενη ανάλυση. Η πρώτη απόφαση παράγεται στο ίδιο παράθυρο στο οποίο αρχίζει η επίθεση και όχι πριν από την εμφάνισή της. Επομένως, η τιμή 0,0 s δηλώνει ότι δεν απαιτήθηκε ένα επιπλέον παράθυρο συλλογής τηλεμετρίας για την αναγνώριση του συγκεκριμένου συνθετικού προφίλ.

Η κάλυψη της επίθεσης από ενεργό αποκλεισμό ήταν 74,2%, ενώ η μέση μείωση της κακόβουλης κίνησης ήταν 74,3%. Οι δύο τιμές είναι παρόμοιες, επειδή όταν ο κανόνας αποκλεισμού είναι ενεργός, οι αντίστοιχες κακόβουλες ροές θεωρούνται ότι δεν φτάνουν στον μηχανισμό λήψης απόφασης (decision engine). Η κάλυψη δεν φτάνει το 100%, επειδή ο αποκλεισμός έχει περιορισμένη διάρκεια. Μετά τη λήξη του πρέπει να εμφανιστεί ξανά κακόβουλη δραστηριότητα και να παραχθεί νέα απόφαση πριν ενεργοποιηθεί ο επόμενος αποκλεισμός.

Στις 50 προσομοιώσεις δεν καταγράφηκε ψευδώς θετική απόφαση στο συγκεκριμένο προφίλ νόμιμης κίνησης. Η τιμή αυτή αφορά αποκλειστικά το συγκεκριμένο σενάριο

προσομοίωσης και δεν αναιρεί τις ψευδώς θετικές αποφάσεις που καταγράφηκαν στα σενάρια εξαγωγής δεδομένων και πλευρικής κίνησης της παραγράφου 6.3. Η διάκριση είναι σημαντική, επειδή τα διαφορετικά πειράματα χρησιμοποιούν διαφορετικά προφίλ εισόδου.

Κατά τη δεύτερη περίοδο επίθεσης, νέα απόφαση ανίχνευσης καταγράφηκε στο 25% των χρονικών παραθύρων. Η συγκεκριμένη μετρική έχει διαφορετική σημασία από τον ρυθμό ανίχνευσης του Πίνακα 6-5. Η τιμή 25% δεν σημαίνει ότι η επανεμφάνιση της επίθεσης αναγνωρίστηκε μόνο στο ένα τέταρτο των δοκιμών. Εκφράζει το ποσοστό των παραθύρων της δεύτερης περιόδου επίθεσης στα οποία χρειάστηκε και παράχθηκε νέα απόφαση ανίχνευσης. Στα υπόλοιπα παράθυρα ο επιτιθέμενος βρισκόταν ήδη υπό ενεργό αποκλεισμό και, επομένως, δεν απαιτούνταν νέα απόφαση. Συνεπώς, το 100% του Πίνακα 6-5 και το 25% του Πίνακα 6-6 δεν είναι αντιφατικές τιμές: η πρώτη τιμή δείχνει ότι η επίθεση ανιχνεύθηκε σε όλες τις αντίστοιχες προσομοιώσεις, ενώ η δεύτερη περιγράφει πόσο συχνά χρειάστηκε να παραχθεί νέα απόφαση κατά τη διάρκεια της επαναλαμβανόμενης επίθεσης.



Σχήμα 6-5: Χρονολόγιο (timeline) τυπικού σεναρίου αντιμετώπισης: ανίχνευση, αποκλεισμός και νέα ανίχνευση μετά τη λήξη του αποκλεισμού.

Στο Σχήμα 6-5 διακρίνονται οι περίοδοι κατά τις οποίες η επίθεση είναι ενεργή, τα χρονικά διαστήματα στα οποία η πηγή βρίσκεται υπό αποκλεισμό και τα σημεία στα οποία παράγεται νέα απόφαση ανίχνευσης. Το σχήμα δείχνει ότι η αντιμετώπιση δεν αποτελεί μία μοναδική ενέργεια που παραμένει ενεργή σε όλη τη διάρκεια του πειράματος. Ο κανόνας αποκλεισμού

έχει καθορισμένο χρόνο ισχύος και, όταν αυτός λήξει ενώ η επίθεση συνεχίζεται ή επανεμφανίζεται, απαιτείται νέα ανίχνευση και επανενεργοποίηση του αποκλεισμού.

Συνολικά, οι δύο συμπληρωματικές αναλύσεις δείχνουν ότι ο μηχανισμός λήψης απόφασης ανταποκρίνεται από το πρώτο παράθυρο συλλογής τηλεμετρίας στα συνθετικά προφίλ επίθεσης που χρησιμοποιήθηκαν και ότι ο προσωρινός αποκλεισμός περιορίζει σημαντικά την κακόβουλη κίνηση στις συγκεκριμένες συνθήκες της προσομοίωσης. Παράλληλα, τα αποτελέσματα αναδεικνύουν τη σημασία της διάρκειας και της ανανέωσης του κανόνα αντιμετώπισης. Επειδή όμως πρόκειται για προσομοιώσεις με προκαθορισμένο τρόπο παραγωγής φυσιολογικής και κακόβουλης κίνησης, τα αποτελέσματα αξιολογούν τη συμπεριφορά του μηχανισμού υπό τις συγκεκριμένες παραμέτρους και δεν αντικαθιστούν τις μετρήσεις της πραγματικής εκτέλεσης σε επίπεδο πακέτων που παρουσιάστηκαν στην παράγραφο 6.2.

6.5 Συμπληρωματική αξιολόγηση της Μεθόδου A

Πέρα από τα βασικά σενάρια ανίχνευσης και αντιμετώπισης, η Μέθοδος A αξιολογήθηκε σε τρεις πρόσθετες περιπτώσεις που εξετάζουν ειδικότερες αδυναμίες ενός Δικτύου Οριζόμενου από Λογισμικό (Software-Defined Networking, SDN). Αρχικά μελετήθηκε μέσω προσομοίωσης ο κορεσμός του επιπέδου ελέγχου (control-plane saturation), ο οποίος προκαλείται από μεγάλο αριθμό νέων ροών που απαιτούν επεξεργασία από τον ελεγκτή. Στη συνέχεια εξετάστηκε η εισαγωγή πλαστών δεδομένων τηλεμετρίας με στόχο την πρόκληση λανθασμένης απόφασης. Τέλος, αξιολογήθηκε η συμπεριφορά του ζωντανού μοντέλου απέναντι σε προσομοιωμένες στρατηγικές με τις οποίες ένας επιτιθέμενος επιχειρεί να μειώσει το στατιστικό αποτύπωμα της δραστηριότητάς του. Οι τρεις δοκιμές εξετάζουν διαφορετική πλευρά της ασφάλειας της Μεθόδου A και, για τον λόγο αυτό, παρουσιάζονται χωριστά στις επόμενες παραγράφους.

6.5.1 Κορεσμός του επιπέδου ελέγχου

Η πρώτη συμπληρωματική δοκιμή αφορά επίθεση κορεσμού του επιπέδου ελέγχου (control-plane saturation) μέσω πλημμύρας αστοχιών αντιστοίχισης πίνακα (table-miss flooding). Ο μηχανισμός της συγκεκριμένης επίθεσης έχει παρουσιαστεί θεωρητικά στην παράγραφο 3.3. Στην παρούσα αξιολόγηση δεν χρησιμοποιείται πραγματικός ελεγκτής OpenFlow, αλλά προσομοίωση διακριτών γεγονότων (discrete-event simulation), στην οποία μοντελοποιούνται η ουρά μηνυμάτων Packet-In του ελεγκτή, ο ρυθμός επεξεργασίας του και ο πίνακας ροών (flow table) του μεταγωγέα. Επομένως, τα αποτελέσματα που

ακολουθούν περιγράφουν τη συμπεριφορά του συγκεκριμένου μοντέλου προσομοίωσης και δεν αποτελούν μετρήσεις από πραγματικό ελεγκτή.

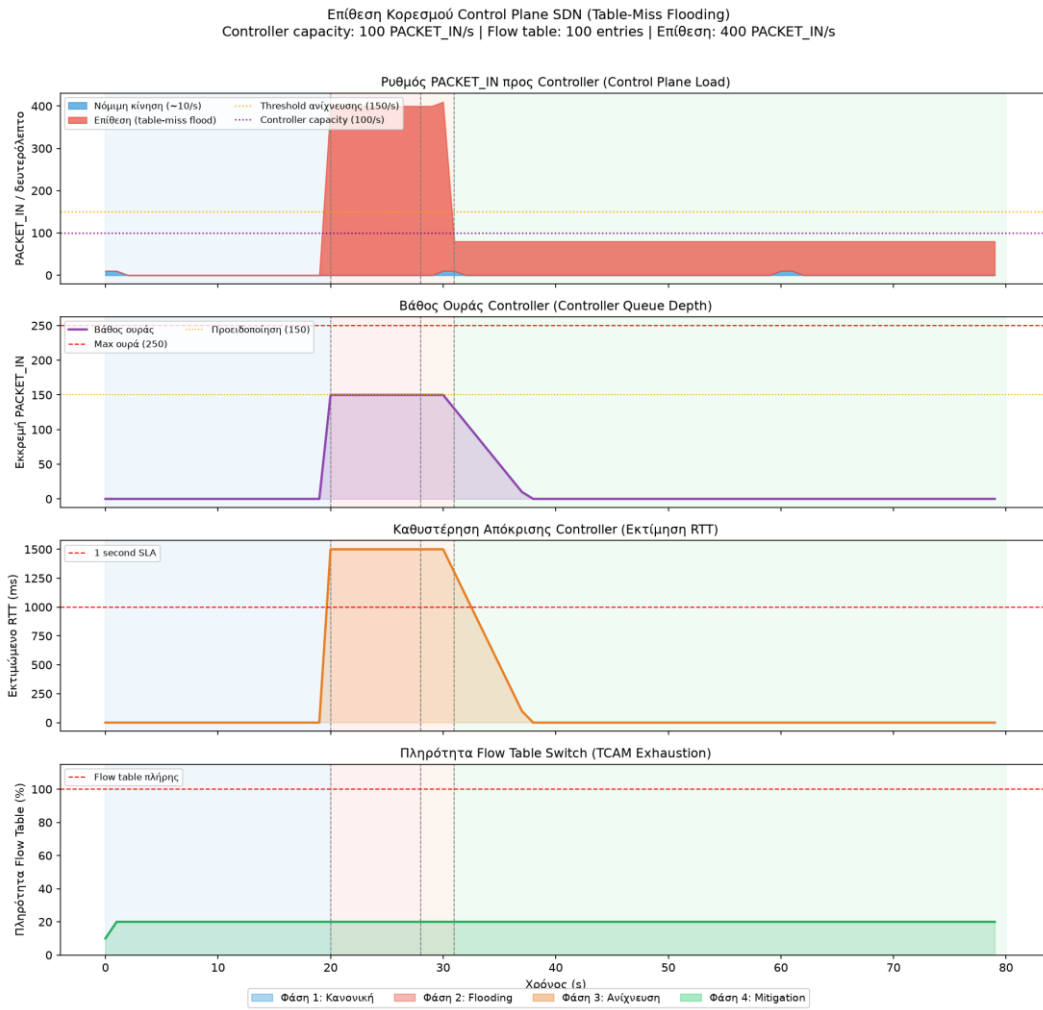
Στην κανονική λειτουργία ο ελεγκτής έχει δυνατότητα επεξεργασίας έως 100 μηνυμάτων Packet-In ανά δευτερόλεπτο και η ουρά του μπορεί να περιέχει έως 250 μηνύματα. Κατά την επίθεση παράγονται 400 κακόβουλα μηνύματα Packet-In ανά δευτερόλεπτο από μεγάλο πλήθος διαφορετικών διευθύνσεων IP. Η εισερχόμενη κίνηση υπερβαίνει επομένως τη δυνατότητα επεξεργασίας του ελεγκτή και δημιουργείται συσσώρευση στην ουρά. Η ανίχνευση πραγματοποιείται με βάση τον ρυθμό των μηνυμάτων Packet-In και την εντροπία Shannon (Shannon entropy) των διευθύνσεων προέλευσης. Η αντιμετώπιση βασίζεται σε περιορισμό του ρυθμού (rate limiting) των μηνυμάτων που προωθούνται προς το επίπεδο ελέγχου

Πίνακας 6-7: Βασικές μετρήσεις κατά την προσομοίωση κορεσμού του επιπέδου ελέγχου (control plane).

Μετρική	Κανονική λειτουργία	Φάση επίθεσης	Φάση αντιμετώπισης
Μέσος ρυθμός Packet-In	1/s	400/s	80/s
Μέσο βάθος ουράς	0/250	150/250	10/250
Εκτιμώμενος χρόνος απόκρισης (Round-Trip Time, RTT)	0 ms	1.500 ms	100 ms
Μέση εντροπία Shannon	1,16 bits	10,52 bits	9,71 bits

Όπως φαίνεται στον Πίνακα 6-7, η αύξηση του ρυθμού Packet-In από περίπου 1 μήνυμα ανά δευτερόλεπτο στην κανονική λειτουργία σε 400 μηνύματα ανά δευτερόλεπτο κατά την επίθεση υπερβαίνει σημαντικά τη δυνατότητα επεξεργασίας των 100 μηνυμάτων ανά δευτερόλεπτο του προσομοιωμένου ελεγκτή. Το μέσο βάθος της ουράς αυξάνεται στα 150 από τα 250 διαθέσιμα στοιχεία και ο εκτιμώμενος χρόνος απόκρισης αυξάνεται από 0 σε 1.500 ms. Μετά την ενεργοποίηση του περιορισμού ρυθμού, η κακόβουλη κίνηση που φτάνει στον ελεγκτή μειώνεται στα 80 μηνύματα ανά δευτερόλεπτο και η ουρά αποσυμφορείται σταδιακά.

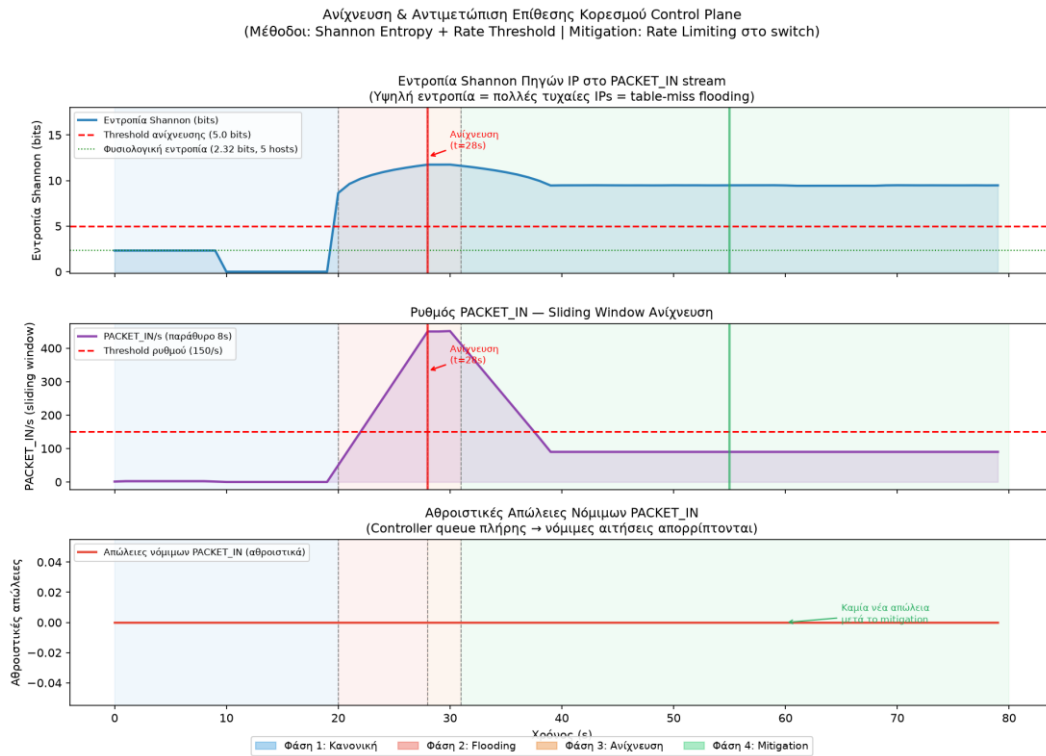
Η συνολική χρονική εξέλιξη των μεγεθών παρουσιάζεται στο Σχήμα 6-6.



Σχήμα 6-6: Εξέλιξη του ρυθμού Packet-In, του βάθους της ουράς του ελεγκτή, του εκτιμώμενου χρόνου απόκρισης και της πληρότητας του πίνακα ροών κατά την προσομοίωση κορεσμού του επιπέδου ελέγχου.

Στο Σχήμα 6-6 διακρίνονται τέσσερις διαδοχικές φάσεις. Μέχρι την έναρξη της επίθεσης ο φόρτος παραμένει χαμηλός. Με την έναρξη της πλημμύρας, ο ρυθμός Packet-In αυξάνεται στα 400 μηνύματα ανά δευτερόλεπτο, η ουρά φτάνει στα 150 στοιχεία και ο εκτιμώμενος χρόνος απόκρισης στα 1.500 ms. Μετά την ανίχνευση και την ενεργοποίηση του περιορισμού ρυθμού, τα μηνύματα που φτάνουν στον ελεγκτή περιορίζονται και τόσο το βάθος της ουράς όσο και ο εκτιμώμενος χρόνος απόκρισης μειώνονται μέχρι την επαναφορά τους σε χαμηλά επίπεδα. Η πληρότητα του πίνακα ροών παραμένει περίπου στο 20%, γεγονός που δείχνει ότι στη συγκεκριμένη προσομοίωση το κύριο αποτέλεσμα της επίθεσης εμφανίζεται στους πόρους επεξεργασίας του επιπέδου ελέγχου και όχι στην εξάντληση της χωρητικότητας του πίνακα ροών.

Η ανίχνευση της επίθεσης παρουσιάζεται αναλυτικότερα στο Σχήμα 6-7.



Σχήμα 6-7: Ανίχνευση και αντιμετώπιση της επίθεσης κορεσμού του επιπέδου ελέγχου με βάση την εντροπία Shannon και τον ρυθμό Packet-In.

Όπως φαίνεται στο Σχήμα 6-7, η επίθεση αρχίζει στο χρονικό σημείο $t=20s$. Η απόφαση ανίχνευσης παράγεται στο $t=28s$, αφού έχει συμπληρωθεί το παράθυρο παρατήρησης των 8 s. Στο σημείο αυτό η εντροπία Shannon έχει αυξηθεί σε περίπου 11,7 bits και ο ρυθμός Packet-In στο παράθυρο παρατήρησης έχει υπερβεί το καθορισμένο όριο των 150 μηνυμάτων ανά δευτερόλεπτο. Ο περιορισμός ρυθμού ενεργοποιείται τρία δευτερόλεπτα αργότερα, στο $t=31s$. Μετά την ενεργοποίησή του, ο ρυθμός που φτάνει στον ελεγκτή μειώνεται και η ουρά αρχίζει να αποσυμφορείται.

Τα αποτελέσματα δείχνουν ότι, υπό τις συγκεκριμένες παραμέτρους της προσομοίωσης, ο συνδυασμός του ρυθμού Packet-In και της εντροπίας των διευθύνσεων προέλευσης επιτρέπει την αναγνώριση της απότομης μεταβολής που προκαλεί η επίθεση. Το συμπέρασμα περιορίζεται στο μοντέλο προσομοίωσης που χρησιμοποιήθηκε και δεν τεκμηριώνει αντίστοιχους χρόνους ή επίπεδα φόρτου σε πραγματικό ελεγκτή OpenFlow.

6.5.2 Δηλητηρίαση τηλεμετρίας

Η δεύτερη δοκιμή εξετάζει τη δηλητηρίαση τηλεμετρίας (telemetry poisoning), δηλαδή την εισαγωγή πλαστών στατιστικών με στόχο να οδηγηθεί ο μηχανισμός ανίχνευσης σε λανθασμένη απόφαση. Η συγκεκριμένη απειλή έχει παρουσιαστεί στην παράγραφο 3.4. Στο

πειραματικό σενάριο, ο αποστολέας κατασκευάζει τηλεμετρία που εμφανίζει έναν νόμιμο κόμβο ως πηγή κίνησης πολύ υψηλής έντασης. Αν τα δεδομένα αυτά γίνουν δεκτά ως γνήσια, μπορούν να προκαλέσουν τον χαρακτηρισμό του νόμιμου κόμβου ως επιτιθέμενου και την εφαρμογή κανόνα αποκλεισμού σε βάρος του.

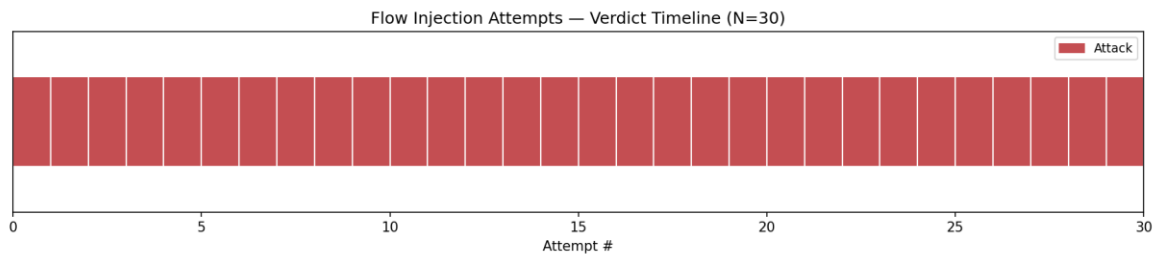
Η υλοποίηση του ελεγκτή περιλαμβάνει μηχανισμό ελέγχου της προέλευσης της τηλεμετρίας μέσω του πεδίου X-Switch-Token. Όταν ο αμυντικός τρόπος λειτουργίας είναι ενεργός, ένα αίτημα τηλεμετρίας χωρίς έγκυρο διακριτικό αυθεντικοποίησης (authentication token) απορρίπτεται πριν χρησιμοποιηθεί από τον μηχανισμό ανίχνευσης.

Στην καταγεγραμμένη εκτέλεση αξιολόγησης πραγματοποιήθηκαν 30 προσπάθειες εισαγωγής πλαστής τηλεμετρίας χωρίς έγκυρο X-Switch-Token. Και οι 30 προσπάθειες καταγράφηκαν από τον ελεγκτή ως μη εξουσιοδοτημένες, αλλά η καταγεγραμμένη εκτέλεση πραγματοποιήθηκε χωρίς ενεργοποιημένη απόρριψη στην είσοδο της διεπαφής. Κατά συνέπεια, το ποσοστό αποκλεισμού των συγκεκριμένων αιτημάτων στην πύλη εισόδου ήταν 0% και ο νόμιμος κόμβος που εμφανιζόταν ψευδώς ως πηγή της επίθεσης κατέληξε να αποκλειστεί από τον μηχανισμό απόκρισης. Τα αριθμητικά αποτελέσματα της δοκιμής συνοψίζονται στον Πίνακα 6-8.

Πίνακας 6-8: Αποτελέσματα της καταγεγραμμένης δοκιμής εισαγωγής πλαστής τηλεμετρίας.

Μετρική	Αποτέλεσμα
Προσπάθειες εισαγωγής πλαστής τηλεμετρίας	30
Καταγεγραμμένες μη εξουσιοδοτημένες προσπάθειες	30/30
Ποσοστό καταγραφής των προσπαθειών	100%
Απόρριψη στην είσοδο της διεπαφής στην καταγεγραμμένη εκτέλεση	0%
Ψευδώς θετικές αποφάσεις στη χωριστή δοκιμή νόμιμης τηλεμετρίας	0/30
Λανθασμένος αποκλεισμός του νόμιμου κόμβου-στόχου	Ναι

Η χρονική ακολουθία των 30 προσπαθειών παρουσιάζεται στο Σχήμα 6-8.



Σχήμα 6-8: Χρονολόγιο των 30 προσπαθειών εισαγωγής πλαστής τηλεμετρίας (telemetry injection) κατά την καταγεγραμμένη εκτέλεση.

Στο Σχήμα 6-8 όλες οι προσπάθειες οδηγούν σε χαρακτηρισμό της κατασκευασμένης τηλεμετρίας ως κακόβουλης δραστηριότητας. Το αποτέλεσμα δείχνει ταυτόχρονα και τον κίνδυνο της μη επαληθευμένης τηλεμετρίας: ακόμη και αν ο μηχανισμός ανίχνευσης αναγνωρίσει σωστά ότι τα υποβληθέντα στατιστικά αντιστοιχούν σε επίθεση, δεν μπορεί από μόνος του να γνωρίζει αν η δηλωμένη διεύθυνση προέλευσης αντιστοιχεί πράγματι στον επιτιθέμενο ή αν έχει χρησιμοποιηθεί για να ενοχοποιηθεί ένας νόμιμος κόμβος.

Η δοκιμή με 30 νόμιμες αποστολές τηλεμετρίας, οι οποίες περιείχαν έγκυρο διακριτικό, δεν παρήγαγε ψευδώς θετική απόφαση. Το αποτέλεσμα αυτό δείχνει ότι το συγκεκριμένο νόμιμο προφίλ δεν επηρεάστηκε από τον μηχανισμό ανίχνευσης. Ωστόσο, η καταγεγραμμένη πειραματική εκτέλεση δεν χρησιμοποιείται για ποσοτικό ισχυρισμό αποτελεσματικότητας της απόρριψης μέσω X-Switch-Token, επειδή το τελικό αρχείο αποτελεσμάτων αντιστοιχεί σε λειτουργία χωρίς ενεργοποιημένη απόρριψη των μη εξουσιοδοτημένων αιτημάτων. Συνεπώς, το πείραμα τεκμηριώνει κυρίως τον κίνδυνο της μη αυθεντικοποιημένης τηλεμετρίας και την ανάγκη ελέγχου της προέλευσης των δεδομένων πριν αυτά τροφοδοτήσουν τον μηχανισμό λήψης απόφασης.

6.5.3 Στιβαρότητα του ζωντανού μοντέλου απέναντι σε στρατηγικές αποφυγής

Η τελευταία συμπληρωματική δοκιμή της Μεθόδου Α εξετάζει τη στιβαρότητα (robustness) του ζωντανού μοντέλου απέναντι σε προσομοιωμένες στρατηγικές αποφυγής της ανίχνευσης (evasion strategies). Στόχος είναι να εξεταστεί αν ένας επιτιθέμενος μπορεί να μειώσει την πιθανότητα ανίχνευσης μεταβάλλοντας τον τρόπο με τον οποίο παράγει την κακόβουλη κίνηση. Η αξιολόγηση πραγματοποιείται πάνω στα συγκεντρωτικά χαρακτηριστικά που χρησιμοποιεί το ζωντανό μοντέλο και δεν αποτελεί επίθεση σε επίπεδο πραγματικών πακέτων εναντίον ολόκληρης της στοίβας Mininet/Open vSwitch.

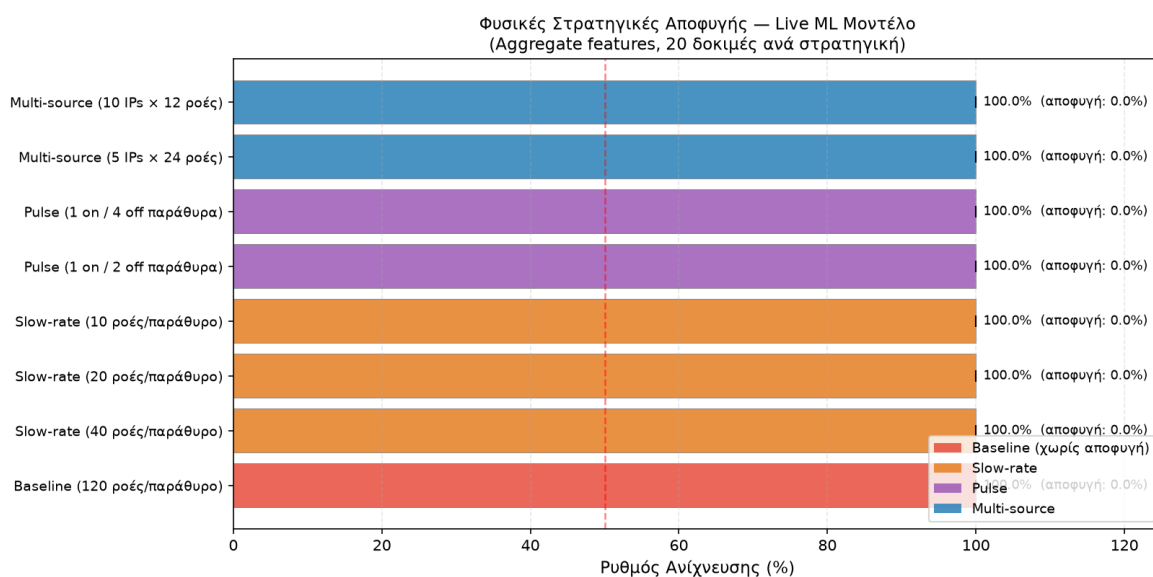
Εξετάστηκαν τρεις βασικές μορφές αποφυγής. Στη στρατηγική χαμηλού ρυθμού (slow-rate) μειώνεται το πλήθος των κακόβουλων ροών ανά παράθυρο. Στην παλμική στρατηγική (pulse) η επίθεση ενεργοποιείται για ένα παράθυρο και ακολουθούν δύο ή τέσσερα παράθυρα παύσης. Στην κατανεμημένη στρατηγική πολλαπλών πηγών (multi-source) ο συνολικός φόρτος κατανέμεται σε πέντε ή δέκα διαφορετικές διευθύνσεις IP. Για κάθε διαμόρφωση πραγματοποιήθηκαν 20 επαναλήψεις.

Τα αποτελέσματα παρουσιάζονται στον Πίνακα 6-9.

Πίνακας 6-9: Ανίχνευση και αποφυγή για τις προσομοιωμένες στρατηγικές αποφυγής του ζωντανού μοντέλου.

Στρατηγική	Ρυθμός ανίχνευσης (detection rate)	Ρυθμός αποφυγής (evasion rate)
Βασική επίθεση — 120 ροές/παράθυρο (baseline)	100,0%	0,0%
Χαμηλός ρυθμός — 40 ροές/παράθυρο (slow-rate)	100,0%	0,0%
Χαμηλός ρυθμός — 20 ροές/παράθυρο (slow-rate)	100,0%	0,0%
Χαμηλός ρυθμός — 10 ροές/παράθυρο (slow-rate)	100,0%	0,0%
Παλμική επίθεση — 1 ενεργό / 2 ανενεργά παράθυρα (pulse)	100,0%	0,0%
Παλμική επίθεση — 1 ενεργό / 4 ανενεργά παράθυρα (pulse)	100,0%	0,0%
Πολλαπλές πηγές — 5 IP × 24 ροές (multi-source)	100,0%	0,0%
Πολλαπλές πηγές — 10 IP × 12 ροές (multi-source)	100,0%	0,0%

Η γραφική παρουσίαση των αποτελεσμάτων δίνεται στο Σχήμα 6-9.



Σχήμα 6-9: Ρυθμός ανίχνευσης (detection rate) του ζωντανού μοντέλου για τις εξεταζόμενες στρατηγικές αποφυγής (evasion strategies).

Όπως φαίνεται στον Πίνακα 6-9 και στο Σχήμα 6-9, ο ρυθμός ανίχνευσης ήταν 100% σε όλες τις εξεταζόμενες διαμορφώσεις και ο αντίστοιχος ρυθμός αποφυγής ήταν 0%. Η μείωση της έντασης έως τις 10 ροές ανά παράθυρο δεν ήταν αρκετή ώστε το συγκεκριμένο προφίλ να προσεγγίσει τη φυσιολογική συμπεριφορά που είχε χρησιμοποιηθεί για το ζωντανό μοντέλο. Αντίστοιχα, οι παλμικές στρατηγικές δεν απέφυγαν την ανίχνευση στα παράθυρα στα οποία η επίθεση ήταν ενεργή, ενώ η κατανομή της κίνησης σε περισσότερες πηγές δεν ήταν αρκετή για να αποκρύψει τα χαρακτηριστικά των κακόβουλων ροών.

Η τιμή 100% έχει εδώ διαφορετικό νόημα από έναν ισχυρισμό γενικής στιβαρότητας του συστήματος. Η μετρική υπολογίζεται στα παράθυρα στα οποία η προσομοιωμένη επίθεση είναι ενεργή και αφορά αποκλειστικά τις συγκεκριμένες στρατηγικές, τις συγκεκριμένες παραμέτρους και τα συγκεντρωτικά χαρακτηριστικά της δοκιμής. Δεν πραγματοποιήθηκε πραγματική επίθεση αποφυγής σε επίπεδο πακέτων εναντίον της πλήρους ζωντανής στοίβας. Επομένως, τα αποτελέσματα δείχνουν ότι οι συγκεκριμένες μεταβολές δεν ήταν αρκετές για να αποφύγουν το μοντέλο στο εξεταζόμενο περιβάλλον, αλλά δεν τεκμηριώνουν ότι το σύστημα είναι στιβαρό απέναντι σε κάθε πιθανή στρατηγική ενός προσαρμοζόμενου επιτιθέμενου.

Συνολικά, οι συμπληρωματικές δοκιμές της Μεθόδου Α αναδεικνύουν τρεις διαφορετικές πλευρές της λειτουργίας του συστήματος. Η προσομοίωση κορεσμού δείχνει ότι η απότομη αύξηση των μηνυμάτων Packet-In μπορεί να επιβαρύνει έντονα το επίπεδο ελέγχου και ότι

ο περιορισμός του ρυθμού μειώνει τον προσομοιωμένο φόρτο. Η δοκιμή δηλητηρίασης τηλεμετρίας δείχνει ότι η ορθότητα της απόφασης εξαρτάται και από την αξιοπιστία της πηγής των δεδομένων, καθώς πλαστά στατιστικά μπορούν να οδηγήσουν σε λανθασμένο αποκλεισμό νόμιμου κόμβου όταν δεν απορρίπτονται πριν από την ανάλυση. Τέλος, οι προσομοιωμένες στρατηγικές αποφυγής δεν κατάφεραν να μειώσουν τον ρυθμό ανίχνευσης του ζωντανού μοντέλου στις παραμέτρους που εξετάστηκαν. Με την ολοκλήρωση των δοκιμών αυτών ολοκληρώνεται η πειραματική παρουσίαση της Μεθόδου Α και η επόμενη ενότητα περνά χωριστά στην αξιολόγηση της Μεθόδου Β.

6.6 Μέθοδος Β: Αξιολόγηση στο συνθετικό σύνολο δεδομένων

Με την ολοκλήρωση της αξιολόγησης της Μεθόδου Α, η ανάλυση περνά στη Μέθοδο Β, η οποία αφορά την εκτός σύνδεσης (offline) αξιολόγηση μοντέλων Μηχανικής Μάθησης σε καταγεγραμμένα δεδομένα ροών. Η διαδικασία προεπεξεργασίας, ο διαχωρισμός των δεδομένων και τα 24 χαρακτηριστικά εισόδου παρουσιάστηκαν στο Κεφάλαιο 5. Στην παρούσα ενότητα εξετάζεται αρχικά η απόδοση των μοντέλων στο συνθετικό σύνολο δεδομένων. Η αξιολόγηση περιλαμβάνει έξι κλασικά μοντέλα Μηχανικής Μάθησης και δύο μοντέλα Βαθιάς Μάθησης (Deep Learning), ενώ στη συνέχεια εξετάζονται η καμπύλη λειτουργικού χαρακτηριστικού δέκτη (Receiver Operating Characteristic, ROC) και η σταθερότητα των αποτελεσμάτων μέσω διασταυρούμενης επικύρωσης (cross-validation).

6.6.1 Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης

Η πρώτη σύγκριση αφορά έξι κλασικά μοντέλα: Random Forest, Μηχανή Διανυσμάτων Υποστήριξης με πυρήνα ακτινικής βάσης (Support Vector Machine with Radial Basis Function, SVM-RBF), Δέντρο Απόφασης (Decision Tree), Πολυεπίπεδο Αντιληπτήρα (Multi-Layer Perceptron, MLP), Λογιστική Παλινδρόμηση (Logistic Regression) και k Πλησιέστερους Γείτονες (k-Nearest Neighbors, KNN). Η σύγκριση πραγματοποιείται με βάση τη συνολική ακρίβεια (accuracy), τη μακρο-ορθότητα (macro-precision), τη μακρο-ανάκληση (macro-recall) και τη μακρο-F1 (macro-F1). Οι μετρικές αυτές έχουν παρουσιαστεί στην παράγραφο 4.6.

Για την κύρια σύγκριση χρησιμοποιείται ο διαχωρισμός που περιγράφηκε στην παράγραφο 5.3.2. Ο ίδιος στρωματοποιημένος διαχωρισμός κατά ομάδες εφαρμόζεται και στο συνθετικό σύνολο, όπου όμως κάθε ομάδα περιλαμβάνει μία μόνο εγγραφή, καθώς δεν υπάρχουν ακριβή διπλότυπα.

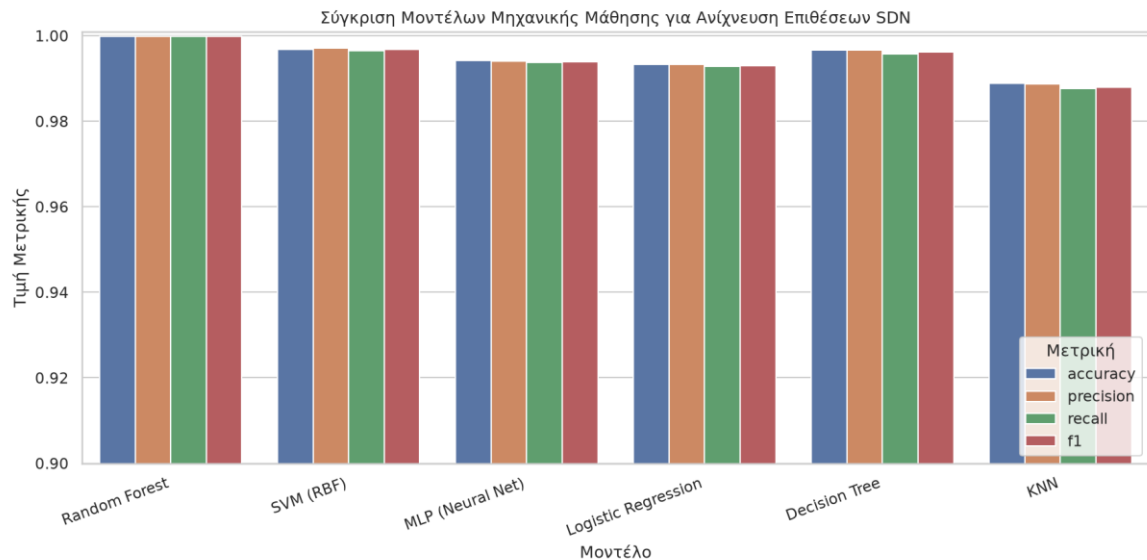
Πίνακας 6-10: Σύγκριση των έξι κλασικών μοντέλων στο συνθετικό σύνολο δεδομένων με 24 χαρακτηριστικά.

Μοντέλο	Συνολική ακρίβεια (accuracy)	Μακρο-ορθότητα (macro-precision)	Μακρο-ανάκληση (macro-recall)	Μακρο-F1 (macro-F1)
Random Forest	0,9999	0,9999	0,9998	0,9999
SVM (RBF)	0,9968	0,9971	0,9964	0,9968
Decision Tree	0,9966	0,9966	0,9958	0,9962
MLP (Neural Net)	0,9941	0,9941	0,9938	0,9939
Logistic Regression	0,9933	0,9933	0,9928	0,9930
KNN	0,9889	0,9887	0,9876	0,9880

Για παράδειγμα, μακρο-F1 ίση με 0,9999 αντιστοιχεί σε τιμή πολύ κοντά στο 100%, ενώ η τιμή 0,9880 του KNN αντιστοιχεί περίπου στο 98,8%. Η διαφορά είναι αριθμητικά μικρή, αλλά το σημαντικότερο εύρημα είναι ότι όλα τα μοντέλα εμφανίζουν πολύ υψηλές επιδόσεις στο συγκεκριμένο συνθετικό σύνολο.

Όπως φαίνεται στον Πίνακα 6-10, όλα τα μοντέλα παρουσιάζουν υψηλή απόδοση στο συγκεκριμένο συνθετικό σύνολο. Το Random Forest εμφανίζει τις υψηλότερες τιμές και στις τέσσερις μετρικές, με μακρο-F1 περίπου 0,9999. Ακολουθούν το SVM και το Decision Tree, ενώ ακόμη και το KNN, το οποίο καταγράφει τη χαμηλότερη τιμή μεταξύ των έξι μοντέλων, επιτυγχάνει μακρο-F1 περίπου 0,9880. Η συγκέντρωση τόσο υψηλών τιμών σε διαφορετικές οικογένειες αλγορίθμων αποτελεί ένδειξη ότι οι κατηγορίες του συνθετικού συνόλου είναι σχετικά εύκολα διαχωρίσιμες με βάση τα χαρακτηριστικά που έχουν δημιουργηθεί για την παρούσα εργασία.

Η σύγκριση των τεσσάρων βασικών μετρικών παρουσιάζεται γραφικά στο Σχήμα 6-10.



Σχήμα 6-10: Σύγκριση των κλασικών μοντέλων Μηχανικής Μάθησης ως προς τη συνολική ακρίβεια, τη μακρο-ορθότητα, τη μακρο-ανάκληση και τη μακρο-F1 στο συνθετικό σύνολο δεδομένων.

Στο Σχήμα 6-10 παρατηρείται ότι οι τέσσερις μετρικές παραμένουν κοντά μεταξύ τους για κάθε μοντέλο. Δεν εμφανίζεται, επομένως, περίπτωση στην οποία ένα μοντέλο επιτυγχάνει υψηλή ορθότητα εις βάρος της ανάκλησης ή το αντίστροφο. Η πολύ μικρή απόσταση μεταξύ των μοντέλων, και κυρίως οι τιμές που προσεγγίζουν τη μονάδα, απαιτούν προσεκτική ερμηνεία και δεν πρέπει να θεωρηθούν από μόνες τους απόδειξη γενίκευσης σε πραγματικά δεδομένα. Ο κατακόρυφος άξονας του Σχήματος 6-10 αρχίζει από την τιμή 0,90 και όχι από το μηδέν. Επομένως, οι οπτικές διαφορές μεταξύ των στηλών εμφανίζονται μεγαλύτερες από τις πραγματικές αριθμητικές διαφορές. Για τον λόγο αυτό, η ακριβής σύγκριση των μοντέλων πρέπει να γίνεται σε συνδυασμό με τις τιμές του Πίνακα 6-10.

Για να εξεταστεί αν η υψηλή απόδοση οφείλεται αποκλειστικά στην καθαρή διακριτότητα των συνθετικών προφίλ, χρησιμοποιήθηκε και μία απαιτητικότερη εκδοχή του συνθετικού συνόλου, στην οποία εισάγονται μεγαλύτερος θόρυβος και μεγαλύτερη επικάλυψη μεταξύ των κατηγοριών. Η σύγκριση πραγματοποιήθηκε για τα πέντε μοντέλα που περιλαμβάνονται στη συγκεκριμένη δοκιμή και παρουσιάζεται στον Πίνακα 6-11.

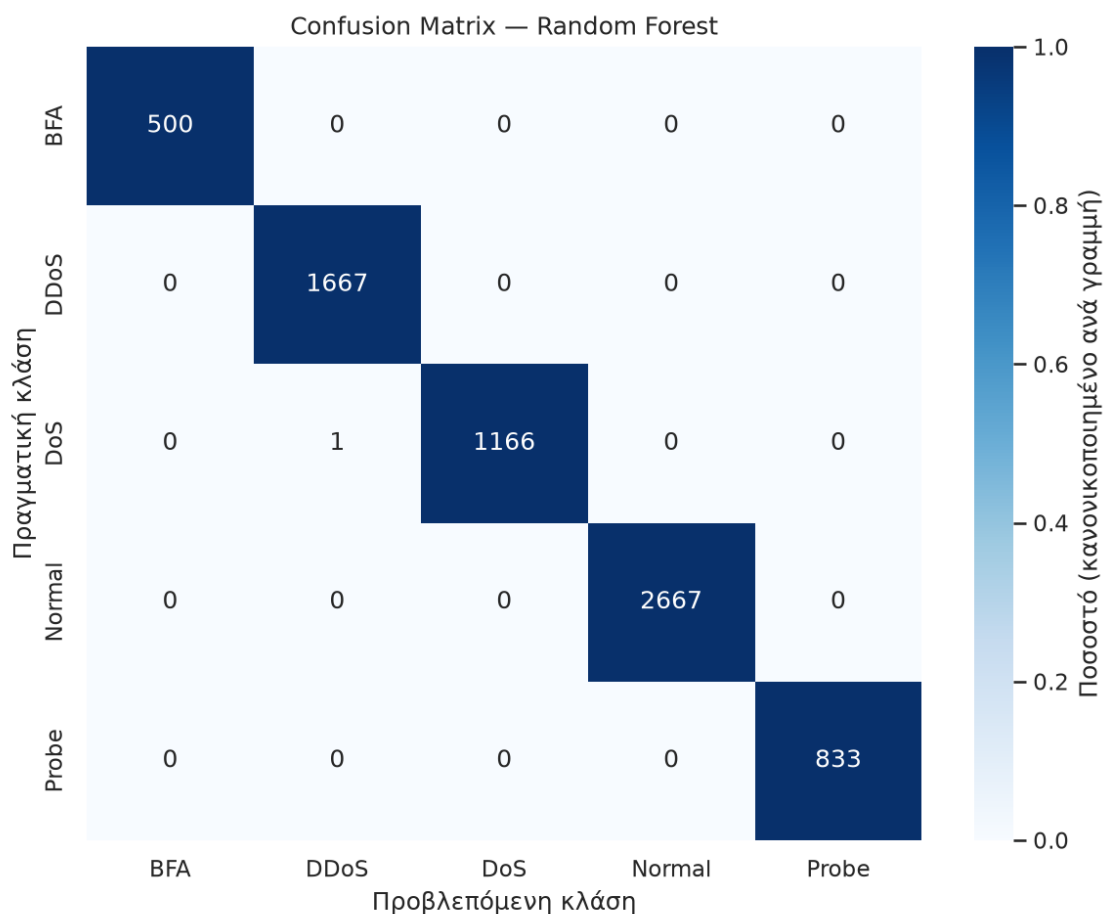
Πίνακας 6-11: Μακρο-F1 στο σύνολο ελέγχου για την καθαρή (clean) και την απαιτητική (hard) εκδοχή του συνθετικού συνόλου.

Μοντέλο	Καθαρή εκδοχή (clean)	Απαιτητική εκδοχή (hard)
Random Forest	1,0000	0,9955
SVM (RBF)	0,9974	0,9893
Decision Tree	0,9955	0,9828
Logistic Regression	0,9947	0,9814

KNN	0,9900	0,9701
-----	--------	--------

Η απόδοση μειώνεται για όλα τα μοντέλα στην απαιτητική εκδοχή. Η μεγαλύτερη μείωση εμφανίζεται στο KNN, του οποίου η μακρο-F1 υποχωρεί από 0,9900 σε 0,9701, ενώ το Random Forest διατηρεί μακρο-F1 ίση με 0,9955. Η πτώση αυτή επιβεβαιώνει ότι μέρος της σχεδόν τέλει απόδοσης στην καθαρή εκδοχή συνδέεται με τον τρόπο δημιουργίας των συνθετικών προφίλ. Ωστόσο, ακόμη και στην απαιτητική εκδοχή οι τιμές παραμένουν πολύ υψηλές. Για τον λόγο αυτό, το συνθετικό σύνολο χρησιμοποιείται κυρίως για ελεγχόμενη σύγκριση των μοντέλων και όχι ως μοναδική βάση για συμπέρασμα σχετικά με τη συμπεριφορά τους σε πραγματική δικτυακή κίνηση. Σημειώνεται ότι οι τιμές του Πίνακα 6-11 προέρχονται από χωριστή εκτέλεση με διαφορετικό διαχωρισμό των δεδομένων, οπότε διαφέρουν ελαφρώς από τις αντίστοιχες τιμές του Πίνακα 6-10.

Ο πίνακας σύγχυσης (confusion matrix) του Random Forest παρουσιάζεται στο Σχήμα 6-11.



Σχήμα 6-11: Πίνακας σύγχυσης (confusion matrix) του Random Forest στο συνθετικό σύνολο δεδομένων.

Στο Σχήμα 6-11 οι γραμμές αντιστοιχούν στις πραγματικές κατηγορίες των δεδομένων και οι στήλες στις κατηγορίες που προέβλεψε το μοντέλο. Οι αριθμοί μέσα στα κελιά εκφράζουν το πλήθος των εγγραφών του συνόλου ελέγχου. Για παράδειγμα, η τιμή 500 στο κελί BFA–BFA σημαίνει ότι στο σύνολο ελέγχου υπήρχαν 500 εγγραφές της κατηγορίας BFA και το Random Forest ταξινόμησε σωστά και τις 500 ως BFA. Αντίστοιχα, και οι 1.667 εγγραφές της κατηγορίας DDoS ταξινομήθηκαν σωστά ως DDoS, ενώ από τις 1.167 εγγραφές της κατηγορίας DoS οι 1.166 ταξινομήθηκαν σωστά ως DoS και μία ταξινομήθηκε λανθασμένα ως DDoS. Οι 2.667 εγγραφές της κατηγορίας Normal και οι 833 εγγραφές της κατηγορίας Probe ταξινομήθηκαν επίσης σωστά στο σύνολό τους. Επομένως, το μοναδικό σφάλμα που εμφανίζεται στον συγκεκριμένο πίνακα σύγχυσης αφορά μία εγγραφή DoS που αποδόθηκε στην κατηγορία DDoS. Οι τιμές της κύριας διαγωνίου αντιστοιχούν στις ορθές ταξινομήσεις, ενώ οι τιμές εκτός της διαγωνίου αντιστοιχούν σε σφάλματα ταξινόμησης. Η χρωματική ένταση του σχήματος είναι κανονικοποιημένη ανά γραμμή και χρησιμοποιείται για την οπτική απεικόνιση του ποσοστού ορθής ή λανθασμένης ταξινόμησης· οι αριθμοί μέσα στα κελιά, αντίθετα, δείχνουν το πραγματικό πλήθος των εγγραφών.

6.6.2 Σύγκριση με μοντέλα Βαθιάς Μάθησης

Η αξιολόγηση επεκτάθηκε σε δύο μοντέλα Βαθιάς Μάθησης (Deep Learning): έναν βαθύ Πολυεπίπεδο Αντιληπτήρα (Deep Multi-Layer Perceptron, Deep MLP) και ένα Μονοδιάστατο Συνελκτικό Νευρωνικό Δίκτυο (One-Dimensional Convolutional Neural Network, 1D-CNN). Τα αποτελέσματα παρουσιάζονται στον Πίνακα 6-12.

Πίνακας 6-12: Απόδοση των μοντέλων Βαθιάς Μάθησης στο συνθετικό σύνολο δεδομένων.

Μοντέλο	Συνολική ακρίβεια (accuracy)	Μακρο-F1 (macro-F1)	Χρόνος εκπαίδευσης (s)
Deep MLP	0,9863	0,9836	18,33
1D-CNN	0,9511	0,9420	11,42

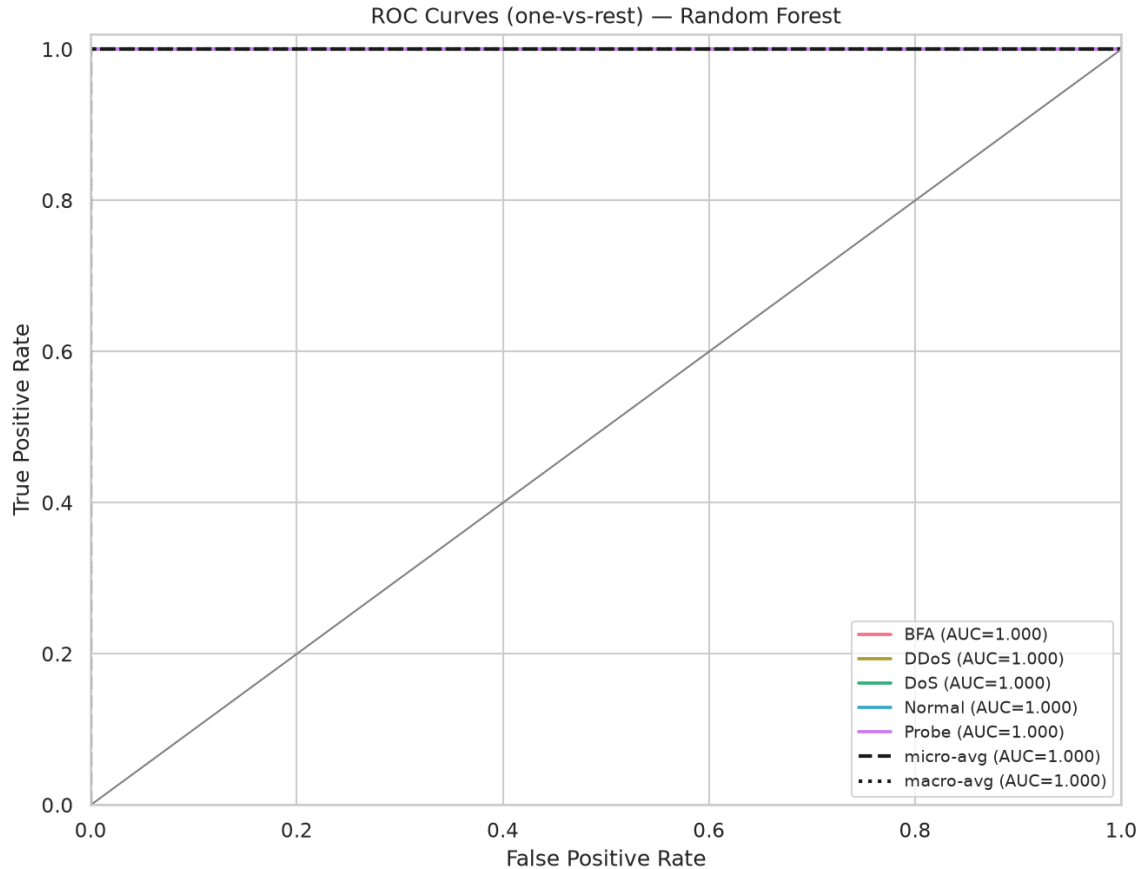
Το Deep MLP επιτυγχάνει υψηλότερη επίδοση από το 1D-CNN, με συνολική ακρίβεια 0,9863 και μακρο-F1 0,9836. Το 1D-CNN εμφανίζει χαμηλότερη επίδοση, με μακρο-F1 0,9420. Οι αριθμητικές τιμές των δύο βαθιών μοντέλων είναι χαμηλότερες από εκείνες των κλασικών μοντέλων του Πίνακα 6-10. Ωστόσο, επειδή χρησιμοποιήθηκε διαφορετικό πρωτόκολλο διαχωρισμού και επικύρωσης, η παρατήρηση αυτή δεν αποτελεί άμεση

κατάταξη μεταξύ των δύο ομάδων μοντέλων, όπως αναφέρθηκε στην παράγραφο 5.3.3. Τα δύο μοντέλα Βαθιάς Μάθησης δεν αξιολογήθηκαν στο InSDN.

Το αποτέλεσμα αυτό δείχνει ότι η μεγαλύτερη πολυπλοκότητα ενός μοντέλου δεν συνεπάγεται αυτομάτως καλύτερη ταξινόμηση. Στο συγκεκριμένο σύνολο, τα 24 χαρακτηριστικά είναι ήδη αριθμητικές περιγραφές των ροών και όχι ακατέργαστες χρονικές ακολουθίες ή πακέτα. Επομένως, τα βαθιά μοντέλα δεν εμφανίζουν σαφές πλεονέκτημα απέναντι σε αλγορίθμους που μπορούν να διαχωρίσουν αποτελεσματικά τα ήδη επεξεργασμένα χαρακτηριστικά. Η σύγκριση αυτή αφορά αποκλειστικά το συγκεκριμένο σύνολο δεδομένων και τις συγκεκριμένες αρχιτεκτονικές που χρησιμοποιήθηκαν.

6.6.3 Καμπύλες ROC και διασταυρούμενη επικύρωση

Η διακριτική ικανότητα του Random Forest εξετάστηκε επιπλέον μέσω καμπυλών λειτουργικού χαρακτηριστικού δέκτη (Receiver Operating Characteristic, ROC), με προσέγγιση μία κατηγορία έναντι των υπολοίπων (one-vs-rest). Η θεωρητική ερμηνεία των καμπυλών ROC και του εμβαδού κάτω από την καμπύλη (Area Under the Curve, AUC) έχει παρουσιαστεί στην παράγραφο 4.6.



Σχήμα 6-12: Καμπύλες ROC του Random Forest ανά κατηγορία, με προσέγγιση μία κατηγορία έναντι των υπολοίπων (one-vs-rest).

Στο Σχήμα 6-12 η γκρίζα διαγώνια γραμμή αντιστοιχεί στην απόδοση μιας τυχαίας ταξινόμησης, ενώ όσο περισσότερο μία καμπύλη ROC προσεγγίζει την άνω αριστερή γωνία τόσο καλύτερη είναι η διακριτική ικανότητα του μοντέλου. Οι καμπύλες όλων των κατηγοριών βρίσκονται σχεδόν πάνω στην άνω και αριστερή πλευρά του διαγράμματος και οι τιμές AUC εμφανίζονται ως 1,000 με ακρίβεια τριών δεκαδικών ψηφίων. Η τιμή αυτή δεν έρχεται σε αντίφαση με το ένα σφάλμα που εμφανίζεται στον πίνακα σύγχυσης του Σχήματος 6-11, επειδή η AUC αξιολογεί την ικανότητα κατάταξης των δειγμάτων σε όλα τα δυνατά κατώφλια απόφασης, ενώ ο πίνακας σύγχυσης προκύπτει από τις τελικές προβλέψεις σε συγκεκριμένο κανόνα απόφασης. Επιπλέον, η τιμή AUC παρουσιάζεται στρογγυλοποιημένη σε τρία δεκαδικά ψηφία. Τα σχεδόν τέλεια αποτελέσματα πρέπει επομένως να ερμηνεύονται μέσα στα όρια του συνθετικού συνόλου και όχι ως απόδειξη αντίστοιχης επίδοσης σε πραγματική δικτυακή κίνηση.

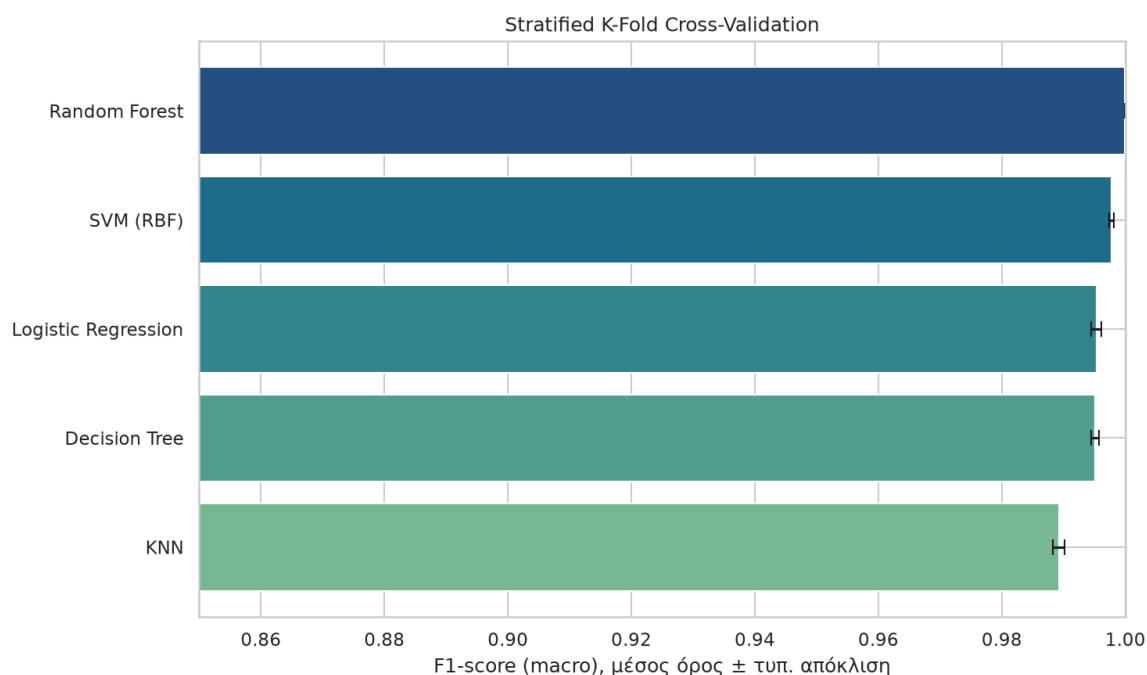
Για να εξεταστεί αν η υψηλή απόδοση εξαρτάται από έναν συγκεκριμένο διαχωρισμό εκπαίδευσης και ελέγχου, εφαρμόστηκε στρωματοποιημένη διασταυρούμενη επικύρωση

πέντε πτυχών (stratified 5-fold cross-validation). Σε κάθε επανάληψη διαφορετικό τμήμα των δεδομένων χρησιμοποιείται για επικύρωση, ενώ διατηρείται κατά το δυνατόν η αναλογία των κατηγοριών. Τα αποτελέσματα της μακρο-F1 παρουσιάζονται στον Πίνακα 6-13.

Πίνακας 6-13: Διασταυρούμενη επικύρωση πέντε πτυχών (5-fold cross-validation) με βάση τη μακρο-F1.

Μοντέλο	Μέση μακρο-F1	Τυπική απόκλιση	Ελάχιστη μακρο-F1	Μέγιστη μακρο-F1
Random Forest	0,99995	0,00010	0,99976	1,00000
SVM (RBF)	0,99777	0,00039	0,99721	0,99830
Logistic Regression	0,99529	0,00083	0,99415	0,99672
Decision Tree	0,99510	0,00068	0,99420	0,99611
KNN	0,98924	0,00097	0,98787	0,99064

Το Random Forest παραμένει πρώτο και στις πέντε πτυχές, με μέση μακρο-F1 περίπου 0,99995 και πολύ μικρή τυπική απόκλιση. Μικρές διακυμάνσεις εμφανίζονται και στα υπόλοιπα μοντέλα. Η διασταυρούμενη επικύρωση δείχνει επομένως ότι τα πολύ υψηλά αποτελέσματα του συνθετικού συνόλου δεν προκύπτουν μόνο από έναν ευνοϊκό τυχαίο διαχωρισμό των δεδομένων. Δεν αναιρεί όμως τον βασικό περιορισμό του συνόλου: όλες οι πτυχές προέρχονται από την ίδια διαδικασία συνθετικής παραγωγής και επομένως δεν αποτελούν ανεξάρτητη αξιολόγηση σε διαφορετική κατανομή πραγματικής κίνησης.



Σχήμα 6-13: Διασταυρούμενη επικύρωση πέντε πτυχών: μέση μακρο-F1 και τυπική απόκλιση ανά μοντέλο.

Στο Σχήμα 6-13 το μήκος κάθε οριζόντιας στήλης αντιστοιχεί στη μέση μακρο-F1 που επιτεύχθηκε στις πέντε πτυχές της διασταυρούμενης επικύρωσης, ενώ οι μικρές μαύρες γραμμές σφάλματος δείχνουν την τυπική απόκλιση μεταξύ των πέντε τιμών. Για παράδειγμα, το Random Forest εμφανίζει μέση μακρο-F1 0,99995 και τυπική απόκλιση μόλις 0,00010, γεγονός που δείχνει ότι η επίδοσή του μεταβλήθηκε ελάχιστα μεταξύ των διαφορετικών πτυχών. Το KNN παρουσιάζει τη χαμηλότερη μέση τιμή, 0,98924, αλλά και σε αυτή την περίπτωση η τυπική απόκλιση παραμένει μικρή. Η μικρή διακύμανση δείχνει ότι τα αποτελέσματα είναι σταθερά μεταξύ διαφορετικών διαχωρισμών του ίδιου συνθετικού συνόλου, χωρίς όμως να αποδεικνύει γενίκευση σε δεδομένα διαφορετικής προέλευσης.

Συνολικά, η αξιολόγηση στο συνθετικό σύνολο δείχνει πολύ υψηλή απόδοση για τα περισσότερα μοντέλα, με το Random Forest να παρουσιάζει την καλύτερη και σταθερότερη συμπεριφορά. Η πτώση των επιδόσεων στην απαιτητική εκδοχή του συνόλου δείχνει ότι η αύξηση του θορύβου και της επικάλυψης δυσκολεύει την ταξινόμηση, χωρίς όμως να αλλάζει τη γενική κατάταξη των ισχυρότερων μοντέλων. Παράλληλα, τα μοντέλα Βαθιάς Μάθησης δεν υπερέχουν των κλασικών μοντέλων στο συγκεκριμένο πρόβλημα. Τα σχεδόν τέλεια αποτελέσματα, οι καμπύλες ROC και η μικρή διακύμανση στη διασταυρούμενη επικύρωση πρέπει να ερμηνεύονται μέσα στα όρια του συνθετικού συνόλου. Για τον λόγο

αυτό, η επόμενη αξιολόγηση πραγματοποιείται στο InSDN, όπου εξετάζεται η συμπεριφορά των μοντέλων σε διαφορετικό και περισσότερο σύνθετο σύνολο δικτυακών ροών.

6.7 Μέθοδος B: Αξιολόγηση στο σύνολο δεδομένων InSDN

Μετά την αξιολόγηση στο συνθετικό σύνολο, η Μέθοδος B εξετάστηκε στο δημόσια διαθέσιμο σύνολο δεδομένων InSDN, το οποίο έχει δημιουργηθεί ειδικά για τη μελέτη επιθέσεων σε περιβάλλοντα Δικτύων Οριζόμενων από Λογισμικό (Software-Defined Networking, SDN) [24]. Στην παρούσα εργασία χρησιμοποιούνται οι κατηγορίες Normal, DoS, DDoS, Probe και Brute Force Attack (BFA), όπως έχει παρουσιαστεί στο Κεφάλαιο 5. Η χρήση του InSDN επιτρέπει την αξιολόγηση των μοντέλων σε δεδομένα διαφορετικής προέλευσης από το συνθετικό σύνολο της προηγούμενης ενότητας.

Κατά την εξέταση του συνόλου διαπιστώθηκε ότι περίπου το 47,5% των εγγραφών αποτελείται από ακριβή διπλότυπα ως προς τα χαρακτηριστικά που χρησιμοποιούνται από τα μοντέλα. Η παρουσία μεγάλου αριθμού πανομοιότυπων διανυσμάτων είναι ιδιαίτερα σημαντική για τον τρόπο διαχωρισμού των δεδομένων. Σε έναν συμβατικό τυχαίο διαχωρισμό (random split), ένα ακριβώς ίδιο διάνυσμα μπορεί να εμφανιστεί τόσο στο σύνολο εκπαίδευσης όσο και στο σύνολο ελέγχου. Σε αυτή την περίπτωση, η αξιολόγηση μπορεί να γίνει υπερβολικά αισιόδοξη, επειδή το μοντέλο εξετάζεται σε δείγματα που είναι ταυτόσημα με δείγματα που έχει ήδη συναντήσει κατά την εκπαίδευση. Το πρόβλημα αυτό αποτελεί μορφή διαρροής δεδομένων (data leakage) [32].

Για τον λόγο αυτό, η αξιολόγηση παρουσιάζεται σε δύο στάδια. Αρχικά δίνονται τα αποτελέσματα του συμβατικού τυχαίου διαχωρισμού, ώστε να υπάρχει ένα σημείο σύγκρισης. Στη συνέχεια εφαρμόζεται αυστηρότερος διαχωρισμός με ομαδοποίηση των ακριβών διπλοτύπων (group-aware split), στον οποίο κάθε ομάδα πανομοιότυπων διανυσμάτων τοποθετείται αποκλειστικά σε ένα μόνο από τα σύνολα εκπαίδευσης, επικύρωσης ή ελέγχου.

6.7.1 Αξιολόγηση με τυχαίο διαχωρισμό

Για λόγους σύγκρισης πραγματοποιήθηκε χωριστή αξιολόγηση με συμβατικό τυχαίο διαχωρισμό πάνω στο ίδιο πλήρες σύνολο δεδομένων InSDN. Η συγκεκριμένη δοκιμή χρησιμοποιείται ως σημείο αναφοράς για τη μελέτη της επίδρασης των ακριβών διπλοτύπων και δεν αποτελεί την κύρια πειραματική διαδρομή της Μεθόδου B, η οποία παρουσιάζεται στην παράγραφο 6.7.2. Επειδή τα ακριβή διπλότυπα δεν ομαδοποιούνται πριν από τον

διαχωρισμό, είναι δυνατόν πανομοιότυπες εγγραφές να εμφανιστούν και στα δύο υποσύνολα. Τα αποτελέσματα παρουσιάζονται στον Πίνακα 6-14.

Πίνακας 6-14: Απόδοση των κλασικών μοντέλων στο InSDN υπό τυχαίο διαχωρισμό.

Μοντέλο	Συνολική ακρίβεια (accuracy)	Μακρο-ορθότητα (macro-precision)	Μακρο-ανάκληση (macro-recall)	Μακρο-F1 (macro-F1)
KNN	0,9898	0,9791	0,9324	0,9523
Random Forest	0,9899	0,9614	0,9309	0,9448
Decision Tree	0,9893	0,9520	0,9358	0,9435
MLP (Neural Net)	0,9740	0,9690	0,9049	0,9306
SVM (RBF)	0,9386	0,9407	0,8076	0,8322
Logistic Regression	0,9107	0,8254	0,7310	0,7289

Όπως φαίνεται στον Πίνακα 6-14, οι υψηλότερες τιμές επιτυγχάνονται από τα KNN, Random Forest και Decision Tree. Το KNN εμφανίζει την υψηλότερη μακρο-F1, ίση με 0,9523, ενώ το Random Forest παρουσιάζει ελαφρώς υψηλότερη συνολική ακρίβεια, ίση με 0,9899. Το Decision Tree ακολουθεί με μακρο-F1 0,9435. Μεγαλύτερη πτώση εμφανίζεται στα SVM και Logistic Regression, κυρίως ως προς τη μακρο-ανάκληση, γεγονός που δείχνει ότι οι επιδόσεις τους δεν είναι το ίδιο ισορροπημένες μεταξύ των διαφορετικών κατηγοριών.

Ιδιαίτερη προσοχή απαιτείται στην ερμηνεία των αποτελεσμάτων αυτών, επειδή ο τυχαίος διαχωρισμός δεν εμποδίζει την παρουσία ακριβώς πανομοιότυπων εγγραφών στην εκπαίδευση και στον έλεγχο. Συνεπώς, οι τιμές του Πίνακα 6-14 δεν χρησιμοποιούνται ως κύρια ένδειξη ικανότητας γενίκευσης.

6.7.2 Αξιολόγηση με ομαδοποίηση των διπλοτύπων

Για αυστηρότερη αξιολόγηση εφαρμόστηκε διαχωρισμός με ομαδοποίηση διπλοτύπων (group-aware split). Η αξιολόγηση αυτή αποτελεί την κύρια πειραματική διαδρομή της Μεθόδου Β και πραγματοποιείται σε ολόκληρο το σύνολο InSDN, χωρίς υποδειγματοληψία, σύμφωνα με τη διαδικασία της παραγράφου 5.3.2. Πριν από τον διαχωρισμό, οι εγγραφές που έχουν ακριβώς το ίδιο διάνυσμα χαρακτηριστικών τοποθετούνται στην ίδια ομάδα. Στη συνέχεια κάθε ομάδα αντιστοιχίζεται εξ ολοκλήρου σε ένα μόνο από τα σύνολα εκπαίδευσης, επικύρωσης ή ελέγχου. Με αυτόν τον τρόπο αποτρέπεται η περίπτωση κατά την οποία ένα ακριβές αντίγραφο ενός δείγματος εκπαίδευσης εμφανίζεται αργότερα και ως

δείγμα ελέγχου. Η διαδικασία αυτή μειώνει τον συγκεκριμένο κίνδυνο διαρροής δεδομένων, χωρίς όμως να αποκλείει άλλες μορφές συσχέτισης μεταξύ των εγγραφών, όπως χρονική, συνεδριακή ή σχεδόν πανομοιότυπη συμπεριφορά [32].

Τα αποτελέσματα του διαχωρισμού με ομαδοποίηση διπλοτύπων παρουσιάζονται στον Πίνακα 6-15.

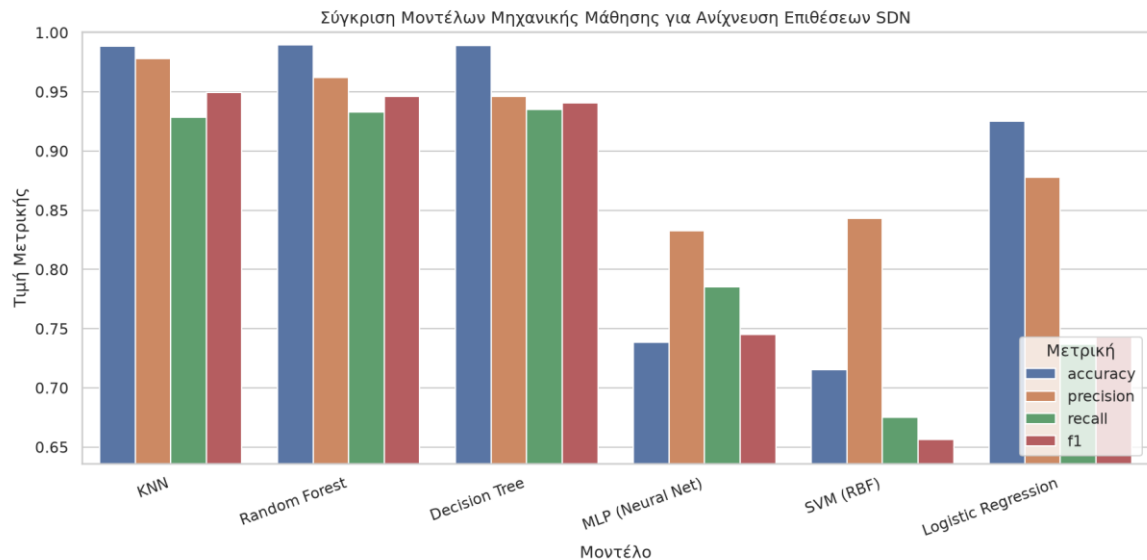
Πίνακας 6-15: Απόδοση των κλασικών μοντέλων στο InSDN υπό διαχωρισμό με ομαδοποίηση ακριβών διπλοτύπων.

Μοντέλο	Συνολική ακρίβεια (accuracy)	Μακρο-ορθότητα (macro-precision)	Μακρο-ανάκληση (macro-recall)	Μακρο-F1 (macro-F1)
KNN	0,9886	0,9780	0,9288	0,9495*
Random Forest	0,9900	0,9622	0,9328	0,9461
Decision Tree	0,9892	0,9464	0,9352	0,9406
MLP (Neural Net)	0,7387	0,8325	0,7854	0,7451
Logistic Regression	0,9254	0,8781	0,7369	0,7429
SVM (RBF)	0,7156	0,8430	0,6751	0,6563

* Η επίδοση του KNN εξετάζεται επιπλέον ως προς τη σταθερότητά της σε ανεξάρτητο διαχωρισμό με την ίδια βασική αρχή ομαδοποίησης των διπλοτύπων.

Στον Πίνακα 6-15 το KNN εμφανίζει την υψηλότερη μακρο-F1, ίση με 0,9495, ενώ το Random Forest ακολουθεί πολύ κοντά με 0,9461. Το Random Forest παρουσιάζει παράλληλα την υψηλότερη συνολική ακρίβεια, ίση με 0,9900. Το Decision Tree διατηρεί επίσης υψηλή επίδοση, με μακρο-F1 0,9406. Αντίθετα, οι επιδόσεις των MLP, Logistic Regression και SVM μειώνονται αισθητά σε σχέση με τον τυχαίο διαχωρισμό.

Η σύγκριση των μοντέλων υπό τον διαχωρισμό με ομαδοποίηση διπλοτύπων παρουσιάζεται γραφικά στο Σχήμα 6-14.



Σχήμα 6-14: Σύγκριση των κλασικών μοντέλων Μηχανικής Μάθησης στο σύνολο δεδομένων InSDN υπό διαχωρισμό με ομαδοποίηση ακριβών διπλοτύπων (group-aware split).

Στο Σχήμα 6-14 παρουσιάζονται για κάθε μοντέλο οι τιμές της συνολικής ακρίβειας, της μακρο-ορθότητας, της μακρο-ανάκλησης και της μακρο-F1. Τα KNN, Random Forest και Decision Tree συγκεντρώνονται στις υψηλότερες τιμές, ενώ το SVM εμφανίζει τη μεγαλύτερη απόσταση από τα υπόλοιπα μοντέλα, με μακρο-F1 0,656. Η εικόνα αυτή διαφέρει από εκείνη του τυχαίου διαχωρισμού, όπου το ασθενέστερο μοντέλο ήταν η Λογιστική Παλινδρόμηση.

Η σύγκριση μεταξύ των Πινάκων 6-14 και 6-15 δείχνει ότι η αποτροπή της επικάλυψης ακριβών αντιγράφων μεταξύ των υποσυνόλων δεν επηρεάζει στον ίδιο βαθμό όλα τα μοντέλα. Για παράδειγμα, το Random Forest μεταβάλλεται από μακρο-F1 0,9448 σε 0,9461 και το Decision Tree από 0,9435 σε 0,9406. Αντίθετα, το MLP μειώνεται από 0,9306 σε 0,7451 και το SVM από 0,8322 σε 0,6563. Οι διαφορές αυτές δείχνουν ότι το πρωτόκολλο διαχωρισμού των δεδομένων μπορεί να επηρεάσει ουσιαστικά την εκτιμώμενη απόδοση ενός μοντέλου.

Ιδιαίτερη εξέταση απαιτεί το KNN. Στο συγκεκριμένο group-aware split εμφανίζει την υψηλότερη μακρο-F1, 0,9495, τιμή ελαφρώς υψηλότερη από εκείνη του Random Forest. Ωστόσο, ανεξάρτητη επανάληψη της αξιολόγησης με διαφορετικό διαχωρισμό ομάδων έδωσε διαφορετική εικόνα. Τα αποτελέσματα για τα τρία ισχυρότερα μοντέλα παρουσιάζονται στον Πίνακα 6-16.

Πίνακας 6-16: Σύγκριση της μακρο-F1 σε δύο ανεξάρτητους διαχωρισμούς με ομαδοποίηση διπλοτύπων.

Μοντέλο	Μακρο-F1 στον κύριο διαχωρισμό	Μακρο-F1 στον ανεξάρτητο διαχωρισμό
KNN	0,950	0,773
Random Forest	0,946	0,947
Decision Tree	0,941	0,943

Ο Πίνακας 6-16 δείχνει ότι το Random Forest και το Decision Tree παραμένουν σχεδόν αμετάβλητα μεταξύ των δύο διαχωρισμών. Αντίθετα, η μακρο-F1 του KNN μειώνεται από περίπου 0,950 σε 0,773. Η διαφορά αυτή είναι σημαντική, επειδή το KNN βασίζει άμεσα την απόφασή του στη σύνθεση των πλησιέστερων γειτόνων του κάθε δείγματος. Όταν αλλάζει το ποιες ομάδες πανομοιότυπων ή πολύ όμοιων ροών περιλαμβάνονται στην εκπαίδευση, αλλάζει αντίστοιχα και η τοπική γειτονιά πάνω στην οποία βασίζεται η πρόβλεψη.

Η υψηλή τιμή του KNN σε έναν μόνο διαχωρισμό δεν αρκεί, επομένως, για να θεωρηθεί το συγκεκριμένο μοντέλο γενικά καλύτερο. Το Random Forest εμφανίζει ελαφρώς χαμηλότερη μακρο-F1 στον κύριο διαχωρισμό, αλλά πολύ μεγαλύτερη σταθερότητα μεταξύ των δύο αξιολογήσεων. Επιπλέον, στην καταγεγραμμένη μέτρηση του συνόλου ελέγχου ο χρόνος πρόβλεψης του Random Forest ήταν περίπου 0,08 s, ενώ του KNN περίπου 9,7 s. Το KNN δεν κατασκευάζει ένα συμπαγές μοντέλο απόφασης κατά την εκπαίδευση, αλλά χρειάζεται να αναζητά πλησιέστερα δείγματα κατά την πρόβλεψη. Για εφαρμογή στην οποία ζητείται γρήγορη απόφαση, η διαφορά αυτή αποτελεί πρόσθετο πρακτικό κριτήριο επιλογής.

Συνεπώς, η επιλογή του Random Forest δεν βασίζεται μόνο στο ποιο μοντέλο εμφανίζει τη μεγαλύτερη τιμή μακρο-F1 σε έναν συγκεκριμένο διαχωρισμό. Βασίζεται στον συνδυασμό υψηλής απόδοσης, σταθερότητας απέναντι σε διαφορετικούς group-aware διαχωρισμούς και μικρότερου χρόνου πρόβλεψης. Με βάση τα συγκεκριμένα πειράματα, το Random Forest αποτελεί επομένως την καταλληλότερη επιλογή για τις επόμενες αναλύσεις της Μεθόδου B.

Τα αποτελέσματα στο InSDN πρέπει παράλληλα να ερμηνεύονται με προσοχή. Η ομαδοποίηση των ακριβών διπλοτύπων αντιμετωπίζει μία συγκεκριμένη πηγή διαρροής, αλλά δεν δημιουργεί πλήρως ανεξάρτητο σύνολο δεδομένων διαφορετικής προέλευσης. Εγγραφές που ανήκουν στην ίδια περίοδο συλλογής, στην ίδια συνεδρία ή σε παρόμοια επίθεση μπορεί να εξακολουθούν να παρουσιάζουν ισχυρές συσχετίσεις. Για τον λόγο αυτό,

η μακρο-F1 περίπου 0,946 του Random Forest ερμηνεύεται ως ένδειξη ότι η διαδικασία της Μεθόδου B μπορεί να εφαρμοστεί αποτελεσματικά στα συγκεκριμένα δεδομένα InSDN και όχι ως απόδειξη γενίκευσης σε οποιοδήποτε πραγματικό δίκτυο. Το ίδιο το InSDN περιλαμβάνει συγκεκριμένες κατηγορίες και σενάρια επιθέσεων και δεν καλύπτει το σύνολο των πιθανών απειλών ενός περιβάλλοντος SDN [24].

Συνολικά, η αξιολόγηση στο InSDN παρουσιάζει πιο απαιτητική εικόνα από εκείνη του συνθετικού συνόλου της παραγράφου 6.6. Οι σχεδόν τέλειες τιμές του συνθετικού συνόλου μειώνονται όταν τα μοντέλα εφαρμόζονται σε δεδομένα διαφορετικής προέλευσης και όταν αποτρέπεται η επικάλυψη ακριβών διπλοτύπων μεταξύ εκπαίδευσης και ελέγχου. Παρά τις διαφορές αυτές, το Random Forest διατηρεί υψηλή και σταθερή απόδοση και επιλέγεται ως το βασικό επιβλεπόμενο μοντέλο για τις επόμενες αναλύσεις ερμηνευσιμότητας και στιβαρότητας.

6.8 Μέθοδος B: Συμπληρωματική αξιολόγηση, ερμηνευσιμότητα και στιβαρότητα

Μετά τη βασική σύγκριση των μοντέλων στο συνθετικό σύνολο και στο InSDN, η αξιολόγηση της Μεθόδου B επεκτείνεται σε τρία επιπλέον ζητήματα. Αρχικά εξετάζεται χωριστά η απόδοση του Isolation Forest σε ανάλυση εκτός σύνδεσης. Στη συνέχεια μελετάται η ερμηνευσιμότητα των αποφάσεων του Random Forest μέσω της μεθόδου SHAP (SHapley Additive exPlanations). Τέλος, εξετάζεται η στιβαρότητα του Random Forest απέναντι σε σκόπιμες μεταβολές των χαρακτηριστικών των επιθέσεων και αξιολογείται η εκπαίδευση με αντίπαλα παραδείγματα (adversarial training) ως μέσο περιορισμού της συγκεκριμένης αδυναμίας.

6.8.1 Αξιολόγηση του Isolation Forest εκτός σύνδεσης

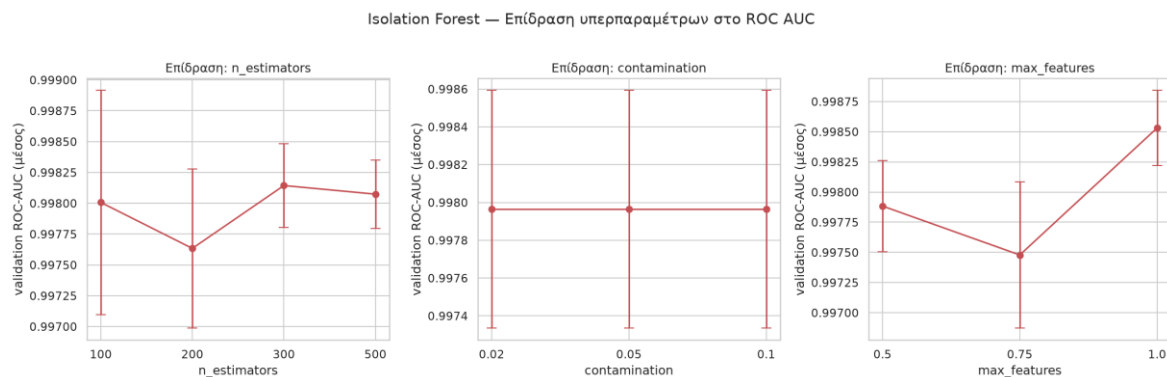
Ο Isolation Forest χρησιμοποιείται στην εργασία με διαφορετικό τρόπο στη ζωντανή Μέθοδο A και στην αξιολόγηση εκτός σύνδεσης της Μεθόδου B. Η διάκριση αυτή είναι σημαντική, επειδή δεν πρόκειται για το ίδιο εκπαιδευμένο μοντέλο ούτε για τον ίδιο χώρο χαρακτηριστικών. Στην αξιολόγηση εκτός σύνδεσης χρησιμοποιούνται τα 24 χαρακτηριστικά ροής, ενώ το μοντέλο που χρησιμοποιείται από τον ζωντανό ελεγκτή βασίζεται σε οκτώ συγκεντρωτικά χαρακτηριστικά ανά πηγή. Οι βασικές διαμορφώσεις παρουσιάζονται στον Πίνακα 6-17.

Πίνακας 6-17: Διαμορφώσεις του Isolation Forest που χρησιμοποιούνται στην εργασία.

Ρόλος	Χαρακτηριστικά	n_estimators	max_samples	Παράμετρος πρόσμειξης (contamination)	max_features
Ρύθμιση υπερπαραμέτρων	24	100	256	0,05	1,0
Αξιολόγηση εκτός σύνδεσης	24	300	512	0,05	0,5
Ζωντανό μοντέλο ελεγκτή	8	300	512	0,03	0,75

Η παράμετρος n_estimators καθορίζει το πλήθος των δέντρων απομόνωσης, ενώ η max_samples το πλήθος των δειγμάτων που χρησιμοποιείται για την κατασκευή κάθε δέντρου. Η παράμετρος πρόσμειξης (contamination) χρησιμοποιείται για τον καθορισμό του κατωφλίου με βάση το οποίο η συνεχής τιμή ανωμαλίας μετατρέπεται σε τελική απόφαση κανονικής ή ανώμαλης παρατήρησης. Η λειτουργία και η μαθηματική βάση του Isolation Forest έχουν αναλυθεί στην παράγραφο 4.3 [23].

Η διαδικασία ρύθμισης των υπερπαραμέτρων αξιολογεί διαφορετικούς συνδυασμούς ως προς το εμβαδόν κάτω από την καμπύλη ROC (ROC-AUC) και την τιμή F1. Η γραφική σύγκριση των συνδυασμών παρουσιάζεται στο Σχήμα 6-15.



Σχήμα 6-15: Ρύθμιση υπερπαραμέτρων του Isolation Forest: ROC-AUC και F1 για τους εξεταζόμενους συνδυασμούς.

Το Σχήμα 6-15 επιτρέπει την ταυτόχρονη εξέταση δύο διαφορετικών πλευρών της απόδοσης. Η ROC-AUC περιγράφει τη συνολική ικανότητα του μοντέλου να διαχωρίζει τις δύο κατηγορίες σε διαφορετικά κατώφλια απόφασης, ενώ η F1 συνδυάζει την ορθότητα και την ανάκληση στο συγκεκριμένο σημείο λειτουργίας. Επομένως, η επιλογή μιας διαμόρφωσης δεν βασίζεται αποκλειστικά σε μία από τις δύο μετρικές.

Η τελική αξιολόγηση εκτός σύνδεσης πραγματοποιήθηκε με 24 χαρακτηριστικά τόσο στο συνθετικό σύνολο όσο και στο InSDN. Τα αποτελέσματα παρουσιάζονται στον Πίνακα 6-18.

Πίνακας 6-18: Μετρικές του Isolation Forest εκτός σύνδεσης στο συνθετικό σύνολο και στο InSDN.

Μετρική	Συνθετικό σύνολο	InSDN
Ορθότητα (precision)	0,987	0,993
Ανάκληση (recall)	0,999	0,676
F1	0,993	0,804
ROC-AUC	0,998	0,930

Στο συνθετικό σύνολο ο Isolation Forest παρουσιάζει πολύ υψηλή απόδοση, με F1 ίση με 0,993 και ROC-AUC ίση με 0,998. Η ανάκληση 0,999 σημαίνει ότι σχεδόν όλα τα δείγματα επίθεσης του συγκεκριμένου συνθετικού συνόλου αναγνωρίζονται ως ανώμαλα. Η εικόνα μεταβάλλεται αισθητά στο InSDN. Παρότι η ορθότητα παραμένει ιδιαίτερα υψηλή, 0,993, η ανάκληση μειώνεται σε 0,676 και η F1 σε 0,804.

Η διαφορά μεταξύ ορθότητας και ανάκλησης είναι σημαντική για την ερμηνεία του αποτελέσματος. Η ορθότητα 0,993 σημαίνει ότι όταν το μοντέλο χαρακτηρίζει μια παρατήρηση ως επίθεση, η απόφαση αυτή είναι σχεδόν πάντα σωστή. Η ανάκληση 0,676, όμως, σημαίνει ότι εντοπίζεται περίπου το 67,6% των πραγματικών επιθέσεων και ότι ένα σημαντικό μέρος τους δεν αναγνωρίζεται. Επομένως, η υψηλή ορθότητα από μόνη της δεν αρκεί για να χαρακτηριστεί το μοντέλο αποτελεσματικό σε πραγματικότερο σύνολο δεδομένων.

Η σύγκριση επιβεβαιώνει επίσης τη διαφορά μεταξύ των δύο πειραματικών περιβαλλόντων. Οι καθαρές και περισσότερο διαχωρίσιμες υπογραφές του συνθετικού συνόλου οδηγούν σε σχεδόν τέλεια διάκριση, ενώ στο InSDN οι διαφορετικές κατηγορίες κίνησης εμφανίζουν μεγαλύτερη επικάλυψη. Για τον λόγο αυτό, η F1 του Isolation Forest μειώνεται από 0,993 σε 0,804. Το αποτέλεσμα αυτό δεν αφορά το ζωντανό μοντέλο των οκτώ χαρακτηριστικών της Μεθόδου Α, το οποίο έχει αξιολογηθεί χωριστά στις προηγούμενες ενότητες.

6.8.2 Ερμηνευσιμότητα των αποφάσεων με SHAP

Η υψηλή τιμή μιας μετρικής ταξινόμησης δεν εξηγεί από μόνη της ποια χαρακτηριστικά οδήγησαν το μοντέλο σε μια συγκεκριμένη απόφαση. Για τον λόγο αυτό πραγματοποιήθηκε συμπληρωματική ανάλυση ερμηνευσιμότητας του Random Forest με τη μέθοδο SHAP

(SHapley Additive exPlanations). Για την ανάλυση χρησιμοποιήθηκαν 2.000 στρωματοποιημένα δείγματα και υπολογίστηκαν τιμές SHAP για τις πέντε κατηγορίες του συνόλου και για τα 24 χαρακτηριστικά ροής. Η θεωρητική λειτουργία της μεθόδου SHAP έχει παρουσιαστεί στην παράγραφο 4.7. Η ανάλυση πραγματοποιήθηκε στο συνθετικό σύνολο δεδομένων.

Για τη συνολική αξιολόγηση της σημαντικότητας χρησιμοποιείται η μέση απόλυτη τιμή SHAP. Η τιμή αυτή δεν αποτελεί ποσοστό, πιθανότητα ή μέτρο ακρίβειας. Για παράδειγμα, η τιμή 0,192 για την τυπική απόκλιση του χρόνου μεταξύ αφίξεων δεν σημαίνει 19,2% πιθανότητα επίθεσης. Σημαίνει ότι, κατά μέσο όρο, το συγκεκριμένο χαρακτηριστικό παρουσιάζει τη μεγαλύτερη απόλυτη επίδραση στην έξοδο του μοντέλου μεταξύ των χαρακτηριστικών που εξετάζονται. Όσο μεγαλύτερη είναι η μέση απόλυτη τιμή SHAP, τόσο ισχυρότερη είναι η συνολική επίδραση του χαρακτηριστικού στις αποφάσεις του μοντέλου.

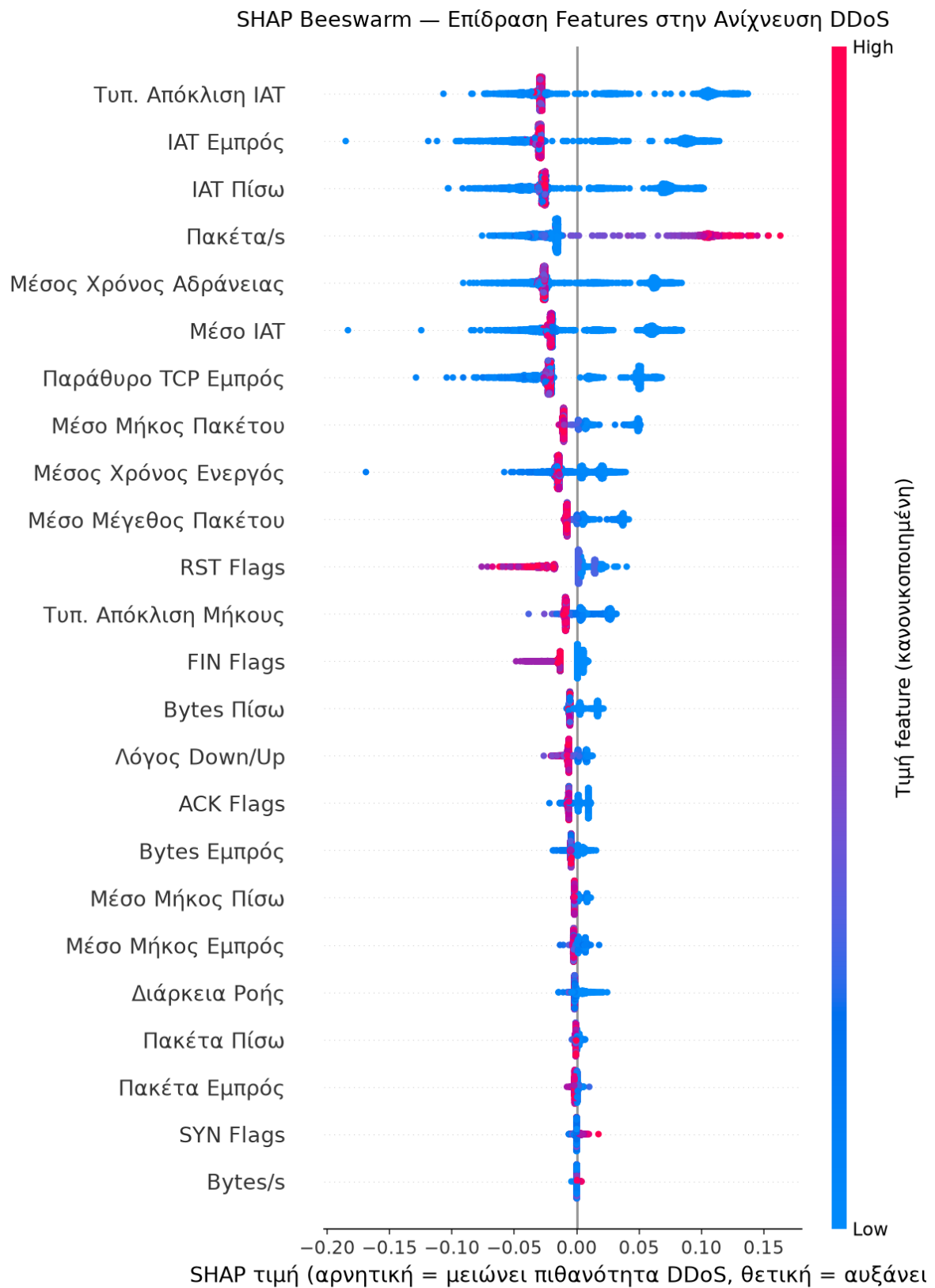
Τα πέντε σημαντικότερα χαρακτηριστικά παρουσιάζονται στον Πίνακα 6-19.

Πίνακας 6-19: Τα πέντε σημαντικότερα χαρακτηριστικά κατά την ανάλυση SHAP.

Θέση	Χαρακτηριστικό	Μέση απόλυτη τιμή SHAP	Δικτυακή ερμηνεία
1	Τυπική απόκλιση IAT	0,192	Μεταβολές στους χρόνους μεταξύ αφίξεων, χαρακτηριστικές σε επιθέσεις πλημμύρας
2	Πακέτα/s	0,157	Υψηλός ρυθμός σε DoS/DDoS και διαφορετικό πρότυπο σε σάρωση
3	Μέσο IAT εμπρός	0,149	Πολύ μικροί χρόνοι μεταξύ διαδοχικών πακέτων εμφανίζονται σε εκρηκτική κίνηση
4	Μέσο μήκος πακέτου	0,146	Διαφορετικά μεγέθη πακέτων συνδέονται με διαφορετικά πρότυπα κίνησης
5	Μέσος χρόνος αδράνειας	0,144	Συμβάλλει στη διάκριση διακοπτόμενης δραστηριότητας από συνεχή πλημμύρα

Το ισχυρότερο χαρακτηριστικό είναι η τυπική απόκλιση του χρόνου μεταξύ αφίξεων (Inter-Arrival Time, IAT), με μέση απόλυτη τιμή SHAP 0,192. Ακολουθούν ο ρυθμός πακέτων ανά δευτερόλεπτο με 0,157 και ο μέσος χρόνος μεταξύ διαδοχικών πακέτων στην εμπρόσθια κατεύθυνση με 0,149. Η παρουσία χρονικών και ρυθμολογικών χαρακτηριστικών στις πρώτες θέσεις δείχνει ότι το μοντέλο δεν βασίζεται μόνο στον συνολικό όγκο της κίνησης, αλλά αξιοποιεί και τον τρόπο με τον οποίο αυτή εξελίσσεται στον χρόνο.

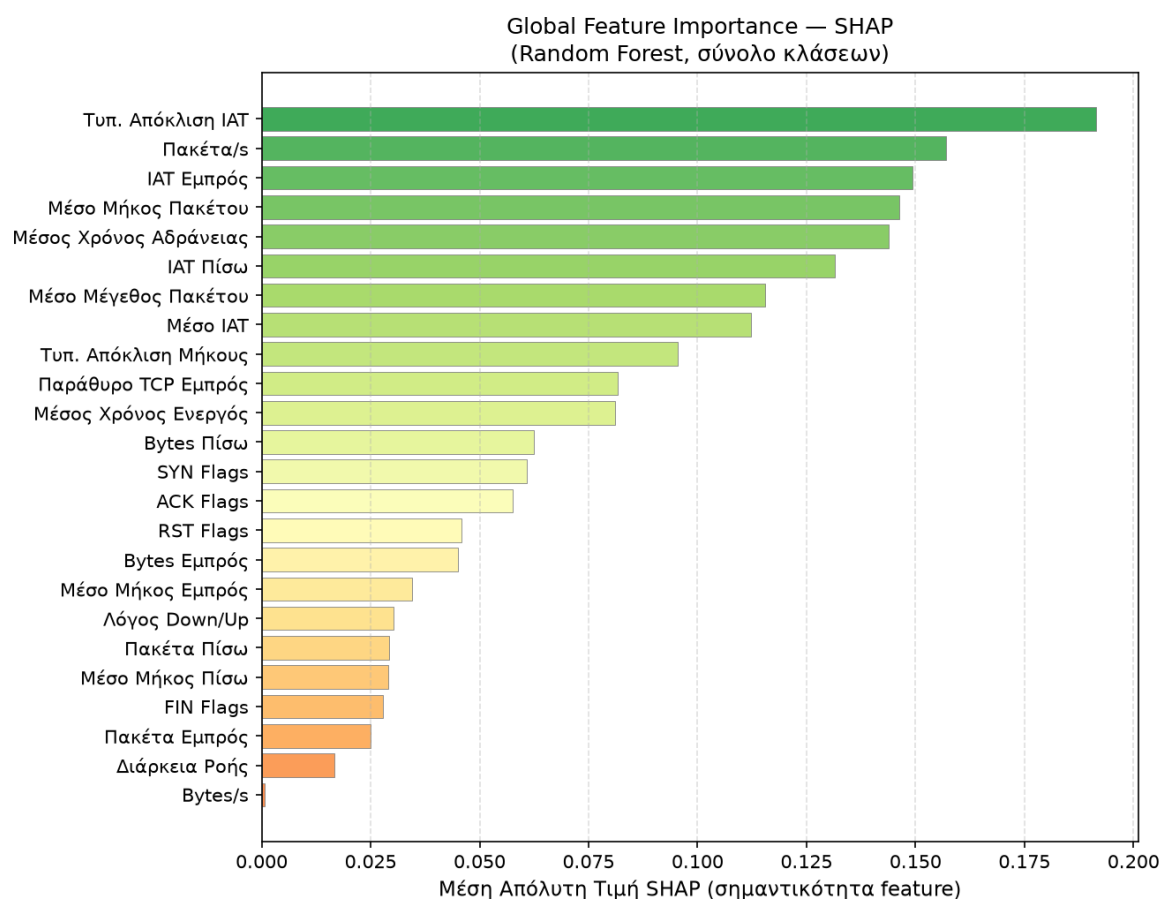
Η κατανομή της επίδρασης των χαρακτηριστικών στις επιμέρους παρατηρήσεις παρουσιάζεται στο Σχήμα 6-16.



Σχήμα 6-16: Διάγραμμα σμήνους SHAP (SHAP beeswarm): κατεύθυνση και μέγεθος της επίδρασης των χαρακτηριστικών στις προβλέψεις.

Στο Σχήμα 6-16 κάθε σημείο αντιστοιχεί σε μία παρατήρηση. Η οριζόντια θέση του δείχνει την τιμή SHAP και επομένως τόσο την κατεύθυνση όσο και το μέγεθος της επίδρασης του αντίστοιχου χαρακτηριστικού. Σημεία που βρίσκονται μακριά από το μηδέν αντιστοιχούν σε περιπτώσεις στις οποίες το χαρακτηριστικό επηρέασε περισσότερο την απόφαση. Έτσι, το διάγραμμα δεν δείχνει μόνο ποια χαρακτηριστικά είναι συνολικά σημαντικά, αλλά και αν η επίδρασή τους είναι σταθερή ή μεταβάλλεται μεταξύ διαφορετικών δειγμάτων.

Η συνολική κατάταξη παρουσιάζεται πιο συνοπτικά στο Σχήμα 6-17.

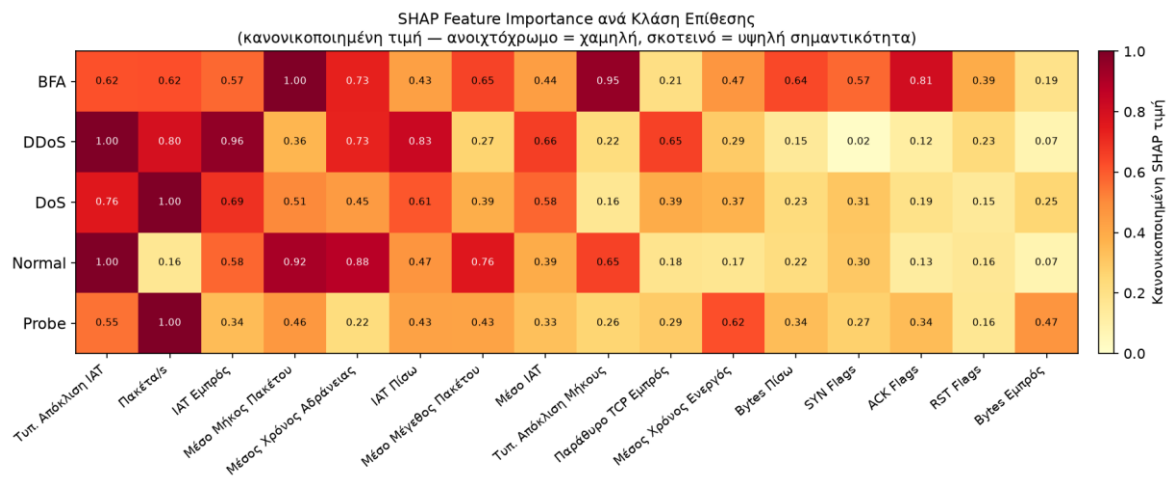


Σχήμα 6-17: Συνολική σημαντικότητα των χαρακτηριστικών κατά SHAP, με βάση τη μέση απόλυτη τιμή SHAP.

Σε αντίθεση με το Σχήμα 6-16, στο Σχήμα 6-17 δεν διατηρείται η κατεύθυνση της επίδρασης. Χρησιμοποιείται το απόλυτο μέγεθος των τιμών SHAP και υπολογίζεται ο μέσος όρος τους, ώστε να φανεί ποια χαρακτηριστικά επηρεάζουν περισσότερο το μοντέλο

συνολικά. Για τον λόγο αυτό, το συγκεκριμένο σχήμα αντιστοιχεί άμεσα στην κατάταξη του Πίνακα 6-19.

Η επίδραση των χαρακτηριστικών δεν είναι ίδια για όλες τις κατηγορίες. Η διαφοροποίηση αυτή παρουσιάζεται στο Σχήμα 6-18.



Σχήμα 6-18: Θερμικός χάρτης SHAP: διαφοροποίηση της σημαντικότητας των χαρακτηριστικών μεταξύ των κατηγοριών κίνησης.

Ο θερμικός χάρτης επιτρέπει τη σύγκριση των χαρακτηριστικών ανά κατηγορία και δείχνει ότι ένα χαρακτηριστικό που είναι ιδιαίτερα χρήσιμο για την αναγνώριση μιας μορφής επίθεσης δεν είναι απαραίτητα εξίσου σημαντικό για όλες τις υπόλοιπες. Αυτό είναι αναμενόμενο, καθώς μια επίθεση πλημμύρας χαρακτηρίζεται κυρίως από τον ρυθμό και τη χρονική πυκνότητα της κίνησης, ενώ άλλες κατηγορίες μπορεί να διαφοροποιούνται περισσότερο από το μέγεθος των πακέτων, τη διάρκεια ή τα διαστήματα αδράνειας.

Συνολικά, η ανάλυση SHAP επιβεβαιώνει ότι οι αποφάσεις του Random Forest δεν στηρίζονται σε ένα μοναδικό χαρακτηριστικό. Η σημαντικότητα κατανέμεται σε πολλαπλές πλευρές της συμπεριφοράς της ροής, με μεγαλύτερη συμμετοχή των χαρακτηριστικών που περιγράφουν τον χρονισμό και τον ρυθμό των πακέτων. Η ερμηνεία αυτή αφορά το συγκεκριμένο εκπαιδευμένο μοντέλο και τα δεδομένα στα οποία πραγματοποιήθηκε η ανάλυση και δεν πρέπει να θεωρηθεί καθολική κατάταξη των σημαντικότερων χαρακτηριστικών για κάθε δίκτυο ή κάθε σύνολο δεδομένων.

6.8.3 Στιβαρότητα σε επιθέσεις αποφυγής και εκπαίδευση με αντίπαλα παραδείγματα

Η τελευταία συμπληρωματική αξιολόγηση εξετάζει αν η υψηλή απόδοση του Random Forest διατηρείται όταν ο επιτιθέμενος δεν παρουσιάζει ακριβώς το ίδιο στατιστικό προφίλ με εκείνο που χρησιμοποιήθηκε κατά την εκπαίδευση. Στις επιθέσεις αποφυγής (evasion attacks), ο στόχος δεν είναι απαραίτητα η διακοπή του συστήματος ανίχνευσης, αλλά η κατάλληλη τροποποίηση της κακόβουλης εισόδου ώστε αυτή να ταξινομηθεί ως νόμιμη.

Στο εξεταζόμενο σενάριο μίμησης (mimicry), κάθε δείγμα επίθεσης μετακινείται σταδιακά προς το μέσο προφίλ της νόμιμης κίνησης. Η παράμετρος ϵ εκφράζει το μέγεθος αυτής της μεταβολής. Για παράδειγμα, $\epsilon=0,20$ σημαίνει ότι το τροποποιημένο δείγμα έχει μετακινηθεί κατά 20% της απόστασης από την αρχική του θέση προς το μέσο προφίλ της νόμιμης κίνησης. Όσο αυξάνεται το ϵ , τόσο περισσότερο τα χαρακτηριστικά της επίθεσης προσεγγίζουν εκείνα της φυσιολογικής κίνησης.

Η αρχική έκδοση του Random Forest παρουσιάζει έντονη ευαισθησία σε αυτή τη μεταβολή. Για μικρή διαταραχή $\epsilon=0,10$ ο ρυθμός αποφυγής είναι 7,5%, αλλά στο $\epsilon=0,20$ αυξάνεται απότομα σε 98,9%. Επομένως, μια σχετικά μικρή επιπλέον μετακίνηση των χαρακτηριστικών είναι αρκετή για να αλλάξει την απόφαση του μοντέλου για σχεδόν όλα τα εξεταζόμενα δείγματα. Η συμπεριφορά αυτή δείχνει ότι η πολύ υψηλή επίδοση σε καθαρά δεδομένα δεν εγγυάται αντίστοιχη στιβαρότητα όταν τα χαρακτηριστικά τροποποιούνται σκόπιμα.

Για τον περιορισμό της ευπάθειας εκπαιδεύτηκε δεύτερη έκδοση του Random Forest με εκπαίδευση με αντίπαλα παραδείγματα (adversarial training). Για κάθε κακόβουλο δείγμα του συνόλου εκπαίδευσης δημιουργήθηκαν επιπλέον μιμητικές εκδοχές προς τη νόμιμη κίνηση για $\epsilon \in \{0,10, 0,20, 0,30\}$, διατηρώντας την αρχική ετικέτα επίθεσης. Με τον τρόπο αυτό το μοντέλο εκτίθεται κατά την εκπαίδευση όχι μόνο στις αρχικές επιθέσεις αλλά και σε παραλλαγές τους που βρίσκονται πλησιέστερα στο φυσιολογικό προφίλ.

Τα αποτελέσματα παρουσιάζονται στον Πίνακα 6-20.

Πίνακας 6-20: Ρυθμός αποφυγής του αρχικού και του ενισχυμένου Random Forest ανά τιμή διαταραχής ϵ .

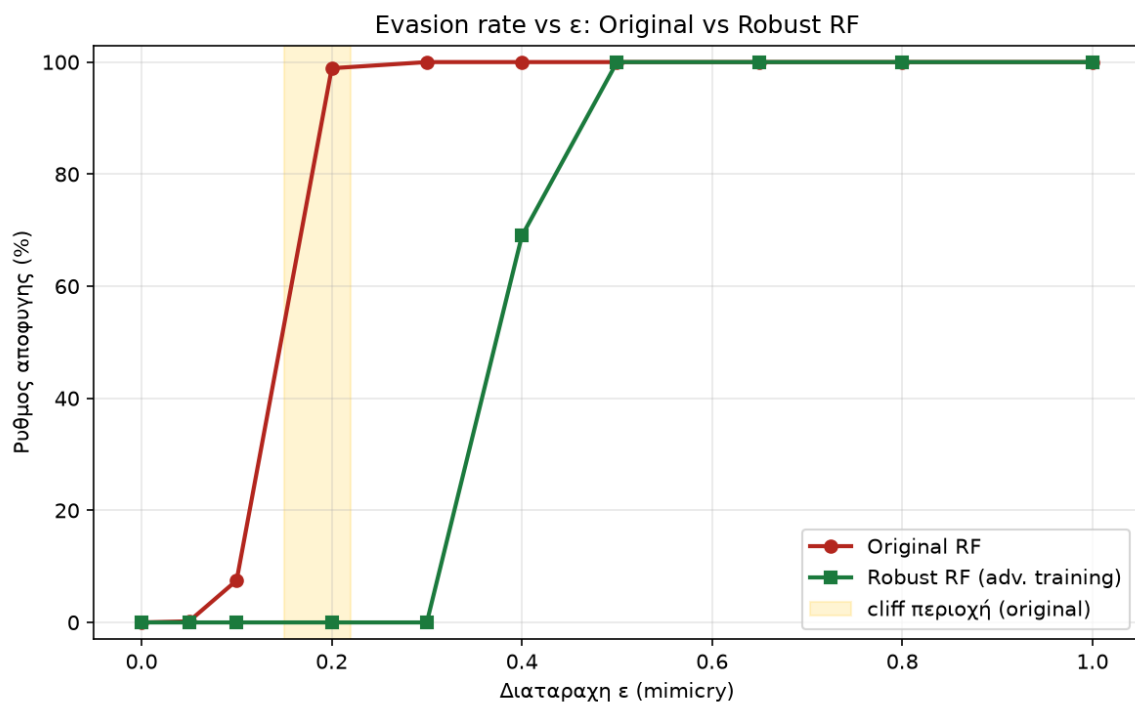
ϵ	Αρχικό Random Forest	Random Forest με εκπαίδευση με αντίπαλα παραδείγματα
0,10	7,5%	0,0%
0,20	98,9%	0,0%
0,30	100,0%	0,0%

0,40	100,0%	69,0%
0,50	100,0%	100,0%

Η σημαντικότερη διαφορά εμφανίζεται στις τιμές $\epsilon=0,20$ και $\epsilon=0,30$. Στο $\epsilon=0,20$ το αρχικό Random Forest αποτυγχάνει να αναγνωρίσει το 98,9% των τροποποιημένων επιθέσεων, ενώ το ενισχυμένο μοντέλο διατηρεί ρυθμό αποφυγής 0%. Στο $\epsilon=0,30$ το αρχικό μοντέλο αποφεύγεται στο 100% των περιπτώσεων, ενώ το μοντέλο που έχει εκπαιδευτεί με αντίπαλα παραδείγματα εξακολουθεί να αναγνωρίζει όλα τα εξεταζόμενα δείγματα ως επιθέσεις.

Η βελτίωση, ωστόσο, δεν είναι απεριόριστη. Στο $\epsilon=0,40$ ο ρυθμός αποφυγής του ενισχυμένου μοντέλου αυξάνεται στο 69% και στο $\epsilon=0,50$ φτάνει το 100%. Συνεπώς, η εκπαίδευση με αντίπαλα παραδείγματα δεν εξαλείφει την ευπάθεια. Μετατοπίζει το σημείο στο οποίο η ανίχνευση καταρρέει προς ισχυρότερες μεταβολές των χαρακτηριστικών.

Η διαφορά μεταξύ των δύο μοντέλων απεικονίζεται στο Σχήμα 6-19.



Σχήμα 6-19: Ρυθμός αποφυγής συναρτήσει της διαταραχής ϵ για το αρχικό Random Forest και το Random Forest που εκπαιδεύτηκε με αντίπαλα παραδείγματα.

Το Σχήμα 6-19 κάνει εμφανή την απότομη αύξηση του ρυθμού αποφυγής του αρχικού μοντέλου μεταξύ $\epsilon=0,10$ και $\epsilon=0,20$. Αντίθετα, η καμπύλη του ενισχυμένου μοντέλου παραμένει στο 0% έως το $\epsilon=0,30$ και αυξάνεται σε μεγαλύτερες τιμές διαταραχής. Η

σύγκριση δείχνει επομένως ότι η εκπαίδευση με τροποποιημένα κακόβουλα δείγματα αυξάνει τη στιβαρότητα απέναντι στη συγκεκριμένη μορφή επίθεσης μίμησης, χωρίς όμως να παρέχει πλήρη προστασία για οποιαδήποτε μεταβολή.

Παράλληλα εξετάστηκε αν η αύξηση της στιβαρότητας επιτυγχάνεται εις βάρος της απόδοσης στα μη τροποποιημένα δεδομένα. Η συνολική ακρίβεια μειώθηκε από 0,9998 στο αρχικό μοντέλο σε 0,9993 στο ενισχυμένο μοντέλο, ενώ η μακρο-F1 μειώθηκε από 0,9998 σε 0,9992. Για τη σύγκριση των δύο μοντέλων χρησιμοποιήθηκε ο έλεγχος McNemar, ο οποίος εξετάζει τις περιπτώσεις στις οποίες τα δύο μοντέλα διαφωνούν ως προς την ορθότητα της πρόβλεψής τους. Ο έλεγχος αυτός είναι ο κατάλληλος όταν τα μοντέλα εκπαιδεύονται μία φορά και συγκρίνονται στο ίδιο σύνολο ελέγχου [37]. Ο έλεγχος έδωσε $p \approx 0,25$ και επομένως η διαφορά στο καθαρό σύνολο ελέγχου δεν ήταν στατιστικά σημαντική για επίπεδο σημαντικότητας 0,05.

Το αποτέλεσμα αυτό δείχνει ότι, στο συγκεκριμένο πείραμα, η εκπαίδευση με αντίπαλα παραδείγματα αύξησε ουσιαστικά τη στιβαρότητα στις εξεταζόμενες επιθέσεις μίμησης, χωρίς σημαντική υποβάθμιση της απόδοσης στα αρχικά δεδομένα. Το συμπέρασμα περιορίζεται, ωστόσο, στη συγκεκριμένη μέθοδο δημιουργίας των αντίπαλων δειγμάτων και στον χώρο χαρακτηριστικών της αξιολόγησης εκτός σύνδεσης. Δεν αποδεικνύει ότι το μοντέλο είναι στιβαρό σε κάθε πιθανή στρατηγική αποφυγής ούτε ότι η ίδια βελτίωση θα παρατηρηθεί χωρίς πρόσθετη αξιολόγηση σε πραγματική δικτυακή κίνηση. Η εκπαίδευση με αντίπαλα παραδείγματα εφαρμόστηκε μόνο στο Random Forest της ανάλυσης εκτός σύνδεσης και όχι στο Isolation Forest της ζωντανής Μεθόδου Α.

Συνολικά, η συμπληρωματική αξιολόγηση της Μεθόδου Β αναδεικνύει τρεις διαφορετικές πλευρές της συμπεριφοράς των μοντέλων. Ο Isolation Forest παρουσιάζει σχεδόν τέλεια επίδοση στο συνθετικό σύνολο αλλά αισθητά χαμηλότερη ανάκληση στο InSDN. Η ανάλυση SHAP δείχνει ότι τα χαρακτηριστικά χρονισμού και ρυθμού της κίνησης έχουν ιδιαίτερα σημαντική συμμετοχή στις αποφάσεις του Random Forest. Τέλος, η δοκιμή αποφυγής δείχνει ότι η υψηλή απόδοση σε μη τροποποιημένα δεδομένα δεν συνεπάγεται αυτόματα αντίστοιχη στιβαρότητα απέναντι σε σκόπιμες μεταβολές των χαρακτηριστικών, ενώ η εκπαίδευση με αντίπαλα παραδείγματα μπορεί να περιορίσει σημαντικά τη συγκεκριμένη ευπάθεια.

7 Συμπεράσματα και Μελλοντική Εργασία

Η παρούσα διπλωματική εργασία μελέτησε την ανίχνευση και την αυτόματη αντιμετώπιση επιθέσεων σε δίκτυα οριζόμενα από λογισμικό (Software-Defined Networking, SDN), με αξιοποίηση αλγορίθμων Μηχανικής Μάθησης. Για τον σκοπό αυτό αναπτύχθηκαν δύο συμπληρωματικές μέθοδοι. Η πρώτη αφορά τη ζωντανή παρακολούθηση της δικτυακής κίνησης και την αυτόματη εφαρμογή μέτρων αντιμετώπισης, ενώ η δεύτερη αφορά την εκτός σύνδεσης ανάλυση καταγεγραμμένων ροών και τη σύγκριση διαφορετικών μοντέλων ταξινόμησης.

Ο συνδυασμός των δύο μεθόδων επέτρεψε να εξεταστεί το πρόβλημα από διαφορετικές πλευρές. Η ανάλυση εκτός σύνδεσης χρησιμοποιήθηκε για τη συστηματική σύγκριση μοντέλων και τη διερεύνηση της επίδρασης των δεδομένων και του τρόπου διαχωρισμού τους. Η ζωντανή υλοποίηση χρησιμοποιήθηκε για να εξεταστεί η πλήρης ακολουθία από τη συλλογή της τηλεμετρίας και την ανίχνευση ασυνήθιστης συμπεριφοράς έως την εφαρμογή μέτρου αποκλεισμού στον μεταγωγέα. Τα αποτελέσματα έδειξαν τόσο τις δυνατότητες αυτής της προσέγγισης όσο και τα σημεία στα οποία απαιτείται περαιτέρω ανάπτυξη.

7.1 Σύνοψη ευρημάτων

Στην ανάλυση εκτός σύνδεσης, το Τυχαίο Δάσος (Random Forest) παρουσίασε την πιο σταθερή συνολική συμπεριφορά μεταξύ των μοντέλων που εξετάστηκαν. Στο συνθετικό σύνολο δεδομένων η τιμή F1 ήταν μεγαλύτερη από 0,999, ενώ στο InSDN η μακρο-F1 έφτασε περίπου στο 0,946 όταν εφαρμόστηκε διαχωρισμός με ομαδοποίηση των πανομοιότυπων διανυσμάτων. Η πολύ υψηλή επίδοση στο συνθετικό σύνολο δεν αποτελεί από μόνη της απόδειξη γενίκευσης, επειδή οι κατηγορίες του έχουν δημιουργηθεί με σαφέστερες στατιστικές διαφορές. Αντίθετα, το InSDN αποτελεί πιο απαιτητική περίπτωση και για τον λόγο αυτό τα αποτελέσματά του έχουν μεγαλύτερη σημασία για την αξιολόγηση της αλυσίδας επεξεργασίας.

Ο ταξινομητής των k πλησιέστερων γειτόνων (KNN) έφτασε επίσης σε υψηλές τιμές σε ορισμένες διαμορφώσεις. Ωστόσο, η επίδοσή του μεταβλήθηκε περισσότερο όταν άλλαξε ο τρόπος σχηματισμού των συνόλων εκπαίδευσης και ελέγχου. Τα αποτελέσματα δείχνουν ότι ο KNN εξαρτάται από το ποιοι γείτονες βρίσκονται στο σύνολο εκπαίδευσης. Παράλληλα, η πρόβλεψή του είχε μεγαλύτερο υπολογιστικό κόστος σε σχέση με το Random Forest. Επομένως, η επιλογή του καταλληλότερου μοντέλου δεν πρέπει να βασίζεται μόνο στη μεγαλύτερη τιμή μίας μετρικής, αλλά και στη σταθερότητα και στο κόστος της πρόβλεψης.

Η μελέτη των διπλότυπων εγγραφών στο InSDN ανέδειξε επίσης τη σημασία του τρόπου διαχωρισμού των δεδομένων. Το 47,5% των εγγραφών αποτελεί πλεονάζοντα ακριβή αντίγραφα ως προς τα 24 χαρακτηριστικά που χρησιμοποιήθηκαν, ενώ στην κατηγορία DDoS το ποσοστό είναι ακόμη μεγαλύτερο. Αν πανομοιότυπα διανύσματα κατανεμηθούν ταυτόχρονα στην εκπαίδευση και στην αξιολόγηση, η μετρούμενη επίδοση μπορεί να εμφανιστεί τεχνητά αυξημένη. Η χρήση διαχωρισμού κατά ομάδες απέτρεψε αυτή την επικάλυψη και επέτρεψε πιο αυστηρή αξιολόγηση των μοντέλων.

Τα δύο μοντέλα Βαθιάς Μάθησης εξετάστηκαν μόνο στο συνθετικό σύνολο δεδομένων και με διαφορετικό πρωτόκολλο αξιολόγησης από εκείνο των έξι κύριων μοντέλων. Για τον λόγο αυτό τα αποτελέσματά τους χρησιμοποιούνται ως συμπληρωματική διερεύνηση και όχι για άμεση κατάταξη απέναντι στα υπόλοιπα μοντέλα. Η συγκεκριμένη σύγκριση δείχνει επίσης ότι η μεγαλύτερη πολυπλοκότητα ενός μοντέλου δεν συνεπάγεται αυτόματα καλύτερη λύση για το εξεταζόμενο πρόβλημα.

Στη ζωντανή Μέθοδο Α επιβεβαιώθηκε ότι η ανίχνευση μπορεί να συνδεθεί με αυτόματη ενέργεια αντιμετώπισης. Στο πείραμα σε επίπεδο πακέτων, η πλημμύρα SYN δημιουργήθηκε μέσα στην τοπολογία Mininet και οι μετρήσεις συλλέχθηκαν από τον Open vSwitch. Η ύποπτη πηγή εντοπίστηκε από το ζωντανό μοντέλο και εγκαταστάθηκε αυτόματα κανόνας απόρριψης στον μεταγωγέα. Το αποτέλεσμα αυτό είναι σημαντικό, επειδή δείχνει ότι η συλλογή τηλεμετρίας, η παραγωγή χαρακτηριστικών, η ανίχνευση και η εφαρμογή μέτρου μπορούν να λειτουργήσουν ως ενιαία ακολουθία και όχι μόνο ως ανεξάρτητα τμήματα.

Τα συμπληρωματικά ζωντανά σενάρια έδειξαν ότι η στατιστική προσέγγιση λειτουργεί καλύτερα όταν η επίθεση προκαλεί έντονη μεταβολή στα χαρακτηριστικά της κίνησης. Η πλημμύρα SYN, η σάρωση θυρών και η εξάντληση του πίνακα ροών αφήνουν έντονο στατιστικό αποτύπωμα και μπορούν να εντοπιστούν ευκολότερα. Αντίθετα, η εξαγωγή δεδομένων, η πλευρική κίνηση και η πλαστογράφηση ARP είναι δυσκολότερες περιπτώσεις. Στην πλαστογράφηση ARP απαιτείται γνώση της σχέσης μεταξύ διευθύνσεων IP και MAC, ενώ στην εξαγωγή δεδομένων μία νόμιμη μεταφορά μεγάλου όγκου μπορεί να μοιάζει στατιστικά με μία κακόβουλη. Τα αποτελέσματα αυτά δείχνουν πού σταματά η στατιστική προσέγγιση και πότε χρειάζεται πρόσθετη πληροφορία από τα πρωτόκολλα του δικτύου.

Η διερεύνηση της στιβαρότητας (robustness) έδειξε ακόμη ότι η υψηλή επίδοση σε κανονικά δεδομένα δεν εξασφαλίζει αντίστοιχη συμπεριφορά όταν ο επιτιθέμενος προσαρμόζει τη δραστηριότητά του. Στην επίθεση μίμησης απέναντι στο Random Forest παρατηρήθηκε απότομη αύξηση του ρυθμού αποφυγής γύρω από διαταραχή $\approx 0,20$. Η εκπαίδευση του Random Forest με αντίπαλα παραδείγματα μείωσε τον ρυθμό αποφυγής από 98,9% σε 0,0% για τη συγκεκριμένη περίπτωση, ενώ η μακρο-F1 στα καθαρά δεδομένα μειώθηκε μόνο από 0,9998 σε 0,9992. Το αποτέλεσμα δείχνει ότι η στιβαρότητα μπορεί να βελτιωθεί, αλλά αφορά το Random Forest της ανάλυσης εκτός σύνδεσης και όχι το Isolation Forest της ζωντανής υλοποίησης.

7.1.1 Απαντήσεις στα ερευνητικά ερωτήματα

RQ1. Η ζωντανή υλοποίηση μπόρεσε να ανιχνεύσει την πλημμύρα SYN ήδη κατά την πρώτη περίοδο συλλογής μετρήσεων. Η απόφαση ανίχνευσης λήφθηκε περίπου 1,16 s μετά την έναρξη της επίθεσης, ο κανόνας αποκλεισμού εγκαταστάθηκε αμέσως μετά και η ανανέωσή του διατήρησε την αντιμετώπιση ενεργή σε όλη τη διάρκεια της επίθεσης από τη στιγμή της ανίχνευσης.

RQ2. Η βελτίωση της συλλογής και της επεξεργασίας της ζωντανής τηλεμετρίας περιόρισε τα ψευδώς θετικά στη νόμιμη κίνηση. Στην τελική διαμόρφωση δεν καταγράφηκαν ψευδώς θετικές αποφάσεις στα εξεταζόμενα παράθυρα νόμιμης κίνησης, χωρίς να χαθεί η δυνατότητα ανίχνευσης της επίθεσης.

RQ3. Στις μετρήσεις του πειράματος, η εφαρμογή του κανόνα αποκλεισμού δεν προκάλεσε μετρήσιμη υποβάθμιση στη νόμιμη κίνηση. Η επικοινωνία του νόμιμου κόμβου συνεχίστηκε χωρίς απώλεια πακέτων και χωρίς ουσιαστική μεταβολή του χρόνου απόκρισης. Παράλληλα, μετά τη λήξη της επίθεσης και του προσωρινού αποκλεισμού αποκαταστάθηκε η συνδεσιμότητα της πηγής που είχε αποκλειστεί. Το συμπέρασμα περιορίζεται στα μεγέθη που μετρήθηκαν και δεν επεκτείνεται σε φόρτο επεξεργαστή, μνήμης ή συνολική διαμεταγωγή.

RQ4. Τα κλασικά μοντέλα παρέμειναν αποτελεσματικά ακόμη και όταν εμποδίστηκε η επικάλυψη ακριβώς πανομοιότυπων διανυσμάτων μεταξύ εκπαίδευσης και αξιολόγησης. Το Random Forest παρουσίασε την πιο σταθερή συνολική συμπεριφορά, με μακρο-F1 περίπου 0,946 στο InSDN υπό τον διαχωρισμό κατά ομάδες. Το αποτέλεσμα δείχνει ότι η υψηλή του επίδοση δεν εξηγείται μόνο από την παρουσία ακριβών διπλοτύπων.

RQ5. Το Isolation Forest εμφάνισε σαφή μείωση της επίδοσής του όταν μεταφέρθηκε από το συνθετικό σύνολο στο InSDN, με διαφορά περίπου 0,19 στην τιμή F1. Το εύρημα αυτό δείχνει ότι η πολύ υψηλή επίδοση σε ένα ελεγχόμενο και καθαρά διαχωρίσιμο σύνολο δεν πρέπει να θεωρείται από μόνη της ένδειξη αντίστοιχης γενίκευσης σε πιο σύνθετα δεδομένα.

Οι συμπληρωματικές αναλύσεις ανέδειξαν ακόμη δύο χρήσιμα σημεία. Η ανάλυση ερμηνευσιμότητας έδειξε ποια χαρακτηριστικά επηρεάζουν περισσότερο τις αποφάσεις του Random Forest, με χαρακτηριστικά που σχετίζονται με τον ρυθμό και τη χρονική συμπεριφορά των πακέτων να εμφανίζονται ιδιαίτερα σημαντικά στις επιθέσεις πλημμύρας. Παράλληλα, η μελέτη κορεσμού του επιπέδου ελέγχου έδειξε σε περιβάλλον προσομοίωσης ότι η μαζική εμφάνιση νέων ροών μπορεί να αυξήσει την ουρά επεξεργασίας και την καθυστέρηση του ελεγκτή. Τα αποτελέσματα αυτά συμπληρώνουν την αξιολόγηση, αλλά δεν αποτελούν μετρήσεις πραγματικού παραγωγικού ελεγκτή.

Συνολικά, τα αποτελέσματα δείχνουν ότι η Μηχανική Μάθηση μπορεί να χρησιμοποιηθεί ως μέρος ενός μηχανισμού ασφάλειας SDN, αλλά η ποιότητα ενός τέτοιου συστήματος δεν μπορεί να κριθεί μόνο από μία υψηλή τιμή ακρίβειας ή F1. Ο τρόπος δημιουργίας και διαχωρισμού των δεδομένων, τα χαρακτηριστικά που είναι διαθέσιμα σε πραγματικό χρόνο, η ταχύτητα της απόφασης, η συμπεριφορά απέναντι σε νέες ή προσαρμοσμένες επιθέσεις και η δυνατότητα εφαρμογής της αντίδρασης στο ίδιο το δίκτυο είναι εξίσου σημαντικά στοιχεία.

7.2 Περιορισμοί της διπλωματικής

Ο σημαντικότερος περιορισμός αφορά τον τρόπο με τον οποίο ελέγχεται το δίκτυο. Στην πλήρη αντιδραστική λειτουργία ενός SDN, ο μεταγωγέας μπορεί να ζητήσει από τον ελεγκτή απόφαση όταν εμφανίζεται μία νέα ροή και ο ελεγκτής να απαντήσει εγκαθιστώντας τον κατάλληλο κανόνα προώθησης, όπως παρουσιάστηκε στην παράγραφο 2.3. Η κύρια υλοποίηση της παρούσας εργασίας δεν λειτουργεί με αυτόν τον τρόπο. Ο μεταγωγέας διατηρεί τοπικά τη δυνατότητα προώθησης της κίνησης και η εφαρμογή ελέγχου παρεμβαίνει όταν πρέπει να αποκλειστεί μία ύποπτη πηγή. Επομένως, δεν διατυπώνεται ισχυρισμός ότι υλοποιήθηκε πλήρης αντιδραστικός έλεγχος κάθε ροής.

Η επιλογή αυτή συνδέεται και με το περιβάλλον εκτέλεσης. Στη συγκεκριμένη εγκατάσταση δεν ήταν διαθέσιμο το απαιτούμενο άρθρωμα πυρήνα του Open vSwitch, ενώ η εναλλακτική διαδρομή με ελεγκτή Ryu παρουσίασε προβλήματα συμβατότητας με τις εκδόσεις του περιβάλλοντος. Η συνέπεια είναι ότι λειτουργίες οι οποίες προϋποθέτουν συνεχή έλεγχο της

διαδρομής κάθε ροής, όπως η δυναμική επιλογή διαδρομών, δεν εξετάστηκαν στην κύρια πειραματική διαμόρφωση. Η μετάβαση σε πλήρη αντιδραστικό έλεγχο αποτελεί επομένως φυσική κατεύθυνση επέκτασης.

Δεύτερος περιορισμός αφορά τα χαρακτηριστικά που χρησιμοποιεί το ζωντανό μοντέλο. Η Μέθοδος Α βασίζεται σε οκτώ συγκεντρωτικά χαρακτηριστικά, ενώ η ανάλυση εκτός σύνδεσης χρησιμοποιεί 24 χαρακτηριστικά ροής. Τα ζωντανά χαρακτηριστικά παράγονται από τη συγκέντρωση μετρήσεων της κίνησης και επομένως παρέχουν μικρότερη λεπτομέρεια. Η επιλογή αυτή αποτελεί συμβιβασμό ανάμεσα στην ταχύτητα συλλογής των δεδομένων και στον πλούτο της διαθέσιμης πληροφορίας.

Επιπλέον, η συγκέντρωση ανά αποστολέα και παραλήπτη δεν ισοδυναμεί με την ξεχωριστή παρακολούθηση κάθε σύνδεσης. Για την πλήρη διάκριση δύο συνδέσεων χρειάζονται η διεύθυνση και η θύρα του αποστολέα, η διεύθυνση και η θύρα του παραλήπτη και το πρωτόκολλο επικοινωνίας. Η ζωντανή υλοποίηση δεν χρησιμοποιεί όλα αυτά τα στοιχεία. Επομένως, διαφορετικές συνδέσεις μεταξύ των ίδιων κόμβων μπορούν να συνυπολογιστούν στην ίδια συγκεντρωτική περιγραφή. Ο περιορισμός αυτός εξηγεί γιατί ορισμένες επιθέσεις με παρόμοιο όγκο κίνησης αλλά διαφορετική σημασία σε επίπεδο πρωτοκόλλου είναι δύσκολο να διακριθούν.

Η πειραματική τοπολογία περιλαμβάνει έναν μεταγωγέα και περιορισμένο αριθμό εικονικών κόμβων. Επομένως, δεν έχει εξεταστεί η συμπεριφορά της αρχιτεκτονικής σε μεγαλύτερα δίκτυα με πολλούς μεταγωγείς, πολλαπλές διαδρομές ή περισσότερους ελεγκτές. Παράλληλα, η χρήση Mininet και Open vSwitch παρέχει ελεγχόμενο και επαναλήψιμο περιβάλλον, αλλά δεν αντικαθιστά την αξιολόγηση σε φυσικό δίκτυο και με πραγματική κίνηση παραγωγής.

Περιορισμός υπάρχει και στα δεδομένα της Μεθόδου Β. Το συνθετικό σύνολο είναι χρήσιμο για τον έλεγχο της λειτουργίας της αλυσίδας επεξεργασίας, αλλά η ελεγχόμενη παραγωγή του δημιουργεί πιο καθαρές διαφορές μεταξύ των κατηγοριών από όσες είναι πιθανό να υπάρχουν σε πραγματική κίνηση. Στο InSDN, από την άλλη πλευρά, η μεγάλη παρουσία πανομοιότυπων εγγραφών απαιτεί ιδιαίτερη προσοχή κατά τον διαχωρισμό. Παρότι ο διαχωρισμός κατά ομάδες αποτρέπει την επικάλυψη ακριβών αντιγράφων μεταξύ εκπαίδευσης και αξιολόγησης, τα αποτελέσματα εξακολουθούν να αντιμετωπίζονται ως ένδειξη καλής λειτουργίας της μεθόδου πάνω στο συγκεκριμένο σύνολο και όχι ως απόδειξη γενίκευσης σε κάθε πραγματικό δίκτυο.

Τα δύο μοντέλα Βαθιάς Μάθησης αποτελούν επίσης περιορισμένο μέρος της αξιολόγησης. Εκτελέστηκαν μόνο στο συνθετικό σύνολο και με διαφορετικό τρόπο διαχωρισμού και επικύρωσης από τα έξι κύρια μοντέλα. Για τον λόγο αυτό δεν μπορούν να χρησιμοποιηθούν για άμεσο συμπέρασμα σχετικά με το αν η Βαθιά Μάθηση υπερτερεί ή υστερεί στο InSDN.

Ένας ακόμη περιορισμός αφορά την εκπαίδευση με αντίπαλα παραδείγματα. Η τεχνική εφαρμόστηκε και αξιολογήθηκε μόνο στο Random Forest της ανάλυσης εκτός σύνδεσης, στον χώρο των 24 χαρακτηριστικών. Δεν εφαρμόστηκε στο Isolation Forest που χρησιμοποιείται στη ζωντανή ροή δεδομένων. Το ζωντανό μοντέλο δοκιμάστηκε απέναντι σε στρατηγικές αποφυγής, ώστε να αξιολογηθεί η στιβαρότητά του, αλλά δεν επανεκπαιδεύτηκε με διαταραγμένα δείγματα. Η εκπαίδευση του ζωντανού μοντέλου με αντίπαλα παραδείγματα παραμένει επομένως ανοιχτό ζήτημα.

Τέλος, δεν εκτελέστηκε πειραματική μέτρηση γραμμής βάσης με σύστημα βάσει υπογραφών, όπως το Snort ή το Suricata. Η σχετική σύγκριση της εργασίας παραμένει ποιοτική και δεν επιτρέπει ισχυρισμό ότι η προτεινόμενη προσέγγιση υπερτερεί πειραματικά έναντι αυτών των συστημάτων.

7.3 Μελλοντικές επεκτάσεις

Μία βασική κατεύθυνση μελλοντικής εργασίας είναι η μετάβαση σε πλήρη αντιδραστικό έλεγχο μέσω σταθερά συνδεδεμένου ελεγκτή OpenFlow. Σε μια τέτοια υλοποίηση ο ελεγκτής θα μπορούσε όχι μόνο να επιβάλλει κανόνες αποκλεισμού, αλλά και να συμμετέχει άμεσα στη διαχείριση των νέων ροών. Αυτό θα επέτρεπε να εξεταστούν λειτουργίες όπως η δυναμική αλλαγή διαδρομής, η απομόνωση ύποπτων κόμβων και η εφαρμογή διαφορετικών πολιτικών ανά τύπο κίνησης.

Παράλληλα, η ζωντανή τηλεμετρία μπορεί να εμπλουτιστεί με μεγαλύτερη λεπτομέρεια ανά σύνδεση. Η καταγραφή των θυρών προέλευσης και προορισμού, του πρωτοκόλλου και πρόσθετων χαρακτηριστικών της διάρκειας και της χρονικής συμπεριφοράς της ροής θα επέτρεπε καλύτερο διαχωρισμό μεταξύ διαφορετικών συνδέσεων των ίδιων κόμβων. Με αυτόν τον τρόπο θα μπορούσαν να αντιμετωπιστούν αποτελεσματικότερα περιπτώσεις στις οποίες τα σημερινά συγκεντρωτικά χαρακτηριστικά δεν επαρκούν, όπως η πλαστογράφηση ARP ή η εξαγωγή δεδομένων που μοιάζει με νόμιμη μεταφορά μεγάλου όγκου.

Μια επόμενη υλοποίηση θα ήταν επίσης χρήσιμο να αξιολογηθεί σε μεγαλύτερη τοπολογία με πολλούς μεταγωγείς και διαφορετικές διαδρομές. Η δοκιμή με περισσότερους ελεγκτές θα επέτρεπε επιπλέον να εξεταστούν ζητήματα πλεονασμού, συγχρονισμού και συνέχειας

της λειτουργίας όταν ένας ελεγκτής αποτύχει. Η τελική αξιολόγηση σε φυσικό δοκιμαστικό δίκτυο και με πραγματική ή ημι-πραγματική κίνηση θα ενίσχυε σημαντικά την εξωτερική εγκυρότητα των αποτελεσμάτων.

Στη Μέθοδο B, τα μοντέλα Βαθιάς Μάθησης θα πρέπει να επαναξιολογηθούν με το ίδιο ακριβώς πρωτόκολλο που χρησιμοποιείται για τα έξι κύρια μοντέλα. Αυτό σημαίνει κοινό διαχωρισμό εκπαίδευσης, επικύρωσης και ελέγχου, ίδια προστασία απέναντι στα διπλότυπα και αξιολόγηση και στο InSDN. Μόνο υπό τις ίδιες συνθήκες μπορεί να γίνει άμεση σύγκριση μεταξύ των διαφορετικών οικογενειών μοντέλων.

Η στιβαρότητα απέναντι σε προσαρμοσμένες επιθέσεις αποτελεί επίσης σημαντική κατεύθυνση μελλοντικής εργασίας. Η εκπαίδευση με αντίπαλα παραδείγματα που εφαρμόστηκε στο Random Forest θα μπορούσε να εξεταστεί και στη ζωντανή διαδρομή. Μια τέτοια μελέτη θα πρέπει να λαμβάνει υπόψη ότι τα οκτώ συγκεντρωτικά χαρακτηριστικά του Isolation Forest είναι διαφορετικά από τα 24 χαρακτηριστικά της εκτός σύνδεσης ανάλυσης και επομένως απαιτείται ξεχωριστός σχεδιασμός των κατάλληλων παραδειγμάτων αποφυγής.

Επιπλέον, θα ήταν χρήσιμη η αξιολόγηση σε νεότερα ή συμπληρωματικά σύνολα δεδομένων που διατηρούν πληροφορίες για τη χρονική σειρά, την πηγή ή τη συνεδρία των ροών. Ένας τέτοιος διαχωρισμός θα επέτρεπε αυστηρότερο έλεγχο της ικανότητας γενίκευσης σε διαφορετικούς κόμβους, χρονικές περιόδους ή συνθήκες δικτύου, πέρα από την απομάκρυνση μόνο των ακριβών διπλοτύπων.

Τέλος, η ποιοτική σύγκριση με συστήματα βάσει υπογραφών μπορεί να μετατραπεί σε πραγματική πειραματική γραμμή βάσης. Η εκτέλεση των ίδιων επιθέσεων απέναντι σε ένα σύστημα όπως το Snort ή το Suricata θα επέτρεπε να συγκριθούν με κοινές μετρικές ο ρυθμός ανίχνευσης, τα ψευδώς θετικά, η καθυστέρηση και το υπολογιστικό κόστος. Μόνο μετά από τέτοια σύγκριση θα μπορούσε να διατυπωθεί τεκμηριωμένο συμπέρασμα για τα πλεονεκτήματα και τα μειονεκτήματα κάθε προσέγγισης.

7.4 Τελικό συμπέρασμα

Η παρούσα εργασία έδειξε ότι είναι εφικτή η σύνδεση τεχνικών Μηχανικής Μάθησης με έναν αυτοματοποιημένο μηχανισμό ανίχνευσης και αντιμετώπισης επιθέσεων σε ελεγχόμενο περιβάλλον SDN. Η εκτός σύνδεσης ανάλυση επέτρεψε τη σύγκριση διαφορετικών μοντέλων και ανέδειξε τη σημασία της σωστής προετοιμασίας και του διαχωρισμού των δεδομένων. Παράλληλα, η ζωντανή Μέθοδος A έδειξε ότι η ανίχνευση

μπορεί να οδηγήσει σε πραγματική ενέργεια πάνω στον μεταγωγέα, όπως επιβεβαιώθηκε στο πείραμα πλημμύρας SYN.

Τα αποτελέσματα δεν αποδεικνύουν ότι η προτεινόμενη προσέγγιση είναι έτοιμη για χρήση σε παραγωγικό δίκτυο ούτε ότι υπερτερεί έναντι συστημάτων βάσει υπογραφών. Δείχνουν όμως ότι τα επιμέρους στοιχεία μπορούν να συνδυαστούν λειτουργικά και ότι οι βασικοί περιορισμοί είναι πλέον σαφείς: απαιτούνται πλουσιότερη τηλεμετρία, πληρέστερη ενσωμάτωση του ελέγχου μέσω OpenFlow, αξιολόγηση σε μεγαλύτερα και πραγματικά δίκτυα και περαιτέρω μελέτη της στιβαρότητας απέναντι σε προσαρμοσμένους επιτιθέμενους.

Η κύρια συνεισφορά της εργασίας βρίσκεται επομένως όχι μόνο στις επιδόσεις των επιμέρους μοντέλων, αλλά στη σύνδεση της ανάλυσης δεδομένων με έναν πλήρη κύκλο παρακολούθησης, απόφασης και αντιμετώπισης, καθώς και στην καταγραφή των συνθηκών κάτω από τις οποίες τα αποτελέσματα μπορούν να θεωρηθούν αξιόπιστα. Το πλαίσιο αυτό μπορεί να αποτελέσει βάση για μια πληρέστερη μελλοντική υλοποίηση και αξιολόγηση σε πραγματικές υποδομές SDN.

8 Βιβλιογραφία

- [1] K. Benzekki, A. El Fergougui, and A. Elbelrhiti Elalaoui, “Software-Defined Networking (SDN): A Survey,” *Secur. Commun. Netw.*, vol. 9, no. 18, pp. 5803–5833, 2017, doi: 10.1002/sec.1737.
- [2] D. Kreutz, F. M. V. Ramos, P. E. Veríssimo, C. E. Rothenberg, S. Azodolmolky, and S. Uhlig, “Software-Defined Networking: A Comprehensive Survey,” *Proc. IEEE*, vol. 103, no. 1, pp. 14–76, Jan. 2015, doi: 10.1109/JPROC.2014.2371999.
- [3] N. McKeown and others, “OpenFlow: Enabling Innovation in Campus Networks,” *ACM SIGCOMM Comput. Commun. Rev.*, vol. 38, no. 2, pp. 69–74, Apr. 2008, doi: 10.1145/1355734.1355746.
- [4] S. Scott-Hayward, S. Natarajan, and S. Sezer, “A Survey of Security in Software Defined Networks,” *IEEE Commun. Surv. Tutor.*, vol. 18, no. 1, pp. 623–654, 2016, doi: 10.1109/COMST.2015.2453114.
- [5] S. Shin and G. Gu, “Attacking Software-Defined Networks: A First Feasibility Study,” in *Proceedings of the 2nd ACM SIGCOMM Workshop on Hot Topics in Software Defined Networking (HotSDN)*, 2013, pp. 165–166.
- [6] N. Sultana, N. Chilamkurti, W. Peng, and R. Alhadad, “Survey on SDN-Based Network Intrusion Detection System Using Machine Learning Approaches,” *Peer--Peer Netw. Appl.*, vol. 12, no. 2, pp. 493–501, Mar. 2019, doi: 10.1007/s12083-017-0630-0.
- [7] R. Sommer and V. Paxson, “Outside the Closed World: On Using Machine Learning for Network Intrusion Detection,” in *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*, 2010, pp. 305–316. doi: 10.1109/SP.2010.25.
- [8] R. Braga, E. Mota, and A. Passito, “Lightweight DDoS Flooding Attack Detection Using NOX/OpenFlow,” in *Proceedings of the IEEE 35th Conference on Local Computer Networks (LCN)*, 2010, pp. 408–415. doi: 10.1109/LCN.2010.5735752.
- [9] A. H. Janabi, T. Kanakis, and M. Johnson, “Survey: Intrusion Detection System in Software-Defined Networking,” *IEEE Access*, vol. 12, pp. 164097–164120, 2024, doi: 10.1109/ACCESS.2024.3493384.

- [10] S. M. Doğan, A. Koçak, and M. Alkan, “Detection and Mitigation of Cyber-Attacks in Software Defined Networks Using Machine Learning/Deep Learning: A Systematic Literature Review, Research Challenges and Future Directions,” *Int. J. Inf. Secur.*, vol. 24, 2025, doi: 10.1007/s10207-025-01114-z.
- [11] M. Antonakakis *et al.*, “Understanding the Mirai Botnet,” presented at the 26th USENIX Security Symposium (USENIX Security 17), 2017, pp. 1093–1110. Accessed: Sep. 12, 2026. [Online]. Available: https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/antonakakis?utm_source=chatgpt.com
- [12] *OpenFlow Switch Specification, Version 1.3.5 (Protocol version 0x04)*, ONF TS-023, Mar. 26, 2015. [Online]. Available: <https://opennetworking.org/wp-content/uploads/2014/10/openflow-switch-v1.3.5.pdf>
- [13] B. Pfaff and others, “The Design and Implementation of Open vSwitch,” in *Proceedings of the 12th USENIX Symposium on Networked Systems Design and Implementation (NSDI)*, 2015, pp. 117–130.
- [14] B. Lantz, B. Heller, and N. McKeown, “A Network in a Laptop: Rapid Prototyping for Software-Defined Networks,” in *Proceedings of the 9th ACM SIGCOMM Workshop on Hot Topics in Networks (HotNets-IX)*, 2010. doi: 10.1145/1868447.1868466.
- [15] T. Peng, C. Leckie, and K. Ramamohanarao, “Survey of Network-Based Defense Mechanisms Countering the DoS and DDoS Problems,” *ACM Comput. Surv.*, vol. 39, no. 1, Apr. 2007.
- [16] D. Tang, Y. Yan, S. Zhang, J. Chen, and Z. Qin, “Performance and Features: Mitigating the Low-Rate TCP-Targeted DoS Attack via SDN,” *IEEE J. Sel. Areas Commun.*, vol. 40, pp. 428–444, Nov. 2021, doi: 10.1109/JSAC.2021.3126053.
- [17] T. Girdler and V. Vassilakis, “Implementing an intrusion detection and prevention system using Software-Defined Networking: Defending against ARP spoofing attacks and Blacklisted MAC Addresses,” *Comput. Electr. Eng.*, vol. 90, p. 106990, Mar. 2021, doi: 10.1016/j.compeleceng.2021.106990.
- [18] “Lateral Movement, Tactic TA0008 - Enterprise | MITRE ATT&CK®.” Accessed: Sep. 12, 2026. [Online]. Available: <https://attack.mitre.org/tactics/TA0008/>

- [19] “Exfiltration, Tactic TA0010 - Enterprise | MITRE ATT&CK®.” Accessed: Sep. 12, 2026. [Online]. Available: <https://attack.mitre.org/tactics/TA0010/>
- [20] R. Tibshirani, “The Elements of Statistical Learning: Data Mining, Inference, and Prediction by HASTIE, T., TIBSHIRANI, R., and FRIEDMAN, J,” *Biometrics*, Jan. 2010, Accessed: Sep. 12, 2026. [Online]. Available: https://www.academia.edu/85883165/The_Elements_of_Statistical_Learning_Data_Mining_Inference_and_Prediction_by_HASTIE_T_TIBSHIRANI_R_and_FRIEDMAN_J
- [21] L. Breiman, “Random Forests,” *Mach. Learn.*, vol. 45, no. 1, pp. 5–32, Oct. 2001, doi: 10.1023/A:1010933404324.
- [22] S. Kiranyaz, O. Avci, O. Abdeljaber, T. Ince, M. Gabbouj, and D. J. Inman, “1D convolutional neural networks and applications: A survey,” *Mech. Syst. Signal Process.*, vol. 151, p. 107398, Apr. 2021, doi: 10.1016/j.ymssp.2020.107398.
- [23] F. T. Liu, K. M. Ting, and Z.-H. Zhou, “Isolation Forest,” in *Proceedings of the 8th IEEE International Conference on Data Mining (ICDM)*, 2008, pp. 413–422. doi: 10.1109/ICDM.2008.17.
- [24] M. S. Elsayed, N.-A. Le-Khac, and A. D. Jurcut, “InSDN: A Novel SDN Intrusion Dataset,” *IEEE Access*, vol. 8, pp. 165263–165284, 2020, doi: 10.1109/ACCESS.2020.3022633.
- [25] “Applications | Research | Canadian Institute for Cybersecurity | UNB.” Accessed: Sep. 12, 2026. [Online]. Available: <https://www.unb.ca/cic/research/applications.html>
- [26] “CICFlowMeter/ReadMe.txt at master · ahlashkari/CICFlowMeter,” GitHub. Accessed: Sep. 12, 2026. [Online]. Available: <https://github.com/ahlashkari/CICFlowMeter/blob/master/ReadMe.txt>
- [27] M. Sokolova and G. Lapalme, “A systematic analysis of performance measures for classification tasks,” *Inf. Process. Manag.*, vol. 45, pp. 427–437, Jul. 2009, doi: 10.1016/j.ipm.2009.03.002.
- [28] T. Fawcett, “Introduction to ROC analysis,” *Pattern Recognit. Lett.*, vol. 27, pp. 861–874, Jun. 2006, doi: 10.1016/j.patrec.2005.10.010.
- [29] S. M. Lundberg and S.-I. Lee, “A Unified Approach to Interpreting Model Predictions,” in *Advances in Neural Information Processing Systems*, 2017, pp. 4765–4774.

- [30] A. Hamarshe, H. I. Ashqar, and M. Hamarsheh, "Detection of DDoS Attacks in Software Defined Networking Using Machine Learning Models." 2023.
- [31] R. Jafari Gohari, L. Aliahmadipour, and M. Kuchaki Rafsanjani, "CTMBIDS: Convolutional Tsetlin Machine Based Intrusion Detection System for DDoS Attacks in an SDN Environment." 2024.
- [32] J. Gama, I. Žliobaitė, A. Bifet, M. Pechenizkiy, and H. Bouchachia, "A survey on concept drift adaptation," *ACM Comput. Surv.*, vol. 46, pp. 1–37, Apr. 2014, doi: 10.1145/2523813.
- [33] S. Kaufman, S. Rosset, C. Perlich, and O. Stitelman, "Leakage in Data Mining: Formulation, Detection, and Avoidance," *ACM Trans. Knowl. Discov. Data*, vol. 6, no. 4, Dec. 2012, doi: 10.1145/2382577.2382579.
- [34] "IsolationForest," scikit-learn. Accessed: Sep. 13, 2026. [Online]. Available: <https://scikit-learn/stable/modules/generated/sklearn.ensemble.IsolationForest.html>
- [35] *Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (Text with EEA relevance)*. 2016. Accessed: Sep. 13, 2026. [Online]. Available: <http://data.europa.eu/eli/reg/2016/679/2016-05-04>
- [36] K. Scarfone and P. Mell, "Guide to Intrusion Detection and Prevention Systems (IDPS)," National Institute of Standards and Technology, NIST Special Publication (SP) 800-94, Feb. 2007. doi: 10.6028/NIST.SP.800-94.
- [37] T. Dietterich, "Approximate Statistical Tests for Comparing Supervised Classification Learning Algorithms," *Neural Comput.*, vol. 10, pp. 1895–1923, Oct. 1998, doi: 10.1162/089976698300017197.

9 Παράρτημα Α: Οδηγίες αναπαραγωγής των πειραμάτων

Το παράρτημα αυτό συνοψίζει τα βήματα αναπαραγωγής των offline και live πειραμάτων της διπλωματικής. Η χρήση Docker και καταγεγραμμένων εξαρτήσεων μειώνει τις διαφορές μεταξύ περιβαλλόντων και διευκολύνει την ανεξάρτητη επαλήθευση, χωρίς να καθιστά τα αποτελέσματα απολύτως ανεξάρτητα από το λειτουργικό σύστημα, τις εκδόσεις του Docker ή το διαθέσιμο υλικό.

A.1 Απαιτήσεις συστήματος

Απαιτούνται: Docker και Docker Compose, περιβάλλον Linux ή Windows με WSL2, Python 3 και οι βιβλιοθήκες του αρχείου requirements.txt. Ο μεταγωγέας εκτελείται σε προνομιακό (privileged) container και κατασκευάζεται σε λειτουργία failMode=standalone με datapath τύπου user, λόγω της απουσίας του kernel module του Open vSwitch στο WSL2.

A.2 Εκκίνηση της στοίβας

```
# Εκκίνηση ελεγκτή, dashboard και μεταγωγέα
docker compose -f app_sdn/docker-compose.yml up -d controller dashboard switch

# Ελεγκτής: http://localhost:9000   Dashboard: http://localhost:8050
```

A.3 Εκτέλεση της αλυσίδας επεξεργασίας εκτός σύνδεσης (Μέθοδος B)

Ο βασικός κορμός της αλυσίδας επεξεργασίας εκτός σύνδεσης για το επιλεγμένο dataset εκτελείται με την ακόλουθη εντολή και παράγει τα κύρια μοντέλα, τις μετρικές και τα γραφήματα ταξινόμησης:

```
bash run_all.sh
# μοντέλα -> models/ , γραφήματα & μετρικές -> results/
```

Για την εκτέλεση των πρόσθετων offline μελετών που παρουσιάζονται στο κείμενο, όπως η leakage study, το easy/hard synthetic study, το hyperparameter tuning, το offline Isolation Forest και το SHAP, χρησιμοποιείται:

```
bash reproduce_thesis.sh
```

Η εκτέλεση αφορά κάθε φορά το επιλεγμένο dataset. Για το InSDN απαιτείται χωριστή εκτέλεση με την αντίστοιχη παράμετρο και διαθεσιμότητα του εξωτερικού dataset.

Το πείραμα μετριασμού της αντίπαλης ευπάθειας μέσω adversarial training (Robust Random Forest, παράγραφο 6.8.3) εκτελείται με μία εντολή και παράγει τη σύγκριση αρχικού και θωρακισμένου μοντέλου:

```
python3 ml_pipeline/adversarial_training.py
# παραγει: results/adv_robust_comparison.csv (evasion vs epsilon),
#         results/adv_robust_clean.csv (clean accuracy/F1),
#         results/adv_robust_mcnemar.txt (McNemar test),
#         results/adv_robust_evasion.png (γραφημα)
```

A.4 Εκτέλεση των ζωντανών σεναρίων (Μέθοδος A)

Τα ζωντανά σενάρια επίθεσης και αντιμετώπισης εκτελούνται έναντι της εκτελούμενης στοίβας:

```
# Όλα τα σενάρια (DDoS, port scan, exfiltration, flow exhaustion,
# lateral movement, ARP spoof)
bash run_live_experiments.sh --controller http://localhost:9000 --duration 60

# Σενάριο επίδειξης 10 λεπτών
bash demo_10min.sh --no-build
```

A.5 Θέση των αποτελεσμάτων

Τα αποτελέσματα αποθηκεύονται ως εξής: τα γραφήματα και οι μετρικές της αλυσίδας επεξεργασίας εκτός σύνδεσης στον φάκελο results/. Τα αποτελέσματα των ζωντανών σεναρίων (CSV/JSON ανά σενάριο) στον φάκελο results/live/. Τα εκπαιδευμένα μοντέλα και οι μετασχηματιστές κανονικοποίησης στον φάκελο models/. Η αναφορά RESULTS_VERIFICATION.md συνοψίζει τα μετρημένα αποτελέσματα ανά σενάριο.

A.6 Λίστα ελέγχου αναπαραγωγιμότητας

Ο ακόλουθος πίνακας συνοψίζει τα βασικά βήματα επαλήθευσης των offline και live αποτελεσμάτων. Η offline αναπαραγωγή, τα API-level σενάρια και το σε επίπεδο πακέτων πείραμα απαιτούν χωριστές εντολές και διαφορετικές προαιρετικές εξαρτήσεις. Η επιτυχής ολοκλήρωση κάθε βήματος επιβεβαιώνει το αντίστοιχο υποσύνολο αποτελεσμάτων και όχι αυτομάτως το σύνολο της διπλωματικής. των πειραμάτων και αποτελεσμάτων

Πίνακας 9-1: Λίστα ελέγχου αναπαραγωγιμότητας των πειραμάτων.

Έλεγχος	Εντολή	Αναμενόμενο αποτέλεσμα
---------	--------	------------------------

Εγκατάσταση εξαρτήσεων	<code>pip install -r requirements.txt</code>	Ολοκλήρωση χωρίς σφάλματα
Offline πειράματα	<code>bash run_all.sh</code>	Ο βασικός κορμός των offline αποτελεσμάτων στο results/
Αντίπαλη στιβαρότητα	<code>python3 ml_pipeline/adversarial_training.py</code>	Παραγωγή των αρχείων <code>adv_robust_*</code>
Αυτοματοποιημένοι έλεγχοι	<code>pytest tests/ -v</code>	Συλλέγονται συνολικά 144 tests. Στην εκτέλεση αναφοράς ολοκληρώθηκαν επιτυχώς 136 και παραλείφθηκαν 8 έλεγχοι που εξαρτώνται από τη διαθεσιμότητα της Docker/live υποδομής, χωρίς καταγεγραμμένες αποτυχίες.
Ζωντανή επίδειξη	<code>Docker Compose -f app_sdn/docker-compose.yml up --build</code>	Ελεγκτής και πίνακας εποπτείας ενεργά (θύρες 9000, 8050)
Εκτεταμένη offline αναπαραγωγή	<code>bash reproduce_thesis.sh</code>	Οι offline μελέτες για το επιλεγμένο dataset, με αναφορά των βημάτων που παραλείφθηκαν λόγω προαιρετικών εξαρτήσεων. Τα σε επίπεδο πακέτων πειράματα εκτελούνται χωριστά.

Packet-level πείραμα	bash run_packet_level_experiment.sh	Πραγματικά dropped packets + κάλυψη αντιμετώπισης στο results/live/mininet_run _*/ και στο experiment_summary.cs v
Επαλήθευση artifacts	python3 ml_pipeline/generate_συνθετικό_datase t.py && sha256sum -c MANIFEST.sha256	Το συνθετικό CSV περιλαμβάνεται στο τελικό ZIP. Η εντολή sha256sum -c MANIFEST.sha256 πρέπει να επιστρέφει OK για όλα τα αρχεία που αναφέρονται στο manifest. Το manifest καλύπτει επιλεγμένα βασικά artifacts και όχι αναγκαστικά κάθε αρχείο του φακέλου results/.

Παράρτημα Β: Πλήρης πίνακας υπερπαραμέτρων του Isolation Forest

Ο ακόλουθος πίνακας παραθέτει τους κορυφαίους συνδυασμούς υπερπαραμέτρων του Isolation Forest, ταξινομημένους κατά το ROC-AUC επικύρωσης, όπως προέκυψαν από την εξαντλητική αναζήτηση (παράγραφο 6.8.1). Η στήλη του ROC-AUC ελέγχου συμπληρώνεται μόνο για τη διαμόρφωση αναφοράς, η οποία αξιολογήθηκε μία φορά στο ανεξάρτητο σύνολο ελέγχου. Οι πρώτες διαμορφώσεις ισοβαθμούν ως προς το validation ROC-AUC και, επομένως, ο πίνακας δεν τεκμηριώνει ότι η τιμή contamination 0,05 (επιλεγμένη βάσει του δεύτερου κριτηρίου, του validation F1) αποτελεί μοναδικά βέλτιστο κατώφλι. Οι τιμές validation F1 παρέχονται ως συμπληρωματική ένδειξη της συμπεριφοράς

του επιλεγμένου threshold. Η μικρή διακύμανση των τιμών επιβεβαιώνει τη στιβαρότητα του αλγορίθμου.

Πίνακας 9-2: Κορυφαίοι συνδυασμοί υπερπαραμέτρων του Isolation Forest, ταξινομημένοι κατά ROC-AUC επικύρωσης. Η τιμή ROC-AUC ελέγχου αναφέρεται μόνο για τη διαμόρφωση αναφοράς.

n_estimators	max_samples	contamination	max_features	val ROC-AUC	val F1	test ROC-AUC
100	256	0,05	1,0	0,9991	0,9943	0,9990
100	auto	0,05	1,0	0,9991	0,9943	-
100	256	0,02	1,0	0,9991	0,9941	-
100	auto	0,02	1,0	0,9991	0,9941	-
100	256	0,10	1,0	0,9991	0,9879	-
100	auto	0,10	1,0	0,9991	0,9879	-
300	512	0,05	1,0	0,9987	0,9946	-
300	512	0,10	1,0	0,9987	0,9884	-
300	512	0,02	1,0	0,9987	0,9845	-
100	512	0,05	0,5	0,9986	0,9940	-